CompTIA Security+
SY0-701 - Guia Completa de Estudio

Preguntas organizadas por dominio oficial del examen

Fuente: ExamCompass.com + CompTIA Official Exam Objectives v6.0

Dominio	Nombre	%
1.0	General Security Concepts	12%
2.0	Threats, Vulnerabilities, and Mitigations	22%
3.0	Security Architecture	18%
4.0	Security Operations	28%
5.0	Security Program Management and Oversight	20%

Total preguntas: 590

Las opciones marcadas en verde son las respuestas correctas.

1.0 General Security Concepts (12% del examen)

1.1 - Compare and contrast various types of security controls.

Conceptos clave:

- Categories: Technical, Managerial, Operational, Physical
- Control types: Preventive, Deterrent, Detective, Corrective, Compensating, Directive

Teoria (Professor Messer):

Security controls

- Various security risks exist for varied assets (data, physical property, computer systems)
- If we recognize security controls, we can prevent events, minimize impact, and limit damage
- Categories:
  - Technical controls
    - Implemented using systems
    - Operating system controls
    - Firewalls, anti-virus
  - Managerial controls
    - Administrative controls, design and implementation
    - Security policies and procedures
  - Operational controls
    - Implemented by people
    - Guards, awareness programs
  - Physical controls
    - Limit physical access
    - Guard shack, fences, locks, badges
- Control types:
  - Preventive: block access to a resource
  - Deterrent: discourage an intrusion attempt
  - Detective: identify and log an intrusion attempt
  - Corrective: applied after an event is detected, reversing impact
  - Compensating: existing controls insufficient, temporarily control using other means
  - Directive: direct a subject towards a compliance (weak, based on suggestion/policy)
-

Tips y trucos para el examen:

TRUCO NEMOTECNICO para los tipos: 'Por Dios, Del Cielo Caen Dones' → Preventive, Deterrent, Detective, Corrective, Compensating, Directive

Ejemplo de examen: Un firewall es un control TECHNICAL + PREVENTIVE. Una camara de seguridad es PHYSICAL + DETECTIVE. Una politica de contrasenas es MANAGERIAL + DIRECTIVE.

Preguntas de practica (21):

1. What are the examples of preventive security controls? (Select 3 answers)

A) Encryption
B) IDS
C) Sensors
✓ D) Firewalls
E) Warning signs
✓ F) AV software

---

2. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ B) Log monitoring
C) Sandboxing

✓ **D) Security audits**
✓ **E) CCTV**
✓ **F) IDS**
✓ **G) Vulnerability scanning**

3. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems
B) Video surveillance
✓ **C) MFA**
✓ **D) Application sandboxing**
✓ **E) Network segmentation**

4. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP
✓ **B) AUP**
C) IDS
D) MFA
E) IPS

5. What are the examples of preventive security controls? (Select 3 answers)

A) Encryption
B) IDS
C) Sensors
✓ **D) Firewalls**
E) Warning signs
✓ **F) AV software**

6. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ **B) Log monitoring**
C) Sandboxing
✓ **D) Security audits**
✓ **E) CCTV**
✓ **F) IDS**
✓ **G) Vulnerability scanning**

7. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems
B) Video surveillance
✓ **C) MFA**
✓ **D) Application sandboxing**
✓ **E) Network segmentation**

8. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP
✓ **B) AUP**
C) IDS
D) MFA
E) IPS

9. Which of the following answers can be used to describe technical security controls? (Select 3 answers)

A) Focused on protecting material assets
✓ **B) Sometimes called logical security controls**
✓ **C) Executed by computer systems (instead of people)**
D) Also known as administrative controls
✓ **E) Implemented with technology**
F) Primarily implemented and executed by people (as opposed to computer systems)

10. Which of the following answers refer to the characteristic features of managerial security controls? (Select 3 answers)

A) Also known as administrative controls

B) Sometimes referred to as logical security controls

✓ C) Focused on reducing the risk of security incidents

D) Executed by computer systems (instead of people)

✓ E) Documented in written policies

F) Focused on protecting material assets

---

11. Which of the answers listed below can be used to describe operational security controls (Select 3 answers)

A) Also known as administrative controls

✓ B) Focused on the day-to-day procedures of an organization

C) Executed by computer systems (instead of people)

✓ D) Used to ensure that the equipment continues to work as specified

E) Focused on managing risk

✓ F) Primarily implemented and executed by people (as opposed to computer systems)

---

12. Which of the answers listed below refers to security controls designed to deter, detect, and prevent unauthorized access, theft, damage, or destruction of material assets?

A) Managerial security controls

✓ B) Physical security controls

C) Technical security controls

D) Operational security controls

---

13. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ F) All of the above answers are examples of vulnerability response and remediation techniques

---

14. What is the best countermeasure against social engineering attacks?

A) Situational awareness

B) Implicit deny policy

✓ C) User education

D) Strong security controls

---

15. Which of the following answers can be used to describe technical security controls? (Select 3 answers)

A) Focused on protecting material assets

✓ B) Sometimes called logical security controls

✓ C) Executed by computer systems (instead of people)

D) Also known as administrative controls

✓ E) Implemented with technology

F) Primarily implemented and executed by people (as opposed to computer systems)

---

16. Which of the following answers refer to the characteristic features of managerial security controls? (Select 3 answers)

A) Also known as administrative controls

B) Sometimes referred to as logical security controls

✓ C) Focused on reducing the risk of security incidents

D) Executed by computer systems (instead of people)

✓ E) Documented in written policies

F) Focused on protecting material assets

17. Which of the answers listed below can be used to describe operational security controls (Select 3 answers)

A) Also known as administrative controls

✓ B) Focused on the day-to-day procedures of an organization

C) Executed by computer systems (instead of people)

✓ D) Used to ensure that the equipment continues to work as specified

E) Focused on managing risk

✓ F) Primarily implemented and executed by people (as opposed to computer systems)

18. Which of the answers listed below refers to security controls designed to deter, detect, and prevent unauthorized access, theft, damage, or destruction of material assets?

A) Managerial security controls

✓ B) Physical security controls

C) Technical security controls

D) Operational security controls

19. Vulnerability scanning: (Select all that apply)

A) Identifies lack of security controls

B) Actively tests security controls

✓ C) Identifies common misconfigurations

D) Exploits vulnerabilities

✓ E) Passively tests security controls

20. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ F) All of the above answers are examples of vulnerability response and remediation techniques

21. Penetration testing: (Select all that apply)

A) Bypasses security controls

B) Only identifies lack of security controls

✓ C) Actively tests security controls

✓ D) Exploits vulnerabilities

E) Passively tests security controls

1.2 - Summarize fundamental security concepts.

Conceptos clave:

- CIA Triad: Confidentiality, Integrity, Availability
- Non-repudiation
- AAA: Authentication, Authorization, Accounting
- Zero Trust: Control Plane, Data Plane, Policy Engine, Policy Administrator
- Physical security: Bollards, Fencing, Video surveillance, Lighting, Sensors
- Deception: Honeypot, Honeynet, Honeyfile, Honeytoken

Teoria (Professor Messer):

The CIA Triad

- Combination of principles, the fundamentals of security (not to be confused with the Central Intelligence Agency)
- **C - Confidentiality**: prevent disclosure of info to those unauthorized

- **I - Integrity**: information cannot be modified without detection
- **A - Availability**: systems and networks must be up and running
-
- Confidentiality
  - Certain info should only be known to certain people
  - Encryption, access controls
- Integrity
  - Data is stored and transferred as intended
  - Hashing, digital signatures, certificates, non-repudiation
- Availability
  - Info accessible to authorized used
  - Redundancy, fault tolerance, patching

Non-repudiation

- You cannot deny what you've said, like signing a digital contract
- Proof of integrity
  - Verify data remains accurate and consistent
  - Can be attained using a hash, data as a short string of text
    - If data changes at all, "fingerprint" changes entirely
  - However... this doesn't associate data with an individual
- Proof of origin
  - Proving the source of the message (authentication)
  - Sign with digital "private key" (only known by sender of data)
    - Verified with "public key"
- Creating a digital signature
  -
  -

Authentication, Authorization, and Accounting

- AAA framework
  - Identification: who you claim to be
  - **Authentication**: prove you are who you claim to be
  - **Authorization**: what access do you have when authorized
  - **Accounting**: what resources did you use when authorized
- Authenticating people
- Authenticating systems
  - Many managed devices, how to authenticate without a user?
  - Device certificate, VPN or software validates authorized system
- Certificate authentication
  - Organization has a trusted **Certificate Authority (CA)** that signs all device certificated
- Authorization models
  - Certain users and services have access to certain data and applications
  - Put the auth model in the middle
  - Without a model, you would need to profile dozens of users individually
  - With a model, you add abstractions (groups) to reduce complexity

Gap Analysis

- Where you are compared with where you want to be, requires extensive research
- Choosing the framework
  - Work towards a known baseline and determine the end goal
  - Following a framework like NIST SP 800-171 Revision 2 or ISO/IEC 27001
- Evaluate people and processes
  - Get a baseline of employees: experience, training, knowledge
  - Examine the current processes: systems and policies
- Analysis: compare and contrast
  - Compare, identify weaknesses, then detailed analysis

- The analysis and report
  - Report includes final comparison of objectives and current state as well as path to goal
  -

Zero Trust

- Many networks are open on the inside, zero trust says everything must be verified and secured at every step (security in depth)
- Planes of operation
  - Split the network into "functional planes"
  - Data plane: frames, packets, network data
  - Control plane: manage actions of data plane (policies, rules, etc.)
- Controlling trust
  - Adaptive identity
    - Consider source and requested resources, multiple risk indicators, make auth stronger
  - Threat scope reduction: reduce number of entry points
  - Policy-driven access control: combine adaptive identity with rules
- Security zones
  - Broad categorization of where a user is connecting from and where you are going
  - Trusted vs. untrusted, internal vs. external, departments, etc.
  - Zones may be enough to deny access or provide implicit trust
- Policy enforcement point
  - Subjects and systems must pass through a "gatekeeper" to access resources
  - Allow, monitor, and terminate connections -- hands over to the policy decision point
- Policy decision point: responsible for examining authentication and deciding authenticity
    - Policy engine: evaluates each decision based on policy -- grant, deny, or revoke
    - Policy administrator: generates access tokens or credentials -- hands back to PEP
- Full zero trust model:

Physical Security

- Barricades / bollards
  - Prevent access
  - Channel people through an access point
  - Identify safety concerns
- Access control vestibules: isolated rooms for access point authentication
  - All doors either normally unlocked or locked depending on level of security
  - When one door is open, other cannot be unlocked -- allows for one-at-a-time or controlled groups to access an area
- Fencing
  - Building a very obvious perimeter
  - May be transparent or opaque
  - Must be robust to prevent bending or cutting
  - Add razor wire or height to prevent climbing for more secure areas (some fences may be solely deterrents)
- Video surveillance
  - CCTV (closed circuit television): can replace physical guards
  - Newer features include motion detection and object recognition
- Guards and access badges
  - Security guard: physical protection at reception area
    - Two-person integrity/control: minimize exposure to attack, no single person has access to a physical asset
  - Access badge: identifying details, worn at all times, electronically logged
- Lighting
  - More light means more security: attackers avoid light and exposed areas
  - Lighting and angles may be important for facial recognition
- Sensors
  - Infrared: detects radiation in light and dark, common in motion detectors
  - Pressure: detects change in force, floor and window sensors
  - Microwave: detects movement across large areas
  - Ultrasonic: sends signals and receives reflected sound waves to detect motion or collision

Deception and Disruption

- Honeypots
  - Attract threat actors and trap them
  - Probably a machine, create a virtual world (can be done with open source software)
  - Constant battle to discern real from fake (honeypot effectiveness)
- Honeynets
  - A collection of honeypots on a large deception network
  - https://projecthoneypot.org
- Honeyfiles
  - More honey, more believable -- increases chance of deception (passwords.txt, etc.)
  - Alert sent if file accessed (virtual bear trap)
- Honeytokens
  - Track malicious actors by adding traceable data to honeynet
  - API credentials that don't actually provide access
  - Fake email addresses whose inbox is monitored

Tips y trucos para el examen:

SEGURIDAD FISICA:

- Bollards: postes antiimpacto para proteger edificios de vehiculos
- Mantrap (airlock): doble puerta que atrapa a intrusos entre ambas
- Faraday cage: jaula que bloquea senales electromagneticas
- Lighting: iluminacion como disuasor

DECEPTION TECHNOLOGY:

- Honeypot: sistema falso que atrae atacantes para estudiarlos
- Honeynet: red entera de honeypots
- Honeyfile: archivo falso que alerta si alguien lo abre
- Honeytoken: credencial falsa que si se usa, delata al atacante

Preguntas de practica (101):

1. In the AAA security architecture, the process of granting or denying access to resources is known as:

A) Authentication
✓ B) Authorization
✓ C) Accounting

---

2. Which part of the AAA security architecture deals with the verification of the identity of a person or process?

A) Accounting
✓ B) Authentication
C) Auditing
D) Authorization

---

3. The term "Non-repudiation" describes the inability to deny responsibility for performing a specific action. In the context of data security, non-repudiation ensures data confidentiality, provides proof of data integrity, and proof of data origin.

A) True
✓ B) False

---

4. Which of the following solutions provide(s) the AAA functionality? (Select all that apply)

A) CHAP
✓ B) TACACS+
C) PAP
✓ D) RADIUS
E) MS-CHAP

---

5. Which part of IPsec provides confidentiality, data integrity, and authentication?

A) AES

B) SHA
C) AH
✓ **D) ESP**

6. What are the characteristic features of RADIUS? (Select 3 answers)

A) Primarily used for network access
B) Encrypts the entire payload of the access-request packet
✓ **C) Combines authentication and authorization**
✓ **D) Encrypts only the password in the access-request packet**
E) Primarily used for device administration
F) Separates authentication and authorization

7. Which of the answers listed below refer to DSA? (Select 3 answers)

A) Asymmetric algorithm
B) Used for the key exchange process
C) Symmetric algorithm
✓ **D) Provides authentication, integrity, and non-repudiation**
✓ **E) Specifically designed for creating and verifying digital signatures**
F) Used for encryption

8. Which of the answers listed below describe(s) the characteristics of ECDSA? (Select all that apply)

A) Provides authentication, integrity, and non-repudiation
✓ **B) Based on elliptic curve cryptography**
C) Designed for data encryption
✓ **D) Specifically designed for creating and verifying digital signatures**
✓ **E) More computationally efficient than other signature algorithms**
F) Enables the key exchange process

9. Which part of IPsec provides authentication, integrity, and confidentiality?

A) SPD
B) PFS
C) AH
✓ **D) ESP**

10. Which block cipher mode combines CTM for encryption with an authentication mechanism to ensure both data confidentiality and integrity?

A) CBC
✓ **B) GCM**
C) ECB
D) CFB

11. Which of the answers listed below refer to common methods of device authentication used within the AAA framework? (Select 3 answers)

A) Usernames and passwords
✓ **B) Digital certificates**
✓ **C) IP addresses**
D) MFA
E) Biometric authentication
✓ **F) MAC addresses**

12. Which of the following statements about honeypots are true? (Select 2 answers)

A) Honeypots are always part of a honeynet
✓ **B) Honeypots mimic real systems to attract cyber attackers**
C) Honeypots are a type of anti-malware solution
✓ **D) Honeypots contain apparent vulnerabilities that are closely monitored by a security team**
E) Honeypots are used to launch attacks on cyber attackers

13. The MIME specification extends the email message format beyond plain text, enabling the transfer of graphics, audio, and video files over the Internet mail system. S/MIME is an enhanced version of the MIME protocol that enables email security features by providing encryption, authentication, message integrity, and other related services.

A) True
B) False

14. Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication, and data integrity for network traffic?

A) TLS
B) SSH
✓ C) IPsec
D) VPN

15. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks
B) IEEE 802.1D
C) Does not require an authentication server
✓ D) IEEE 802.1X
E) Suitable for all types of wireless LANs
✓ F) Requires RADIUS authentication server

16. Which of the answers listed below refers to a secure network protocol used to provide encryption, authentication, and integrity for real-time multimedia communication?

A) IPsec
B) SIP
C) VoIP
✓ D) SRTP

17. OpenID Connect is a protocol used for:

A) Attestation
B) Authorization
C) Auditing
✓ D) Authentication

18. What are the characteristic features of SAML? (Select 3 answers)

A) Enables only the exchange of SSO authorization data
✓ B) Handles both authentication and authorization for SSO
✓ C) Uses XML for data exchange
✓ D) Commonly used in enterprise environments and legacy systems
E) Enables only the exchange of SSO authentication data
F) Uses JSON for data exchange
G) Specifically designed for web and mobile applications

19. An authentication subsystem that enables a user to access multiple, connected system components (such as separate hosts on a network) after a single login on only one of the components is referred to as:

A) NAC
✓ B) SSO
C) AAA
D) MFA

20. Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication, and data integrity for network traffic?

A) TLS
B) SSH
C) IPsec
D) VPN

21. The MIME specification extends the email message format beyond simple text, enabling the transfer of graphics, audio, and video files over the Internet mail system. S/MIME is an enhanced version of the MIME protocol that enables email security features by providing encryption, authentication, message integrity, and other related services.

A) True
B) False

22. A wireless disassociation attack is a type of: (Select 2 answers)

A) Downgrade attack
✓ B) Deauthentication attack
C) Brute-force attack
✓ D) DoS attack
E) Cryptographic attack

23. Which of the answers listed below refers to a technology that provides control over the usage of a mobile device within a designated area?

A) Geofencing
B) Captive portal
C) Honeypot
D) Geolocation
Respuesta no detectada automaticamente

24. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks
B) IEEE 802.1D
C) Does not require an authentication server
✓ D) IEEE 802.1X
E) Suitable for all types of wireless LANs
✓ F) Requires RADIUS authentication server

25. Which of the answers listed below refers to an open standard wireless network authentication protocol that enhances security by encapsulating authentication process within an encrypted TLS tunnel?

A) PEAP
B) EAP
C) LEAP
D) RADIUS
Respuesta no detectada automaticamente

26. What are the examples of preventive security controls? (Select 3 answers)

A) Encryption
B) IDS
C) Sensors
✓ D) Firewalls
E) Warning signs
✓ F) AV software

27. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ B) Log monitoring
C) Sandboxing
✓ D) Security audits
✓ E) CCTV
✓ F) IDS
✓ G) Vulnerability scanning

28. Which type of user account violates the concept of non-repudiation?

A) Standard user account

✓ **B) Shared account**

C) Guest user account

D) Service account

29. Which of the following terms describes the process of identifying differences between an organization's current security posture and its desired security posture?

A) Tabletop exercise

✓ **B) Gap analysis**

C) Security awareness training

D) Risk assessment

30. Which of the answers listed below refers to a Zero Trust Control Plane security approach that takes into account user identity, device security, network conditions, and other contextual information to enable dynamic access decisions?

A) Implicit trust

B) Monitoring and logging

✓ **C) Adaptive identity**

D) Microsegmentation

31. In the Zero Trust security architecture, the Policy Enforcement Point (PEP) is a Data Plane component that enforces the security policies defined at the Control Plane by the Policy Decision Point (PDP).

A) True

B) False

Respuesta no detectada automaticamente

32. Which of the answers listed below refers to a honeynet example?

A) A network of fake websites

B) A network of fake servers

C) A network of fake databases

D) A network of fake file shares

✓ **E) All of the above**

33. A honeyfile can be used for:

A) Attracting cyber attackers

B) Triggering alerts when accessed

C) Monitoring network activity

✓ **D) All of the above**

34. Which of the following should not be used as honeytokens? (Select all that apply)

A) Active user account credentials

B) Database entries mimicking real data

✓ **C) Actual URLs to live websites or resources**

D) Dummy server logs with enticing information

E) Fake identifiers, including usernames, passwords, email addresses, and IP addresses

35. What is the typical use of a public key?

A) Data encryption

B) Data decryption

C) User/device authentication

D) All of the above

36. Which of the answers listed below refers to software technology designed to provide confidentiality for an entire data storage device?

A) TPM

B) FDE

C) EFS

D) HSM

37. Which of the answers listed below refers to a shared secret authentication method used in WPA, WPA2, and EAP?

A) PSK
B) 802.1X
C) SAE
D) TKIP

38. Which of the following answers refers to an embedded microcontroller used for secure boot, disk encryption, and system integrity verification?

A) TPM
B) SoC
C) UEFI
✓ D) HSM

39. What is the purpose of steganography?

A) Checking data integrity
B) Verifying hash values
✓ C) Hiding data within another piece of data
D) Encrypting data

40. Hash functions find use in a variety of applications, including:

A) Cryptography
B) Data integrity verification
C) Password verification and storage
D) Digital signatures
E) Blockchain technology
✓ F) All of the above

41. Which of the following answers refers to a family of cryptographic hash functions designed for various security-related applications, including digital signatures, password storage, secure communications, and data integrity verification?

A) RSA
B) AES
C) PKCS
✓ D) SHA

42. Which of the following combines a cryptographic hash function with a secret key to provide a means of verifying both the authenticity and integrity of a message or data?

A) MD5
B) DSA
✓ C) HMAC
D) DES

43. Examples of threat vectors directly related to the use of removable devices include: (Select 2 answers)

A) Pretexting
✓ B) Malware delivery
C) Watering hole attacks
✓ D) Data exfiltration
E) Social engineering attacks

44. Which of the following answers refer to common threat vectors that apply to MSPs, vendors, and suppliers in the supply chain? (Select 2 answers)

A) Compliance violations
B) Brand reputation damage
✓ C) Propagation of malware
D) Operational disruptions
✓ E) Social engineering techniques

45. Which social engineering attack relies on identity theft?

A) Pretexting
B) Spear phishing
C) Tailgating
✓ **D) Impersonation**

46. Which of the answers listed below refers to a social engineering technique where an attacker creates a false scenario or situation to deceive the victim into revealing sensitive information?

A) Impersonation
B) Credential harvesting
✓ **C) Pretexting**
D) Watering hole attack

47. The practice of installing mobile apps from websites and app stores other than the official marketplaces is referred to as:

A) Jailbreaking
B) Rooting
✓ **C) Sideloading**
D) Carrier unlocking

48. What are the characteristic features of a session ID? (Select all that apply)

A) Enables the server to identify the session and retrieve the corresponding session data
✓ **B) A unique identifier assigned by the website to a specific user**
C) Contains user's authentication credentials, e.g., username and password
✓ **D) A piece of data that can be stored in a cookie, or embedded as a URL parameter**
✓ **E) Stored on the client side (in the user's browser) and sent to the server with each request**
F) A unique identifier assigned to a server

49. Which of the following facilitate(s) privilege escalation attacks? (Select all that apply)

A) System/application vulnerabilities
B) Password hashing
✓ **C) System/application misconfigurations**
D) Network segmentation
✓ **E) Social engineering techniques**

50. A dot-dot-slash attack is also referred to as:

A) Disassociation attack
B) On-path attack
✓ **C) Directory traversal attack**
D) Downgrade attack

51. Which of the following policies applies to any requests that fall outside the criteria defined in an ACL?

A) Fair access policy
✓ **B) Implicit deny policy**
C) Transitive trust
D) Context-aware authentication

52. Which of the answers listed below refers to a technology that provides control over the usage of a mobile device within a designated area?

A) Geofencing
B) Device tracking
C) Perimeter security
D) Geolocation

53. Which of the answers listed below refers to the primary function of load balancing?

A) Maintains identical copies of data across multiple servers to enhance data availability and reliability
✓ **B) Distributes workload across multiple servers for improved performance**

✓ **C) Groups servers together to provide high availability and fault tolerance**

D) Distributes content geographically across multiple servers to improve performance, reduce latency, and handle high volumes of traffic

54. Implementing full device encryption is one of the methods for securing sensitive data on a smartphone. When enabled, this type of encryption works in conjunction with the phone's screen lock, i.e., to decrypt the phone (which stays encrypted whenever the phone is locked), a user must first unlock the screen. On Android devices, the unlocking methods include entering a PIN, password, or drawing a simple pattern with a finger. Apple devices use passcodes, facial recognition (Face ID), and fingerprint (Touch ID).

A) True

B) False

Respuesta no detectada automaticamente

55. Which of the answers listed below refers to the process of assessing the physical environment, such as the layout of the building, to identify potential sources of interference and determine the optimal placement of a WAP?

A) Gap analysis

B) Capacity planning

✓ **C) Site survey**

D) Vulnerability scanning

56. An SSID is a unique identifier (a.k.a. wireless network name) for a WLAN. Wireless networks advertise their presence by regularly broadcasting SSID in a special packet called beacon frame. In wireless networks with disabled security features, knowing the network SSID is enough to get access to the network. SSID also pinpoints the wireless router that acts as a WAP. Wireless routers from the same manufacturer are frequently configured with default (well-known) SSID names. Since multiple devices with the same SSID displayed on the list of available networks create confusion and encourage accidental access by unauthorized users (applies to networks that lack security), changing the default SSID is a recommended practice.

A) True

B) False

Respuesta no detectada automaticamente

57. Which of the following acronyms refers to a client authentication method used in WPA3 Personal mode?

A) SAE

B) IKE

C) PSK

D) AES

58. Which of the following answers refers to a deprecated wireless authentication protocol developed by Cisco?

A) PEAP

B) EAP-TTLS

✓ **C) LEAP**

D) EAP-TLS

59. Which of the following statements does not apply to dark web?

A) Typically requires specialized software to access its contents

✓ **B) Forms a large part of the deep web**

C) Not indexed by traditional search engines

D) Often associated with trading stolen data, malware, and cyber threats

60. A responsible disclosure program is a formal process established by an organization to encourage security researchers and ethical hackers to report vulnerabilities they discover in the organization's systems or software. A bug bounty program is a specific type of responsible disclosure program that offers financial rewards to security researchers for reporting valid vulnerabilities.

A) True

B) False

61. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ F) All of the above answers are examples of vulnerability response and remediation techniques

---

62. Which of the following answers refers to a policy framework that allows domain owners to specify how email receivers should handle emails that fail authentication checks?

✓ A) DKIM

B) SPF

C) PEM

✓ D) DMARC

---

63. Which of the answers listed below refers to an authentication method that enables the signing of an outbound email message with a digital signature?

A) SPF

B) DKIM

C) DMARC

D) PEM

---

64. Which of the following answers refers to an email authentication mechanism that allows domain owners to specify which IP addresses are authorized to send emails on behalf of their domain?

A) DMARC

B) PEM

C) DKIM

D) SPF

---

65. Which of the answers listed below refers to the process of maintaining the integrity of files and data?

A) DLP

B) SIEM

C) FIM

D) SHA

---

66. Which of the following answers refers to a solution that helps organizations mitigate risks associated with data breaches, insider threats, and compliance violations?

A) EDR

B) DLP

C) IAM

D) UTM

---

67. Which of the answers listed below refer(s) to a medium type that can be used as a hardware authentication token? (Select all that apply)

A) Smart card

✓ B) Key fob

✓ C) Security key

D) Passphrase

E) Biometric reader

✓ F) RFID badge

---

68. Which of the answers listed below refer to the features of a security key? (Select 3 answers)

A) Used for OTP generation, remote vehicle access, and building access

✓ B) Hardware authentication token

✓ **C) Typically, a physical USB stick or key fob-sized device**

✓ **D) Primarily used for digital security (2FA/MFA)**

E) Software authentication token

F) Typically, a credit card-sized plastic card with an embedded chip

69. Which of the following answers refers to a general term used to describe a specialized group within an organization focusing on specific tasks or areas of responsibility?

A) Council

B) Advisory board

C) Committee

D) Task force

70. Which of the answers listed below refers to public sector organizations that set and enforce laws and regulations at local, regional, or national levels?

A) Government entities

B) Trade associations

C) Statutory bodies

D) Regulatory agencies

71. Which of the terms listed below refers to a situation where a party's impartiality could be questioned due to potential personal or financial gains?

A) Dual relationship

B) Undue influence

✓ **C) Conflict of interest**

D) Self-dealing

72. Which of the terms listed below is used to describe actions taken to address and mitigate already identified risks?

A) Due diligence

B) Standard of care

✓ **C) Due care**

D) Fiduciary duty

73. What is the best countermeasure against social engineering attacks?

A) Situational awareness

B) Implicit deny policy

✓ **C) User education**

D) Strong security controls

74. A type of document stipulating rules of behavior to be followed by users of computers, networks, and associated resources is called:

A) SLA

B) EULA

✓ **C) AUP**

D) BPA

75. Which of the following answers refers to a shared secret authentication method used in WPA, WPA2, and EAP?

A) PSK

B) 802.1X

C) SAE

D) TKIP

Respuesta no detectada automaticamente

76. Which of the following answers refers to a family of cryptographic hash functions used in a variety of security applications, including digital signatures, password storage, secure communications, and data integrity verification?

A) RSA

B) IDEA
C) AES
✓ **D) SHA**

77. Which of the terms listed below applies to the authentication process?

A) MFA
B) MMC
C) MDM
D) MFD

78. Which of the following answers refers to an embedded microcontroller used for secure boot, disk encryption, and system integrity verification?

A) TPM
B) SoC
C) UEFI
D) HSM

79. A software technology designed to provide confidentiality for an entire data storage device is known as:

A) TPM
✓ **B) FDE**
C) EFS
D) HSM

80. Which of the answers listed below refers to a remote access authentication protocol that periodically re-authenticates client at random intervals to prevent session hijacking?

A) EAP
B) CHAP
C) PAP
D) PEAP

81. Which of the acronyms listed below refers to a piece of hardware and associated software/firmware designed to provide cryptographic and key management functions?

A) EFS
✓ **B) HSM**
C) SFC
D) TPM

82. Which of the answers listed below refers to a rule-based access control mechanism associated with files and/or directories?

A) EFS
✓ **B) FACL**
C) FIM
D) NTFS

83. Which of the answers listed below refers to the process of maintaining the integrity of files and data?

A) DLP
B) SIEM
C) FIM
D) SHA

84. Which of the answers listed below refers to a deprecated wireless authentication protocol developed by Cisco?

A) PEAP
B) EAP-TTLS
C) LEAP
D) EAP-TLS

85. Which of the following combines a cryptographic hash function with a secret key to provide a means of verifying both the authenticity and integrity of a message or data?

A) MD5

B) DSA

✓ C) HMAC

D) DES

86. What are the examples of preventive security controls? (Select 3 answers)

A) Encryption

B) IDS

C) Sensors

✓ D) Firewalls

E) Warning signs

✓ F) AV software

87. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting

✓ B) Log monitoring

C) Sandboxing

✓ D) Security audits

✓ E) CCTV

✓ F) IDS

✓ G) Vulnerability scanning

88. Which of the answers listed below refers to a cryptographic technique that verifies the authenticity and integrity of digital documents or messages by using a unique encrypted identifier from the sender?

A) Digital signature

B) Cryptographic hash function

C) Digital certificate

D) Asymmetric encryption

89. An attack surface is the sum of all the potential points (vulnerabilities) through which an attacker can interact with or compromise a system or network, indicating the overall exposure to potential threats. Examples of attack surfaces can be all software, hardware, and network interfaces with known security flaws. A threat vector represents the method or means through which a cyber threat is introduced or delivered to a target system. It outlines the pathway or avenue used by attackers to exploit vulnerabilities. Common threat vector types include phishing emails, malware, drive-by downloads, and social engineering techniques.

A) True

B) False

Respuesta no detectada automaticamente

90. A social engineering technique whereby attackers under disguise of a legitimate request attempt to gain access to confidential information is commonly referred to as:

A) Phishing

B) Smishing

C) Pharming

D) Spoofing

91. Which of the following answers refers to a social engineering attack that exploits SMS or text messages to deceive recipients into taking harmful actions, such as revealing sensitive information or clicking malicious links?

A) Pharming

B) Spoofing

C) Quishing

✓ D) Smishing

92. Which of the following terms best describes deliberately false or misleading information spread with the intent to deceive or manipulate?

A) Disinformation

B) Deception

C) Gaslighting

D) Manipulation

Respuesta no detectada automaticamente

93. The practice of installing mobile apps from websites and app stores other than the official marketplaces is referred to as:

A) Jailbreaking

B) Rooting

✓ C) Sideloading

D) Carrier unlocking

94. Which of the answers listed below refers to the primary function of load balancing?

A) Maintains identical copies of data across multiple servers to enhance data availability and reliability

✓ B) Distributes workload across multiple servers for improved performance

✓ C) Groups servers together to provide high availability and fault tolerance

D) Distributes content geographically across multiple servers to improve performance, reduce latency, and handle high volumes of traffic

95. An SSID is a unique identifier (a.k.a. wireless network name) for a WLAN. Wireless networks advertise their presence by regularly broadcasting SSID in a special packet called beacon frame. In wireless networks with disabled security features, knowing the network SSID is enough to get access to the network. SSID also pinpoints the wireless router that acts as a WAP. Wireless routers from the same manufacturer are frequently configured with default (well-known) SSID names. Since multiple devices with the same SSID displayed on the list of available networks create confusion and encourage accidental access by unauthorized users (applies to networks that lack security), changing the default SSID is a recommended practice.

A) True

B) False

Respuesta no detectada automaticamente

96. Which of the following acronyms refers to a client authentication method used in WPA3 Personal mode?

A) SAE

B) IKE

C) PSK

D) AES

97. Which of the following statements does not apply to dark web?

A) Typically requires specialized software to access its contents

✓ B) Forms a large part of the deep web

C) Not indexed by traditional search engines

D) Often associated with trading stolen data, malware, and cyber threats

98. A responsible disclosure program is a formal process established by an organization to encourage security researchers and ethical hackers to report vulnerabilities they discover in the organization's systems or software. A bug bounty program is a specific type of responsible disclosure program that offers financial rewards to security researchers for reporting valid vulnerabilities.

A) True

B) False

99. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ F) All of the above answers are examples of vulnerability response and remediation techniques

---

100. Which cryptographic technique is used to prevent the effectiveness of rainbow tables in cracking hashed passwords?

A) Data masking

B) Two-Factor Authentication (2FA)

C) Key stretching

✓ D) Salting

---

101. The process of maintaining a documented record of the handling and movement of evidence to ensure its integrity and admissibility in court is called:

A) Chain of custody

B) Chain of evidence

C) Chain of accountability

D) Chain of responsibility

Respuesta no detectada automaticamente

1.3 - Explain the importance of change management processes.

Conceptos clave:

- Business processes: Approval, Ownership, Impact analysis, Backout plan, Maintenance window
- Technical implications: Allow/deny lists, Downtime, Legacy applications, Dependencies
- Documentation: Updating diagrams, policies/procedures
- Version control

Teoria (Professor Messer):

and the impact to security."

Change Management

- Upgrading software, patching an application, changing firewall configuration, modifying switch ports, etc.
- One of the most common and frequent risks and enterprise, must be standardized
- **Change approval process**: a formal process for making change

1. Complete request forms
2. Determine purpose of change
3. Identify scope of change
4. Schedule a date and time
5. Determine affected systems and impact
6. Analyze risk associated with change
   - Ownership
     - Individual or entity needs to make a change - they own the process but don't perform the actual change
     - Owner manages the change process, is informed of updates and must test their system afterward
   - Stakeholders - who is impacted by this change?
   - Impact analysis
     - Determine a risk value (high, medium, low)
     - What risks can occur upon making the change? What about NOT making the change?
   - Test results - sandbox testing environment
     - Technological "safe space"
     - Use before making change to production
     - Confirm a backout (revert) plan
   - Backout plan
     - Change might not go well, always have a way to revert your changes
     - Some changes may be very difficult to revert

- Maintenance window - when is the change happening?
  - Might be the most difficult part of the process
  - Time of day, time of month, time of year
- Standard operating procedure
  - Change management is critical and must be well-documented
  - Changes to process itself must fit within standards

Technical Change Management

- Put change management process into action
- Change management concerned with what, technical team handles the how
- Allow list / deny list - security policy controlling app execution
  - Allow list - nothing runs unless it's approved
  - Deny list - everything runs unless it's disapproved (i.e. anti-malware)
- Restricted activities
  - Scope of a change is critical
  - Change approval is permission only for specific changes
  - Scope may need to be expanded
  - Change management process determines next steps
- Downtime
  - Services will be eventually unavailable, usually done during non-business hours
  - If possible, prevent any downtime, switch to secondary system
    - Should be as automated as possible, part of backout plans
  - Send email notifications and calendar updates
- Restarts - common requirement
  - Reboot OS, power cycle switch, bounce service
  - Services - stop and restart service or daemon
  - Application - close completely
- Legacy applications
  - Been around a while, often no longer supported
  - Document the system, may be quirky
- Dependencies - may add complexity
  - To complete A, you must complete B
  - Libraries, other applications, etc.
  - Modifying one component may require modifying/restarting several others
- Documentation
  - New changes require new processes and documentation
  - Updating diagrams (network, etc.)
  - Updating policies and procedures
- Version control
  - Track changes to a file or config data over time
  - Router configs, Windows patches, application registry entries, etc.
  - Some devices/suites provide this , some need additional software

Tips y trucos para el examen:

DOCUMENTACION: siempre actualizar diagramas de red, politicas y procedimientos tras un cambio. Version control para el codigo y configuraciones.

Regla de oro del examen: si una pregunta menciona 'que hacer antes de implementar un cambio critico', la respuesta casi siempre incluye 'backout plan' y 'impact analysis'.

Preguntas de practica (4):

1. Which of the answers listed below refers to a deprecated stream cipher used in some legacy applications, such as WEP?

A) RSA

B) DES

C) SSL

D) RC4

2. Which of the terms listed below refers to tracking and managing software application components, such as third-party libraries and other dependencies?

A) Version control
B) Package monitoring
C) Configuration enforcement
D) Application hardening

3. Which of the following answers refers to a deprecated stream cipher used in some legacy applications, such as WEP?

A) RSA
B) DES
C) SSL
D) RC4

4. Which of the terms listed below refers to tracking and managing software application components, such as third-party libraries and other dependencies?

A) Version control
B) Package monitoring
C) Configuration enforcement
D) Application hardening

1.4 - Explain the importance of using appropriate cryptographic solutions.

Conceptos clave:

- PKI: Public key, Private key, Key escrow
- Encryption: Full-disk, Partition, File, Volume, Database, Symmetric, Asymmetric
- Tools: TPM, HSM, Key management system, Secure enclave
- Obfuscation: Steganography, Tokenization, Data masking
- Hashing, Salting, Digital signatures, Key stretching, Blockchain
- Certificates: CA, CRL, OCSP, CSR, Wildcard, Self-signed

Teoria (Professor Messer):

solutions."

Public Key Infrastructure (PKI)

- Includes policies, procedures, hardware, software, people
- Creating, distributing, managing, storing, revoking digital certificates
- Also refers to the binding of public keys to people or devices, in association with certificate authority
- Symmetric encryption
  - A single, shared key
    - Used for the encryption and decryption of data
  - Secret key algorithm
  - Doesn't scale very well, but very fast
  - Often combined with asymmetric encryption
- Asymmetric encryption
  - Public key cryptography - two mathematically related keys
  - Private key and public key
    - Alice encrypts with Bob's public key
    - Bob decrypts with his private key
  - Cannot derive private key from public key
- The key pair
  - Key generation involves random and very large prime numbers
  - Everyone has public key, only individual has private key
-
- Key escrow

    - Someone else holds your decryption keys (third-party)
        - May be within your organization
    - Business/government might need to decrypt partner data
    - Controversial, but can be legitimate business arrangement

Encrypting Data

- Encrypting stored data
    - Protect data on stored data (data at rest)
    - Full-disk and partition/volume encryption - BitLocker, FileVault, etc.
    - File encryption - EFS, etc.
- Database encryption
    - Protecting and transmitting stored data
    - Transparent encryption - encrypt all database info with symmetric key
    - Record-level encryption - encrypt individual columns and use separate keys
- Transport encryption
    - Protect data traversing the network
    - Encrypting in the application (HTTPS, etc.)
    - VPN (Virtual Private Network)
        - Encrypts all data transmitted over the network
        - Client-based using SSL/TLS, site-to-site using IPSec
- Encryption algorithms
    - Many different options, both sides decide on algorithm
    - Differentiate in security, speed, complexity
    - (his graphic here for DES vs. AES is too vague/inaccurate)
- Cryptographic keys
    - To be secure, cryptographic solutions must be able to withstand the algorithm/process being revealed (only cracked if key is in possession)
    - Kerckhoff's principle - **the security of a cryptographic system shouldn't rely on the secrecy of the algorithm**
    - Key determines the output (encrypted data, hash value, etc.)
- Key lengths
    - Larger key = more secure
    - Symmetric encryption is commonly 128-, 192-, or 256-bit (AES)
    - Asymmetric encryption requires larger keys (3,072-bit or larger)
- Key stretching - make a key stronger by encrypting data multiple times

Key Exchange

- Large and popular logistical challenge
- One example is "out-of-band" (not over network)
- In-band key exchange - over network, protect key with additional encryption
- Real-time encryption/decryption
    - Share a symmetric session key using asymmetric encryption (i.e. Diffie-Hellman)

Encryption Technologies

- Trusted Platform Module (TPM)
    - **Cryptography hardware on a device,** specification for cryptographic functions
    - Cryptographic processor (RNG, keygen)
    - Persistent memory - keys burned during manufacturing
    - Versatile memory - storage keys and hardware config info (BitLocker, etc.)
    - Password protected
- Hardware Security Module (HSM)
    - Used in large environments - securely store thousands of keys
    - High-end cryptographic hardware
    - Cryptographic accelerators - offload high computing requirement
- Key management system
    - Centralized management system, on-premises or cloud-based
    - Separate keys from encrypted data

    - All key management from one console
  - Keeping data private
    - Many, many different locations, wide attack vector
  - Secure enclave - a protected area, hardware isolated from main processor
    - Provides extensive security features
      - Has own boot ROM, monitors bot process
      - Has TRNG, real-time memory encryption, and root keys

Obfuscation

- The process of making something unclear, hiding info in plain sight
- Steganography - hiding information in images
  - Message is invisible but extractable
- Common steganography techniques
  - Network-based - embed messages in TCP packets
  - Use and image - embed message in the image itself
  - Invisible watermarks
  - Audio and video steganography
- Tokenization - replace sensitive data with a non-sensitive placeholder
  - Common with credit card processing - temporary token during payment
  - NOT encryption or hashing, original data and token not related
  -
- Data masking
  - Data obfuscation - hide some of the original data - protects S/PII
  - May only be hidden from view (still in storage)

Hashing and Digital Signatures

- Hashes - represent data as a short string of text
  - One-way function, impossible to recover data from hash
  - Used for integrity and digital signatures
- Collision
  - Hash functions may produce an identical hash from different input (i.e. MD5)
  - Modern hash functions (SHA256, etc.) do not have this problem
- Practical hashing
  - Verify a downloaded file by comparing hash with one provided on source
  - Storing passwords as a salted hash and use those during authentication
- Adding some salt - random data added to a password when hashing
  - Every user gets their own random salt, changes hash completely
  - Breaks rainbow tables (pre-computed hashes of common passwords)
- Digital signatures
  - Prove integrity, authentication, non-repudiation
  - Sign with private key, verify with public key
  - Any change in message will invalidate the signature

Blockchain Technology

- Blockchain - a distributed ledger to keep track of transactions
  - Everyone maintains the ledger
- The blockchain process

1. Transaction is requested
2. Transaction is sent to every node in a decentralized network to be verified
3. Verified transaction is added to a new block of data with other transactions
4. Hash is calculated from previous blocks of transaction data and added to new block of verified transactions
5. Block is added to end of Blockchain, updated to all nodes in the network
6. If any blocks altered, all hashes recalculated, altered chain now rejected

Certificates

- Digital certificates - a public key certificate

    - Binds a public key with a digital signature
    - Adds trust using Certificate Authority
    - Web of Trust adds other users for additional trust
    - Can also be built in to OS (Windows Domain services, etc.
  - What's in a digital certificate?
    - X.509 - standard format
    - Details - serial number, version, algorithm, issuer, cert holder, public key, etc.
  - Root of trust - an inherently trusted component to build trust
    - Hardware, software, firmware, etc.
    - HSM, Secure Enclave, CA, etc.
  - Certificate Authorities
    - Digitally signs website certificates to provide real-time verification
    - Third-party trust for an unknown entity (website)
    - Hundreds of third-party CAs, built in to browser
  - Certificate signing requests
    - Create key pair, send public key to CA to be signed
      - Certificate signing request (CSR)
    - CA validates request (confirm DNS emails and website ownership)
    - CA digitally signs cert and returns to applicant
    -
  - Private certificate authorities
    - You're your own CA, devices must trust internal CA
    - Needed for medium to large organizations with lots of web servers
    - Windows Certificate Services, OpenCA, etc.
  - Self-signed certificates
    - Internal certificates don't need to be signed by a public CA
    - Build your own CA to issue your own certificates
    - Install CA certificate on all internal devices
  - Wildcard certificates
    - Subject Alternative Name (SAN) - *.domain.com
      - Extension to X.509
      - Allows certificate to support many domains
    - Wildcard domain
      - Certificates based on the name of the server
      - Applies to all server names in a domain
  - Key revocation
    - Certificate Revocation List (CRL)
      - Maintained by CA
      - CVE-2014-0160 (Heartbleed) - OpenSSL flaw that required every web server certificate be replaced
  - OCSP stapling - Online Certificate Status Protocol
    - Provides scalability for OCSP checks
    - CA responsible for responding to all client OCSP requests
    - Instead of this, have certificate holder very their own status
    - OCSP status is "stapled" into the SSL/TLS handshake
  - Getting revocation details to the browser
    - OCSP - browser can check certificate revocation
    - Messages usually sent to OCSP responder via HTTP
      - More efficient than downloading a CRL
    - Not all browsers/apps support OCSP (most modern do)

Tips y trucos para el examen:

OTROS CONCEPTOS DE CRIPTOGRAFIA:

- TPM (Trusted Platform Module): chip en la placa base que almacena claves y verifica el arranque seguro
- HSM (Hardware Security Module): dispositivo dedicado a operaciones criptograficas de alta seguridad
- Steganography: ocultar informacion dentro de otros archivos (imagen, audio) sin que sea visible

- Tokenization: sustituir datos sensibles por un token sin valor criptografico (usado en pagos con tarjeta)
- Data masking: ocultar parte de los datos (ej: mostrar solo los ultimos 4 digitos de una tarjeta)
- Blockchain: registro distribuido e inmutable, cada bloque encadena el hash del anterior

CERTIFICADOS DIGITALES:

- Wildcard certificate: cubre un dominio y todos sus subdominios (*.ejemplo.com)
- SAN (Subject Alternative Name): un solo certificado para multiples dominios
- Self-signed: firmado por uno mismo, no validado por CA externa (util en redes internas)
- CSR (Certificate Signing Request): solicitud enviada a la CA para obtener un certificado

Preguntas de practica (354):

1. In asymmetric encryption, any message encrypted with the use of a public key can only be decrypted by applying the same algorithm and a matching private key (and vice versa).

A) True
B) False

---

2. Which of the following algorithms do(es) not fall into the category of asymmetric encryption? (Select all that apply)

A) AES
✓ B) DES
C) DHE
D) ECC
✓ E) IDEA
✓ F) RC4
G) RSA

---

3. Which of the answers listed below refers to a cryptographic technique that verifies the authenticity and integrity of digital documents or messages by using a unique encrypted identifier from the sender?

A) Digital signature
B) Cryptographic hash function
C) Digital certificate
D) Asymmetric encryption

---

4. Which of the answers listed below refers to a set of standards and specifications that define various cryptographic techniques, including formats for public keys, private keys, digital signatures, and digital certificates?

A) ITIL
B) RFC
C) PKCS
D) ISO/IEC

---

5. Which of the answers listed below refers to a set of standards and specifications that define various cryptographic techniques, including formats for public keys, private keys, digital signatures, and digital certificates?

A) ITIL
B) RFC
C) PKCS
D) ISO/IEC

---

6. Which of the following answers refers to a deprecated (largely replaced by AES) symmetric-key block cipher encryption algorithm?

A) ECDSA
B) RSA
C) IDEA
D) DSA

---

7. Which of the answers listed below refer to DSA? (Select 3 answers)

A) Asymmetric algorithm
B) Used for the key exchange process
C) Symmetric algorithm
✓ **D) Provides authentication, integrity, and non-repudiation**
✓ **E) Specifically designed for creating and verifying digital signatures**
F) Used for encryption

8. Which of the following answers refers to a deprecated (largely replaced by AES) symmetric-key block cipher encryption algorithm?

A) ECDSA
B) RSA
C) IDEA
D) DSA
Respuesta no detectada automaticamente

9. Which of the following answers refer(s) to deprecated/insecure encryption protocols and cryptographic hash functions? (Select all that apply)

A) DES
B) AES-256
✓ **C) MD5**
D) ECC
✓ **E) SHA-1**
✓ **F) SSL**
✓ **G) RC4**

10. Examples of techniques used for encrypting information include symmetric encryption (also called public-key encryption) and asymmetric encryption (also called secret-key encryption, or session-key encryption).

A) True
✓ **B) False**

11. Which of the algorithms listed below are not symmetric ciphers? (Select 3 answers)

A) AES
✓ **B) DES**
✓ **C) DHE**
✓ **D) ECC**
E) IDEA
F) RC4
✓ **G) RSA**

12. Which of the following answers refers to an embedded microcontroller used for secure boot, disk encryption, and system integrity verification?

A) TPM
B) SoC
C) UEFI
✓ **D) HSM**

13. Which of the following answers refers to a family of cryptographic hash functions designed for various security-related applications, including digital signatures, password storage, secure communications, and data integrity verification?

A) RSA
B) AES
C) PKCS
✓ **D) SHA**

14. Given the computational limitations of IoT devices, smartcards, and mobile devices, which of the following digital signature algorithms would be the most efficient choice due to its smaller key size and lower

processing requirements?

A) RSA
B) ECDHE
C) DSA
✓ **D) ECDSA**
E) ECC

15. Which of the answers listed below refers to a technique that enables converting input data into a fixed-size string, making it difficult to reverse or retrieve the original data?

✓ **A) Obfuscation**
✓ **B) Tokenization**
C) Hashing
D) Encryption

16. Which of the following answers refers to a family of cryptographic hash functions used in a variety of security applications, including digital signatures, password storage, secure communications, and data integrity verification?

A) RSA
B) IDEA
C) AES
✓ **D) SHA**

17. Which of the following answers refers to an embedded microcontroller used for secure boot, disk encryption, and system integrity verification?

A) TPM
B) SoC
C) UEFI
D) HSM

18. Which of the following answers refers to a public-key cryptosystem used for digital signatures, secure key exchange, and encryption?

A) DHE
B) RSA
C) AES
D) DSA

19. What is the fastest way for checking the validity of a digital certificate?

A) CRL
B) OSPF
C) CSR
✓ **D) OCSP**

20. Which of the answers listed below refers to an encoding method (and a file format) for storing cryptographic objects such as X.509 certificates, CRLs, and private keys?

A) ECB
✓ **B) PEM**
C) FIM
D) PFS

21. Given the computational limitations of IoT devices, smartcards, and mobile devices, which of the following digital signature algorithms would be the most efficient choice due to its smaller key size and lower processing requirements?

A) RSA
B) ECDHE
C) DSA
✓ **D) ECDSA**
E) ECC

22. A type of digital document that verifies the identity of an individual, device, service, or organization in online communications is known as:

A) Encryption key

✓ B) Digital certificate

C) Identity token

D) Digital signature

---

23. Which of the answers listed below refers to a protocol that enables on-demand querying of the revocation status of a digital certificate?

A) CSP

✓ B) OCSP

C) DN

D) CRL

---

24. Which of the answers listed below refers to a technique that enables converting input data into a fixed-size string, making it difficult to reverse or retrieve the original data?

A) Obfuscation

B) Tokenization

✓ C) Hashing

D) Encryption

---

25. A hierarchical system for the creation, management, storage, distribution, and revocation of digital certificates is known as:

A) PKI

B) RA

C) PKCS

D) CA

---

26. What is the typical use of a public key?

A) Data encryption

B) Data decryption

C) User/device authentication

D) All of the above

---

27. Which of the following answers refers to a data storage device equipped with hardware-level encryption functionality?

A) HSM

B) TPM

C) EFS

✓ D) SED

---

28. Which of the following answers refers to a legacy symmetric-key block cipher encryption algorithm?

A) RC4

✓ B) DES

C) RSA

D) DSA

---

29. Hash functions find use in a variety of applications, including:

A) Cryptography

B) Data integrity verification

C) Password verification and storage

D) Digital signatures

E) Blockchain technology

✓ F) All of the above

---

30. Which of the answers listed below refers to a hierarchical system for the creation, management, storage, distribution, and revocation of digital certificates?

A) PKI
B) RA
C) PKCS
D) CA

31. Which of the following answers refers to a data storage device equipped with hardware-level encryption functionality?

A) HSM
B) TPM
C) EFS
✓ D) SED

32. Which of the solutions listed below allows to check whether a digital certificate has been revoked?

A) OCR
✓ B) CRL
C) CSR
D) OSPF

33. Which of the following answers refers to a cryptographic file generated by an entity requesting a digital certificate from a CA?

A) OID
✓ B) CSR
C) DN
D) CRL

34. Which of the answers listed below describe(s) the characteristics of ECDSA? (Select all that apply)

A) Provides authentication, integrity, and non-repudiation
✓ B) Based on elliptic curve cryptography
C) Designed for data encryption
✓ D) Specifically designed for creating and verifying digital signatures
✓ E) More computationally efficient than other signature algorithms
F) Enables the key exchange process

35. What are the applications of PGP? (Select 3 answers)

A) Compressing data
✓ B) Encrypting and decrypting data
✓ C) Signing and verifying digital signatures
✓ D) Managing public and private keys
E) Securing website traffic

36. Which of the following answers refers to a data storage device equipped with hardware-level encryption functionality?

A) HSM
B) TPM
C) EFS
✓ D) SED

37. Which of the answers listed below refers to a situation where sensitive data is stored in a separate location and can be retrieved with a non-sensitive replacement that can also be processed just like the original data without the risk of revealing the contents of original data?

A) Masking
✓ B) Obfuscation
C) Encryption
✓ D) Tokenization

38. Which cryptographic technique is used to prevent the effectiveness of rainbow tables in cracking hashed passwords?

A) Data masking

B) Two-Factor Authentication (2FA)
C) Key stretching
✓ **D) Salting**

39. Which of the answers listed below refer to common methods of device authentication used within the AAA framework? (Select 3 answers)

A) Usernames and passwords
✓ **B) Digital certificates**
✓ **C) IP addresses**
D) MFA
E) Biometric authentication
✓ **F) MAC addresses**

40. Which of the answers listed below refers to software technology designed to provide confidentiality for an entire data storage device?

A) TPM
B) FDE
C) EFS
D) HSM

41. The MIME specification extends the email message format beyond plain text, enabling the transfer of graphics, audio, and video files over the Internet mail system. S/MIME is an enhanced version of the MIME protocol that enables email security features by providing encryption, authentication, message integrity, and other related services.

A) True
B) False

42. Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication, and data integrity for network traffic?

A) TLS
B) SSH
✓ **C) IPsec**
D) VPN

43. An encryption protocol primarily used in Wi-Fi networks implementing the WPA2 security standard is called:

A) TKIP
✓ **B) CCMP**
C) SSL
D) IPsec

44. Which of the answers listed below refers to a deprecated stream cipher used in some legacy applications, such as WEP?

A) RSA
B) DES
C) SSL
D) RC4

45. In cryptography, the number of bits in a key used by a cryptographic algorithm is referred to as key size or key length. The key length determines the maximum number of combinations required to break the encryption algorithm, therefore typically a longer key means stronger cryptographic security.

A) True
B) False

46. Which of the following answers refers to a centralized server that is used to distribute cryptographic keys and authenticate users and services within a computer network?

A) PKI
B) RAS

✓ **C) KDC**

D) NAS

47. Which of the following answers refer to algorithms used for generating and verifying digital signatures? (Select 3 answers)

A) ECDSA

B) RSA

C) ECDHE

D) DSA

E) GPG/PGP

48. Which of the answers listed below refers to a trusted third party responsible for issuing, revoking, and managing digital certificates?

A) RA

B) DN

C) CA

D) CSP

49. Which of the following answers can be used to describe self-signed digital certificates? (Select 3 answers)

A) Backed by a well-known and trusted third party

✓ **B) Not trusted by default by web browsers and other applications**

✓ **C) Used in trusted environments, such as internal networks and development environments**

D) Suitable for websites and other applications that are accessible to the public

E) Trusted by default by web browsers and other applications

✓ **F) Not backed by a well-known and trusted third party**

50. Third-party digital certificates, issued by trusted CAs, are automatically trusted by most browsers and operating systems, involve a cost, and require validation of the applicant's identity. In contrast, self-signed certificates, issued by the entity to itself, are not automatically trusted, are free to create and use, and do not require validation by a CA.

A) True

B) False

Respuesta no detectada automaticamente

51. Which of the answers listed below refers to a PKI trust model?

A) Single CA model

B) Hierarchical model (root CA + intermediate CAs)

C) Mesh model (cross-certifying CAs)

D) Web of trust model (all CAs function as root CAs)

E) Chain of trust model (multiple CAs in a sequential chain)

F) Bridge model (cross-certifying between separate PKIs)

G) Hybrid model (combining aspects of different models)

✓ **8) All of the above**

52. A type of digital certificate that can be used to secure multiple subdomains within a primary domain is known as:

A) Root signing certificate

✓ **B) Subject Alternative Name (SAN) certificate**

C) Extended Validation (EV) certificate

✓ **D) Wildcard certificate**

53. Which of the following facilitate(s) privilege escalation attacks? (Select all that apply)

A) System/application vulnerabilities

B) Password hashing

✓ **C) System/application misconfigurations**

D) Network segmentation

✓ **E) Social engineering techniques**

54. Which of the following URLs is a potential indicator of a directory traversal attack?

A) http://www.example.com/var/../etc/passwd

B) http://www.example.com/var/www/../../etc/passwd

C) http://www.example.com/var/www/files/../../../etc/passwd

D) http://www.example.com/var/www/files/images/../../../../etc/passwd

✓ E) Any of the above

---

55. Which of the following answers does not refer to the concept of system/application isolation?

A) Virtualization

B) Containerization

C) Sandboxing

✓ D) Data encryption

---

56. Which part of IPsec provides confidentiality, data integrity, and authentication?

A) AES

B) SHA

C) AH

✓ D) ESP

---

57. Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answers)

A) Enhances security by limiting the spread of cyberattacks

✓ B) Helps organizations comply with data regulatory requirements by isolating and protecting specific data types

C) Provides security for data in transit with the use of encryption

D) Guarantees data recovery in case of accidental deletion or system failures

✓ E) Provides better control over user access to sensitive data

---

58. Which of the following acronyms refers to a client authentication method used in WPA3 Personal mode?

A) SAE

B) IKE

C) PSK

D) AES

---

59. Which of the answers listed below refers to a secure network protocol used to provide encryption, authentication, and integrity for real-time multimedia communication?

A) IPsec

B) SIP

C) VoIP

✓ D) SRTP

---

60. Which of the answers listed below refers to an authentication method that enables the signing of an outbound email message with a digital signature?

A) SPF

B) DKIM

C) DMARC

D) PEM

---

61. Which of the answers listed below refers to a cryptographic standard (and a file format) used for the storage and transmission of private keys in email communications?

A) PEM

B) DMARC

C) SPF

D) DKIM

---

62. Which of the answers listed below refers to a software tool specifically designed to store and manage login credentials?

A) BitLocker

B) Password manager
C) Key escrow
D) Password vault

63. Which wireless security protocol has been deprecated in favor of newer standards due to known vulnerabilities resulting from implementation flaws?

A) EAP
B) AES
C) WPA2
✓ D) WEP

64. Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication, and data integrity for network traffic?

A) TLS
B) SSH
C) IPsec
D) VPN

65. Which of the following answers refers to a method for creating and verifying digital signatures?

A) DHE
B) AES
C) DSA
D) SHA

66. A software technology designed to provide confidentiality for an entire data storage device is known as:

A) TPM
✓ B) FDE
C) EFS
D) HSM

67. Which of the acronyms listed below refers to a piece of hardware and associated software/firmware designed to provide cryptographic and key management functions?

A) EFS
✓ B) HSM
C) SFC
D) TPM

68. The MIME specification extends the email message format beyond simple text, enabling the transfer of graphics, audio, and video files over the Internet mail system. S/MIME is an enhanced version of the MIME protocol that enables email security features by providing encryption, authentication, message integrity, and other related services.

A) True
B) False

69. Which of the answers listed below refers to a logical operation commonly used in the context of cybersecurity, particularly in encryption and obfuscation techniques?

A) AND
B) OR
C) NOT
D) XOR
Respuesta no detectada automaticamente

70. Which of the following answers refers to a deprecated stream cipher used in some legacy applications, such as WEP?

A) RSA
B) DES
C) SSL
D) RC4

71. An MS Windows component that enables encryption of individual files is called:

A) SED

✓ B) EFS

C) BitLocker

D) FDE

72. Which cryptographic protocol is designed to provide secure communications over a computer network and is the successor to SSL?

A) IPsec

✓ B) TLS

C) AES

D) CCMP

73. A block cipher mode that combines a unique counter with encryption key to generate a stream of pseudorandom data blocks which are then used for encrypting data is called:

A) CBC

B) GCM

C) CFB

✓ D) CTM

74. Which block cipher mode combines CTM for encryption with an authentication mechanism to ensure both data confidentiality and integrity?

A) CBC

✓ B) GCM

C) ECB

D) CFB

75. Which of the following answers refer to algorithms used for generating and verifying digital signatures? (Select 3 answers)

A) ECDSA

B) RSA

C) ECDHE

D) DSA

E) GPG/PGP

76. Which of the answers listed below refers to a trusted third party responsible for issuing, revoking, and managing digital certificates?

A) RA

B) DN

✓ C) CA

D) CSP

77. Which of the following answers can be used to describe self-signed digital certificates? (Select 3 answers)

A) Backed by a well-known and trusted third party

✓ B) Not trusted by default by web browsers and other applications

✓ C) Used in trusted environments, such as internal networks and development environments

D) Suitable for websites and other applications that are accessible to the public

E) Trusted by default by web browsers and other applications

✓ F) Not backed by a well-known and trusted third party

78. Third-party digital certificates, issued by trusted CAs, are automatically trusted by most browsers and operating systems, involve a cost, and require validation of the applicant's identity. In contrast, self-signed certificates, issued by the entity to itself, are not automatically trusted, are free to create and use, and do not require validation by a CA.

A) True

B) False

Respuesta no detectada automaticamente

79. Which of the answers listed below refers to a PKI trust model?

A) Single CA model
B) Hierarchical model (root CA + intermediate CAs)
C) Mesh model (cross-certifying CAs)
D) Web of trust model (all CAs function as root CAs)
E) Chain of trust model (multiple CAs in a sequential chain)
F) Bridge model (cross-certifying between separate PKIs)
G) Hybrid model (combining aspects of different models)
✓ 8) All of the above

80. A type of digital certificate that can be used to secure multiple subdomains within a primary domain is called:

A) Root signing certificate
✓ B) Subject Alternative Name (SAN) certificate
C) Extended Validation (EV) certificate
✓ D) Wildcard certificate

81. Which of the following URLs is a potential indicator of a directory traversal attack?

A) http://www.example.com/var/../etc/passwd
B) http://www.example.com/var/www/../../etc/passwd
C) http://www.example.com/var/www/files/../../../etc/passwd
D) http://www.example.com/var/www/files/images/../../../../etc/passwd
✓ E) Any of the above

82. Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answers)

A) Enhances security by limiting the spread of cyberattacks
✓ B) Helps organizations comply with data regulatory requirements by isolating and protecting specific data types
C) Provides security for data in transit with the use of encryption
D) Guarantees data recovery in case of accidental deletion or system failures
✓ E) Provides better control over user access to sensitive data

83. Which of the following acronyms refers to a client authentication method used in WPA3 Personal mode?

A) SAE
B) IKE
C) PSK
D) AES

84. Which of the wireless encryption schemes listed below offers the highest level of protection?

A) WPS
✓ B) WPA3
C) AES
D) TKIP

85. Which of the answers listed below refers to a software tool specifically designed to store and manage login credentials?

A) BitLocker
B) Password manager
C) Key escrow
D) Password vault

86. Which of the following answers can be used to describe technical security controls? (Select 3 answers)

A) Focused on protecting material assets
✓ B) Sometimes called logical security controls
✓ C) Executed by computer systems (instead of people)
D) Also known as administrative controls
✓ E) Implemented with technology

F) Primarily implemented and executed by people (as opposed to computer systems)

87. Which of the following answers refer to the characteristic features of managerial security controls? (Select 3 answers)

A) Also known as administrative controls

B) Sometimes referred to as logical security controls

✓ C) Focused on reducing the risk of security incidents

D) Executed by computer systems (instead of people)

✓ E) Documented in written policies

F) Focused on protecting material assets

88. Which of the answers listed below can be used to describe operational security controls (Select 3 answers)

A) Also known as administrative controls

✓ B) Focused on the day-to-day procedures of an organization

C) Executed by computer systems (instead of people)

✓ D) Used to ensure that the equipment continues to work as specified

E) Focused on managing risk

✓ F) Primarily implemented and executed by people (as opposed to computer systems)

89. Which of the answers listed below refers to security controls designed to deter, detect, and prevent unauthorized access, theft, damage, or destruction of material assets?

A) Managerial security controls

✓ B) Physical security controls

C) Technical security controls

D) Operational security controls

90. What are the examples of preventive security controls? (Select 3 answers)

A) Encryption

B) IDS

C) Sensors

✓ D) Firewalls

E) Warning signs

✓ F) AV software

91. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting

✓ B) Log monitoring

C) Sandboxing

✓ D) Security audits

✓ E) CCTV

✓ F) IDS

✓ G) Vulnerability scanning

92. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems

B) Video surveillance

✓ C) MFA

✓ D) Application sandboxing

✓ E) Network segmentation

93. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP

✓ B) AUP

C) IDS

D) MFA

E) IPS

94. In the AAA security architecture, the process of granting or denying access to resources is known as:

A) Authentication

✓ **B) Authorization**

✓ **C) Accounting**

95. Which of the following solutions provide(s) the AAA functionality? (Select all that apply)

A) CHAP

✓ **B) TACACS+**

C) PAP

✓ **D) RADIUS**

E) MS-CHAP

96. A honeyfile can be used for:

A) Attracting cyber attackers

B) Triggering alerts when accessed

C) Monitoring network activity

✓ **D) All of the above**

97. SFTP is an extension of the FTP protocol that adds support for SSL/TLS encryption.

A) True

✓ **B) False**

98. A system that uses public network (such as the Internet) as a means for creating private encrypted connections between remote locations is referred to as:

A) WWAN

✓ **B) VPN**

C) PAN

D) VLAN

99. Which of the answers listed below refers to a shared secret authentication method used in WPA, WPA2, and EAP?

A) PSK

B) 802.1X

C) SAE

D) TKIP

100. Which of the cryptographic algorithms listed below is the least vulnerable to attacks?

A) AES

B) DES

C) RC4

D) 3DES

Respuesta no detectada automaticamente

101. Which block mode transforms a block cipher into a stream cipher enabling the encryption of individual bits or bytes of data?

A) CFB

B) CBC

C) GCM

D) ECB

Respuesta no detectada automaticamente

102. In cryptography and security, the term "Secure enclave" typically refers to a protected and isolated hardware or software environment within a computing device, such as a smartphone, tablet, or computer, where sensitive data and cryptographic operations can be stored and processed securely.

A) True

B) False

Respuesta no detectada automaticamente

103. What is the purpose of steganography?

A) Checking data integrity
B) Verifying hash values
✓ **C) Hiding data within another piece of data**
D) Encrypting data

104. Replacing password characters in a password field with a series of asterisks is an example of:

A) Data masking
B) Tokenization
C) Anonymization
D) Pseudo-anonymization
Respuesta no detectada automaticamente

105. Which of the following is an example of a key stretching algorithm?

A) RIPEMD
B) SHA
C) HMAC
✓ **D) PBKDF2**

106. Blockchain technology is an example of:

A) Online payment gateway
B) Centralized database
✓ **C) Open public ledger**
D) Cloud storage system

107. Which of the answers listed below refers to an identifier used for PKI objects?

A) OID
B) DN
C) SAN
D) GUID
Respuesta no detectada automaticamente

108. Assign the level of sophistication attribute to each threat actor type listed below.

Respuesta no detectada automaticamente

109. From the drop-down list on the right, select the typical motivations behind the actions of each threat actor type.

Respuesta no detectada automaticamente

110. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM
✓ **B) APT**
C) XSRF
D) DDoS

111. Which of the answers listed below refers to an example of a potential threat vector in IM-based communication?

A) Phishing attack
B) Malware distribution
C) Spoofing attack
D) Eavesdropping
E) Account hijacking
F) Malicious link/attachment
✓ **G) All of the above**

112. Which of the following answers refers to a threat vector characteristic only to wired networks?

A) ARP Spoofing

B) VLAN hopping

✓ **C) Cable tapping**

D) Port sniffing

E) All of the above

113. Which of the answers listed below refers to the most probable cause of an unauthorized access caused by the exploitation of a specific network entry point?

A) Outdated AV software

B) Browser cookies

✓ **C) Open service ports**

D) Insufficient logging and monitoring

114. The term "URL hijacking" (a.k.a. "Typosquatting") refers to a deceptive practice involving the deliberate registration of domain names with misspellings or slight variations that closely resemble well-established and popular domain names. The primary goal of this strategy is to exploit the common typographical errors made by users while entering URLs into their web browser's address bar. Beyond capturing inadvertent traffic, typosquatting may also be used for hosting phishing sites to trick users into divulging sensitive information, distributing malware through deceptive websites, generating ad revenue by redirecting mistyped traffic, or engaging in brand impersonation to harm the reputation of authentic brands or deceive users.

A) True

B) False

115. A collection of precompiled functions designed to be used by more than one Microsoft Windows application simultaneously to save system resources is known as:

A) DLL

B) API

C) EXE

D) INI

116. A type of exploit in which an application overwrites the contents of a memory area it should not have access to is called:

A) DLL injection

✓ **B) Buffer overflow**

C) Memory leak

D) Privilege escalation

117. Which of the following answers does not refer to a common type of OS-based vulnerability?

A) Access control and permissions vulnerabilities (weak passwords, privilege escalation)

B) Vulnerabilities in installed applications, system utilities, and device drivers

C) Memory-related vulnerabilities (memory leaks, buffer overflows, race conditions)

D) Patch and update management vulnerabilities (security patch and update delays, malicious updates)

E) Vulnerabilities related to system/security misconfigurations

F) Network-related vulnerabilities (DoS attacks, remote code execution attacks)

✓ **G) All of the above answer choices are examples of OS-based vulnerabilities**

118. The practice of installing mobile apps from websites and app stores other than the official marketplaces is referred to as:

A) Jailbreaking

B) Rooting

✓ **C) Sideloading**

D) Carrier unlocking

119. The term "Rooting" refers to the capability of gaining administrative access to the operating system and system applications on:

A) Android devices

B) iOS devices

C) Microsoft devices

D) All types of mobile devices

120. Malware that restricts access to a computer system by encrypting files or locking the entire system down until the user performs requested action is called:

A) Grayware
B) Adware
✓ C) Ransomware
D) Spyware

121. A standalone malicious computer program that typically propagates itself over a computer network to adversely affect system resources and network bandwidth is referred to as:

A) Worm
B) Fileless virus
C) Bot
D) Logic bomb

122. Malicious code activated by a specific event is called:

A) Cryptomalware
B) Backdoor
C) Rootkit
✓ D) Logic bomb

123. The term "RFID cloning" refers to copying the data stored on any RFID-enabled device (including tags, cards, key fobs, implants, and other objects embedded with RFID technology) onto another RFID-enabled device, which then can be read and used in the same way as the original tag. While RFID cloning can be utilized for legitimate purposes, such as replicating important tags for backup and testing purposes, it also poses significant security risk, as duplicate tags can potentially be used for gaining unauthorized access or unauthorized information disclosure.

A) True
B) False
Respuesta no detectada automaticamente

124. What defines a reflected DDoS attack?

A) Overwhelming the target with a high volume of traffic to saturate its bandwidth
B) Exploiting vulnerabilities in network protocols to consume resources and disrupt services
✓ C) Utilizing third-party servers to reflect and amplify attack traffic towards the target
D) Targeting vulnerabilities in applications or web servers to exhaust resources

125. Which of the following is a vulnerability characteristic to NFC communication?

A) Eavesdropping
B) Data interception
C) Replay attacks
D) DoS attacks
✓ E) All of the above

126. Which of the statements listed below can be used to describe the characteristics of an on-path attack? (Select all that apply)

A) An on-path attack is also known as MITM attack
✓ B) Attackers place themselves on the communication route between two devices
✓ C) Attackers intercept or modify packets sent between two communicating devices
D) Attackers do not have access to packets exchanged during the communication between two devices

127. What are the characteristic features of a session ID? (Select all that apply)

A) Enables the server to identify the session and retrieve the corresponding session data
✓ B) A unique identifier assigned by the website to a specific user
C) Contains user's authentication credentials, e.g., username and password
✓ D) A piece of data that can be stored in a cookie, or embedded as a URL parameter
✓ E) Stored on the client side (in the user's browser) and sent to the server with each request

F) A unique identifier assigned to a server

128. A technique that allows an attacker to authenticate to a remote server without extracting cleartext password from a digest is called:

A) Pass the hash
B) Replay attack
C) Brute-force attack
D) Spraying attack
Respuesta no detectada automaticamente

129. A dot-dot-slash attack is also referred to as:

A) Disassociation attack
B) On-path attack
✓ C) Directory traversal attack
D) Downgrade attack

130. An attack against encrypted data that relies heavily on computing power to check all possible keys and passwords until the correct one is found is called:

A) Replay attack
✓ B) Brute-force attack
C) Dictionary attack
D) Birthday attack

131. A type of forensic evidence that can be used to detect unauthorized access attempts or other malicious activities is called:

A) CVE
✓ B) IoC
C) AIS
D) OSINT

132. Which of the terms listed below most accurately describes a situation wherein a single account is being used from multiple locations/devices at the same time?

A) Spraying attack
✓ B) Concurrent session usage
C) Single Sign-On (SSO)
D) Impossible travel

133. Which of the terms listed below most accurately describes a situation wherein an account is accessed from a location that is physically impossible for the user to be in?

A) Login time restrictions
✓ B) Impossible travel
C) Concurrent session usage
D) Out-of-cycle logging

134. Which of the following would indicate an attempt to hide evidence of malicious activity?

A) Account lockout
B) Resource inaccessibility
✓ C) Missing logs
D) Concurrent session usage

135. Which of the answers listed below refers to a solution that allows for easier management and control of network segmentation policies through software applications?

A) VDI
✓ B) SDN
C) VPC
D) EDR

136. Which of the following policies applies to any requests that fall outside the criteria defined in an ACL?

A) Fair access policy

✓ **B) Implicit deny policy**

C) Transitive trust

D) Context-aware authentication

137. The importance of changing default usernames and passwords can be illustrated on the example of certain network devices (such as routers) which are often shipped with default and well-known admin credentials that can be looked up on the web.

A) True

B) False

138. The term "Hybrid cloud" refers to a mixed computing environment that can include different cloud service models like public and private clouds, as well as on-premises infrastructure.

A) True

B) False

139. Which of the following provides isolation from external computer networks?

A) Network segmentation

✓ **B) Air gap**

C) Hardware firewall

D) Protected cable distribution

140. Which of the answers listed below refers to a means for logical network segmentation?

A) Switch

B) VLAN

C) Screened subnet

D) Router

141. Which of the answers listed below refers to the process of packaging an application and its dependencies into a single, self-contained unit, which can run across different computing environments?

A) Edge computing

B) Containerization

C) Virtualization

D) Cloud computing

142. A computer system or an application that acts as an intermediary between another computer and the Internet is commonly referred to as:

A) Bridge

B) Active hub

C) Server

✓ **D) Proxy**

143. Which of the answers listed below refers to an IEEE standard that can be implemented in a situation where an Ethernet switch acts as an authenticator for devices that intend to connect to a network through one of its ports?

A) IEEE 802.1X

B) IEEE 802.11ac

C) IEEE 802.1D

D) IEEE 802.11x

144. Which of the answers listed below refer to a Layer 7 firewall? (Select 3 answers)

A) Offers complex (slower) traffic filtering

B) Filters traffic based on source/destination IP addresses, ports, and protocol types (e.g., TCP/UDP)

C) Operates at the transport layer of the OSI model

✓ **D) Adds the ability to inspect the contents of data packets in addition to the header information**

E) Offers basic (faster) traffic filtering

✓ **F) Operates at the application layer of the OSI model**

145. An IPsec mode providing encryption only for the payload (the data part of the packet) is referred to as:

A) Protected mode

B) Tunnel mode

✓ C) Transport mode

D) Safe mode

146. Which of the following answers refers to a cybersecurity framework that combines network and security functions into a single cloud-based service?

A) SASE

B) SWG

C) CASB

D) SD-WAN

Respuesta no detectada automaticamente

147. The purpose of PCI DSS is to provide protection for:

A) Credit cardholder data

B) Licensed software

C) User passwords

D) Personal health information

148. Encryption methods used to protect data in transit include: (Select all that apply)

A) NFS

✓ B) VPN

C) SED

✓ D) IPsec

E) FDE

✓ F) TLS

149. A mobile device's built-in functionality enabling the usage of locator applications is known as:

A) WPS

B) GSM

C) SIM

✓ D) GPS

150. Which of the answers listed below refers to a technology that provides control over the usage of a mobile device within a designated area?

A) Geofencing

B) Device tracking

C) Perimeter security

D) Geolocation

151. Hardware RAID Level 0: (Select all that apply)

A) Requires a minimum of 2 drives to implement

✓ B) Is also known as disk striping

✓ C) Decreases reliability (failure of any disk in the array results in the loss of all data in the array)

D) Is also referred to as disk mirroring

E) Offers less volume capacity in comparison to RAID 1

F) Requires at least 3 drives to implement

✓ G) Is suitable for systems where performance has higher priority than fault tolerance

8) Offers improved reliability by creating identical data sets on each drive (failure of one drive does not destroy the array as each drive contains identical copy of the data)

152. Hardware RAID Level 5: (Select 3 answers)

A) Requires at least 2 drives to implement

B) Continues to operate in case of failure of more than 1 drive

C) Is also known as disk striping with double parity

✓ D) Requires at least 3 drives to implement

✓ **E) Offers increased performance and fault tolerance (single drive failure does not destroy the array and lost data can be re-created by the remaining drives)**

✓ **F) Requires at least 4 drives to implement**

✓ **G) Is also known as disk striping with parity**

153. Hardware RAID Level 10 (a.k.a. RAID 1+0): (Select 3 answers)

A) Requires a minimum of 4 drives to implement

✓ **B) Is referred to as stripe of mirrors, i.e., a combination of RAID 1 (disk mirroring) and RAID 0 (disk striping)**

C) Requires a minimum of 5 drives to implement

✓ **D) Offers increased performance and fault tolerance (failure of one drive in each mirrored pair of disk drives does not destroy the array)**

E) Requires a minimum of 3 drives to implement

F) Continues to operate in case of failure of more than 2 drives

G) Is referred to as stripe of mirrors, i.e., a combination of RAID 1 (disk striping) and RAID 0 (disk mirroring)

154. Which of the answers listed below refers to the primary function of load balancing?

A) Maintains identical copies of data across multiple servers to enhance data availability and reliability

✓ **B) Distributes workload across multiple servers for improved performance**

✓ **C) Groups servers together to provide high availability and fault tolerance**

D) Distributes content geographically across multiple servers to improve performance, reduce latency, and handle high volumes of traffic

155. Which of the terms listed below refers to a duplicate of the original site, with fully operational computer systems as well as near-complete backups of user data?

A) Hot site

B) Warm site

C) Cold site

D) Mobile site

Respuesta no detectada automaticamente

156. A disaster recovery facility that provides only the physical space for recovery operations is known as:

A) Hot site

B) Warm site

✓ **C) Cold site**

D) Mirror site

157. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise

B) Sandboxing

C) Threat hunting

D) Security awareness training

Respuesta no detectada automaticamente

158. Which of the following terms refers to a backup strategy that relies on creating and maintaining copies of data in real-time or near real-time on a separate system?

A) Mirroring

B) Virtualization

✓ **C) Journaling**

✓ **D) Replication**

159. Which of the terms listed below is used to describe a foundational level of security configurations and settings required to safeguard a system?

A) Logical segmentation

✓ **B) Secure baseline**

C) Access control levels

D) Principle of least privilege

160. Data on a lost or stolen mobile device can be erased by:

A) Rooting

B) Sideloading

C) Low-level formatting

✓ **D) Remote wipe**

161. Implementing full device encryption is one of the methods for securing sensitive data on a smartphone. When enabled, this type of encryption works in conjunction with the phone's screen lock, i.e., to decrypt the phone (which stays encrypted whenever the phone is locked), a user must first unlock the screen. On Android devices, the unlocking methods include entering a PIN, password, or drawing a simple pattern with a finger. Apple devices use passcodes, facial recognition (Face ID), and fingerprint (Touch ID).

A) True

B) False

Respuesta no detectada automaticamente

162. Which of the answers listed below refer to workstation hardening techniques? (Select 3 answers)

A) Hiding administrator accounts

✓ **B) Regularly applying security patches and updates to the OS and installed software**

C) Disabling all internet access

✓ **D) Removing or disabling unnecessary drivers, services, software, and network protocols**

✓ **E) Limiting unauthorized or unauthenticated user access**

163. Which of the answers listed below refers to the process of assessing the physical environment, such as the layout of the building, to identify potential sources of interference and determine the optimal placement of a WAP?

A) Gap analysis

B) Capacity planning

✓ **C) Site survey**

D) Vulnerability scanning

164. An SSID is a unique identifier (a.k.a. wireless network name) for a WLAN. Wireless networks advertise their presence by regularly broadcasting SSID in a special packet called beacon frame. In wireless networks with disabled security features, knowing the network SSID is enough to get access to the network. SSID also pinpoints the wireless router that acts as a WAP. Wireless routers from the same manufacturer are frequently configured with default (well-known) SSID names. Since multiple devices with the same SSID displayed on the list of available networks create confusion and encourage accidental access by unauthorized users (applies to networks that lack security), changing the default SSID is a recommended practice.

A) True

B) False

Respuesta no detectada automaticamente

165. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks

B) IEEE 802.1D

C) Does not require an authentication server

✓ **D) IEEE 802.1X**

E) Suitable for all types of wireless LANs

✓ **F) Requires RADIUS authentication server**

166. What are the characteristic features of RADIUS? (Select 3 answers)

A) Primarily used for network access

B) Encrypts the entire payload of the access-request packet

✓ **C) Combines authentication and authorization**

✓ **D) Encrypts only the password in the access-request packet**

E) Primarily used for device administration

F) Separates authentication and authorization

167. Which of the following answers refers to a deprecated wireless authentication protocol developed by Cisco?

A) PEAP

B) EAP-TTLS

✓ **C) LEAP**

D) EAP-TLS

---

168. Which of the programming aspects listed below are critical in the secure application development process? (Select 2 answers)

A) Patch management

✓ **B) Input validation**

C) Password protection

✓ **D) Error and exception handling**

E) Application whitelisting

---

169. Which of the terms listed below refers to an automated or manual code review process aimed at discovering logic and syntax errors in the application's source code?

A) Input validation

B) Dynamic code analysis

C) Fuzzing

✓ **D) Static code analysis**

---

170. The term "Static code analysis" refers to the process of discovering application runtime errors.

A) True

✓ **B) False**

---

171. The practice of finding vulnerabilities in an application by feeding it incorrect input is called:

A) Normalization

B) Hardening

C) Dynamic code analysis

✓ **D) Fuzzing**

---

172. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA

✓ **B) CAPTCHA**

C) SSO

D) NIDS

---

173. Which of the following wireless technologies enables identification and tracking of tags attached to objects?

A) GPS

B) IR

✓ **C) RFID**

D) NFC

---

174. Which policy typically specifies the period during which certain types of data must be stored prior to disposal?

A) Data protection policy

B) Data classification policy

C) Data backup policy

✓ **D) Data retention policy**

---

175. Which of the answers listed below refer to the characteristic features of static code analysis? (Select 3 answers)

A) Involves examining the code without executing it

✓ **B) Often used early in the development process**

✓ **C) Examines code structure, syntax, and semantics to detect issues like syntax errors, coding standards violations, security vulnerabilities, and bugs**

D) Typically used later in the software development lifecycle

E) Involves executing the code and analyzing its behavior at runtime

F) Analyzes runtime properties like memory usage, performance, and error handling to identify issues such as memory leaks, performance bottlenecks, and runtime errors

176. Which of the following statements describe the features of dynamic code analysis? (Select 3 answers)

A) Typically used later in the software development lifecycle

B) Involves examining the code without executing it

✓ **C) Analyzes runtime properties like memory usage, performance, and error handling to identify issues such as memory leaks, performance bottlenecks, and runtime errors**

D) Often used early in the development process

E) Examines code structure, syntax, and semantics to detect issues like syntax errors, coding standards violations, security vulnerabilities, and bugs

✓ **F) Involves executing the code and analyzing its behavior at runtime**

177. Which of the terms listed below refers to tracking and managing software application components, such as third-party libraries and other dependencies?

A) Version control

B) Package monitoring

C) Configuration enforcement

D) Application hardening

178. A dedicated transport mechanism for cyber threat information is called:

A) TCP/IP

B) TLS

✓ **C) TAXII**

D) S/MIME

179. Which of the following statements does not apply to dark web?

A) Typically requires specialized software to access its contents

✓ **B) Forms a large part of the deep web**

C) Not indexed by traditional search engines

D) Often associated with trading stolen data, malware, and cyber threats

180. A responsible disclosure program is a formal process established by an organization to encourage security researchers and ethical hackers to report vulnerabilities they discover in the organization's systems or software. A bug bounty program is a specific type of responsible disclosure program that offers financial rewards to security researchers for reporting valid vulnerabilities.

A) True

B) False

181. Which of the following refers to a system that identifies, defines, and catalogs publicly known cybersecurity vulnerabilities?

A) TAXII

✓ **B) CVE**

C) STIX

D) CVSS

182. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ F) All of the above answers are examples of vulnerability response and remediation techniques

183. Which of the following answers refer to SCAP? (Select 3 answers)

A) A type of security system designed to collect logs and events from various sources

✓ B) Designed to provide a centralized user interface for accessing collected data

✓ C) A collection of standards developed by NIST

✓ D) Provides a common language for communicating security information

✓ E) Allows different security tools to share data and work together more effectively

F) Enables real-time threat detection, incident response, and compliance monitoring

184. Simple Network Management Protocol (SNMP) is a UDP-based, application layer protocol used in network management systems to monitor network-attached devices. SNMP is typically integrated into most modern network infrastructure devices such as routers, bridges, switches, servers, printers, copiers, fax machines, and other network-attached devices. An SNMP-managed network comprises three essential components: a managed device, a network-management software module that resides on a managed device (Agent), and a Network Management Station (NMS), which runs applications responsible for monitoring and controlling managed devices, as well as collecting SNMP information from Agents. The manager receives notifications (Traps and InformRequests) on UDP port 162, while the SNMP Agent receives requests on UDP port 161.

A) True

B) False

Respuesta no detectada automaticamente

185. Firewall rules are evaluated based on their order of precedence. Rules at the top of the list take precedence over rules further down the list. Once a matching rule is found, no further evaluation of subsequent rules occurs. The "implicit deny" policy on a firewall is a common default behavior in which any traffic that does not explicitly match any of the configured allow rules is automatically denied or blocked. In other words, if a packet does not meet the criteria of any allow rule, the default behavior of the firewall is to deny the traffic.

A) True

B) False

186. A lightly protected subnet (a.k.a. DMZ) consisting of publicly available servers placed on the outside of the company's firewall is known as:

A) Captive portal

B) Quarantine network

C) Extranet

✓ D) Screened subnet

187. Which of the answers listed below refer to filtering techniques that can allow or block access to a site based on its web address? (Select 2 answers)

A) SSL/TLS inspection

✓ B) URL scanning

C) Content categorization

✓ D) DNS filtering

E) Reputation-based filtering

188. In Windows Active Directory environment, this feature enables centralized management and configuration of operating systems, applications, and user account settings.

A) Local Users and Groups

B) Resource Monitor

✓ C) Group Policy

D) User Account Control

189. TCP is an example of a connectionless protocol. Because TCP does not support three-way handshake while establishing a network connection, it is referred to as unreliable or best-effort protocol. Example applications of TCP include transmission of video and audio streaming data.

A) True

✓ B) False

190. Which of the following answers refers to a policy framework that allows domain owners to specify how email receivers should handle emails that fail authentication checks?

✓ A) DKIM

B) SPF

C) PEM

✓ D) DMARC

191. Which of the following answers refers to an email authentication mechanism that allows domain owners to specify which IP addresses are authorized to send emails on behalf of their domain?

A) DMARC

B) PEM

C) DKIM

D) SPF

192. OpenID Connect is a protocol used for:

A) Attestation

B) Authorization

C) Auditing

✓ D) Authentication

193. What are the characteristic features of SAML? (Select 3 answers)

A) Enables only the exchange of SSO authorization data

✓ B) Handles both authentication and authorization for SSO

✓ C) Uses XML for data exchange

✓ D) Commonly used in enterprise environments and legacy systems

E) Enables only the exchange of SSO authentication data

F) Uses JSON for data exchange

G) Specifically designed for web and mobile applications

194. Which of the following answers refer(s) to the Mandatory Access Control (MAC) model? (Select all that apply)

A) Users are not allowed to change access policies at their own discretion

✓ B) Labels and clearance levels can only be applied and changed by an administrator

C) Every object has an owner who at his/her own discretion determines what kind of permissions other users can have to that object

D) Access to resources based on user identity

✓ E) Every resource has a sensitivity label matching a clearance level assigned to a user

195. In the context of IT security, the term "Biometrics" refers to both biological characteristics of the human body and behavioral traits that can be used for identification and access control purposes.

A) True

B) False

Respuesta no detectada automaticamente

196. Which of the answers listed below refer(s) to a medium type that can be used as a hardware authentication token? (Select all that apply)

A) Smart card

✓ B) Key fob

✓ C) Security key

D) Passphrase

E) Biometric reader

✓ **F) RFID badge**

197. Which of the answers listed below refer to the features of a security key? (Select 3 answers)

A) Used for OTP generation, remote vehicle access, and building access

✓ **B) Hardware authentication token**

✓ **C) Typically, a physical USB stick or key fob-sized device**

✓ **D) Primarily used for digital security (2FA/MFA)**

E) Software authentication token

F) Typically, a credit card-sized plastic card with an embedded chip

198. The maximum password age policy setting determines the period of time that a password must be used before the user can change it.

A) True

✓ **B) False**

199. Which of the answers listed below refers to a term primarily used in software development to describe the cost of short-term decisions that can lead to long-term problems?

A) Code entropy

B) Exposure factor

C) Risk register

✓ **D) Technical debt**

200. In the incident response process, the step that involves identifying and understanding potential incidents to determine their scope, impact, and root cause is a part of the:

A) Preparation stage

✓ **B) Detection and analysis stage**

C) Containment, eradication, and recovery stage

D) Post-incident activity stage

201. Which stage of the incident response process involves updating incident response plans, policies, and procedures?

A) Preparation

B) Detection and analysis

C) Containment, eradication, and recovery

✓ **D) Post-incident activity**

202. Which of the following answers refers to a more in-depth exercise, which can include activating systems and performing real actions to respond to the incident?

A) Penetration testing

B) Threat hunting

✓ **C) Simulation**

D) Vulnerability scanning

203. The term "Threat hunting" refers to a proactive search for IoC to identify and address potential threats and vulnerabilities before they can escalate into full-blown incidents.

A) True

B) False

Respuesta no detectada automaticamente

204. The process of identifying, collecting, and producing electronically stored information with the intent of using it in a legal proceeding or investigation is referred to as:

A) Litigation hold

B) Evidence management

C) Digital forensics

✓ **D) E-discovery**

205. The term "Metadata" refers to data that provides information about other data, but not the actual content of the data. Typically, metadata is not visible to the user by default but can be accessed if needed. For

example, email metadata, found in email headers, includes detailed information about the sender, recipient, and the route the message took. Mobile device metadata encompasses details such as the device model, geolocation, camera information, internet usage, phone call and text messaging activity, application usage statistics, and metadata from various files on the device. In web browsing, metadata comes from HTML meta tags located in the head section of a web page. For files, metadata includes details about the author (e.g., the file creator), file type, size, creation date and time, and the last modification date and time.

A) True

B) False

---

206. Which of the answers listed below refers to a process of intercepting network traffic data for analysis and troubleshooting purposes?

A) AIS

✓ **B) PCAP**

C) EDR

D) MaaS

---

207. Which of the following acronyms refers to a comprehensive strategy and set of procedures designed to ensure that an organization can continue its critical operations and functions during and after a disruptive event?

✓ **A) DRP**

B) CP

✓ **C) BCP**

D) COOP

---

208. Which of the terms listed below refers to the process of creating and maintaining computer applications?

A) RAD

✓ **B) SDLC**

C) OOP

D) SaaS

---

209. A new-user setup checklist includes all the activities that enable a new hire to become productive. Examples of such activities (which are part of the so-called onboarding process) include setting up the hardware and software environment for the new user as well as providing all the necessary training. An end-user termination checklist deals with all the actions that should take place during the offboarding process (i.e., whenever an employee leaves the company). Examples of the checklist items include fulfilling all the required documents, removing the employee's access to resources (e.g., company-owned devices, user accounts, etc.), and discussing their reasons for leaving and experiences with the employer during an exit interview.

A) True

B) False

Respuesta no detectada automaticamente

---

210. Which of the answers listed below refers to public sector organizations that set and enforce laws and regulations at local, regional, or national levels?

A) Government entities

B) Trade associations

C) Statutory bodies

D) Regulatory agencies

---

211. An estimate based on the historical data of how often a threat would be successful in exploiting a vulnerability is known as:

A) ALE

B) SLA

✓ **C) ARO**

D) SLE

---

212. A high MTBF value indicates that a component or system provides low reliability and is more likely to fail.

A) True

✓ **B) False**

213. Which of the following answers refers to a contractual provision that grants one party the right to inspect the other party's operations, facilities, processes, and records?

A) Right-to-audit clause

B) Oversight clause

C) Compliance verification clause

D) Transparency clause

214. A detailed agreement between a client and a vendor that describes the work to be performed on a project is called:

A) MSA

B) SLA

C) WO

✓ **D) SOW**

215. Which of the terms listed below is used to describe actions taken to address and mitigate already identified risks?

A) Due diligence

B) Standard of care

✓ **C) Due care**

D) Fiduciary duty

216. Which of the terms listed below refers to a legal principle that allows individuals to request the removal of personal information from Internet searches and other public sources?

A) De-identification

✓ **B) Right to be forgotten**

C) Anonymization

D) Consent management

217. In the context of audits, an attestation is typically provided by:

A) Regulatory body

✓ **B) External auditor**

C) Audit committee

D) Internal audit team

218. In penetration testing, active reconnaissance involves gathering any type of publicly available information that can be used later for exploiting vulnerabilities found in the targeted system.

A) True

✓ **B) False**

219. In email communication, what signs can be of help in recognizing a phishing attempt?

A) The message contains poor spelling and grammar

B) The message asks for personal information

C) The message includes a call to action with a sense of urgency

D) The message includes suspicious links or attachments

✓ **E) Any of the above**

220. What is the best countermeasure against social engineering attacks?

A) Situational awareness

B) Implicit deny policy

✓ **C) User education**

D) Strong security controls

221. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA

✓ **B) CAPTCHA**
C) ACL
D) NIPS

222. Which of the terms listed below refers to the process of creating and maintaining computer applications?
A) RAD
✓ **B) SDLC**
C) OOP
D) SaaS

223. What is the name of a network protocol that secures web traffic via SSL/TLS encryption?
A) SFTP
✓ **B) HTTPS**
C) FTPS
D) SHTTP

224. What is the common term for a group of protocols used to carry voice data over a packet-switched network?
A) ISDN
B) PBX
✓ **C) VoIP**
D) PSTN

225. Which of the following file transfer protocols does not provide encryption?
A) SCP
B) FTPS
✓ **C) FTP**
D) SFTP

226. An authentication subsystem that enables a user to access multiple, connected system components (such as separate hosts on a network) after a single login on only one of the components is referred to as:
A) NAC
✓ **B) SSO**
C) AAA
D) MFA

227. A type of document stipulating rules of behavior to be followed by users of computers, networks, and associated resources is called:
A) SLA
B) EULA
✓ **C) AUP**
D) BPA

228. A type of cryptographic network protocol for secure data communication, remote command-line login, remote command execution, and other secure network services between two networked computers is known as:
A) RDP
✓ **B) SSH**
C) Telnet
D) SCP

229. Which of the answers listed below refers to a security standard introduced to address the vulnerabilities found in WEP?
A) TKIP
B) AES
C) WPA
D) CCMP

230. A type of network connecting computers within a small geographical area such as a building or group of buildings is referred to as:

A) PAN

✓ **B) LAN**

C) MAN

D) WAN

231. Which of the following answers refers to a shared secret authentication method used in WPA, WPA2, and EAP?

A) PSK

B) 802.1X

C) SAE

D) TKIP

Respuesta no detectada automaticamente

232. Which type of unsolicited messaging relies on text-based communication?

A) VAM

✓ **B) SPIM**

C) JMS

D) SPIT

233. Which of the terms listed below applies to the authentication process?

A) MFA

B) MMC

C) MDM

D) MFD

234. Which of the answers listed below refers to a dedicated programming language used in database management?

A) PHP

B) C

C) SQL

D) JS

235. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM

✓ **B) APT**

C) XSRF

D) DDoS

236. Which of the answers listed below refers to a concept that provides insights into methods and tools that cybercriminals use to carry out attacks?

A) TTP

B) CVE

C) ATT&CK

D) CVSS

Respuesta no detectada automaticamente

237. Which part of the AAA security architecture deals with the verification of the identity of a person or process?

A) Accounting

✓ **B) Authentication**

C) Auditing

D) Authorization

238. Which of the answers listed below refers to a remote access authentication protocol that periodically re-authenticates client at random intervals to prevent session hijacking?

A) EAP
B) CHAP
C) PAP
D) PEAP

239. Which of the following acronyms refers to a comprehensive strategy and set of procedures designed to ensure that an organization can continue its critical operations and functions during and after a disruptive event?

A) DRP
B) CP
✓ C) BCP
D) COOP

240. The term "AI" refers to computer systems and algorithms that can perform tasks typically requiring human intelligence, such as problem-solving, learning, and decision-making.

A) True
B) False
Respuesta no detectada automaticamente

241. A type of cyberattack focused on making a website, service, or network unavailable to users by overloading it with traffic or malicious requests is called:

A) SQLi
B) XSS
C) CSRF
✓ D) DoS

242. Which of the answers listed below refers to a broad term that encompasses various control and automation systems used in industrial settings to control and monitor physical processes and machinery?

A) ICS
B) PLC
C) SCADA
D) HMI

243. Which of the acronyms listed below refers to a cryptographic software tool for secure email communication and data protection?

A) DES
B) PEM
C) EFS
✓ D) PGP

244. A type of vulnerability where the state of a resource is verified at one point in time but may change before the resource is actually used is called:

A) TOC
✓ B) TOC/TOU
C) TOU
D) TSIG

245. Which of the following answers refers to a system containing mappings of domain names to various types of data, such as numerical IP addresses?

A) TCP/IP
✓ B) DNS
C) SQL
D) DHCP

246. Which of the acronyms listed below refers to a comprehensive strategy and set of procedures designed to ensure that an organization can continue its critical operations and functions during and after a disruptive event?

A) BIA

B) SLE

✓ **C) BCP**

D) BPA

247. A cloud computing service model offering remote access to applications based on monthly or annual subscription fee is called:

A) PaaS

✓ **B) SaaS**

C) IaaS

D) DaaS

248. Which AES key length provides the highest level of security?

A) 128-bit key

B) 192-bit key

✓ **C) 256-bit key**

D) 320-bit key

249. A set of procedures put in place to recover IT systems and data following a major disruption is called:

A) DRP

B) BIA

C) SLE

D) BCP

Respuesta no detectada automaticamente

250. Which of the answers listed below refers to a mobile device deployment model that allows employees to use private mobile devices for accessing company's restricted data and applications?

A) COPE

B) BYOD

C) JBOD

D) CYOD

251. Which of the answers listed below refers to a deprecated wireless authentication protocol developed by Cisco?

A) PEAP

B) EAP-TTLS

C) LEAP

D) EAP-TLS

252. A software development approach that aims for speedy application creation and continuous improvement through iterative development and user collaboration is referred to as:

A) FDD

B) DevOps

✓ **C) RAD**

D) SaaS

253. Which of the answers listed below refers to a technology that allows USB devices to act as both hosts and peripherals, enabling them to connect to and communicate with other USB devices directly without the need for a computer or dedicated host?

A) PnP

B) OTG

C) P2P

D) HCI

254. Which of the answers listed below refers to a mobile device's built-in functionality enabling the usage of locator applications?

A) WPS

B) GSM

C) SIM

✓ **D) GPS**

255. In older, non-UEFI based PCs, the first sector of a storage drive containing information about partitions and a piece of executable code used to load the installed OS is called:

A) MBR
B) GPT
C) PXE
D) GUID

256. Which of the following terms refers to a technology that enables real-time audio and video communication between individuals or groups?

A) VPC
✓ **B) VTC**
C) VoIP
D) VDI

257. Which of the answers listed below can be used to describe XSRF? (Select 3 answers)

A) Exploits the trust a website has in the user's web browser
✓ **B) A user is tricked by an attacker into submitting unauthorized web requests**
✓ **C) Website executes attacker's requests**
D) Exploits the trust a user's web browser has in a website
✓ **E) A malicious script is injected into a trusted website**
✓ **F) User's browser executes attacker's script**

258. An AI feature that enables it to accomplish tasks based on training data without explicit human instructions is called:

A) AGI
✓ **B) ML**
C) NN
D) LLM

259. Which of the answers listed below refers to a key exchange protocol that generates temporary keys for each session, providing forward secrecy to protect past and future communications?

A) PFS
B) SHA
C) PGP
✓ **D) DHE**

260. Which of the answers listed below refer to the characteristic features of NIDS? (Select 3 answers)

A) Takes proactive measures to block or mitigate intrusion attempts
✓ **B) Does not take direct action to block or prevent attacks**
✓ **C) Generates alerts and notifies security personnel or administrators when suspicious activity is detected**
✓ **D) Monitors network traffic without direct involvement in traffic routing or packet modification**
E) Can drop or reject network packets, terminate connections, or take other actions to stop the attack
F) Operates in an inline mode, actively intercepting and inspecting network traffic

261. Which of the answers listed below refers to a basic method for establishing a dedicated point-to-point link between two networked devices?

A) PPTP
B) IGMP
C) PPP
D) MPLS

262. Which of the answers listed below refers to a deprecated TLS-based method for securing SMTP?

A) IDPS
B) STARTTLS
C) DKIM
D) SMTPS

263. Which of the answers listed below refers to a smart card used in mobile phones to identify the phone user?

A) IMSI
B) SoC
C) IMEI
✓ **D) SIM**

264. Which of the terms listed below refers to a US government initiative for real-time sharing of cyber threat indicators?

A) NVD
✓ **B) AIS**
C) TTP
D) CVSS

265. A company or organization that offers cloud computing services over the Internet is called:

A) ISP
B) MSSP
✓ **C) CSP**
D) MSP

266. Which of the following answers refers to an encryption protocol primarily used in Wi-Fi networks implementing the WPA2 security standard?

A) TKIP
B) CCMP
C) SSL
D) HMAC

267. Which of the following acronyms refers to a discontinued research program focused on promoting innovation and development in the field of telecommunications and information technology?

A) IETF
B) CERN
C) DARPA
D) RACE

268. Which of the following answers can be used to describe technical security controls? (Select 3 answers)

A) Focused on protecting material assets
✓ **B) Sometimes called logical security controls**
✓ **C) Executed by computer systems (instead of people)**
D) Also known as administrative controls
✓ **E) Implemented with technology**
F) Primarily implemented and executed by people (as opposed to computer systems)

269. Which of the following answers refer to the characteristic features of managerial security controls? (Select 3 answers)

A) Also known as administrative controls
B) Sometimes referred to as logical security controls
✓ **C) Focused on reducing the risk of security incidents**
D) Executed by computer systems (instead of people)
✓ **E) Documented in written policies**
F) Focused on protecting material assets

270. Which of the answers listed below can be used to describe operational security controls (Select 3 answers)

A) Also known as administrative controls
✓ **B) Focused on the day-to-day procedures of an organization**
C) Executed by computer systems (instead of people)
✓ **D) Used to ensure that the equipment continues to work as specified**

E) Focused on managing risk

✓ **F) Primarily implemented and executed by people (as opposed to computer systems)**

271. Which of the answers listed below refers to security controls designed to deter, detect, and prevent unauthorized access, theft, damage, or destruction of material assets?

A) Managerial security controls

✓ **B) Physical security controls**

C) Technical security controls

D) Operational security controls

272. What are the examples of preventive security controls? (Select 3 answers)

A) Encryption

B) IDS

C) Sensors

✓ **D) Firewalls**

E) Warning signs

✓ **F) AV software**

273. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting

✓ **B) Log monitoring**

C) Sandboxing

✓ **D) Security audits**

✓ **E) CCTV**

✓ **F) IDS**

✓ **G) Vulnerability scanning**

274. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems

B) Video surveillance

✓ **C) MFA**

✓ **D) Application sandboxing**

✓ **E) Network segmentation**

275. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP

✓ **B) AUP**

C) IDS

D) MFA

E) IPS

276. What is the name of a network protocol that secures web traffic via SSL/TLS encryption?

✓ **A) SFTP**

✓ **B) HTTPS**

C) FTPS

D) SHTTP

277. SFTP is an extension of the FTP protocol that adds support for SSL/TLS encryption.

A) True

✓ **B) False**

278. Which part of IPsec provides authentication, integrity, and confidentiality?

A) SPD

B) PFS

C) AH

✓ **D) ESP**

279. Which of the following answers refers to a key exchange protocol that generates temporary keys for each session, providing forward secrecy to protect past and future communications?

A) PFS
B) SHA
C) PGP
D) DHE

280. Which of the following answers refers to a cryptographic key exchange protocol that leverages ECC for enhanced security and efficiency?

A) S/MIME
B) ECDHE
C) DHE
D) ECDSA

281. Which AES key length provides the highest level of security?

A) 128-bit key
B) 192-bit key
✓ **C) 256-bit key**
D) 320-bit key

282. A hash function is a mathematical algorithm that maps data of arbitrary size to a fixed-size hash value, typically represented as a short string of characters. The hash function result, also known as a digest or checksum, provides a unique representation of the original data input. The functionality of hash functions relies on the fact that if there is any change to the data after the original hash was generated, the new hash value calculated after content modification will be different from the original result because hash functions are designed to be sensitive to changes in the input data.

A) True
B) False
Respuesta no detectada automaticamente

283. Which of the answers listed below refers to a cryptographic hash function that has been widely used in the past but is now considered deprecated for security-sensitive applications due to known vulnerabilities?

A) MD5
B) SHA
C) CRC
D) HMAC
Respuesta no detectada automaticamente

284. Which of the answers listed below refers to an identifier used for PKI objects?

A) OID
B) DN
C) SAN
D) GUID
Respuesta no detectada automaticamente

285. Assign the level of sophistication attribute to each threat actor type listed below.

Respuesta no detectada automaticamente

286. From the drop-down list on the right, select the typical motivations behind the actions of each threat actor type.

Respuesta no detectada automaticamente

287. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM
✓ **B) APT**
C) XSRF
D) DDoS

288. An attack surface is the sum of all the potential points (vulnerabilities) through which an attacker can interact with or compromise a system or network, indicating the overall exposure to potential threats. Examples of attack surfaces can be all software, hardware, and network interfaces with known security flaws. A threat vector represents the method or means through which a cyber threat is introduced or delivered to a target system. It outlines the pathway or avenue used by attackers to exploit vulnerabilities. Common threat vector types include phishing emails, malware, drive-by downloads, and social engineering techniques.

A) True

B) False

Respuesta no detectada automaticamente

289. Which of the answers listed below refers to an example of a potential threat vector in IM-based communication?

A) Phishing attack

B) Malware distribution

C) Spoofing attack

D) Eavesdropping

E) Account hijacking

F) Malicious link/attachment

✓ G) All of the above

290. Which of the following answers refer to examples of image-based threat vectors? (Select 3 answers)

A) Steganography

B) BEC attacks

C) Image spoofing (deepfakes)

D) Brand impersonation

E) Malware-embedded images

291. The term "Typosquatting" refers to a deceptive practice involving the deliberate registration of domain names with misspellings or slight variations that closely resemble well-established and popular domain names. The primary goal of this strategy is to exploit the common typographical errors made by users while entering URLs into their web browser's address bar. Beyond capturing inadvertent traffic, typosquatting may also be used for hosting phishing sites to trick users into divulging sensitive information, distributing malware through deceptive websites, generating ad revenue by redirecting mistyped traffic, or engaging in brand impersonation to harm the reputation of authentic brands or deceive users.

A) True

B) False

Respuesta no detectada automaticamente

292. What would be an appropriate user response to an email phishing attempt? (Select all that apply)

A) Not replying to the message or providing any personal information

✓ B) Reporting the message to the IT or security department, if applicable

✓ C) Deleting the message from the inbox

✓ D) Not clicking on any links or downloading any attachments in the message

E) Forwarding the message to the sender to verify its legitimacy

F) Opening the attachment in a sandbox environment to check its safety

293. Which type of application attack relies on introducing external code into the address space of a running program?

A) Buffer overflow

✓ B) Memory injection

C) Replay attack

D) Pointer dereference

294. Which of the answers listed below refers to an application attack that relies on executing a library of code?

A) Memory leak

✓ B) DLL injection

C) Pointer dereference

✓ **D) Buffer overflow**

295. A malicious application update is a type of malware that can be installed through a seemingly legitimate software update. The introduction of a malicious update into the application code can be enabled through various means, including:

A) Unsigned application code

B) Unencrypted update channel (HTTP vs HTTPS)

C) Fake update website

D) Unauthorized access to update server

E) Compromised software development process

✓ **F) All of the above**

296. What is the main vulnerability related to legacy hardware?

A) Compatibility issues

✓ **B) Lack of security updates and patches**

C) Worn-out physical components

D) Lack of skilled personnel to run it and maintain it

297. Which of the following answers refers to a virtualization-related vulnerability where virtualized assets allocated to one VM are improperly isolated and can be accessed or compromised by another VM?

A) Resource reuse

B) Privilege escalation

C) Resource exhaustion

D) Concurrent session usage

Respuesta no detectada automaticamente

298. The practice of installing mobile apps from websites and app stores other than the official marketplaces is referred to as:

A) Jailbreaking

B) Rooting

✓ **C) Sideloading**

D) Carrier unlocking

299. The term "Rooting" refers to the capability of gaining administrative access to the operating system and system applications on:

A) Android devices

B) iOS devices

C) Microsoft devices

D) All types of mobile devices

300. Malware that restricts access to a computer system by encrypting files or locking the entire system down until the user performs requested action is called:

A) Grayware

B) Adware

✓ **C) Ransomware**

D) Spyware

301. A standalone malicious computer program that typically propagates itself over a computer network to adversely affect system resources and network bandwidth is referred to as:

A) Worm

B) Fileless virus

C) Bot

D) Logic bomb

302. Malicious code activated by a specific event is called:

A) Cryptomalware

B) Backdoor

C) Rootkit

✓ **D) Logic bomb**

303. What defines a reflected DDoS attack?

A) Overwhelming the target with a high volume of traffic to saturate its bandwidth

B) Exploiting vulnerabilities in network protocols to consume resources and disrupt services

✓ **C) Utilizing third-party servers to reflect and amplify attack traffic towards the target**

D) Targeting vulnerabilities in applications or web servers to exhaust resources

304. A wireless disassociation attack is a type of: (Select 2 answers)

A) Downgrade attack

✓ **B) Deauthentication attack**

C) Brute-force attack

✓ **D) DoS attack**

E) Cryptographic attack

305. A network replay attack occurs when an attacker captures sensitive user data and resends it to the receiver with the intent of gaining unauthorized access or tricking the receiver into unauthorized operations.

A) True

B) False

306. What type of action allows an attacker to exploit the XSS vulnerability?

A) Code injection

B) Privilege escalation

C) Session hijacking

D) Packet sniffing

307. Which type of exploit targets web applications that generate content used to store and transport data?

A) SQL injection attack

B) CSRF/XSRF attack

✓ **C) XML injection attack**

D) LDAP injection attack

308. A situation where an attacker intercepts and retransmits valid data exchange between an application and a server, or another application is known as:

A) Sideloading

✓ **B) Replay attack**

C) Phishing attack

D) Race condition

309. A type of forensic evidence that can be used to detect unauthorized access attempts or other malicious activities is called:

A) CVE

✓ **B) IoC**

C) AIS

D) OSINT

310. Which of the terms listed below most accurately describes a situation wherein a single account is being used from multiple locations/devices at the same time?

A) Spraying attack

✓ **B) Concurrent session usage**

C) Single Sign-On (SSO)

D) Impossible travel

311. Which of the terms listed below most accurately describes a situation wherein an account is accessed from a location that is physically impossible for the user to be in?

A) Login time restrictions

✓ **B) Impossible travel**

C) Concurrent session usage
D) Out-of-cycle logging

312. Which of the following would indicate an attempt to hide evidence of malicious activity?

A) Account lockout
B) Resource inaccessibility
✓ C) Missing logs
D) Concurrent session usage

313. Which of the answers listed below refers to any type of information pertaining to an individual that can be used to uniquely identify that person?

A) PHI
B) Biometrics
C) ID
✓ D) PII

314. Which of the answers listed below refer(s) to encryption method(s) used to protect data at rest? (Select all that apply)

A) FDE
✓ B) SED
C) IPsec
D) TLS
✓ E) VPN
✓ F) EFS

315. Which of the following data states typically requires data to be processed in an unencrypted form?

A) Data in motion
B) Data at rest
C) Data in transit
✓ D) Data in use

316. Which of the answers listed below refers to a technology that provides control over the usage of a mobile device within a designated area?

A) Geofencing
B) Captive portal
C) Honeypot
D) Geolocation
Respuesta no detectada automaticamente

317. Hardware RAID Level 0: (Select all that apply)

A) Requires a minimum of 2 drives to implement
✓ B) Is also known as disk striping
✓ C) Decreases reliability (failure of any disk in the array results in the loss of all data in the array)
D) Is also referred to as disk mirroring
E) Offers less volume capacity in comparison to RAID 1
F) Requires at least 3 drives to implement
✓ G) Is suitable for systems where performance has higher priority than fault tolerance
8) Offers improved reliability by creating identical data sets on each drive (failure of one drive does not destroy the array as each drive contains identical copy of the data)

318. Hardware RAID Level 5: (Select 3 answers)

A) Requires at least 2 drives to implement
B) Continues to operate in case of failure of more than 1 drive
C) Is also known as disk striping with double parity
✓ D) Requires at least 3 drives to implement
✓ E) Offers increased performance and fault tolerance (single drive failure does not destroy the array and lost data can be re-created by the remaining drives)

✓ **F) Requires at least 4 drives to implement**

✓ **G) Is also known as disk striping with parity**

319. Hardware RAID Level 10 (a.k.a. RAID 1+0): (Select 3 answers)

A) Requires a minimum of 4 drives to implement

✓ **B) Is referred to as stripe of mirrors, i.e., a combination of RAID 1 (disk mirroring) and RAID 0 (disk striping)**

C) Requires a minimum of 5 drives to implement

✓ **D) Offers increased performance and fault tolerance (failure of one drive in each mirrored pair of disk drives does not destroy the array)**

E) Requires a minimum of 3 drives to implement

F) Continues to operate in case of failure of more than 2 drives

G) Is referred to as stripe of mirrors, i.e., a combination of RAID 1 (disk striping) and RAID 0 (disk mirroring)

320. Which of the answers listed below refers to the primary function of load balancing?

A) Maintains identical copies of data across multiple servers to enhance data availability and reliability

✓ **B) Distributes workload across multiple servers for improved performance**

✓ **C) Groups servers together to provide high availability and fault tolerance**

D) Distributes content geographically across multiple servers to improve performance, reduce latency, and handle high volumes of traffic

321. Which of the terms listed below refers to a duplicate of the original site, with fully operational computer systems as well as near-complete backups of user data?

A) Hot site

B) Warm site

C) Cold site

D) Mobile site

Respuesta no detectada automaticamente

322. A disaster recovery facility that provides only the physical space for recovery operations is known as:

A) Hot site

B) Warm site

✓ **C) Cold site**

D) Mirror site

323. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise

B) Sandboxing

C) Threat hunting

D) Security awareness training

Respuesta no detectada automaticamente

324. Which of the following terms refers to a backup strategy that relies on creating and maintaining copies of data in real-time or near real-time on a separate system?

A) Mirroring

B) Virtualization

✓ **C) Journaling**

✓ **D) Replication**

325. An SSID is a unique identifier (a.k.a. wireless network name) for a WLAN. Wireless networks advertise their presence by regularly broadcasting SSID in a special packet called beacon frame. In wireless networks with disabled security features, knowing the network SSID is enough to get access to the network. SSID also pinpoints the wireless router that acts as a WAP. Wireless routers from the same manufacturer are frequently configured with default (well-known) SSID names. Since multiple devices with the same SSID displayed on the list of available networks create confusion and encourage accidental access by unauthorized users (applies to networks that lack security), changing the default SSID is a recommended practice.

A) True

B) False

Respuesta no detectada automaticamente

326. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks

B) IEEE 802.1D

C) Does not require an authentication server

✓ D) IEEE 802.1X

E) Suitable for all types of wireless LANs

✓ F) Requires RADIUS authentication server

327. Which of the answers listed below refers to an open standard wireless network authentication protocol that enhances security by encapsulating authentication process within an encrypted TLS tunnel?

A) PEAP

B) EAP

C) LEAP

D) RADIUS

Respuesta no detectada automaticamente

328. Which of the programming aspects listed below are critical in the secure application development process? (Select 2 answers)

A) Patch management

✓ B) Input validation

C) Password protection

✓ D) Error and exception handling

E) Application whitelisting

329. Which of the terms listed below refers to an automated or manual code review process aimed at discovering logic and syntax errors in the application's source code?

A) Input validation

B) Dynamic code analysis

C) Fuzzing

✓ D) Static code analysis

330. The term "Static code analysis" refers to the process of discovering application runtime errors.

A) True

✓ B) False

331. The practice of finding vulnerabilities in an application by feeding it incorrect input is called:

A) Normalization

B) Hardening

C) Dynamic code analysis

✓ D) Fuzzing

332. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA

✓ B) CAPTCHA

C) SSO

D) NIDS

333. Vulnerability scanning: (Select all that apply)

A) Identifies lack of security controls

B) Actively tests security controls

✓ C) Identifies common misconfigurations

D) Exploits vulnerabilities

✓ E) Passively tests security controls

334. Which of the following statements describe the features of dynamic code analysis? (Select 3 answers)

A) Typically used later in the software development lifecycle

B) Involves examining the code without executing it

✓ C) Analyzes runtime properties like memory usage, performance, and error handling to identify issues such as memory leaks, performance bottlenecks, and runtime errors

D) Often used early in the development process

E) Examines code structure, syntax, and semantics to detect issues like syntax errors, coding standards violations, security vulnerabilities, and bugs

✓ F) Involves executing the code and analyzing its behavior at runtime

---

335. Which of the terms listed below refers to tracking and managing software application components, such as third-party libraries and other dependencies?

A) Version control

B) Package monitoring

C) Configuration enforcement

D) Application hardening

---

336. A dedicated transport mechanism for cyber threat information is called:

A) TCP/IP

B) TLS

✓ C) TAXII

D) S/MIME

---

337. Which of the following statements does not apply to dark web?

A) Typically requires specialized software to access its contents

✓ B) Forms a large part of the deep web

C) Not indexed by traditional search engines

D) Often associated with trading stolen data, malware, and cyber threats

---

338. A responsible disclosure program is a formal process established by an organization to encourage security researchers and ethical hackers to report vulnerabilities they discover in the organization's systems or software. A bug bounty program is a specific type of responsible disclosure program that offers financial rewards to security researchers for reporting valid vulnerabilities.

A) True

B) False

---

339. Which of the following refers to a system that identifies, defines, and catalogs publicly known cybersecurity vulnerabilities?

A) TAXII

✓ B) CVE

C) STIX

D) CVSS

---

340. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ F) All of the above answers are examples of vulnerability response and remediation techniques

---

341. Which of the following answers refer(s) to the Mandatory Access Control (MAC) model? (Select all that apply)

A) Users are not allowed to change access policies at their own discretion

✓ B) Labels and clearance levels can only be applied and changed by an administrator

C) Every object has an owner who at his/her own discretion determines what kind of permissions other users can have to that object

D) Access to resources based on user identity

✓ E) Every resource has a sensitivity label matching a clearance level assigned to a user

342. Examples of properties used for defining access policies in Attribute-Based Access Control (ABAC) model include:

A) Subject (i.e., user or process requesting access)

B) Type of action (for example "read", "write", "execute")

C) Resource type (medical record, bank account etc.)

D) Environment (contextual data, such as time of day or geolocation)

✓ E) All of the above

343. The maximum password age policy setting determines the period of time that a password must be used before the user can change it.

A) True

✓ B) False

344. The importance of changing default usernames and passwords can be illustrated by the example of certain network devices (such as routers), which are often shipped with default and well-known admin credentials that can be looked up on the web.

A) True

B) False

Respuesta no detectada automaticamente

345. An attack against encrypted data that relies heavily on computing power to check all possible keys and passwords until the correct one is found is called:

A) Replay attack

✓ B) Brute-force attack

C) Dictionary attack

D) Birthday attack

346. Which part of the incident response process involves establishing and maintaining the incident response capability as well as setting up an incident response team?

A) Preparation

B) Detection and analysis

C) Containment, eradication, and recovery

D) Post-incident activity

347. Which of the following answers refer(s) to the containment, eradication, and recovery stage of the incident response process? (Select all that apply)

A) Restoring normal operations

✓ B) Eliminating the threat

C) Monitoring and detecting potential incidents

D) Establishing and maintaining an incident response policy

✓ E) Mitigating the impact of the incident

348. Which of the answers listed below refers to a discussion-based activity where team members walk through different scenarios to evaluate the incident response plan without activating any systems?

A) Tabletop exercise

✓ B) Simulation

C) Threat hunting

D) Root cause analysis

349. During the post-incident activity stage, this step involves analyzing logs, forensics data, and other evidence to prevent incident reoccurrence.

A) Reporting

B) E-discovery

✓ **C) Root cause analysis**

D) Threat hunting

350. The process of maintaining a documented record of the handling and movement of evidence to ensure its integrity and admissibility in court is called:

A) Chain of custody

B) Chain of evidence

C) Chain of accountability

D) Chain of responsibility

Respuesta no detectada automaticamente

351. The process of determining potential risks that could affect an organization's ability to achieve its objectives is called:

✓ **A) Risk assessment**

✓ **B) Risk identification**

C) Risk analysis

D) Risk management

352. Which of the following answers refers to a risk assessment method based on need, typically conducted in response to specific events or changes, such as after a major organizational change or a security breach?

A) Ad hoc

B) Recurring

C) One-time

D) Continuous

353. A high MTBF value indicates that a component or system provides low reliability and is more likely to fail.

A) True

✓ **B) False**

354. In penetration testing, active reconnaissance involves gathering any type of publicly available information that can be used later for exploiting vulnerabilities found in the targeted system.

A) True

✓ **B) False**

2.0 Threats, Vulnerabilities, and Mitigations (22% del examen)

2.1 - Compare and contrast common threat actors and motivations.

Conceptos clave:

- Threat actors: Nation-state, Unskilled attacker, Hacktivist, Insider threat, Organized crime, Shadow IT
- Attributes: Internal/external, Resources/funding, Level of sophistication
- Motivations: Data exfiltration, Espionage, Financial gain, Disruption, Revenge, War

Teoria (Professor Messer):

Threat Actors

- The entity responsible for an event that has an impact on the safety of another entity
  - Also called a malicious actor
  - Attributes (types, etc.) of threat actors often considered
- Useful to categorize motivation -- why is this attack happening?
- Attributes of threat actors
  - Internal vs. external (within or outside a company)
  - Resources and funding (no money vs. extensive funding)
  - Level of sophistication (script kiddie or nation-state zero-days)
- Motivations of threat actors
  - Data exfiltration
  - Espionage
  - Service disruption
  - Blackmail
  - Financial gain
  - Philosophical/political
  - Ethical
  - Revenge
  - Disruption/chaos
  - War
- Nation states
  - External entity
  - Motivations could be data exfiltration, political, revenge, disruption, war
  - Constant attacks, massive resources
    - Advanced Persistent Threat (APT)
  - Highest sophistication
    - Military control, utilities, finances
    - Stuxnet (U.S. and Israel) destroyed 1,000 nuclear centrifuges
- Unskilled attackers
  - Runs pre-made scripts
  - Motivated by the hunt (disruption, data exfiltration, financial)
  - Can be internal or external
  - Not very sophisticated
  - No formal funding (low hanging fruit)
- Hacktivist
  - Hacker with a purpose (philosophy, politics, ethics, disruption)
  - Often external (could infiltrate to be internal)
  - Can be remarkably sophisticated (DDoS, defacing websites, releasing documents)
  - Funding may be limited, some perform fundraising
- Insider threat
  - Motivated by revenge, financial gain
  - Extensive resources, uses organization's stuff
  - Medium sophistication
    - Has institutional knowledge
    - Can attack known vulnerable systems

- Organized crime
  - Professional criminals (almost always money)
  - Very sophisticated, hierarchical
  - Lots of capital, the best tools and personnel money can buy
- Shadow IT
  - Going rogue inside their own internal IT,
  - IT can put up roadblocks, so those in IT are a more advanced internal threat
  - Limit resources with company budget
  - Medium sophistication, some have IT background
-

Tips y trucos para el examen:

MOTIVACIONES (el PORQUE atacan):

- Data exfiltration: robar datos para venderlos o usarlos
- Financial gain: ransomware, fraude, robo de credenciales bancarias
- Espionage: robar secretos industriales o gubernamentales
- Disruption/Chaos: tirar sistemas sin motivo economico
- Philosophical/political: hacktivismo
- Revenge: empleado descontento
- War: ciberguerra entre estados

APT (Advanced Persistent Threat): actor sofisticado (normalmente nation-state) que permanece en la red de la victima durante meses o anos sin ser detectado, extrayendo informacion de forma continua.

Preguntas de practica (26):

1. Which term best describes a disgruntled employee abusing legitimate access to a company's internal resources?

A) APT

✓ B) Insider threat

C) Gray hat

D) Threat actor

---

2. From the drop-down list on the right, select the typical motivations behind the actions of each threat actor type.

Respuesta no detectada automaticamente

---

3. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM

✓ B) APT

C) XSRF

D) DDoS

---

4. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM

✓ B) APT

C) XSRF

D) DDoS

---

5. From the drop-down list on the right, select the typical motivations behind the actions of each threat actor type.

Respuesta no detectada automaticamente

---

6. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM

✓ **B) APT**

C) XSRF

D) DDoS

7. Which of the answers listed below refers to a Zero Trust Control Plane security approach that takes into account user identity, device security, network conditions, and other contextual information to enable dynamic access decisions?

A) Implicit trust

B) Monitoring and logging

✓ **C) Adaptive identity**

D) Microsegmentation

8. Choose an answer from the drop-down list on the right to match a threat actor type on the left with its common attack vector attribute.

Respuesta no detectada automaticamente

9. Match each threat actor type with its corresponding resources/funding attribute.

Respuesta no detectada automaticamente

10. Assign the level of sophistication attribute to each threat actor type listed below.

Respuesta no detectada automaticamente

11. Examples of threat vectors directly related to the use of removable devices include: (Select 2 answers)

A) Pretexting

✓ **B) Malware delivery**

C) Watering hole attacks

✓ **D) Data exfiltration**

E) Social engineering attacks

12. The term "URL hijacking" (a.k.a. "Typosquatting") refers to a deceptive practice involving the deliberate registration of domain names with misspellings or slight variations that closely resemble well-established and popular domain names. The primary goal of this strategy is to exploit the common typographical errors made by users while entering URLs into their web browser's address bar. Beyond capturing inadvertent traffic, typosquatting may also be used for hosting phishing sites to trick users into divulging sensitive information, distributing malware through deceptive websites, generating ad revenue by redirecting mistyped traffic, or engaging in brand impersonation to harm the reputation of authentic brands or deceive users.

A) True

B) False

13. Which type of Trojan enables unauthorized remote access to a compromised system?

A) APT

✓ **B) RAT**

C) MaaS

D) PUP

14. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA

✓ **B) CAPTCHA**

C) SSO

D) NIDS

15. A lightly protected subnet (a.k.a. DMZ) consisting of publicly available servers placed on the outside of the company's firewall is known as:

A) Captive portal

B) Quarantine network

C) Extranet

✓ **D) Screened subnet**

16. Which of the following answers refers to a solution that helps organizations mitigate risks associated with data breaches, insider threats, and compliance violations?

A) EDR
B) DLP
C) IAM
D) UTM

17. Which of the terms listed below refers to a situation where a party's impartiality could be questioned due to potential personal or financial gains?

A) Dual relationship
B) Undue influence
✓ **C) Conflict of interest**
D) Self-dealing

18. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA
✓ **B) CAPTCHA**
C) ACL
D) NIPS

19. Choose an answer from the drop-down list on the right to match a threat actor type on the left with its common attack vector attribute.

Respuesta no detectada automaticamente

20. Match each threat actor type with its corresponding resources/funding attribute.

Respuesta no detectada automaticamente

21. Assign the level of sophistication attribute to each threat actor type listed below.

Respuesta no detectada automaticamente

22. The term "Typosquatting" refers to a deceptive practice involving the deliberate registration of domain names with misspellings or slight variations that closely resemble well-established and popular domain names. The primary goal of this strategy is to exploit the common typographical errors made by users while entering URLs into their web browser's address bar. Beyond capturing inadvertent traffic, typosquatting may also be used for hosting phishing sites to trick users into divulging sensitive information, distributing malware through deceptive websites, generating ad revenue by redirecting mistyped traffic, or engaging in brand impersonation to harm the reputation of authentic brands or deceive users.

A) True
B) False

Respuesta no detectada automaticamente

23. Which type of Trojan enables unauthorized remote access to a compromised system?

A) APT
✓ **B) RAT**
C) MaaS
D) PUP

24. A network replay attack occurs when an attacker captures sensitive user data and resends it to the receiver with the intent of gaining unauthorized access or tricking the receiver into unauthorized operations.

A) True
B) False

25. Which of the answers listed below refers to a technology that provides control over the usage of a mobile device within a designated area?

A) Geofencing
B) Captive portal
C) Honeypot

D) Geolocation

Respuesta no detectada automaticamente

26. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA

✓ B) CAPTCHA

C) SSO

D) NIDS

2.2 - Explain common threat vectors and attack surfaces.

Conceptos clave:

- Message-based: Email, SMS, IM
- File-based, Image-based, Voice call, Removable device
- Vulnerable software, Unsupported systems, Unsecure networks
- Supply chain: MSPs, Vendors, Suppliers
- Social engineering: Phishing, Vishing, Smishing, Pretexting, Watering hole, Typosquatting

Teoria (Professor Messer):

Common Threat Vectors

- A method used by the attacker to gain access to or infect the target
  - Also called "attack vectors"
- A lot of work goes into finding them, security professionals spend lots of time protecting existing vectors and finding new vectors
- Message-based vectors
  - One of the biggest and most successful vectors
  - Email, SMS (malicious links/attachments)
  - Phishing attacks
  - Deliver malware via attachment
  - Social engineering attacks (scams)
- Image-based vectors
  - Easy to identify text-based, harder to identify threat in an image
  - Some image formats can be a threat (SVG, described in XML)
  - HTML injection, JavaScript attack code
  - Browsers must provide input validation
- File-based vectors
  - More than just executables
  - Adobe PDF, file format containing other objects
  - ZIP/RAR/any compression, obfuscates attack
  - Microsoft Office (macros, add-in files)
- Voice call vectors
  - Vishing - phone phishing
  - Spam over IP - large-scale phone calls over IP
  - War dialing - finding unpublished phone numbers to gain access
  - Call tampering - disrupting voice calls (DoS)
- Removable device vectors
  - Get around firewall - malicious software on a USB stick
  - Infecting air-gapped networks, industrial systems, high-security services
  - USB devices can act as keyboards
  - Data exfiltration - terabytes of data can walk out the door with zero bandwidth
- Vulnerable software vectors
  - Client-based - infected executable with known (or unknown) vulnerabilities
  - Agentless - no installed executable
    - Compromised software on server would affect all users
- Unsupported system vectors

    - Patching must be done, but some systems are too old to be patched
    - A single unsupported system could be an entry for attack
- Unsecure network vectors
    - Network connects everything, view all unencrypted data
    - Wireless - outdated protocols and open/rogue networks
    - Wired - unsecure interfaces, must enable 802.1X
    - Bluetooth - reconnaissance, implementation vulnerabilities
- Open service ports
    - Most network-based services connect over a TCP or UDP port (open)
    - Every open port is an opportunity
    - Every application has their own open port
    - Firewall rules, limit open port rules
- Default credentials
    - Most devices have defaults, absolutely MUST change them immediately
- Supply chain vectors
    - Tamper with underlying infrastructure or manufacturing process
    - Managed service providers - gives access to many customer networks
    - Gain access to a network using a vendor - 2013 Target credit card breach
    - Suppliers - counterfeit networking equipment
        - Install backdoors, substandard performance and availability
        - 2020 - fake Cisco Catalyst switches

Phishing

- Social engineering with a touch of spoofing (email, SMS, etc.)
- Check URL domains and attachments!
- Usually there's something not quite right
- Business email compromise
    - Attackers take advantage of the internal network trust
    - Spoofed email address, one or two characters changed
    - Financial fraud, bank information or wire transfer details
    - Links or attachments with malware
- Tricks and misdirection
    - Typosquatting - URL hijacking (similar URLs)
    - Pretexting - lying to get information, creating a character
- Phishing with different bait
    - Vishing (voice phishing) - spoofing caller ID
        - Fake security checks or bank updates
    - Smishing (SMS phising)
        - Commonly a shipment tracking scam (USPS, etc.)
- https://reddit.com/r/Scams

Impersonation

- Attackers pretend to be someone they aren't
- Use some details from reconnaissance, aids in trust
    - Attack victim as someone higher in rank
    - Throw around technical or personal details
- Eliciting information
    - Extracting information, often seen in vishing, well documented
- Identity fraud
    - Credit card fraud, your name and credit information
    - Bank fraud, loan fraud, government benefits fraud, tax fraud
- Protect against impersonation
    - Never volunteer information
    - Don't disclose personal details
    - Always verify before revealing info

Watering Hole Attacks

- Attacker poisons the "watering hole" and waits for you to visit
- Executing
  - Determine the frequented website/service
  - Infect one of these third-party sites
  - Infect all visitors
- Polish Financial supervision Authority, National Banking and Stock Commission of Mexico, State-owned bank in Uruguay (January 2017)
  - Visiting site would download malicious JS files, only to IPs matching targeted financial institutions
- Watching the watering hole
  - Security-in-depth (layered defense, even when internal access granted)
  - Firewalls and IPS
  - Anti-virus/malware signature updates

Other Social Engineering Attacks

- Misinformation/disinformation
  - Create confusion and division by disseminating factually incorrect information
  - Influence campaigns (political and social issues)
  - Nation-state actors
  - Enabled through social media and advertising
- The misinformation process
- Brand impersonation - pretend to be a well-known brand
  - Create tens of thousands of impersonated sites to get into the Google index
  - Malware infection is almost guaranteed

Tips y trucos para el examen:

SUPPLY CHAIN ATTACKS - Atacar a traves de proveedores:

- MSP (Managed Service Provider): comprometer al proveedor para llegar a sus clientes
- Vendors: software malicioso en actualizaciones legitimas (ej: SolarWinds)
- Suppliers: hardware comprometido antes de llegar al cliente

El ataque a SolarWinds (2020) es el ejemplo clasico: los atacantes insertaron codigo malicioso en una actualizacion legitima que llego a miles de organizaciones.

INGENIERIA SOCIAL - Tecnicas:

- Phishing: email fraudulento que imita una entidad legitima
- Spear phishing: phishing dirigido a una persona o empresa especifica
- Whaling: spear phishing dirigido a ejecutivos de alto nivel
- Vishing: phishing por llamada de voz
- Smishing: phishing por SMS
- Pretexting: crear un escenario falso para obtener informacion (ej: hacerse pasar por IT support)
- Watering hole: comprometer un sitio web que la victima visita frecuentemente
- Typosquatting: registrar dominios con erratas (gooogle.com) para capturar trafico
- Business Email Compromise (BEC): suplantar al CEO para ordenar transferencias bancarias

Preguntas de practica (30):

1. Examples of threat vectors directly related to the use of removable devices include: (Select 2 answers)

A) Pretexting

✓ B) Malware delivery

C) Watering hole attacks

✓ D) Data exfiltration

E) Social engineering attacks

---

2. Which social engineering attack relies on identity theft?

A) Pretexting

B) Spear phishing

C) Tailgating

✓ **D) Impersonation**

3. Which of the answers listed below refers to a social engineering technique where an attacker creates a false scenario or situation to deceive the victim into revealing sensitive information?

A) Impersonation
B) Credential harvesting
✓ **C) Pretexting**
D) Watering hole attack

4. An attack surface is the sum of all the potential points (vulnerabilities) through which an attacker can interact with or compromise a system or network, indicating the overall exposure to potential threats. Examples of attack surfaces can be all software, hardware, and network interfaces with known security flaws. A threat vector represents the method or means through which a cyber threat is introduced or delivered to a target system. It outlines the pathway or avenue used by attackers to exploit vulnerabilities. Common threat vector types include phishing emails, malware, drive-by downloads, and social engineering techniques.

A) True
B) False
Respuesta no detectada automaticamente

5. Which of the following answers refer to common threat vectors that apply to MSPs, vendors, and suppliers in the supply chain? (Select 2 answers)

A) Compliance violations
B) Brand reputation damage
✓ **C) Propagation of malware**
D) Operational disruptions
✓ **E) Social engineering techniques**

6. The term "URL hijacking" (a.k.a. "Typosquatting") refers to a deceptive practice involving the deliberate registration of domain names with misspellings or slight variations that closely resemble well-established and popular domain names. The primary goal of this strategy is to exploit the common typographical errors made by users while entering URLs into their web browser's address bar. Beyond capturing inadvertent traffic, typosquatting may also be used for hosting phishing sites to trick users into divulging sensitive information, distributing malware through deceptive websites, generating ad revenue by redirecting mistyped traffic, or engaging in brand impersonation to harm the reputation of authentic brands or deceive users.

A) True
B) False

7. A social engineering technique whereby attackers under disguise of a legitimate request attempt to gain access to confidential information is commonly referred to as:

A) Phishing
B) Smishing
C) Pharming
D) Spoofing

8. A BEC attack is an example of:

A) Smishing
✓ **B) Phishing**
C) Vishing
D) Pharming

9. The term "Typosquatting" refers to a deceptive practice involving the deliberate registration of domain names with misspellings or slight variations that closely resemble well-established and popular domain names. The primary goal of this strategy is to exploit the common typographical errors made by users while entering URLs into their web browser's address bar. Beyond capturing inadvertent traffic, typosquatting may also be used for hosting phishing sites to trick users into divulging sensitive information, distributing malware through deceptive websites, generating ad revenue by redirecting mistyped traffic, or engaging in brand impersonation to harm the reputation of authentic brands or deceive users.

A) True
B) False
Respuesta no detectada automaticamente

10. Which of the answers listed below refers to an email-based threat vector?

A) Spoofing
B) Phishing
C) BEC attacks
D) Malicious links
E) Malware attachments
✓ F) All of the above

11. Which of the answers listed below refers to an example of a potential threat vector in IM-based communication?

A) Phishing attack
B) Malware distribution
C) Spoofing attack
D) Eavesdropping
E) Account hijacking
F) Malicious link/attachment
✓ G) All of the above

12. Which of the following answers refer to agentless software threat vectors? (Select 2 answers)

A) Phishing email
B) Malicious USB drive
✓ C) Network protocol vulnerability
D) Infected macro
✓ E) Packet sniffing

13. The practice of gaining unauthorized access to a Bluetooth device is known as:

A) Phishing
B) Bluejacking
C) Smishing
✓ D) Bluesnarfing

14. Which of the answers listed below refers to an email-based threat vector?

A) Spoofing
B) Phishing
C) BEC attacks
D) Malicious links
E) Malware attachments
✓ F) All of the above

15. Which of the answers listed below refers to an example of a potential threat vector in IM-based communication?

A) Phishing attack
B) Malware distribution
C) Spoofing attack
D) Eavesdropping
E) Account hijacking
F) Malicious link/attachment
✓ G) All of the above

16. Which of the following answers refer to examples of image-based threat vectors? (Select 3 answers)

A) Steganography
B) BEC attacks
C) Image spoofing (deepfakes)

D) Brand impersonation
E) Malware-embedded images

17. Which of the following answers refers to a social engineering attack that exploits SMS or text messages to deceive recipients into taking harmful actions, such as revealing sensitive information or clicking malicious links?

A) Pharming
B) Spoofing
C) Quishing
✓ D) Smishing

18. Which of the answers listed below refers to a file-based threat vector?

A) PDF exploits
B) Malicious macros in documents
C) Compressed files (ZIP, RAR)
D) Malicious scripts in web pages
E) Infected images
F) Malicious executables
✓ G) All of the above

19. Exploiting known vulnerability is a common threat vector for:

A) Legacy systems/apps
✓ B) Unsupported systems/apps
C) Newly released systems/apps
D) Systems/apps with zero-day vulnerability

20. Which of the wireless technologies listed below are considered potential threat vectors and should be avoided due to their known vulnerabilities? (Select all that apply)

A) WPS
B) WAP
✓ C) WPA
D) WAF
✓ E) WPA2
✓ F) WEP

21. Which of the following answers refers to a threat vector characteristic only to wired networks?

A) ARP Spoofing
B) VLAN hopping
✓ C) Cable tapping
D) Port sniffing
E) All of the above

22. When domain registrants due to unlawful actions of third parties lose control over their domain names, they fall victim to:

A) Sybil attack
✓ B) Domain hijacking
C) Typosquatting
D) URL hijacking

23. Which of the following facilitate(s) privilege escalation attacks? (Select all that apply)

A) System/application vulnerabilities
B) Password hashing
✓ C) System/application misconfigurations
D) Network segmentation
✓ E) Social engineering techniques

24. In email communication, what signs can be of help in recognizing a phishing attempt?

A) The message contains poor spelling and grammar

B) The message asks for personal information
C) The message includes a call to action with a sense of urgency
D) The message includes suspicious links or attachments
✓ E) Any of the above

25. What is the best countermeasure against social engineering attacks?

A) Situational awareness
B) Implicit deny policy
✓ C) User education
D) Strong security controls

26. Which of the answers listed below refers to a file-based threat vector?

A) PDF exploits
B) Malicious macros in documents
C) Compressed files (ZIP, RAR)
D) Malicious scripts in web pages
E) Infected images
F) Malicious executables
G) All of the above

27. Which of the following terms refers to a common platform for watering hole attacks?

A) Mail gateways
✓ B) Websites
C) PBX systems
D) Web browsers

28. What would be an appropriate user response to an email phishing attempt? (Select all that apply)

A) Not replying to the message or providing any personal information
✓ B) Reporting the message to the IT or security department, if applicable
✓ C) Deleting the message from the inbox
✓ D) Not clicking on any links or downloading any attachments in the message
E) Forwarding the message to the sender to verify its legitimacy
F) Opening the attachment in a sandbox environment to check its safety

29. When domain registrants due to unlawful actions of third parties lose control over their domain names, they fall victim to:

A) Sybil attack
✓ B) Domain hijacking
C) Typosquatting
D) URL hijacking

30. A situation where an attacker intercepts and retransmits valid data exchange between an application and a server, or another application is known as:

A) Sideloading
✓ B) Replay attack
C) Phishing attack
D) Race condition

2.3 - Explain various types of vulnerabilities.

Conceptos clave:

- Application: Memory injection, Buffer overflow, Race conditions (TOC/TOU), Malicious update
- Web-based: SQLi, XSS
- Hardware: Firmware, End-of-life, Legacy
- Virtualization: VM escape, Resource reuse
- Cloud-specific, Supply chain, Cryptographic, Misconfiguration
- Mobile: Side loading, Jailbreaking

- Zero-day

Teoria (Professor Messer):

Memory Injections

- Finding malware
  - Malware runs in memory
  - Memory contains running processes
    - DLLs, threads, buffers, etc.
  - Malware is hidden somewhere, either runs its own or injects itself into a legitimate process
- Memory injection - adding code into memory of an existing process
  - Get access to the data in that process
- DLL injection
  - Dynamic-linked library - widely used Windows libraries
  - Attackers inject a path to a malicious DLL, very popular
  -

Buffer overflows

- Reference made outside memory buffer, revealing/overwriting existing memory
- Developers need to perform bound checking, large attack surface
- Not a simple exploit, looking for easy and repeatable buffer overflows
- Before overflow:
- After overflow:

Race Conditions

- Two events happening almost simultaneously in a program, can end poorly or lead to vulnerabilities if not handled
- Time-of-check to time-of-use attack (TOCTOU)
  - Something might happen between these two moments
-
- January 2004 - Mars rover "Spirit"
  - Reboot when a problem is identified ... problem is within the filesystem
  - Error repeats on reboot ... reboot loop ensues
  - Fixed by deleting some erroneous software on the flash memory
- Pwn2Own Vancouver 2023
  - TOCTOU attack on Tesla Model 3 - against infotainment using Bluetooth
  - Elevated to root privileges, earned $100,000 and the Tesla

Malicious Updates

- Update process can be injected with malicious code
- Always, ALWAYS have a good backup
- Install from trusted sources and check signatures
- Downloading and updating
  - Confirm the source
  - Visit the developer's site directly\
  - Many OSs will only allow signed apps
- Automatic updates
  - Often include security checks / signatures
  - Relatively trustworthy, but...
  - SolarWinds Orion supply chain attack
    - Attackers gained access to development system
    - Added their own code and gained access to gov agencies and companies

Operating System Vulnerabilities

- Large target, foundational computing platform
- Remarkably complex, extremely large attack surface
- Patch Tuesday
  - 2nd Tuesday of each month
  - Microsoft releases windows CVE patches

    - [June 2024 (49 Microsoft CVEs)](https://msrc.microsoft.com/update-guide/releaseNote/2024-Jun)
  - Best practices
    - Always update when available
    - Safely and carefully, of course - backup and test in sandboxes

SQL Injection

- Code injection - adding your own information to a data stream
  - Side effect of bad program design
  - HTML, SQL, XML, LDAP, etc.
- SQL - structured query language, common relational DBMS language
- SQL injection (SQLi) - outside queries can reach internal database and display sensitive information, commonly on a web browser
-

Cross-site scripting

- XSS (not to be confused with CSS - Cascading Style Sheets)
- Originally called this because of browser security flaws
- One of the most common web app vulnerabilities - commonly uses JS
-
- Non-persistent (reflected) XSS attack
  - Website allows scripts to run in user input (search boxes, etc.)
  - Payload (script) returned as part of the HTML response
  - Victim tricked into sending malicious code to vulnerable web app, reflected back to victim's browser
- Persistent (stored) XSS attack
  - Attacker posts on social media or elsewhere with link or malicious payload (script)
  - Everyone gets the payload, no specific target
- Hackling a Subaru - June 2017, Aaron Guzman
  - During authentication w/ Subaru, users get a token that never expires
  - Can be used for any service request
  - Along with this, Subaru website front-end included an XSS vulnerability
- Protecting against XSS
  - Be incredibly careful when clicking untrusted links
  - Consider disabling JavaScript
  - Keep browser and applications updated
  - Validate (clean) input on web apps

Hardware Vulnerabilities

- Surrounded by hardware / embedded systems, some with no accessible OS
- Potential security issues, everything is connected to the network (IoT)
- Firmware - the software inside of the hardware (OS, BIOS, UEFI, etc.)
  - Vendors are the only ones who can fix their hardware
  - Some don't care as much, take months or even years to supply a patch
- End of life (EOL) - manufacturer stops selling product
  - Support may continue, even security patches
  - End of service life (EOSL) - no longer selling or supporting (patching) device
- Legacy platforms - older OSs, apps, middleware (?)
  - May be running EOL/EOSL software
  - May require additional security protections (firewall rules, IPS signatures)

Virtualization Vulnerabilities

- Quantity of resources vary between VMs
- Quite different, but also many similarities to physical machines
- VM escape protection
  - VM is self-contained, so no way out... right?
  - VM escape - breaking out and interacting with host OS/hardware
  - Pwn2Own March 2017
    - JS bug in Microsoft Edge --> code execution in Edge sandbox

    - Windows 10 kernel bug to compromise guest OS
    - Hardware simulation bug in VMWare --> move to other VMs in hypervisor
- Resource reuse
  - Hypervisor can be tasked with handing out more memory than is on the hardware, for example
  - If software outdated, some memory can be overwritten or read unintentionally and create security risks

Cloud-specific vulnerabilities

- Lots of sensitive data, but 76% of companies are not using MFA and 63% of code is unpatched with a CVSS >= 7.0
- Attack the service
  - Denial of Service (DoS or DDoS)
  - Authentication bypass
  - Directory traversal
  - Remote code execution
- Attack the application
  - Web app attacks are on the rise (Log4j and Spring Cloud Function)
  - Cross-site scripting (XSS)
  - Out of bounds (memory) write
  - SQL injection

Supply Chain Vulnerabilities

- Only as strong as your weakest link
- Supply chain risks
  - Contains many moving parts, large attack surface and lots of room for error
  - Raw material, supplier, manufacturer, distributor, customer, consumer
- Service providers
  - You can only control your own security posture, but not always a third-party
  - Can have access to internal services, so consider ongoing audits for providers
  - Target service provider attack - November 2013
    - Heating and AC firm in PA had a tech's VPN creds stolen via malware delivered in an email
    - Firm was a service provider for Target, network wide open and every cash register was infected
    - Months later it was discovered, but 40 million credit cards stolen
- Hardware providers - can you trust your new anything?
  - Use a small supplier base
  - Strict controls over policies and procedures
  - Cisco or not Cisco?
    - All network traffic flows through switches and routers
    - July 2022 Homeland Security arrests reseller CEO, $1 billion of counterfeit Cisco products creating over 30 different companies since 2013
    - Made in China and distributed, started breaking / catching on fire
- Software providers
  - Check signatures on initial installation
  - Ensure security and authenticity of updates and patches
  - Open source isn't immune
  - SolarWinds Orion supply chain attack
    - Used by 18,000 customers including Fortune 500 and US Gov
    - Software updates were compromised from the inside
    - Compromise March and June 2020, not found until December 2020

Misconfiguration Vulnerabilities

- Open permissions
  - Easy to accidentally leave a door open - June 2017, 14 mil Verizon records exposed because a third-party just left an Amazon S3 data repo sitting open, thankfully it was found by a researcher
  - Increasingly common with cloud storage
- Unsecured admin accounts
  - Linux root / Windows Administrator
  - Can be a misconfiguration or intentional malicious configuration (bad password)

    - Disable direct login to the root account (su/sudo, run as Admin)
  - Insecure protocols
    - Some protocols like Telnet, FTP, SMTP, IMAP send unencrypted traffic
    - Verify with a packet capture
    - Use encrypted versions like SSH, SFTP, IMAPS, etc.
    - [DEF CON Wall of Sheep](https://www.wallofsheep.com/pages/wall-of-sheep)
  - Default settings
    - Every app, device, etc. has a default login
    - Mirai botnet - took advantage of IoT default configs, released as open source software
  - Open ports and services
    - Often managed with a firewall
    - Firewall rulesets can be complex
    - Always test and audit

Mobile Device Vulnerabilities

- Challenging to secure - small, in motion, containing sensitive data, connected
- Jailbreaking/rooting
  - Purpose-built systems without access to OS, but rooting (Android) and jailbreaking (iOS) can allow OS/hardware access to install new firmware
  - Uncontrolled access, mobile device manager (MDM) becomes useless
- Sideloading
  - One malicious app can cause a breach
  - On most modern phones, all installations are managed by a store
  - Sideloading (installing your own software) circumvents this security

Zero-day Vulnerabilities

- Many apps have unfound vulnerabilities, can be found by researchers or attackers
- If first found by attackers, they are zero-day vulnerabilities
  - Vendor has no idea the vulnerability exists, no patch
  - Zero-day attacks use these exploits
  - [Common Vulnerabilities and Exposures (CVE)](https://cve.mitre.org/)
- April 2023 - Chrome zero-day memory corruption, sandbox escape
- May 2023 - Microsoft zero-day secure boot, UEFI self-signed code
- May 2023 - iOS and iPadOS sandbox escape, info disclosure, code execution

Tips y trucos para el examen:

VULNERABILIDADES DE VIRTUALIZACION:

- VM escape: el codigo malicioso sale de la maquina virtual y accede al hipervisor o a otras VMs
- Resource reuse: datos de una VM anterior quedan accesibles en memoria para otra VM

OTRAS VULNERABILIDADES:

- Cloud-specific: misconfiguraciones en S3 buckets, IAM mal configurado, APIs expuestas
- Cryptographic: uso de algoritmos debiles (MD5, SHA-1, DES), claves cortas, mala implementacion
- Misconfiguration: la causa mas comun de brechas. Puertos abiertos, credenciales por defecto, permisos excesivos
- Zero-day: vulnerabilidad desconocida para el fabricante, sin parche disponible
- Mobile - Side loading: instalar apps fuera de la tienda oficial (Android permite esto por defecto)
- Mobile - Jailbreaking/Rooting: eliminar las restricciones del SO del movil, exponiendo el sistema

Preguntas de practica (87):

1. Which of the following answers does not refer to a common type of OS-based vulnerability?

A) Access control and permissions vulnerabilities (weak passwords, privilege escalation)

B) Vulnerabilities in installed applications, system utilities, and device drivers

C) Memory-related vulnerabilities (memory leaks, buffer overflows, race conditions)

D) Patch and update management vulnerabilities (security patch and update delays, malicious updates)

E) Vulnerabilities related to system/security misconfigurations

F) Network-related vulnerabilities (DoS attacks, remote code execution attacks)

✓ **G) All of the above answer choices are examples of OS-based vulnerabilities**

2. A type of vulnerability where the state of a resource is verified at one point in time but may change before the resource is actually used is referred to as:

A) TOC

✓ **B) TOC/TOU**

C) TOU

D) TSIG

3. Which of the answers listed below refers to a security vulnerability that enables inserting malicious code into input fields, such as search bars or login forms, to execute unauthorized commands on a database?

A) RCE

✓ **B) SQLi**

C) XSS

D) CSRF

4. A type of vulnerability where the state of a resource is verified at one point in time but may change before the resource is actually used is called:

A) TOC

✓ **B) TOC/TOU**

C) TOU

D) TSIG

5. Which of the answers listed below refers to a security vulnerability that enables inserting malicious code into input fields, such search bars or login forms, to execute unauthorized commands on a database?

A) RCE

✓ **B) SQLi**

C) XSS

D) CSRF

6. Which of the following answers refer to agentless software threat vectors? (Select 2 answers)

A) Phishing email

B) Malicious USB drive

✓ **C) Network protocol vulnerability**

D) Infected macro

✓ **E) Packet sniffing**

7. Exploiting known vulnerability is a common threat vector for:

A) Legacy systems/apps

✓ **B) Unsupported systems/apps**

C) Newly released systems/apps

D) Systems/apps with zero-day vulnerability

8. Which of the following exploits targets a protocol used for managing and accessing networked resources?

A) CSRF/XSRF attack

✓ **B) XML injection attack**

✓ **C) LDAP injection attack**

D) SQL injection attack

9. A type of cyberattack focused on making a website, service, or network unavailable to users by overloading it with traffic or malicious requests is called:

A) SQLi

B) XSS

C) CSRF

✓ **D) DoS**

10. Which type of application attack relies on introducing external code into the address space of a running program?

A) Buffer overflow

✓ **B) Memory injection**

C) Replay attack

D) Pointer dereference

---

11. What type of action allows an attacker to exploit the XSS vulnerability?

A) Code injection

B) Privilege escalation

C) Session hijacking

D) Packet sniffing

---

12. Vulnerability scanning: (Select all that apply)

A) Identifies lack of security controls

B) Actively tests security controls

✓ **C) Identifies common misconfigurations**

D) Exploits vulnerabilities

✓ **E) Passively tests security controls**

---

13. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting

✓ **B) Log monitoring**

C) Sandboxing

✓ **D) Security audits**

✓ **E) CCTV**

✓ **F) IDS**

✓ **G) Vulnerability scanning**

---

14. The MIME specification extends the email message format beyond plain text, enabling the transfer of graphics, audio, and video files over the Internet mail system. S/MIME is an enhanced version of the MIME protocol that enables email security features by providing encryption, authentication, message integrity, and other related services.

A) True

B) False

---

15. SFTP is an extension of the FTP protocol that adds support for SSL/TLS encryption.

A) True

✓ **B) False**

---

16. Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication, and data integrity for network traffic?

A) TLS

B) SSH

✓ **C) IPsec**

D) VPN

---

17. An encryption protocol primarily used in Wi-Fi networks implementing the WPA2 security standard is called:

A) TKIP

✓ **B) CCMP**

C) SSL

D) IPsec

---

18. Which of the following answers refer(s) to deprecated/insecure encryption protocols and cryptographic hash functions? (Select all that apply)

A) DES

B) AES-256

✓ **C) MD5**

D) ECC

✓ **E) SHA-1**
✓ **F) SSL**
✓ **G) RC4**

19. Which of the following answers refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL
B) IKE
C) ESP
D) DHE

20. A type of exploit in which an application overwrites the contents of a memory area it should not have access to is called:

A) DLL injection
✓ **B) Buffer overflow**
C) Memory leak
D) Privilege escalation

21. Which of the answers listed below describe the characteristics of a cross-site scripting attack? (Select 3 answers)

A) Exploits the trust a user's web browser has in a website
✓ **B) A malicious script is injected into a trusted website**
✓ **C) User's browser executes attacker's script**
D) Exploits the trust a website has in the user's web browser
E) A user is tricked by an attacker into submitting unauthorized web requests
F) Website executes attacker's requests

22. Which of the following answers refers to a type of software embedded into a hardware chip?

A) Firmware
B) Middleware
C) Device driver
D) Machine code
Respuesta no detectada automaticamente

23. The practice of installing mobile apps from websites and app stores other than the official marketplaces is referred to as:

A) Jailbreaking
B) Rooting
✓ **C) Sideloading**
D) Carrier unlocking

24. What defines a reflected DDoS attack?

A) Overwhelming the target with a high volume of traffic to saturate its bandwidth
B) Exploiting vulnerabilities in network protocols to consume resources and disrupt services
✓ **C) Utilizing third-party servers to reflect and amplify attack traffic towards the target**
D) Targeting vulnerabilities in applications or web servers to exhaust resources

25. Which of the following is a vulnerability characteristic to NFC communication?

A) Eavesdropping
B) Data interception
C) Replay attacks
D) DoS attacks
✓ **E) All of the above**

26. Which of the following facilitate(s) privilege escalation attacks? (Select all that apply)

A) System/application vulnerabilities
B) Password hashing
✓ **C) System/application misconfigurations**

D) Network segmentation

✓ **E) Social engineering techniques**

27. Which of the answers listed below refer to a Layer 7 firewall? (Select 3 answers)

A) Offers complex (slower) traffic filtering

B) Filters traffic based on source/destination IP addresses, ports, and protocol types (e.g., TCP/UDP)

C) Operates at the transport layer of the OSI model

✓ **D) Adds the ability to inspect the contents of data packets in addition to the header information**

E) Offers basic (faster) traffic filtering

✓ **F) Operates at the application layer of the OSI model**

28. Which of the answers listed below refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL

✓ **B) IKE**

C) ESP

D) DHE

29. Implementing full device encryption is one of the methods for securing sensitive data on a smartphone. When enabled, this type of encryption works in conjunction with the phone's screen lock, i.e., to decrypt the phone (which stays encrypted whenever the phone is locked), a user must first unlock the screen. On Android devices, the unlocking methods include entering a PIN, password, or drawing a simple pattern with a finger. Apple devices use passcodes, facial recognition (Face ID), and fingerprint (Touch ID).

A) True

B) False

Respuesta no detectada automaticamente

30. Which of the answers listed below refer to workstation hardening techniques? (Select 3 answers)

A) Hiding administrator accounts

✓ **B) Regularly applying security patches and updates to the OS and installed software**

C) Disabling all internet access

✓ **D) Removing or disabling unnecessary drivers, services, software, and network protocols**

✓ **E) Limiting unauthorized or unauthenticated user access**

31. Which of the answers listed below refers to the process of assessing the physical environment, such as the layout of the building, to identify potential sources of interference and determine the optimal placement of a WAP?

A) Gap analysis

B) Capacity planning

✓ **C) Site survey**

D) Vulnerability scanning

32. Which of the following answers refers to a deprecated wireless authentication protocol developed by Cisco?

A) PEAP

B) EAP-TTLS

✓ **C) LEAP**

D) EAP-TLS

33. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ F) All of the above answers are examples of vulnerability response and remediation techniques

34. Simple Network Management Protocol (SNMP) is a UDP-based, application layer protocol used in network management systems to monitor network-attached devices. SNMP is typically integrated into most modern network infrastructure devices such as routers, bridges, switches, servers, printers, copiers, fax machines, and other network-attached devices. An SNMP-managed network comprises three essential components: a managed device, a network-management software module that resides on a managed device (Agent), and a Network Management Station (NMS), which runs applications responsible for monitoring and controlling managed devices, as well as collecting SNMP information from Agents. The manager receives notifications (Traps and InformRequests) on UDP port 162, while the SNMP Agent receives requests on UDP port 161.

A) True

B) False

Respuesta no detectada automaticamente

35. Which of the following protocols allow(s) for secure file transfer? (Select all that apply)

A) FTPS

B) TFTP

C) FTP

✓ D) SFTP

36. Which of the protocols listed below enable secure retrieval of emails from a mail server to an email client? (Select 2 answers)

A) FTPS

✓ B) IMAPS

✓ C) POP3S

D) STARTTLS

E) SMTPS

37. Which of the answers listed below refers to a secure network protocol used to provide encryption, authentication, and integrity for real-time multimedia communication?

A) IPsec

B) SIP

C) VoIP

✓ D) SRTP

38. TCP is an example of a connectionless protocol. Because TCP does not support three-way handshake while establishing a network connection, it is referred to as unreliable or best-effort protocol. Example applications of TCP include transmission of video and audio streaming data.

A) True

✓ B) False

39. OpenID Connect is a protocol used for:

A) Attestation

B) Authorization

C) Auditing

✓ D) Authentication

40. Which of the following answers refers to a more in-depth exercise, which can include activating systems and performing real actions to respond to the incident?

A) Penetration testing

B) Threat hunting

✓ C) Simulation

D) Vulnerability scanning

41. An estimate based on the historical data of how often a threat would be successful in exploiting a vulnerability is known as:

A) ALE
B) SLA
✓ **C) ARO**
D) SLE

42. What is the name of a network protocol that secures web traffic via SSL/TLS encryption?

A) SFTP
✓ **B) HTTPS**
C) FTPS
D) SHTTP

43. What is the common term for a group of protocols used to carry voice data over a packet-switched network?

A) ISDN
B) PBX
✓ **C) VoIP**
D) PSTN

44. Which of the following file transfer protocols does not provide encryption?

A) SCP
B) FTPS
✓ **C) FTP**
D) SFTP

45. Which wireless security protocol has been deprecated in favor of newer standards due to known vulnerabilities resulting from implementation flaws?

A) EAP
B) AES
C) WPA2
✓ **D) WEP**

46. Which of the answers listed below refers to a suite of protocols used for connecting hosts on the Internet?

A) NetBIOS
B) IPv4
✓ **C) TCP/IP**
D) IPv6

47. A type of cryptographic network protocol for secure data communication, remote command-line login, remote command execution, and other secure network services between two networked computers is known as:

A) RDP
✓ **B) SSH**
C) Telnet
D) SCP

48. Which type of firmware performs initial hardware checks after the computer is powered on?

A) BIOS
B) POST
C) CMOS
D) PROM
Respuesta no detectada automaticamente

49. Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication, and data integrity for network traffic?

A) TLS
B) SSH
C) IPsec
D) VPN

50. Which of the following answers refers to a routing protocol used in computer networks to determine the best path for routing data packets from one network node to another?

A) BGP
B) EIGRP
C) RIP
D) OSPF

---

51. Which of the answers listed below refers to a remote access authentication protocol that periodically re-authenticates client at random intervals to prevent session hijacking?

A) EAP
B) CHAP
C) PAP
D) PEAP

---

52. Which of the following answers refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL
✓ B) IKE
C) ESP
D) DHE

---

53. Which of the acronyms listed below refers to a piece of hardware and associated software/firmware designed to provide cryptographic and key management functions?

A) EFS
✓ B) HSM
C) SFC
D) TPM

---

54. The MIME specification extends the email message format beyond simple text, enabling the transfer of graphics, audio, and video files over the Internet mail system. S/MIME is an enhanced version of the MIME protocol that enables email security features by providing encryption, authentication, message integrity, and other related services.

A) True
B) False

---

55. A network protocol used for secure file transfer over SSH is known as:

A) TFTP
✓ B) SFTP
C) SCP
D) FTPS

---

56. Which of the answers listed below refers to a network protocol used for synchronizing clocks over a computer network?

A) NTP
B) VTP
C) NNTP
D) RTP

---

57. Which of the answers listed below refers to a protocol used by routers, hosts, and network devices to generate error messages and troubleshoot problems with delivery of IP packets?

A) CCMP
B) RSTP
C) ICMP
D) SNMP

---

58. Which of the answers listed below refers to a deprecated wireless authentication protocol developed by Cisco?

A) PEAP
B) EAP-TTLS
C) LEAP
D) EAP-TLS

59. Which of the answers listed below refers to a key exchange protocol that generates temporary keys for each session, providing forward secrecy to protect past and future communications?

A) PFS
B) SHA
C) PGP
✓ D) DHE

60. Which of the following answers refers to an obsolete protocol used for secure data transfer over the web?

A) SMTPS
B) SRTP
C) SHTTP
D) S/MIME

61. A protocol designed to improve the security of existing WEP implementations is known as:

A) SRTP
✓ B) TKIP
C) CCMP
D) WPA2

62. Which of the answers listed below refers to a tunneling protocol commonly used in creating VPNs?

A) VRRP
✓ B) GRE
C) RTSP
D) BGP

63. Which of the following answers refers to a network protocol for delivering audio and video over IP networks?

A) RDP
B) VoIP
C) RTP
D) UDP

64. Which of the following answers refers to an encryption protocol primarily used in Wi-Fi networks implementing the WPA2 security standard?

A) TKIP
B) CCMP
C) SSL
D) HMAC

65. Which of the acronyms listed below refers to a protocol used in network management systems for monitoring network-attached devices?

A) SSH
B) VNC
C) SNMP
D) RDP

66. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ B) Log monitoring
C) Sandboxing
✓ D) Security audits
✓ E) CCTV
✓ F) IDS

✓ **G) Vulnerability scanning**

67. What is the name of a network protocol that secures web traffic via SSL/TLS encryption?

✓ **A) SFTP**

✓ **B) HTTPS**

C) FTPS

D) SHTTP

68. SFTP is an extension of the FTP protocol that adds support for SSL/TLS encryption.

A) True

✓ **B) False**

69. Which protocol enables secure, real-time delivery of audio and video over an IP network?

A) S/MIME

B) RTP

C) SIP

✓ **D) SRTP**

70. Which cryptographic protocol is designed to provide secure communications over a computer network and is the successor to SSL?

A) IPsec

✓ **B) TLS**

C) AES

D) CCMP

71. Which of the answers listed below refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL

✓ **B) IKE**

C) ESP

D) DHE

72. Which of the following answers refers to a key exchange protocol that generates temporary keys for each session, providing forward secrecy to protect past and future communications?

A) PFS

B) SHA

C) PGP

D) DHE

73. Which of the following answers refers to a cryptographic key exchange protocol that leverages ECC for enhanced security and efficiency?

A) S/MIME

B) ECDHE

C) DHE

D) ECDSA

74. Which of the answers listed below refers to a protocol that enables on-demand querying of the revocation status of a digital certificate?

A) CSP

✓ **B) OCSP**

C) DN

D) CRL

75. Which of the answers listed below refers to an application attack that relies on executing a library of code?

A) Memory leak

✓ **B) DLL injection**

C) Pointer dereference

✓ **D) Buffer overflow**

76. A malfunction in a preprogrammed sequential access to a shared resource is described as:

A) Race condition
B) Concurrency error
C) Multithreading
D) Synchronization error

---

77. Which of the answers listed below describe the characteristics of a cross-site scripting attack? (Select 3 answers)

A) Exploits the trust a user's web browser has in a website
✓ B) A malicious script is injected into a trusted website
✓ C) User's browser executes attacker's script
D) Exploits the trust a website has in the user's web browser
E) A user is tricked by an attacker into submitting unauthorized web requests
F) Website executes attacker's requests

---

78. What is the main vulnerability related to legacy hardware?

A) Compatibility issues
✓ B) Lack of security updates and patches
C) Worn-out physical components
D) Lack of skilled personnel to run it and maintain it

---

79. Which of the following answers refers to a virtualization-related vulnerability where virtualized assets allocated to one VM are improperly isolated and can be accessed or compromised by another VM?

A) Resource reuse
B) Privilege escalation
C) Resource exhaustion
D) Concurrent session usage
Respuesta no detectada automaticamente

---

80. The practice of installing mobile apps from websites and app stores other than the official marketplaces is referred to as:

A) Jailbreaking
B) Rooting
✓ C) Sideloading
D) Carrier unlocking

---

81. What defines a reflected DDoS attack?

A) Overwhelming the target with a high volume of traffic to saturate its bandwidth
B) Exploiting vulnerabilities in network protocols to consume resources and disrupt services
✓ C) Utilizing third-party servers to reflect and amplify attack traffic towards the target
D) Targeting vulnerabilities in applications or web servers to exhaust resources

---

82. Which type of exploit targets web applications that generate content used to store and transport data?

A) SQL injection attack
B) CSRF/XSRF attack
✓ C) XML injection attack
D) LDAP injection attack

---

83. A situation where an attacker intercepts and retransmits valid data exchange between an application and a server, or another application is known as:

A) Sideloading
✓ B) Replay attack
C) Phishing attack
D) Race condition

---

84. Which of the answers listed below refers to an open standard wireless network authentication protocol that enhances security by encapsulating authentication process within an encrypted TLS tunnel?

A) PEAP

B) EAP
C) LEAP
D) RADIUS
Respuesta no detectada automaticamente

85. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)
B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)
C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)
D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)
E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)
✓ F) All of the above answers are examples of vulnerability response and remediation techniques

86. Which of the protocols listed below is used to enable secure web browsing?

A) L2TP
✓ B) HTTPS
C) SSH
D) IPsec

87. FTPS is an extension to the SSH protocol and runs by default on TCP port 22.

A) True
✓ B) False

2.4 - Given a scenario, analyze indicators of malicious activity.

Conceptos clave:

- Malware: Ransomware, Trojan, Worm, Spyware, Virus, Keylogger, Logic bomb, Rootkit, Bloatware
- Network attacks: DDoS (Amplified/Reflected), DNS attacks, On-path, Credential replay
- Application attacks: Injection, Buffer overflow, Replay, Privilege escalation, Directory traversal
- Cryptographic attacks: Downgrade, Collision, Birthday
- Password attacks: Spraying, Brute force
- Indicators: Account lockout, Impossible travel, Resource consumption, Missing logs

Teoria (Professor Messer):

An Overview of Malware

- Malware: malicious software that can gather information, show you advertising, encrypt your data, and overall ruin your day :(
- Malware types and methods
  - Virus
  - Worm
  - Ransomware
  - Trojan Horse
  - Rootkit, Keylogger, Spyware, Bloatware, Logic bomb, etc.
- How you get malware
  - Worm exploits a vulnerability, installs malware with a remote access backdoor
  - Your computer must run a program (email links, website pop-ups, drive-by download, and sometimes worms)
- Your data is valuable
  - Personal data (pictures, videos, tax documents)
  - Organizational data (planning documents, employee PII, financial info)
- Ransomware
  - Encrypt all data on computer and request money
  - Encrypted with a very strong symmetric or asymmetric key
  - Using an untraceable payment method like cryptocurrency (blockchain)
- Protecting against ransomware

    - Make backups
    - Keep OS and applications up to date
    - Keep anti-virus/-malware signatures up to date

Viruses and Worms

- Malware that can reproduce itself
- Reproduces through filesystem or network
- Some cause immediate problems, some are invisible
- Anti-virus is very common, update signatures!!!
- Virus types
    - Program viruses
    - Boot sector viruses
    - Script viruses
    - Macro Viruses
- Fileless virus
    - Stealth attack, avoids detection
    - Operates in memory, never installed
- Worms
    - Malware that self-replicates without user interaction
    - Can take over systems very quickly
    - Firewalls and IDS/IPS can mitigate
    - WannaCry

Spyware and Bloatware

- Spyware
    - Spies on you for advertising, ID theft, etc.
    - Can trick you into installing
    - Browser monitoring and keyloggers
- Protecting against spyware
    - Maintain anti-virus/-malware (latest signatures)
    - Always know what you're installing
    - Always have a backup
    - Run malware scans
- Bloatware
    - New device has OS necessary apps, but also unnecessary ones
    - May use storage and open device to vulnerabilities
- Removing uninstaller
    - Use built-in uninstaller
    - Some apps have their own uninstaller
    - Third-party uninstaller

Other Malware Types

- Keyloggers
    - Logins, passwords, emails, etc.
    - Keystrokes captured and sent
    - Circumvents encryption
    - Other data logging: clipboard, screen, instant message
- Logic bomb
    - Waits for predefined event
    - Time or date, user event
    - Difficult to identify and recover
- Preventing a logic bomb
    - Formal change control
    - Electronic monitoring (IPS/IDS)
    - Constant auditing
- Rootkit

    - Originally a Unix technique
    - Modifies core system files (kernel)
    - Can be invisible to OS, has full control
  - Finding and removing rootkits
    - Look for unusual
    - Use a remover specific to rootkit
    - Secure boot with UEFI

Physical Attacks

- Old-school security, locks and guards
- If you have physical access to a server, you have full control
- "Door locks keep out the honest people"
- Brute force
  - Physical version... lol
  - Push through / break obstruction
- RFID cloning
  - Access badges, key fobs
  - Duplicators are cheap and effectives
  - A good reason for MFA
- Environmental attacks
  - Attack everything
  - Power monitoring
  - HVAC and humidity controls
  - Fire suppression

Denial of Service

- Force a service to fail by overloading
- Take advantage of design failure or vulnerability
- Cause systems to be unavailable to cause a smoke screen
- "Friendly" DoS
  - Layer 2 loop without STP
  - Downloading large files over DSL line
  - Water line breaks
  - Pressing two generic remotes at the same time!
- Distributed Denial of Service (DDoS)
  - Launch an army of computers to bring down a service
  - Usually assembled via a botnet
    - At peak, Zeus infected >3.6 mil PCs
  - Asymmetric attack, attacker may have limited resources but inflates them
- DDoS reflection and amplification
  - Abuse specific devices/protocols that respond with more data then probed
  - DNS amplification (~15 --> ~1300 characters)
  - DNS amplification DDoS

DNS Attacks

- DNS poisoning
  - Modify DNS server, less common
  - Modify client host file (DNS precedent)
  - Send a fake response to a valid DNS request
- Domain hijacking
  - Get access to domain registration, control where traffic flows
  - Brute force, social engineering, etc.
  - 8/22/2016, 36 domains of Brazilian bank changed, under control for 6 hours
- URL hijacking
  - Sell a domain typo to the legitimate owner and redirect to a website with lots of advertisements, a competitor company, or phishing/malware (typosquatting)

Wireless Attacks

- De-authentication attack (type of DoS)
- 802.11 management frames
  - Management features, important for operations
  - Original standards did not add protection
- Protecting against de-auth attacks
  - IEEE addressed with updates in 802.11ac
  - Important management frames encrypted, but not everything
- Radio frequency (RF) jamming
  - Denial of service
  - Transmit interfering wireless signals, more noise than actual data
  - Sometimes not intentional (microwave, fluorescent lights)
- Wireless jamming
  - Constant, random, legitimate, reactive (when someone transmits)
  - Needs to be somewhere close
  - "Fox hunting" -- hunting down a jam

On-path Attack

- AKA Man-in-the-Middle
- Effectively invisible, redirects your traffic
- ARP poisoning
  - On-path in local subnet, ARP has no security
  -
- On-path browser attack
  - Malware/Trojan on host does the proxy work
  - AKA Man-in-the-Browser
  - Easy and looks encrypted
  - Malware waits for logins and sensitive info

Replay Attacks

- Useful info transmitted over network
- Need access to raw network data
- Gathered info can help "replay" to pretend you're a trusted device
- Pass the hash
  - Client logs in to server, send user and hashed password over network
  - Attacker captures, replays to gain access to server
  - Avoid by using traffic encryption and/or salted hashed (with session ID, etc.)
- Browser cookies and session IDs
  - Cookies: info stored by your browser
  - Used for tracking, personalization, etc.
  - Could be considered a privacy risk, session IDs stored stored
- Session hijacking (Sidejacking)
  - Using an intercepted session ID to communicated with server
- Header manipulation
  - Gather info via Wireshark, Kismet
  - Modify headers (Tamper, Firesheep, Scapy)
  - Modify cookies (Cookies Manager+ on Firefox)
- Prevent session hijacking
  - Encrypt end-to-end (additional load on web server), force HTTPS/TLS
  - Encrypt end-to-somewhere, at least avoid over local wireless network (personal VPN)

Malicious Code

- Exploiting a vulnerability
  - Social engineering, default creds, etc. don't require technical skills
  - You can still get in by exploiting with malicious code
- Can be executable, script, macro, worm, Trojan

- Can be protected by anti-everything, firewall, patches, etc.
- Examples
  - WannaCry ransomware
    - Executable exploited vuln in Windows SMBv1
  - British Airways XSS
    - 22 lines of malicious JS, info stolen
  - Estonian Central Health DB
    - SQL injection, healthcare info breached

Application Attacks

- Injection attacks
  - Add your own info to a data stream
  - Enabled because of bad programming
  - HTML, SQL, XML, etc.
- Buffer overflow (prev.)
- Replay attack (prev.)
- Privilege escalation
  - Gain higher-level access to a system by exploiting a vulnerability
  - Higher-level = more capabilities
  - High-priority patches
  - Horizontal privilege (User A can access B resources) also useful
  - [CVE-2023-29336](https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-29336)
- Mitigating privilege escalation
  - Employ patches as soon as possible, carefully of course
  - Update anti-everything software and signatures
  - Data Execution Prevention (only in executable areas can run)
  - Address space layout randomization (prevent buff overflow and known address)
- Cross-site request
  - Load info from other websites, HTML directs requests
  - The client and the server
    - Client side: renders page (HTML, JS)
    - Server side: performs requests (HTML, PHP)
  - Cross-site request forgery
    - One-click attack, session riding (XSRF, CSRF, "sea surf")
    - Takes advantage of the trust a web app has for user, requests made w/o knowledge
    - Significant development oversight
    -
- Directory traversal
  - Read files from web server that are outside of website's file directory
  - Web server software of web app code vulnerability
  - A "dot dot slash" (../) is an indicator, accessing parent directory

Cryptographic Attacks

- Usually attacker doesn't have the "combination" so they attack the "safe"
- Birthday attack
  - In a classroom of 23 students, same birthday 50%
  - Digital equivalent is hash collision, find through brute force
  - Mitigate with a larger hash
- Collisions
  - Hash digests are *supposed* to be unique
  - MD5 is very susceptible, no longer used
- Downgrade attack
  - Force systems to downgrade security
  - SSL stripping
    - Combines on-path w/ downgrade
    - Browser page un-encrypted (HTTP)

    -

Password Attacks

- Plaintext / unencrypted passwords
  - Some apps store passwords without any encryptions -- DON'T DO THIS
  - Use more secure software
- Hashing a password
  - Hashes represent data as a fixed-length string of text (digest/fingerprint)
  - One-way function with (hopefully) no collisions
  - Common way to store passwords (common hash is SHA-256)
- The password file -- varies between OSs, different syntax and algorithms
  -
- Spraying attack
  - Logging in with incorrect password can cause lockout, so common passwords are tried
  - Attack account with top three or so passwords, move on to next if nothing
  - No lockouts, alarms, or alerts - mini brute force
  - https://en.wikipedia.org/wiki/List_of_the_most_common_passwords
- Brute force - try every combination until hash matches
  - Might take some time with strong/slow hash
  - Online - keep trying API login, slow, most will lockout
  - Offline - obtain users and hashes, calculate and compare, large comp. req.

Indicators of Compromise (IOC)

- An event that indicates an intrusion, high confidence
- Common
  - Unusual amount of network activity
  - Change to file hashes
  - Irregular international traffic
  - Changes to DNS data
  - Uncommon login patterns
  - Spikes of read requests to certain files
- Account lockout
  - Credentials are not working, exceeded login attempts
  - Could also be administrative disabled, more confident indicator
  - Part of a larger plan, could lead to a social engineering attack
- Concurrent session usage
  - Cannot be in two places at the same time (duh)
  - Look for single account logged in from different locations
  - This could also be a remote desktop connection or automated process, however, so it's hard to track
- Blocked content
  - Attacker wants to be persistent, block security updates and patches
  - IOC could be removed access to security updates
- Impossible travel
  - Authentication logs (on/off)
  - One login at HQ, another international, huge IOC
  - Easy to identify
- Resource consumption
  - e.g. unusual bandwidth spikes outside office hours
  - Often first notification of real issue
- Resource inaccessibility
  - Server is down
  - Network disruption, cover for exploit
  - Server outage
  - Encrypted data (ransomware)
  - Brute force attack --> lockout
- Out-of-cycle logging

    - Occurs at unexpected time
    - Patch logs outside normal time/day
    - Firewall log activity (protocols/apps)
  - Missing logs
    - Log information is evidence, so some during attack might be removed
    - Missing logs are also suspicious, IOC
  - Published/documented
    - Sometimes, attack and exfiltration can go unnoticed
    - Only noticed when large data dump is released, obvious IOC

Tips y trucos para el examen:

ATAQUES CRIPTOGRAFICOS:

- Downgrade attack: forzar el uso de versiones antiguas e inseguras de protocolos (ej: SSL en lugar de TLS)
- Collision attack: encontrar dos inputs distintos que producen el mismo hash
- Birthday attack: basado en la paradoja del cumpleanos, busca colisiones en hashes

INDICADORES DE ACTIVIDAD MALICIOSA:

- Account lockout inesperado: posible ataque de fuerza bruta
- Impossible travel: login desde Madrid y desde Tokyo en 10 minutos
- Resource consumption anormal: CPU/RAM al 100% sin razon aparente (cryptomining)
- Missing logs: alguien borro los logs para cubrir sus huellas
- Unauthorized changes: archivos modificados sin causa conocida

Preguntas de practica (51):

1. Malware that restricts access to a computer system by encrypting files or locking the entire system down until the user performs requested action is called:

A) Grayware
B) Adware
✓ C) Ransomware
D) Spyware

---

2. A standalone malicious computer program that typically propagates itself over a computer network to adversely affect system resources and network bandwidth is referred to as:

A) Worm
B) Fileless virus
C) Bot
D) Logic bomb

---

3. Malicious code activated by a specific event is called:

A) Cryptomalware
B) Backdoor
C) Rootkit
✓ D) Logic bomb

---

4. A dot-dot-slash attack is also referred to as:

A) Disassociation attack
B) On-path attack
✓ C) Directory traversal attack
D) Downgrade attack

---

5. Malware that restricts access to a computer system by encrypting files or locking the entire system down until the user performs requested action is called:

A) Grayware
B) Adware
✓ C) Ransomware
D) Spyware

---

6. A standalone malicious computer program that typically propagates itself over a computer network to adversely affect system resources and network bandwidth is referred to as:

A) Worm
B) Fileless virus
C) Bot
D) Logic bomb

7. Malicious code activated by a specific event is called:

A) Cryptomalware
B) Backdoor
C) Rootkit
✓ D) Logic bomb

8. Which of the following statements about honeypots are true? (Select 2 answers)

A) Honeypots are always part of a honeynet
✓ B) Honeypots mimic real systems to attract cyber attackers
C) Honeypots are a type of anti-malware solution
✓ D) Honeypots contain apparent vulnerabilities that are closely monitored by a security team
E) Honeypots are used to launch attacks on cyber attackers

9. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM
✓ B) APT
C) XSRF
D) DDoS

10. Which of the answers listed below refers to an email-based threat vector?

A) Spoofing
B) Phishing
C) BEC attacks
D) Malicious links
E) Malware attachments
✓ F) All of the above

11. Which of the answers listed below refers to an example of a potential threat vector in IM-based communication?

A) Phishing attack
B) Malware distribution
C) Spoofing attack
D) Eavesdropping
E) Account hijacking
F) Malicious link/attachment
✓ G) All of the above

12. Examples of threat vectors directly related to the use of removable devices include: (Select 2 answers)

A) Pretexting
✓ B) Malware delivery
C) Watering hole attacks
✓ D) Data exfiltration
E) Social engineering attacks

13. Which of the following answers refer to common threat vectors that apply to MSPs, vendors, and suppliers in the supply chain? (Select 2 answers)

A) Compliance violations
B) Brand reputation damage
✓ C) Propagation of malware

D) Operational disruptions

✓ **E) Social engineering techniques**

14. The term "URL hijacking" (a.k.a. "Typosquatting") refers to a deceptive practice involving the deliberate registration of domain names with misspellings or slight variations that closely resemble well-established and popular domain names. The primary goal of this strategy is to exploit the common typographical errors made by users while entering URLs into their web browser's address bar. Beyond capturing inadvertent traffic, typosquatting may also be used for hosting phishing sites to trick users into divulging sensitive information, distributing malware through deceptive websites, generating ad revenue by redirecting mistyped traffic, or engaging in brand impersonation to harm the reputation of authentic brands or deceive users.

A) True

B) False

15. A type of exploit in which an application overwrites the contents of a memory area it should not have access to is called:

A) DLL injection

✓ **B) Buffer overflow**

C) Memory leak

D) Privilege escalation

16. Which of the following answers does not refer to a common type of OS-based vulnerability?

A) Access control and permissions vulnerabilities (weak passwords, privilege escalation)

B) Vulnerabilities in installed applications, system utilities, and device drivers

C) Memory-related vulnerabilities (memory leaks, buffer overflows, race conditions)

D) Patch and update management vulnerabilities (security patch and update delays, malicious updates)

E) Vulnerabilities related to system/security misconfigurations

F) Network-related vulnerabilities (DoS attacks, remote code execution attacks)

✓ **G) All of the above answer choices are examples of OS-based vulnerabilities**

17. Which type of Trojan enables unauthorized remote access to a compromised system?

A) APT

✓ **B) RAT**

C) MaaS

D) PUP

18. As opposed to simple DoS attacks that usually are performed from a single system, a DDoS attack uses multiple compromised computer systems to perform the attack against its target. The intermediary systems that are used as a platform for the attack (often referred to as zombies, and collectively as a botnet) are the secondary victims of the DDoS attack.

A) True

B) False

Respuesta no detectada automaticamente

19. What defines a reflected DDoS attack?

A) Overwhelming the target with a high volume of traffic to saturate its bandwidth

B) Exploiting vulnerabilities in network protocols to consume resources and disrupt services

✓ **C) Utilizing third-party servers to reflect and amplify attack traffic towards the target**

D) Targeting vulnerabilities in applications or web servers to exhaust resources

20. A wireless jamming attack is a type of:

A) Cryptographic attack

✓ **B) DoS attack**

C) Brute-force attack

D) Downgrade attack

21. Which of the statements listed below can be used to describe the characteristics of an on-path attack? (Select all that apply)

A) An on-path attack is also known as MITM attack

✓ **B) Attackers place themselves on the communication route between two devices**

✓ **C) Attackers intercept or modify packets sent between two communicating devices**

D) Attackers do not have access to packets exchanged during the communication between two devices

22. Which of the following facilitate(s) privilege escalation attacks? (Select all that apply)

A) System/application vulnerabilities

B) Password hashing

✓ **C) System/application misconfigurations**

D) Network segmentation

✓ **E) Social engineering techniques**

23. Which of the following URLs is a potential indicator of a directory traversal attack?

A) http://www.example.com/var/../etc/passwd

B) http://www.example.com/var/www/../../etc/passwd

C) http://www.example.com/var/www/files/../../../etc/passwd

D) http://www.example.com/var/www/files/images/../../../../etc/passwd

✓ **E) Any of the above**

24. A short list of commonly used passwords tried against large number of user accounts is a characteristic feature of:

A) Replay attack

B) Dictionary attack

✓ **C) Spraying attack**

D) Birthday attack

25. An attack against encrypted data that relies heavily on computing power to check all possible keys and passwords until the correct one is found is called:

A) Replay attack

✓ **B) Brute-force attack**

C) Dictionary attack

D) Birthday attack

26. Which of the terms listed below most accurately describes a situation wherein a single account is being used from multiple locations/devices at the same time?

A) Spraying attack

✓ **B) Concurrent session usage**

C) Single Sign-On (SSO)

D) Impossible travel

27. Which of the terms listed below most accurately describes a situation wherein an account is accessed from a location that is physically impossible for the user to be in?

A) Login time restrictions

✓ **B) Impossible travel**

C) Concurrent session usage

D) Out-of-cycle logging

28. Which of the following would indicate an attempt to hide evidence of malicious activity?

A) Account lockout

B) Resource inaccessibility

✓ **C) Missing logs**

D) Concurrent session usage

29. Which of the following statements does not apply to dark web?

A) Typically requires specialized software to access its contents

✓ **B) Forms a large part of the deep web**

C) Not indexed by traditional search engines

D) Often associated with trading stolen data, malware, and cyber threats

30. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM

✓ **B) APT**

C) XSRF

D) DDoS

31. Which type of software is used to prevent, detect, and remove malware from computer systems and networks?

A) IDS

B) SaaS

✓ **C) AV**

D) WAF

32. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM

✓ **B) APT**

C) XSRF

D) DDoS

33. An attack surface is the sum of all the potential points (vulnerabilities) through which an attacker can interact with or compromise a system or network, indicating the overall exposure to potential threats. Examples of attack surfaces can be all software, hardware, and network interfaces with known security flaws. A threat vector represents the method or means through which a cyber threat is introduced or delivered to a target system. It outlines the pathway or avenue used by attackers to exploit vulnerabilities. Common threat vector types include phishing emails, malware, drive-by downloads, and social engineering techniques.

A) True

B) False

Respuesta no detectada automaticamente

34. Which of the answers listed below refers to an email-based threat vector?

A) Spoofing

B) Phishing

C) BEC attacks

D) Malicious links

E) Malware attachments

✓ **F) All of the above**

35. Which of the answers listed below refers to an example of a potential threat vector in IM-based communication?

A) Phishing attack

B) Malware distribution

C) Spoofing attack

D) Eavesdropping

E) Account hijacking

F) Malicious link/attachment

✓ **G) All of the above**

36. Which of the following answers refer to examples of image-based threat vectors? (Select 3 answers)

A) Steganography

B) BEC attacks

C) Image spoofing (deepfakes)

D) Brand impersonation

E) Malware-embedded images

37. The term "Typosquatting" refers to a deceptive practice involving the deliberate registration of domain names with misspellings or slight variations that closely resemble well-established and popular domain names. The primary goal of this strategy is to exploit the common typographical errors made by users while entering URLs into their web browser's address bar. Beyond capturing inadvertent traffic, typosquatting may also be used for hosting phishing sites to trick users into divulging sensitive information, distributing malware through deceptive websites, generating ad revenue by redirecting mistyped traffic, or engaging in brand impersonation to harm the reputation of authentic brands or deceive users.

A) True

B) False

Respuesta no detectada automaticamente

---

38. A malicious application update is a type of malware that can be installed through a seemingly legitimate software update. The introduction of a malicious update into the application code can be enabled through various means, including:

A) Unsigned application code

B) Unencrypted update channel (HTTP vs HTTPS)

C) Fake update website

D) Unauthorized access to update server

E) Compromised software development process

✓ F) All of the above

---

39. Which of the following answers refers to a virtualization-related vulnerability where virtualized assets allocated to one VM are improperly isolated and can be accessed or compromised by another VM?

A) Resource reuse

B) Privilege escalation

C) Resource exhaustion

D) Concurrent session usage

Respuesta no detectada automaticamente

---

40. Which type of Trojan enables unauthorized remote access to a compromised system?

A) APT

✓ B) RAT

C) MaaS

D) PUP

---

41. As opposed to simple DoS attacks that usually are performed from a single system, a DDoS attack uses multiple compromised computer systems to perform the attack against its target. The intermediary systems that are used as a platform for the attack (often referred to as zombies, and collectively as a botnet) are the secondary victims of the DDoS attack.

A) True

B) False

Respuesta no detectada automaticamente

---

42. What defines a reflected DDoS attack?

A) Overwhelming the target with a high volume of traffic to saturate its bandwidth

B) Exploiting vulnerabilities in network protocols to consume resources and disrupt services

✓ C) Utilizing third-party servers to reflect and amplify attack traffic towards the target

D) Targeting vulnerabilities in applications or web servers to exhaust resources

---

43. A wireless disassociation attack is a type of: (Select 2 answers)

A) Downgrade attack

✓ B) Deauthentication attack

C) Brute-force attack

✓ D) DoS attack

E) Cryptographic attack

---

44. What type of action allows an attacker to exploit the XSS vulnerability?

A) Code injection
B) Privilege escalation
C) Session hijacking
D) Packet sniffing

45. Which of the following URLs is a potential indicator of a directory traversal attack?

A) http://www.example.com/var/../etc/passwd
B) http://www.example.com/var/www/../../etc/passwd
C) http://www.example.com/var/www/files/../../../etc/passwd
D) http://www.example.com/var/www/files/images/../../../../etc/passwd
✓ E) Any of the above

46. Which of the terms listed below most accurately describes a situation wherein a single account is being used from multiple locations/devices at the same time?

A) Spraying attack
✓ B) Concurrent session usage
C) Single Sign-On (SSO)
D) Impossible travel

47. Which of the terms listed below most accurately describes a situation wherein an account is accessed from a location that is physically impossible for the user to be in?

A) Login time restrictions
✓ B) Impossible travel
C) Concurrent session usage
D) Out-of-cycle logging

48. Which of the following would indicate an attempt to hide evidence of malicious activity?

A) Account lockout
B) Resource inaccessibility
✓ C) Missing logs
D) Concurrent session usage

49. Which of the following statements does not apply to dark web?

A) Typically requires specialized software to access its contents
✓ B) Forms a large part of the deep web
C) Not indexed by traditional search engines
D) Often associated with trading stolen data, malware, and cyber threats

50. A short list of commonly used passwords tried against large number of user accounts is a characteristic feature of:

A) Replay attack
B) Dictionary attack
✓ C) Spraying attack
D) Birthday attack

51. An attack against encrypted data that relies heavily on computing power to check all possible keys and passwords until the correct one is found is called:

A) Replay attack
✓ B) Brute-force attack
C) Dictionary attack
D) Birthday attack

2.5 - Explain the purpose of mitigation techniques.

Conceptos clave:

- Segmentation, Access control (ACL, Permissions)
- Application allow list, Isolation, Patching, Encryption, Monitoring

- Least privilege, Configuration enforcement, Decommissioning
- Hardening: Endpoint protection, Host-based firewall, HIPS, Disabling ports, Default password changes

Teoria (Professor Messer):

enterprise."

Segmentation and Access Control

- Segmenting the network
  - Physical, logical, of virtual (devices, VLANs, virtual networks)
  - To get...
    - Performance (high-bandwidth apps)
    - Security (isolation)
    - Compliance
- Access control lists (ACLs)
  - Allow or disallow traffic
  - Restrict access to network devices
  - List the permissions
    - User X can access resource Y through port Z
  - Many OSs use ACLs for file access
- Application allow/deny list
  - Any app can be dangerous, security policy can control app execution
  - Allow list - nothing runs unless approved (more restrictive)
  - Deny list - everything runs unless disapproved
  - Examples
    - Decisions are built in to OSs
    - Application hash (allow only with unique identifier)
    - Certificate (allow digitally signed apps from certain publishers)
    - Path (only run apps in these folders)
    - Network zone (only run from this zone)

Mitigation Techniques

- Patching
  - Incredibly, incredibly important
  - Monthly incremental updates
  - Third-party updates
  - Auto-update (not always the best, patch testing may be necessary)
  - Emergency (out-of-band) updates might be necessary
- Encryption
  - Prevent access to app data files
  - File level encryption (Windows EFS)
  - Full disk encryption (FDE) - encrypt everything (BitLocker, etc.)
  - Application Data encryption - managed by app
- Monitoring
  - Aggregate information from devices, integrated
  - Sensors - IPS, firewalls, auth logs, etc.
  - Collectors - IPS, firewalls, SIEM tools, etc.
- Principle of Least Privilege
  - Rights and permissions set to bare minimum for functionality
  - All user accounts must be limited
  - Don't allow users to run with admin privileges
- Configuration enforcement
  - Perform a posture assessment each time a device connects (latest OS, patch, etc.)
  - Systems out of compliance are quarantined
- Decommissioning
  - Should be a formal policy, don't throw data into trashed
  - Mostly associated with storage devices (HDD, SSD, USB stick, etc.)

    - Recycle or destroy (FUBAR)

Hardening Techniques

- System hardening
  - Lost of systems, lots of variety
  - Updates (system, service packs)
  - User accounts (passwords, limitations)
  - Network access and security
  - Monitor and secure (anti-x)
- Encryption (prev.)
  - Encrypt all network communication (VPN)
- The endpoint - individual devices
  - The user's access (apps and data)
  - Stop the attackers (inbound/outbound)
  - Many different platforms
  - Protection is multi-faceted, practice defense in depth
- Endpoint detection and response (EDR)
  - Detect by signatures, behavioral analysis
  - Lightweight agent
  - Can investigate and determine root cause of threat
  - Respond to threat (isolate, rollback, etc.)
  - Driven by API - no intervention required
- Host-based firewall
  - Software-based (personal, runs on every endpoint)
  - Allow/disallow incoming or outgoing app traffic
  - Identify and block unknown processes
  - Manage centrally
- Finding intrusions
  - Host-based IPS (HIPS)
    - Recognize and block known attacks
    - Secure OS and app configs
    - Built into endpoint protection software
  - HIPS identification
    - Sigs, heuristics, behavioral
    - Buffer overflows, reg updates, writing files to sensitive folders
    - Access to non-encrypted data
- Open ports and services
  - Every open port is a possible entry point (least privilege, close most)
  - Control access with firewall (NGFW ideal)
  - Unused or unknown services - be wary
  - Applications with broad port ranges (more than 3 or 4) are suspicious
  - Use Nmap or similar port scanner
- Default password changes
  - All network devices and most apps have a management interface
  - Important to change defaults, these are widely available
  - Add MFA or third-party auth
- Removal of unnecessary software
  - All software contains bugs, some vulnerabilities
  - Every application has a different patching process
  - Remove all unused software to reduce risk

Tips y trucos para el examen:

TECNICAS DE MITIGACION - Como reducir el riesgo:

- Segmentation: dividir la red en segmentos para limitar el movimiento lateral del atacante. VLANs, subredes
- ACL (Access Control List): reglas que definen que trafico se permite o deniega
- Least privilege: dar a cada usuario/sistema solo los permisos minimos necesarios

- Patching: aplicar actualizaciones de seguridad regularmente. Critico para vulnerabilidades conocidas
- Encryption: cifrar datos en reposo y en transito
- Monitoring: vigilar sistemas y logs continuamente
- Decommissioning: dar de baja sistemas obsoletos de forma segura

HARDENING - Endurecer sistemas:

- Cambiar credenciales por defecto: lo primero siempre
- Deshabilitar servicios y puertos innecesarios
- Endpoint protection: antivirus/EDR en todos los endpoints
- Host-based firewall: firewall a nivel de sistema operativo (Windows Defender Firewall)
- HIPS (Host-based Intrusion Prevention System): detecta y bloquea actividad maliciosa en el host
- Application allow list: solo se ejecutan las aplicaciones aprobadas (mas seguro que la blacklist)
- Configuration enforcement: usar herramientas como Group Policy, Ansible, Puppet para mantener la configuracion correcta

Preguntas de practica (30):

1. Which of the following provides isolation from external computer networks?

A) Network segmentation

✓ B) Air gap

C) Hardware firewall

D) Protected cable distribution

---

2. Which of the terms listed below is used to describe a foundational level of security configurations and settings required to safeguard a system?

A) Logical segmentation

✓ B) Secure baseline

C) Access control levels

D) Principle of least privilege

---

3. Which of the terms listed below refers to tracking and managing software application components, such as third-party libraries and other dependencies?

A) Version control

B) Package monitoring

C) Configuration enforcement

D) Application hardening

---

4. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ F) All of the above answers are examples of vulnerability response and remediation techniques

---

5. Which of the terms listed below refers to tracking and managing software application components, such as third-party libraries and other dependencies?

A) Version control

B) Package monitoring

C) Configuration enforcement

D) Application hardening

---

6. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ F) All of the above answers are examples of vulnerability response and remediation techniques

7. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems

B) Video surveillance

✓ C) MFA

✓ D) Application sandboxing

✓ E) Network segmentation

8. Which of the answers listed below refers to a Zero Trust Control Plane security approach that takes into account user identity, device security, network conditions, and other contextual information to enable dynamic access decisions?

A) Implicit trust

B) Monitoring and logging

✓ C) Adaptive identity

D) Microsegmentation

9. Which of the following facilitate(s) privilege escalation attacks? (Select all that apply)

A) System/application vulnerabilities

B) Password hashing

✓ C) System/application misconfigurations

D) Network segmentation

✓ E) Social engineering techniques

10. Which of the answers listed below refers to a solution that allows for easier management and control of network segmentation policies through software applications?

A) VDI

✓ B) SDN

C) VPC

D) EDR

11. A rule-based access control mechanism implemented on routers, switches, and firewalls is referred to as:

A) MAC

B) AUP

C) DAC

✓ D) ACL

12. Which of the following policies applies to any requests that fall outside the criteria defined in an ACL?

A) Fair access policy

✓ B) Implicit deny policy

C) Transitive trust

D) Context-aware authentication

13. Which of the following answers does not refer to the concept of system/application isolation?

A) Virtualization

B) Containerization

C) Sandboxing

✓ D) Data encryption

14. Which of the answers listed below refer to the concept of data isolation? (Select 2 answers)

A) DLP

B) SDN

✓ C) EFS

D) SWG

E) EDR

15. Which of the following provides active network security breach response on an individual computer system?

A) NIDS
B) HIDS
C) NIPS
✓ D) HIPS

16. Which of the answers listed below refers to a means for logical network segmentation?

A) Switch
B) VLAN
C) Screened subnet
D) Router

17. Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answers)

A) Enhances security by limiting the spread of cyberattacks
✓ B) Helps organizations comply with data regulatory requirements by isolating and protecting specific data types
C) Provides security for data in transit with the use of encryption
D) Guarantees data recovery in case of accidental deletion or system failures
✓ E) Provides better control over user access to sensitive data

18. Which of the answers listed below refer to workstation hardening techniques? (Select 3 answers)

A) Hiding administrator accounts
✓ B) Regularly applying security patches and updates to the OS and installed software
C) Disabling all internet access
✓ D) Removing or disabling unnecessary drivers, services, software, and network protocols
✓ E) Limiting unauthorized or unauthenticated user access

19. Which of the following answers refers to a security feature used in Bluetooth device pairing?

A) SAE
✓ B) PIN
C) MFA
D) ACL

20. The practice of finding vulnerabilities in an application by feeding it incorrect input is called:

A) Normalization
B) Hardening
C) Dynamic code analysis
✓ D) Fuzzing

21. Which of the following access control methods would be the most suitable for scheduling system maintenance tasks during periods of low user activity?

A) Resource provisioning
✓ B) Time-of-day restrictions
C) Principle of least privilege
D) Just-in-time permissions

22. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA
✓ B) CAPTCHA
C) ACL
D) NIPS

23. Which of the following answers illustrates the difference between passive and active network security breach response?

A) HIPS vs. NIPS
B) UTM vs. Firewall
C) NIPS vs. UTM
✓ D) IDS vs. IPS

24. Which of the following solutions provides active network security breach response on an individual computer system?

A) NIDS
B) HIDS
C) NIPS
✓ D) HIPS

25. Which of the answers listed below refers to a rule-based access control mechanism associated with files and/or directories?

A) EFS
✓ B) FACL
C) FIM
D) NTFS

26. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems
B) Video surveillance
✓ C) MFA
✓ D) Application sandboxing
✓ E) Network segmentation

27. Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answers)

A) Enhances security by limiting the spread of cyberattacks
✓ B) Helps organizations comply with data regulatory requirements by isolating and protecting specific data types
C) Provides security for data in transit with the use of encryption
D) Guarantees data recovery in case of accidental deletion or system failures
✓ E) Provides better control over user access to sensitive data

28. Which of the following answers refers to a security feature used in Bluetooth device pairing?

A) SAE
✓ B) PIN
C) MFA
D) ACL

29. The practice of finding vulnerabilities in an application by feeding it incorrect input is called:

A) Normalization
B) Hardening
C) Dynamic code analysis
✓ D) Fuzzing

30. The principle of least privilege is a security rule that prevents users from accessing information and resources that lie beyond the scope of their responsibilities.

A) True
B) False
Respuesta no detectada automaticamente

3.0 Security Architecture (18% del examen)

3.1 - Compare and contrast security implications of different architecture models.

Conceptos clave:

- Cloud: Responsibility matrix, Hybrid, IaC, Serverless, Microservices
- Physical isolation: Air-gapped, Logical segmentation, SDN
- IoT, ICS/SCADA, RTOS, Embedded systems, High availability
- Considerations: Availability, Resilience, Cost, Scalability, Patch availability

Teoria (Professor Messer):

architecture models."

Cloud Infrastructures

- Cloud responsibility matrix
  - IaaS, PaaS, SaaS... who is responsible for security? Should be well documented
  -
- Hybrid considerations
  - Hybrid cloud - more than one public or private cloud
  - Network protection mismatches - auth, firewall, server settings
  - Different security monitoring
  - Data leakage
- Third-party vendors in the cloud
  - You, the cloud provider, and third parties
  - Ongoing vendor risk assessments to maintain posture of third-parties
  - Constant monitoring
- Infrastructure as code
  - Describe an infrastructure (servers, network, and apps) as code
  - Modify infrastructure and create versions
  - Use the code as a template to build more instances
  - Very important concept for cloud computing
- Serverless architecture
  - Function as a Service (FaaS)
    - Apps separated into functions
    - Remove OS from the equation
  - Dev still creates the server-side logic
  - May be event-triggered
  - Managed by third-party
- Microservices and APIs
  - Old: monolithic applications running locally, hard to manage
  - New: Application Programming Interfaces, "glue" for the microservices, scalable
  -

Network Infrastructure Concepts

- Physical isolation - devices are physically separate (air gap)
  - Must be connected to provide communication
  - Different servers on different racks (separate types, customers, etc.)
  - Physical segmentation
- Local segmentation with VLANs
  - Virtual Local Area Networks, same effect
  - Separate logically instead of physically, cannot communicate between without a Layer 3 device (router)
- SDN (Software Defined Networking)
  - Networking devices have different functional planes of operation
    - Data, control, and management
  - Split these into separate logical units (devices)
  - Infrastructure/Data plane - network frames and packets

    - Control plane - manages actions of data plane (routing, etc.)
    - Application/Management Plane - configure and manage devices
    -
    - Has major new cloud applications, completely logical networking

Other Infrastructure Concepts

- Cloud vs. on-premise
    - Cloud-based - centralized and cheaper
    - On-premises - security burden on client, but complete control
    - All in all, attackers want your data, they don't care where it is!
- On-premises security
    - Pros
        - Customize security posture
        - On-site IT team can easily manage
        - Local team maintains uptime and ability
    - Cons
        - Security updates may take time
- Centralized vs. decentralized
    - Most are physically decentralized
        - Difficult to manage
    - Centralized approach can consolidate status, logs, maintenance
        - Not perfect, single point of failure
- Virtualization
    - Run many different operating systems on the same hardware
    - Each app instance has its own operating system, adds overhead
    - Relatively expensive
- App containerization
    - Container - contains everything (code, dependencies), standardized unit of software
    - Isolated process in a sandbox, efficient
    - Lightweight, uses host kernel
    - Secure separation between apps
    - Popular software is Docker
    -
- IoT (Internet of Things)
    - Sensors, monitors, cameras, smart hubs, watches, phones, thermostats
    - Provide automation and flexibility but lots of security flaws
- SCADA / ICS
    - Supervisory Control and Data Acquisition System
        - Large-scale, multi-site Industrial Control Systems (ICS)
    - PC manages equipment
    - Distributed control systems - real-time info, sys control
    - Requires extensive segmentation
- RTOS (Real-Time Operating System)
    - OS with deterministic processing schedule - industrial, military, automotive
        - No time to wait for other processes
    - Extremely sensitive to security issues
- Embedded systems
    - Hardware and software specifically designed for a function / larger system
    - Traffic light controllers, digital watches, medical imaging systems
- High availability
    - Redundancy - handy, not always available
    - HA (high availability) - always on, always available
    - May include different components working concurrently
    - Almost always higher cost

Infrastructure Considerations

- Availability
  - Uptime - access data, complete transactions; foundation of IT security
- Resilience
  - How to maintain availability and recover
  - MTTR (Mean Time to Repair)
- Cost
  - How much money is required
  - Ongoing maintenance and taxes, recurring cost
- Responsiveness
  - Request info, how quickly is request satisfied
  - Important for interactive applications
- Scalability
  - How can we increase/decrease capacity
  - Elasticity of application/infrastructure
- Ease of deployment
  - Many moving parts, how easy can it be employed
- Risk transference
  - Transfer risk to a third-party
  - Cybersecurity insurance, attacks/downtime covered
  - Recover internal losses, protect against legal issues
- Ease of recovery
  - Something will always go wrong eventually
  - Malware infection - reload OS (hard, time consuming), reload from backup (better, faster)
- Patch availability
  - Software (mostly) isn't static
  - Must be up to date and update regularly
  - Inability to patch - embedded systems, etc.; not designed for end-user updates
    - Might require additional security controls
- Power
  - Foundational, can require extensive thought and engineering
  - Overall requirements (data center vs. office vs. home)
  - Primary power and backup power (UPS, generator)
- Compute
  - Application's heavy lifting, the compute engine
  - Can be single or multiple processors

Tips y trucos para el examen:

TECNOLOGIAS CLOUD:

- Serverless: codigo que se ejecuta sin gestionar servidores (AWS Lambda). Escalado automatico
- Microservices: aplicacion dividida en servicios pequenos e independientes
- Containerization: empaquetar apps con sus dependencias (Docker). Mas ligero que VMs
- Infrastructure as Code (IaC): gestionar infraestructura mediante codigo (Terraform, CloudFormation)
- SDN (Software Defined Networking): red gestionada por software, separando el plano de control del de datos

SISTEMAS ESPECIALIZADOS:

- IoT (Internet of Things): dispositivos conectados con recursos limitados, frecuentemente sin seguridad adecuada
- ICS/SCADA: sistemas de control industrial (fabricas, plantas electricas). Prioridad: disponibilidad sobre seguridad
- RTOS (Real-Time Operating System): SO para sistemas que necesitan respuesta en tiempo real (sistemas de control)
- Embedded systems: hardware con software fijo integrado (routers, camaras IP, PLCs)
- Air-gapped: sistema fisicamente aislado de cualquier red. Maximo nivel de aislamiento

Preguntas de practica (44):

1. A cloud computing service model offering remote access to applications based on monthly or annual subscription fee is called:

A) PaaS

✓ **B) SaaS**

C) IaaS

D) DaaS

2. Which of the answers listed below refers to the process of packaging an application and its dependencies into a single, self-contained unit, which can run across different computing environments?

A) Edge computing

B) Containerization

C) Virtualization

D) Cloud computing

3. Which of the following answers does not refer to the concept of system/application isolation?

A) Virtualization

B) Containerization

C) Sandboxing

✓ **D) Data encryption**

4. The term "Hybrid cloud" refers to a mixed computing environment that can include different cloud service models like public and private clouds, as well as on-premises infrastructure.

A) True

B) False

5. Which of the following answers refers to software technology designed to simplify network infrastructure management?

A) SDN

B) SaaS

C) VDI

D) SNMP

6. Which of the answers listed below refers to a broad term that encompasses various control and automation systems used in industrial settings to control and monitor physical processes and machinery?

A) ICS

B) PLC

C) SCADA

D) HMI

7. The MIME specification extends the email message format beyond plain text, enabling the transfer of graphics, audio, and video files over the Internet mail system. S/MIME is an enhanced version of the MIME protocol that enables email security features by providing encryption, authentication, message integrity, and other related services.

A) True

B) False

8. Given the computational limitations of IoT devices, smartcards, and mobile devices, which of the following digital signature algorithms would be the most efficient choice due to its smaller key size and lower processing requirements?

A) RSA

B) ECDHE

C) DSA

✓ **D) ECDSA**

E) ECC

9. Blockchain technology is an example of:

A) Online payment gateway

B) Centralized database

✓ **C) Open public ledger**

D) Cloud storage system

10. Which of the answers listed below describe the characteristics of a cross-site scripting attack? (Select 3 answers)

A) Exploits the trust a user's web browser has in a website

✓ B) A malicious script is injected into a trusted website

✓ C) User's browser executes attacker's script

D) Exploits the trust a website has in the user's web browser

E) A user is tricked by an attacker into submitting unauthorized web requests

F) Website executes attacker's requests

---

11. Which of the statements listed below can be used to describe the characteristics of an on-path attack? (Select all that apply)

A) An on-path attack is also known as MITM attack

✓ B) Attackers place themselves on the communication route between two devices

✓ C) Attackers intercept or modify packets sent between two communicating devices

D) Attackers do not have access to packets exchanged during the communication between two devices

---

12. Which of the answers listed below refers to a solution that allows for easier management and control of network segmentation policies through software applications?

A) VDI

✓ B) SDN

C) VPC

D) EDR

---

13. Which of the answers listed below refer to the concept of data isolation? (Select 2 answers)

A) DLP

B) SDN

✓ C) EFS

D) SWG

E) EDR

---

14. A serverless architecture allows developers to create apps and services without having to manage the required infrastructure resources (such as servers, databases, and storage systems), which are handled by:

A) CSP

B) ISP

C) MSP

D) IdP

Respuesta no detectada automaticamente

---

15. Which of the following provides isolation from external computer networks?

A) Network segmentation

✓ B) Air gap

C) Hardware firewall

D) Protected cable distribution

---

16. Which of the following answers refers to a cybersecurity framework that combines network and security functions into a single cloud-based service?

A) SASE

B) SWG

C) CASB

D) SD-WAN

Respuesta no detectada automaticamente

---

17. Which of the following terms refers to a backup strategy that relies on creating and maintaining copies of data in real-time or near real-time on a separate system?

A) Mirroring

B) Virtualization

✓ C) Journaling

✓ **D) Replication**

18. Which of the answers listed below refer to the characteristic features of static code analysis? (Select 3 answers)

A) Involves examining the code without executing it

✓ **B) Often used early in the development process**

✓ **C) Examines code structure, syntax, and semantics to detect issues like syntax errors, coding standards violations, security vulnerabilities, and bugs**

D) Typically used later in the software development lifecycle

E) Involves executing the code and analyzing its behavior at runtime

F) Analyzes runtime properties like memory usage, performance, and error handling to identify issues such as memory leaks, performance bottlenecks, and runtime errors

19. Which of the following statements describe the features of dynamic code analysis? (Select 3 answers)

A) Typically used later in the software development lifecycle

B) Involves examining the code without executing it

✓ **C) Analyzes runtime properties like memory usage, performance, and error handling to identify issues such as memory leaks, performance bottlenecks, and runtime errors**

D) Often used early in the development process

E) Examines code structure, syntax, and semantics to detect issues like syntax errors, coding standards violations, security vulnerabilities, and bugs

✓ **F) Involves executing the code and analyzing its behavior at runtime**

20. Which of the following terms refers to predefined patterns or characteristics of known threats or attack methods?

A) Security logs

B) Baselines

C) Trends

✓ **D) Signatures**

21. In the context of IT security, the term "Biometrics" refers to both biological characteristics of the human body and behavioral traits that can be used for identification and access control purposes.

A) True

B) False

Respuesta no detectada automaticamente

22. The process of identifying, collecting, and producing electronically stored information with the intent of using it in a legal proceeding or investigation is referred to as:

A) Litigation hold

B) Evidence management

C) Digital forensics

✓ **D) E-discovery**

23. The term "Metadata" refers to data that provides information about other data, but not the actual content of the data. Typically, metadata is not visible to the user by default but can be accessed if needed. For example, email metadata, found in email headers, includes detailed information about the sender, recipient, and the route the message took. Mobile device metadata encompasses details such as the device model, geolocation, camera information, internet usage, phone call and text messaging activity, application usage statistics, and metadata from various files on the device. In web browsing, metadata comes from HTML meta tags located in the head section of a web page. For files, metadata includes details about the author (e.g., the file creator), file type, size, creation date and time, and the last modification date and time.

A) True

B) False

24. Which of the terms listed below refers to the process of creating and maintaining computer applications?

A) RAD

✓ **B) SDLC**

C) OOP

D) SaaS

25. Which of the terms listed below refers to the process of creating and maintaining computer applications?

A) RAD

✓ B) SDLC

C) OOP

D) SaaS

26. What is the common term for a group of protocols used to carry voice data over a packet-switched network?

A) ISDN

B) PBX

✓ C) VoIP

D) PSTN

27. Which of the answers listed below refers to a software technology designed to simplify network infrastructure management?

A) SDN

B) QoS

C) VDI

D) CDN

28. Which type of software is used to prevent, detect, and remove malware from computer systems and networks?

A) IDS

B) SaaS

✓ C) AV

D) WAF

29. The MIME specification extends the email message format beyond simple text, enabling the transfer of graphics, audio, and video files over the Internet mail system. S/MIME is an enhanced version of the MIME protocol that enables email security features by providing encryption, authentication, message integrity, and other related services.

A) True

B) False

30. Which of the answers listed below refers to a virtualization platform for delivering virtual desktops to a community of users?

A) VDE

B) VNC

C) VDI

D) RDP

31. A software development approach that aims for speedy application creation and continuous improvement through iterative development and user collaboration is referred to as:

A) FDD

B) DevOps

✓ C) RAD

D) SaaS

32. Which of the following answers refers to a software tool that provides a single management interface for mobile devices, PCs, printers, IoT devices and wearables?

A) MDM

B) RCS

✓ C) UEM

D) MAM

33. Which of the answers listed below describe(s) the characteristics of ECDSA? (Select all that apply)

A) Provides authentication, integrity, and non-repudiation

✓ B) Based on elliptic curve cryptography

C) Designed for data encryption

✓ D) Specifically designed for creating and verifying digital signatures

✓ E) More computationally efficient than other signature algorithms

F) Enables the key exchange process

34. Which of the following answers refers to a cybersecurity framework that combines network and security functions into a single cloud-based service?

A) SASE

B) SIEM

C) SWG

D) SOAR

35. Which of the answers listed below describe the characteristics of a non-persistent VDI? (Select 2 answers)

A) At the end of a session, user desktop reverts to its original state

B) Each user runs their own copy of virtual desktop

C) At the end of a session, user data and personal settings are saved

✓ D) Virtual desktop is shared among multiple users

36. Which of the following answers refers to a software tool designed to simplify the process of creating and maintaining online content?

A) VDI

B) SaaS

C) CMS

D) SDK

37. A company or organization that offers cloud computing services over the Internet is called:

A) ISP

B) MSSP

✓ C) CSP

D) MSP

38. Given the computational limitations of IoT devices, smartcards, and mobile devices, which of the following digital signature algorithms would be the most efficient choice due to its smaller key size and lower processing requirements?

A) RSA

B) ECDHE

C) DSA

✓ D) ECDSA

E) ECC

39. Which of the answers listed below describe the characteristics of a cross-site scripting attack? (Select 3 answers)

A) Exploits the trust a user's web browser has in a website

✓ B) A malicious script is injected into a trusted website

✓ C) User's browser executes attacker's script

D) Exploits the trust a website has in the user's web browser

E) A user is tricked by an attacker into submitting unauthorized web requests

F) Website executes attacker's requests

40. Which of the following answers refers to a virtualization-related vulnerability where virtualized assets allocated to one VM are improperly isolated and can be accessed or compromised by another VM?

A) Resource reuse

B) Privilege escalation

C) Resource exhaustion

D) Concurrent session usage

Respuesta no detectada automaticamente

41. Which of the answers listed below refers to any type of information pertaining to an individual that can be used to uniquely identify that person?

A) PHI

B) Biometrics

C) ID

✓ D) PII

42. Which of the following terms refers to a backup strategy that relies on creating and maintaining copies of data in real-time or near real-time on a separate system?

A) Mirroring

B) Virtualization

✓ C) Journaling

✓ D) Replication

43. Which of the following statements describe the features of dynamic code analysis? (Select 3 answers)

A) Typically used later in the software development lifecycle

B) Involves examining the code without executing it

✓ C) Analyzes runtime properties like memory usage, performance, and error handling to identify issues such as memory leaks, performance bottlenecks, and runtime errors

D) Often used early in the development process

E) Examines code structure, syntax, and semantics to detect issues like syntax errors, coding standards violations, security vulnerabilities, and bugs

✓ F) Involves executing the code and analyzing its behavior at runtime

44. During the post-incident activity stage, this step involves analyzing logs, forensics data, and other evidence to prevent incident reoccurrence.

A) Reporting

B) E-discovery

✓ C) Root cause analysis

D) Threat hunting

3.2 - Apply security principles to secure enterprise infrastructure.

Conceptos clave:

- Device placement, Security zones, Attack surface, Fail-open/Fail-closed
- Network appliances: Jump server, Proxy, IPS/IDS, Load balancer
- Port security: 802.1X, EAP
- Firewall types: WAF, UTM, NGFW, Layer 4/7
- Secure communication: VPN, TLS, IPSec, SD-WAN, SASE

Teoria (Professor Messer):

infrastructure."

Secure Infrastructure

- Device placement
  - Firewalls - separate trusted from untrusted
  - Other devices may require their own measures (honeypots, load balancers, etc.)
- Security zones
  - Separate by use and access
  - Each area associated with a zone - trusted/untrusted, internal/external
  - Simplifies security policies, traffic from some zones to others allowed, some not\\
  -
- Attack surface
  - Any opening that may be on the network
    - Code, ports, auth process, human error

    - Want to minimize - audit, block ports, monitor traffic
  - Connectivity
    - Every connected device contributes to security
    - Secure physical and logical connections
    - Only as strong as the weakest link
    - Application/network-level encryption

Intrusion Prevention

- IPS - watch network traffic, detect common/uncommon intrusions, enable preventative measures
  - IDS similar, but only alarms - does not stop traffic
- Failure modes
  - 100% uptime is a nice though, but not realistic - we need to think about what will happen during the downtime
  - Fail-open - when a system fails, data continues to flow
  - Fail-close - data stops flowing
- Device connections
  - Active monitoring - I(D/P)S connected inline, data blocked in real-time, IPS active
    - Could be too aggressive, in link so it can cause downtime
  - Passive monitoring - through switch (taps traffic), data not blocked, common

Network Appliances

- Jump server - access secure network zones
  - Highly secured device, SSH/Tunnel/VPN for access, significant security concern
- Proxies - sit between users and external network
  - Receives requests and sends on proxy's behalf
  - Caching, access control, URL filtering
  - Explicit proxy - apps know how to use and is apparent
  - Transparent proxy - users may not know it's even happening
  - Application proxies
    - NAT - network level
    - Application proxy - ... application level, understands app
      - May only know one app, like HTTP proxy
      - Many are multipurpose, handle several protocols/apps
  - Forward proxy - "internal proxy", used to protect and control user access to the internet
  - Reverse proxy - inbound traffic from internet to your internal service (server)
  - Open proxy - third-party, uncontrolled proxy
    - Can be a significant concern, can circumvent existing controls
    - Most times are blocked
- Load balancers - distribute load to multiple services for seamless end-user experience
  - Active/active - all servers active, all being used actively
    - Configurable load across servers
    - TCP offload, SSL offload, caching, prioritization, content switching
  - Active/passive - all on, some inactive
    - If active server fails, passive takes its place (stand-by)
- Sensors and collectors
  - Aggregate information from network devices - built-in sensors, etc.
  - Sensors - IPS, firewall logs, auth logs
  - Collectors - proprietary consoles, SIEM consoles

Port Security

- Individual services and resources
- Extensible Authentication Protocol (EAP) - an authentication framework
  - Manufacturers build their own methods
  - EAP integrates with 802.1X, no access until auth succeeds
- IEEE 802.1X - port-based Network Access Control (NAC), ^^^
  - Used in conjunction with auth database (LDAP, Kerberos, etc.)
  - Supplicant - client, authenticator - access provider, auth server - validator

    - Authenticator sits in the middle and forwards messages

Firewall Types

- The universal security control, control flow of network traffic, inbound/outbound
- Network-based firewalls - filter traffic by port number or application
    - Most are layer 3 devices (routers)
    - NAT functionality, encrypt traffic (VPN), dynamic routing communication
    -
- UTM (Unified Threat Management) /
    - All-in-one security appliance, web security gateway
    - URL filter, content inspection, malware inspection, spam filter, router, switch, firewall, IDS/IPS, bandwidth shaper, VPN endpoint
    - Only operate at layer 4, drawback on performance and single point of failure
- Next-generation firewall (NGFW)
    - OSI application layer (layer 7), all data in every packet
    - Requires some advanced decodes
    - Doesn't just rely on port number
    - Can have an IPS, content filtering, etc.
- Web application firewall (WAF)
    - Not like a normal firewall, rules for HTTP/S conversations
    - Allow or deny based on expected input, identify SQL injections
    - Major focus of [PCI DSS](https://en.wikipedia.org/wiki/Payment_Card_Industry_Data_Security_Standard)

Secure Communication

- VPNs (Virtual Private Networks) - encrypted data traversing public network
    - Concentrator - en/decryption access device, integrated into firewall
    - Many options (cryptography, etc.), used with client software
    -
- Encrypted tunnel
    - Add new headers and tailers, "tunneling", decrypt on the other side
    -
- SSL/TLS VPN (Secure Sockets Layer VPN)
    - Uses 443, almost no firewall issues
    - No big VPN clients
    - Authenticate users, can be run from a browser
    - On-demand access from a remote device
- Site-to-site IPsec VPN
    - Always (or almost always) on
    - Firewalls act as VPN concentrators
    -
- SD-WAN (Software Defined WAN)
    - WAN built for the cloud
    - Cloud-based apps communicate directly from the cloud, no centralization needed
- Secure Access Service Edge (SASE)
    - Update secure access for cloud services, securely connect from different locations
    - Next generation VPN, security technologies in the cloud
    -
- Selection of effective controls
    - VPN - SSL/TLS for user access, IPsec for site-to-site
    - SD-WAN - manage network connectivity to cloud, not great for security
    - SASE - complete network and security solution, fixes ^^^

Tips y trucos para el examen:

ZONAS DE RED:

- DMZ (Demilitarized Zone) / Screened subnet: zona entre internet e intranet donde van los servidores publicos (web, email)
- Fail-open: si el dispositivo falla, deja pasar todo el trafico (prioriza disponibilidad)

• Fail-closed: si el dispositivo falla, bloquea todo el trafico (prioriza seguridad)

PROTOCOLOS DE COMUNICACION SEGURA:

• TLS (Transport Layer Security): sucesor de SSL, cifra el trafico web (HTTPS = HTTP + TLS)
• IPSec: cifrado a nivel de red (capa 3). Dos modos: Transport (solo payload) y Tunnel (todo el paquete)
• VPN: tunel cifrado sobre internet. Tipos: Site-to-site (entre oficinas) y Remote access (usuario a red)
• SD-WAN: WAN definida por software, optimiza el trafico entre sedes
• SASE (Secure Access Service Edge): combina red y seguridad en la nube
• 802.1X: estandar de autenticacion para acceso a red (NAC). Requiere autenticarse antes de conectarse

Preguntas de practica (67):

1. Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication, and data integrity for network traffic?

A) TLS
B) SSH
✓ C) IPsec
D) VPN

---

2. Which of the answers listed below refers to network security technology designed to monitor WLANs for unauthorized access, security threats, and suspicious activities?

A) UTM
B) WIDS
C) NGFW
D) WAF
Respuesta no detectada automaticamente

---

3. Encryption methods used to protect data in transit include: (Select all that apply)

A) NFS
✓ B) VPN
C) SED
✓ D) IPsec
E) FDE
✓ F) TLS

---

4. Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication, and data integrity for network traffic?

A) TLS
B) SSH
C) IPsec
D) VPN

---

5. Which of the answers listed below refer(s) to encryption method(s) used to protect data at rest? (Select all that apply)

A) FDE
✓ B) SED
C) IPsec
D) TLS
✓ E) VPN
✓ F) EFS

---

6. Which of the following answers refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL
B) IKE
C) ESP
D) DHE

7. Which of the answers listed below refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL

✓ B) IKE

C) ESP

D) DHE

---

8. Which of the following answers illustrates the difference between passive and active network security breach response?

A) HIPS vs. NIPS

B) UTM vs. Firewall

C) NIPS vs. UTM

✓ D) IDS vs. IPS

---

9. Which of the following answers refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL

✓ B) IKE

C) ESP

D) DHE

---

10. Which cryptographic protocol is designed to provide secure communications over a computer network and is the successor to SSL?

A) IPsec

✓ B) TLS

C) AES

D) CCMP

---

11. Which of the answers listed below refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL

✓ B) IKE

C) ESP

D) DHE

---

12. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP

✓ B) AUP

C) IDS

D) MFA

E) IPS

---

13. An encryption protocol primarily used in Wi-Fi networks implementing the WPA2 security standard is called:

A) TKIP

✓ B) CCMP

C) SSL

D) IPsec

---

14. Which of the answers listed below refers to a shared secret authentication method used in WPA, WPA2, and EAP?

A) PSK

B) 802.1X

C) SAE

D) TKIP

---

15. Which of the following provides active network security breach response on an individual computer system?

A) NIDS
B) HIDS
C) NIPS
✓ **D) HIPS**

16. Which part of IPsec provides confidentiality, data integrity, and authentication?

A) AES
B) SHA
C) AH
✓ **D) ESP**

17. An IPsec mode providing encryption only for the payload (the data part of the packet) is referred to as:

A) Protected mode
B) Tunnel mode
✓ **C) Transport mode**
D) Safe mode

18. Which of the following answers refers to a cybersecurity framework that combines network and security functions into a single cloud-based service?

A) SASE
B) SWG
C) CASB
D) SD-WAN
Respuesta no detectada automaticamente

19. Which of the following answers refers to a deprecated wireless authentication protocol developed by Cisco?

A) PEAP
B) EAP-TTLS
✓ **C) LEAP**
D) EAP-TLS

20. Which of the following acronyms refers to software or hardware-based security solutions designed to detect and prevent unauthorized use and transmission of confidential information?

A) IPS
✓ **B) DLP**
C) IDS
D) DEP

21. A lightly protected subnet (a.k.a. DMZ) consisting of publicly available servers placed on the outside of the company's firewall is known as:

A) Captive portal
B) Quarantine network
C) Extranet
✓ **D) Screened subnet**

22. Which of the answers listed below refers to a secure replacement for Telnet?

A) RSH
B) IPsec
✓ **C) SSH**
D) RTPS

23. Which of the answers listed below refers to a secure network protocol used to provide encryption, authentication, and integrity for real-time multimedia communication?

A) IPsec
B) SIP
C) VoIP
✓ **D) SRTP**

24. Which of the following answers refers to a network security solution providing a single point of protection against various types of threats?

A) IDP
B) AV
✓ **C) UTM**
D) NGFW

25. Which of the following acronyms refers to software or hardware-based security solutions designed to detect and prevent unauthorized use and transmission of confidential information?

A) IPS
✓ **B) DLP**
C) IDS
D) DEP

26. Which of the following answers refers to a shared secret authentication method used in WPA, WPA2, and EAP?

A) PSK
B) 802.1X
C) SAE
D) TKIP
Respuesta no detectada automaticamente

27. Which of the answers listed below refers to a network security technology designed to monitor, detect, and mitigate unauthorized access, security threats, and suspicious activities in WLANs?

A) WIPS
B) NIDS
C) NIPS
D) WIDS

28. Which of the following solutions provides active network security breach response on an individual computer system?

A) NIDS
B) HIDS
C) NIPS
✓ **D) HIPS**

29. Which type of software is used to prevent, detect, and remove malware from computer systems and networks?

A) IDS
B) SaaS
✓ **C) AV**
D) WAF

30. Which of the answers listed below refers to a deprecated wireless authentication protocol developed by Cisco?

A) PEAP
B) EAP-TTLS
C) LEAP
D) EAP-TLS

31. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP
✓ **B) AUP**
C) IDS
D) MFA
E) IPS

32. Which part of IPsec provides authentication, integrity, and confidentiality?

A) SPD
B) PFS
C) AH
✓ **D) ESP**

33. Which of the answers listed below refers to an open standard wireless network authentication protocol that enhances security by encapsulating authentication process within an encrypted TLS tunnel?

A) PEAP
B) EAP
C) LEAP
D) RADIUS
Respuesta no detectada automaticamente

34. Which of the protocols listed below is used to enable secure web browsing?

A) L2TP
✓ **B) HTTPS**
C) SSH
D) IPsec

35. Which of the answers listed below refers to a secure replacement for Telnet?

A) RSH
B) IPsec
C) SSH
D) RTPS

36. What are the examples of preventive security controls? (Select 3 answers)

A) Encryption
B) IDS
C) Sensors
✓ **D) Firewalls**
E) Warning signs
✓ **F) AV software**

37. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ **B) Log monitoring**
C) Sandboxing
✓ **D) Security audits**
✓ **E) CCTV**
✓ **F) IDS**
✓ **G) Vulnerability scanning**

38. SFTP is an extension of the FTP protocol that adds support for SSL/TLS encryption.

A) True
✓ **B) False**

39. A system that uses public network (such as the Internet) as a means for creating private encrypted connections between remote locations is referred to as:

A) WWAN
✓ **B) VPN**
C) PAN
D) VLAN

40. Which of the wireless technologies listed below are considered potential threat vectors and should be avoided due to their known vulnerabilities? (Select all that apply)

A) WPS
B) WAP
✓ **C) WPA**

D) WAF

✓ **E) WPA2**

✓ **F) WEP**

41. Which of the answers listed below refers to a means for logical network segmentation?

A) Switch

B) VLAN

C) Screened subnet

D) Router

42. A computer system or an application that acts as an intermediary between another computer and the Internet is commonly referred to as:

A) Bridge

B) Active hub

C) Server

✓ **D) Proxy**

43. Which of the answers listed below refers to an IEEE standard that can be implemented in a situation where an Ethernet switch acts as an authenticator for devices that intend to connect to a network through one of its ports?

A) IEEE 802.1X

B) IEEE 802.11ac

C) IEEE 802.1D

D) IEEE 802.11x

44. Which of the following terms is used to describe a type of VPN that alleviates bottlenecks and conserves bandwidth by enabling utilization of both the VPN and public network links?

A) Split tunnel

B) Clientless

C) Full tunnel

D) Remote access

45. Which type of VPN enables connectivity between two networks?

A) Site-to-site

B) Host-to-network

C) Remote access

D) Client-to-site

Respuesta no detectada automaticamente

46. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks

B) IEEE 802.1D

C) Does not require an authentication server

✓ **D) IEEE 802.1X**

E) Suitable for all types of wireless LANs

✓ **F) Requires RADIUS authentication server**

47. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA

✓ **B) CAPTCHA**

C) SSO

D) NIDS

48. A dedicated transport mechanism for cyber threat information is called:

A) TCP/IP

B) TLS

✓ **C) TAXII**

D) S/MIME

49. Which of the answers listed below refer to filtering techniques that can allow or block access to a site based on its web address? (Select 2 answers)

A) SSL/TLS inspection

✓ B) URL scanning

C) Content categorization

✓ D) DNS filtering

E) Reputation-based filtering

50. Which of the protocols listed below enable secure retrieval of emails from a mail server to an email client? (Select 2 answers)

A) FTPS

✓ B) IMAPS

✓ C) POP3S

D) STARTTLS

E) SMTPS

51. Which of the following answers refers to a solution that helps organizations mitigate risks associated with data breaches, insider threats, and compliance violations?

A) EDR

B) DLP

C) IAM

D) UTM

52. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA

✓ B) CAPTCHA

C) ACL

D) NIPS

53. What is the name of a network protocol that secures web traffic via SSL/TLS encryption?

A) SFTP

✓ B) HTTPS

C) FTPS

D) SHTTP

54. Which wireless security protocol has been deprecated in favor of newer standards due to known vulnerabilities resulting from implementation flaws?

A) EAP

B) AES

C) WPA2

✓ D) WEP

55. Which of the answers listed below refers to a remote access authentication protocol that periodically re-authenticates client at random intervals to prevent session hijacking?

A) EAP

B) CHAP

C) PAP

D) PEAP

56. Which of the answers listed below refer to the characteristic features of NIDS? (Select 3 answers)

A) Takes proactive measures to block or mitigate intrusion attempts

✓ B) Does not take direct action to block or prevent attacks

✓ C) Generates alerts and notifies security personnel or administrators when suspicious activity is detected

✓ D) Monitors network traffic without direct involvement in traffic routing or packet modification

E) Can drop or reject network packets, terminate connections, or take other actions to stop the attack

F) Operates in an inline mode, actively intercepting and inspecting network traffic

57. Which of the following answers refers to a cybersecurity framework that combines network and security functions into a single cloud-based service?

A) SASE
B) SIEM
C) SWG
D) SOAR

58. Which of the answers listed below refers to a deprecated TLS-based method for securing SMTP?

A) IDPS
B) STARTTLS
C) DKIM
D) SMTPS

59. Which of the following technologies enables automated handling of multiple security incidents?

A) SOAP
B) SIEM
✓ C) SOAR
D) SASE

60. Which of the answers listed below refers to a tunneling protocol commonly used in creating VPNs?

A) VRRP
✓ B) GRE
C) RTSP
D) BGP

61. What are the examples of preventive security controls? (Select 3 answers)

A) Encryption
B) IDS
C) Sensors
✓ D) Firewalls
E) Warning signs
✓ F) AV software

62. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ B) Log monitoring
C) Sandboxing
✓ D) Security audits
✓ E) CCTV
✓ F) IDS
✓ G) Vulnerability scanning

63. What is the name of a network protocol that secures web traffic via SSL/TLS encryption?

✓ A) SFTP
✓ B) HTTPS
C) FTPS
D) SHTTP

64. SFTP is an extension of the FTP protocol that adds support for SSL/TLS encryption.

A) True
✓ B) False

65. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks
B) IEEE 802.1D
C) Does not require an authentication server

✓ **D) IEEE 802.1X**

E) Suitable for all types of wireless LANs

✓ **F) Requires RADIUS authentication server**

---

66. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA

✓ **B) CAPTCHA**

C) SSO

D) NIDS

---

67. A dedicated transport mechanism for cyber threat information is called:

A) TCP/IP

B) TLS

✓ **C) TAXII**

D) S/MIME

3.3 - Compare and contrast concepts and strategies to protect data.

Conceptos clave:

- Data types: Regulated, Trade secret, Intellectual property, Financial, PII, PHI
- Classifications: Sensitive, Confidential, Public, Restricted, Private, Critical
- Data states: At rest, In transit, In use
- Methods: Geographic restrictions, Encryption, Hashing, Masking, Tokenization, Segmentation

Teoria (Professor Messer):

Data Types and Classifications

- Types
  - Regulated: managed by a third party - government laws and statutes
  - Trade secret: organizations' "secret formulas" - often unique
  - Intellectual property: publicly visible but copyrighted/trademarked
  - Legal information: records, documents, info - contains PII
  - Financial information: internal financial details, payment records, payment medium data, etc.
  - Human-readable: understandable, clear and obvious
  - Non-human-readable: not easily understood, encoded data
    - Some are a hybrid (CSV, JSON, etc.)
- Classifying sensitive data
  - Different sensitivities require different security and handling
  - Stronger network, DMZ, MFA, etc.
- Classifications
  - Proprietary: property of an organization
  - PII - Personally Identifiable Information: used to identify an individual
  - PHI - Protected Health Information: health info used to identify an individual or associated with an individual
  - Sensitive: intellectual property, S/PII, PHI
  - Confidential: VERY sensitive, approved to view
  - Public/Unclassified: no restrictions
  - Private/Classified/Restricted: restricted access, may require NDA
  - Critical: data that should always be accessible

States of Data

- Data at rest: on a storage device
  - Encrypt the data - whole disk, database, file-/folder-level
  - Apply permissions
- Data in transit/motion: being transmitted over the network
  - Not much protection as it travels
  - Network-based protection - firewall, IPS

    - Provide transport encryption - TLS, IPsec
  - Data in use: actively processing in memory (system RAM, CPU)
    - Data is almost always decrypted
    - Attackers pick the decrypted information out of RAM
    - Target breach November 2013, attackers picked credit card numbers out of point-of-sale RAM
  - Data sovereignty: data that resides in a country is subject to the laws of that country
    - Laws may prohibit where data is stored
    - GDPR - data collected on EU citizens must be stored in the EU
    - Compliance laws may prohibit data moving out of the country
  - Geolocation: location details
    - Many ways to determine - 802.11, mobile providers, GPS
    - Can be used to manage access
      - Limited administrative tasks unless secure area is used

Protecting Data

- Geographic restrictions
  - Network location: IP or subnet, difficult with mobile devices
  - Geolocation: GPS, 802.11 wireless, IP address (most to least accurate)
  - Geofencing: automatically determine access based on location
- Protecting data
  - Primary important job task, but data is everywhere
  - Encrypt, employ permissions
- Encryption: encode information into unreadable data
  - Two-way: able to convert between one and the other
  - Confusion: encrypted data is drastically different than plaintext
- Hashing: represent data as a short string of test (message digest, fingerprint, etc.)
  - One-way: impossible to recover original message, used to store passwords
  - Verify a downloaded document is the same as the original
  - Can be a digital signature (with public-key crypto)
  - Will not (usually) have collision
- Obfuscation: make something normally understandable difficult to understand
  - Take readable code and turn it into nonsense
  - Helps prevent the search for security holes (malware, etc.)
  - Not a good technique for securing on-premises data, security-by-obscurity isn't very powerful
- Masking: type of obfuscation, hides some of the original data
  - Protects PII and other sensitive data
  - Example: showing only last 4 digits of credit/debit card number, replace the rest of asterisks
  - May only be hidden from view, could still be in storage
- Tokenization: replace sensitive data with non-sensitive placeholder
  - Common with credit card processing
  - Not encryption or hashing - original data and token not related mathematically
- Segmentation
  - Spread data among many servers/locations, no central point of failure
  - Some data should also have stronger security
- Permission restrictions
  - Control access to an account
  - Auth process then permissions once in account

Tips y trucos para el examen:

ESTADOS DE LOS DATOS:

- Data at rest: datos almacenados en disco/BD. Proteger con: cifrado de disco (BitLocker, FileVault)
- Data in transit: datos moviendose por la red. Proteger con: TLS, VPN, IPSec
- Data in use: datos en memoria RAM siendo procesados. El mas dificil de proteger. Tecnica: Secure Enclave

METODOS DE PROTECCION DE DATOS:

- Encryption: cifrar datos para que sean ilegibles sin la clave

- Tokenization: sustituir el dato real por un token (sin valor matematico). Usado en pagos
- Data masking: ocultar parte del dato (mostrar solo ****1234 de una tarjeta)
- Anonymization: eliminar toda informacion identificativa de forma irreversible
- Pseudonymization: sustituir identificadores por pseudonimos (reversible con la clave)
- DLP (Data Loss Prevention): herramienta que detecta y bloquea fuga de datos
- Geographic restrictions / Data sovereignty: los datos deben almacenarse en un pais especifico por ley

Preguntas de practica (89):

1. Which of the answers listed below refers to a situation where sensitive data is stored in a separate location and can be retrieved with a non-sensitive replacement that can also be processed just like the original data without the risk of revealing the contents of original data?

A) Masking
✓ B) Obfuscation
C) Encryption
✓ D) Tokenization

2. Which of the following data states typically requires data to be processed in an unencrypted form?

A) Data in motion
B) Data at rest
C) Data in transit
✓ D) Data in use

3. In cryptography and security, the term "Secure enclave" typically refers to a protected and isolated hardware or software environment within a computing device, such as a smartphone, tablet, or computer, where sensitive data and cryptographic operations can be stored and processed securely.

A) True
B) False
Respuesta no detectada automaticamente

4. Replacing password characters in a password field with a series of asterisks is an example of:

A) Data masking
B) Tokenization
C) Anonymization
D) Pseudo-anonymization
Respuesta no detectada automaticamente

5. Which of the answers listed below refers to a technique that enables converting input data into a fixed-size string, making it difficult to reverse or retrieve the original data?

✓ A) Obfuscation
✓ B) Tokenization
C) Hashing
D) Encryption

6. Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answers)

A) Enhances security by limiting the spread of cyberattacks
✓ B) Helps organizations comply with data regulatory requirements by isolating and protecting specific data types
C) Provides security for data in transit with the use of encryption
D) Guarantees data recovery in case of accidental deletion or system failures
✓ E) Provides better control over user access to sensitive data

7. Which of the following acronyms refers to software or hardware-based security solutions designed to detect and prevent unauthorized use and transmission of confidential information?

A) IPS
✓ B) DLP
C) IDS
D) DEP

8. Which of the following acronyms refers to software or hardware-based security solutions designed to detect and prevent unauthorized use and transmission of confidential information?

A) IPS

✓ B) DLP

C) IDS

D) DEP

---

9. A social engineering technique whereby attackers under disguise of a legitimate request attempt to gain access to confidential information is commonly referred to as:

A) Phishing

B) Smishing

C) Pharming

D) Spoofing

---

10. Which of the answers listed below refers to any type of information pertaining to an individual that can be used to uniquely identify that person?

A) PHI

B) Biometrics

C) ID

✓ D) PII

---

11. The US Health Insurance Portability and Accountability Act (HIPAA) provides privacy protection for:

A) PII

B) PI

✓ C) PHI

D) PIV

---

12. Which of the answers listed below refers to a technique that enables converting input data into a fixed-size string, making it difficult to reverse or retrieve the original data?

A) Obfuscation

B) Tokenization

✓ C) Hashing

D) Encryption

---

13. Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answers)

A) Enhances security by limiting the spread of cyberattacks

✓ B) Helps organizations comply with data regulatory requirements by isolating and protecting specific data types

C) Provides security for data in transit with the use of encryption

D) Guarantees data recovery in case of accidental deletion or system failures

✓ E) Provides better control over user access to sensitive data

---

14. Which cryptographic technique is used to prevent the effectiveness of rainbow tables in cracking hashed passwords?

A) Data masking

B) Two-Factor Authentication (2FA)

C) Key stretching

✓ D) Salting

---

15. The term "Non-repudiation" describes the inability to deny responsibility for performing a specific action. In the context of data security, non-repudiation ensures data confidentiality, provides proof of data integrity, and proof of data origin.

A) True

✓ B) False

---

16. Which of the answers listed below refers to software technology designed to provide confidentiality for an entire data storage device?

A) TPM
B) FDE
C) EFS
D) HSM

17. The MIME specification extends the email message format beyond plain text, enabling the transfer of graphics, audio, and video files over the Internet mail system. S/MIME is an enhanced version of the MIME protocol that enables email security features by providing encryption, authentication, message integrity, and other related services.

A) True
B) False

18. Which of the following answers refer(s) to deprecated/insecure encryption protocols and cryptographic hash functions? (Select all that apply)

A) DES
B) AES-256
✓ C) MD5
D) ECC
✓ E) SHA-1
✓ F) SSL
✓ G) RC4

19. The term "KEK" refers to a type of cryptographic key often used in key management systems to add an additional layer of security when encrypting and decrypting other cryptographic keys.

A) True
B) False
Respuesta no detectada automaticamente

20. Which of the following answers refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL
B) IKE
C) ESP
D) DHE

21. Which of the cryptographic algorithms listed below is the least vulnerable to attacks?

A) AES
B) DES
C) RC4
D) 3DES
Respuesta no detectada automaticamente

22. In cryptography, the number of bits in a key used by a cryptographic algorithm is referred to as key size or key length. The key length determines the maximum number of combinations required to break the encryption algorithm, therefore typically a longer key means stronger cryptographic security.

A) True
B) False

23. Which of the following answers refers to a centralized server that is used to distribute cryptographic keys and authenticate users and services within a computer network?

A) PKI
B) RAS
✓ C) KDC
D) NAS

24. Which of the following answers refers to a family of cryptographic hash functions designed for various security-related applications, including digital signatures, password storage, secure communications, and data integrity verification?

A) RSA
B) AES
C) PKCS
✓ **D) SHA**

25. Which of the following combines a cryptographic hash function with a secret key to provide a means of verifying both the authenticity and integrity of a message or data?

A) MD5
B) DSA
✓ **C) HMAC**
D) DES

26. Which of the answers listed below refers to a non-cryptographic hash function often used for error-checking purposes?

A) MD5
B) CRC
C) SHA
D) RIPEMD

27. Which of the answers listed below refers to a set of standards and specifications that define various cryptographic techniques, including formats for public keys, private keys, digital signatures, and digital certificates?

A) ITIL
B) RFC
C) PKCS
D) ISO/IEC

28. Assign the level of sophistication attribute to each threat actor type listed below.

Respuesta no detectada automaticamente

29. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM
✓ **B) APT**
C) XSRF
D) DDoS

30. Which of the answers listed below refers to an email-based threat vector?

A) Spoofing
B) Phishing
C) BEC attacks
D) Malicious links
E) Malware attachments
✓ **F) All of the above**

31. Which of the answers listed below refers to an example of a potential threat vector in IM-based communication?

A) Phishing attack
B) Malware distribution
C) Spoofing attack
D) Eavesdropping
E) Account hijacking
F) Malicious link/attachment
✓ **G) All of the above**

32. Which of the following answers refer to agentless software threat vectors? (Select 2 answers)

A) Phishing email
B) Malicious USB drive

✓ **C) Network protocol vulnerability**

D) Infected macro

✓ **E) Packet sniffing**

33. Which social engineering attack relies on identity theft?

A) Pretexting

B) Spear phishing

C) Tailgating

✓ **D) Impersonation**

34. The term "URL hijacking" (a.k.a. "Typosquatting") refers to a deceptive practice involving the deliberate registration of domain names with misspellings or slight variations that closely resemble well-established and popular domain names. The primary goal of this strategy is to exploit the common typographical errors made by users while entering URLs into their web browser's address bar. Beyond capturing inadvertent traffic, typosquatting may also be used for hosting phishing sites to trick users into divulging sensitive information, distributing malware through deceptive websites, generating ad revenue by redirecting mistyped traffic, or engaging in brand impersonation to harm the reputation of authentic brands or deceive users.

A) True

B) False

35. The practice of gaining unauthorized access to a Bluetooth device is known as:

A) Phishing

B) Bluejacking

C) Smishing

✓ **D) Bluesnarfing**

36. A wireless jamming attack is a type of:

A) Cryptographic attack

✓ **B) DoS attack**

C) Brute-force attack

D) Downgrade attack

37. A hash collision occurs when cryptographic hash function produces two different digests for the same data input.

A) True

✓ **B) False**

38. Which of the answers listed below refer to the concept of data isolation? (Select 2 answers)

A) DLP

B) SDN

✓ **C) EFS**

D) SWG

E) EDR

39. Which of the answers listed below refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL

✓ **B) IKE**

C) ESP

D) DHE

40. Which part of IPsec provides confidentiality, data integrity, and authentication?

A) AES

B) SHA

C) AH

✓ **D) ESP**

41. Which of the following regulates personal data privacy of the EU citizens?

✓ **A) PHI**

B) HIPAA

C) PCI DSS

✓ **D) GDPR**

42. Encryption methods used to protect data in transit include: (Select all that apply)

A) NFS

✓ **B) VPN**

C) SED

✓ **D) IPsec**

E) FDE

✓ **F) TLS**

43. Which of the answers listed below refers to the primary function of load balancing?

A) Maintains identical copies of data across multiple servers to enhance data availability and reliability

✓ **B) Distributes workload across multiple servers for improved performance**

✓ **C) Groups servers together to provide high availability and fault tolerance**

D) Distributes content geographically across multiple servers to improve performance, reduce latency, and handle high volumes of traffic

44. Implementing full device encryption is one of the methods for securing sensitive data on a smartphone. When enabled, this type of encryption works in conjunction with the phone's screen lock, i.e., to decrypt the phone (which stays encrypted whenever the phone is locked), a user must first unlock the screen. On Android devices, the unlocking methods include entering a PIN, password, or drawing a simple pattern with a finger. Apple devices use passcodes, facial recognition (Face ID), and fingerprint (Touch ID).

A) True

B) False

Respuesta no detectada automaticamente

45. Which of the following methods provides the most effective way for permanent removal of data stored on a magnetic drive?

A) Cryptographic erasure

B) Data overwriting

✓ **C) Degaussing**

D) Low-level formatting

46. Which policy typically specifies the period during which certain types of data must be stored prior to disposal?

A) Data protection policy

B) Data classification policy

C) Data backup policy

✓ **D) Data retention policy**

47. Which of the answers listed below refers to a cryptographic standard (and a file format) used for the storage and transmission of private keys in email communications?

A) PEM

B) DMARC

C) SPF

D) DKIM

48. Which of the answers listed below refers to the process of maintaining the integrity of files and data?

A) DLP

B) SIEM

C) FIM

D) SHA

49. Which of the following answers refers to a solution that helps organizations mitigate risks associated with data breaches, insider threats, and compliance violations?

A) EDR
B) DLP
C) IAM
D) UTM

50. In email communication, what signs can be of help in recognizing a phishing attempt?

A) The message contains poor spelling and grammar
B) The message asks for personal information
C) The message includes a call to action with a sense of urgency
D) The message includes suspicious links or attachments
✓ E) Any of the above

51. A type of cryptographic network protocol for secure data communication, remote command-line login, remote command execution, and other secure network services between two networked computers is known as:

A) RDP
✓ B) SSH
C) Telnet
D) SCP

52. A type of network connecting computers within a small geographical area such as a building or group of buildings is referred to as:

A) PAN
✓ B) LAN
C) MAN
D) WAN

53. Which of the following answers refers to a family of cryptographic hash functions used in a variety of security applications, including digital signatures, password storage, secure communications, and data integrity verification?

A) RSA
B) IDEA
C) AES
✓ D) SHA

54. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM
✓ B) APT
C) XSRF
D) DDoS

55. A software technology designed to provide confidentiality for an entire data storage device is known as:

A) TPM
✓ B) FDE
C) EFS
D) HSM

56. Which of the following answers refers to a cryptographic file generated by an entity requesting a digital certificate from a CA?

A) OID
✓ B) CSR
C) DN
D) CRL

57. Which of the following answers refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL

✓ **B) IKE**

C) ESP

D) DHE

58. Which of the acronyms listed below refers to a cryptographic software tool for secure email communication and data protection?

A) DES

B) PEM

C) EFS

✓ **D) PGP**

59. Which of the acronyms listed below refers to a piece of hardware and associated software/firmware designed to provide cryptographic and key management functions?

A) EFS

✓ **B) HSM**

C) SFC

D) TPM

60. Which of the answers listed below refers to a cryptographic method used to verify that a message or data has remained unaltered during transmission and originates from an authorized source?

A) MAC

B) CBC

C) PEM

D) GCM

61. In modern OSs, this feature prevents malicious code from executing in certain memory regions intended for data.

A) DEP

B) ECB

C) DLP

D) CRC

Respuesta no detectada automaticamente

62. The MIME specification extends the email message format beyond simple text, enabling the transfer of graphics, audio, and video files over the Internet mail system. S/MIME is an enhanced version of the MIME protocol that enables email security features by providing encryption, authentication, message integrity, and other related services.

A) True

B) False

63. Which of the following answers refers to a non-cryptographic hash function often used for error-checking purposes?

A) MD5

B) CRC

C) SHA

D) RIPEMD

64. Which of the answers listed below refers to a set of standards and specifications that define various cryptographic techniques, including formats for public keys, private keys, digital signatures, and digital certificates?

A) ITIL

B) RFC

C) PKCS

D) ISO/IEC

65. Which of the answers listed below refers to a logical operation commonly used in the context of cybersecurity, particularly in encryption and obfuscation techniques?

A) AND

B) OR
C) NOT
D) XOR
Respuesta no detectada automaticamente

66. Which of the answers listed below refers to the process of maintaining the integrity of files and data?

A) DLP
B) SIEM
C) FIM
D) SHA

67. Which of the answers listed below refers to an encoding method (and a file format) for storing cryptographic objects such as X.509 certificates, CRLs, and private keys?

A) ECB
✓ B) PEM
C) FIM
D) PFS

68. Which of the following combines a cryptographic hash function with a secret key to provide a means of verifying both the authenticity and integrity of a message or data?

A) MD5
B) DSA
✓ C) HMAC
D) DES

69. Which part of IPsec provides authentication, integrity, and confidentiality?

A) SPD
B) PFS
C) AH
✓ D) ESP

70. Which cryptographic protocol is designed to provide secure communications over a computer network and is the successor to SSL?

A) IPsec
✓ B) TLS
C) AES
D) CCMP

71. Which of the answers listed below refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL
✓ B) IKE
C) ESP
D) DHE

72. Which of the following answers refers to a cryptographic key exchange protocol that leverages ECC for enhanced security and efficiency?

A) S/MIME
B) ECDHE
C) DHE
D) ECDSA

73. Which block cipher mode combines CTM for encryption with an authentication mechanism to ensure both data confidentiality and integrity?

A) CBC
✓ B) GCM
C) ECB
D) CFB

74. Which of the answers listed below refers to a cryptographic hash function that has been widely used in the past but is now considered deprecated for security-sensitive applications due to known vulnerabilities?

A) MD5
B) SHA
C) CRC
D) HMAC

Respuesta no detectada automaticamente

75. Which of the answers listed below refers to a non-cryptographic hash function often used for error-checking purposes?

A) MD5
✓ B) CRC
C) SHA
D) RIPEMD

76. Which of the answers listed below refers to a cryptographic technique that verifies the authenticity and integrity of digital documents or messages by using a unique encrypted identifier from the sender?

A) Digital signature
B) Cryptographic hash function
C) Digital certificate
D) Asymmetric encryption

77. Assign the level of sophistication attribute to each threat actor type listed below.

Respuesta no detectada automaticamente

78. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM
✓ B) APT
C) XSRF
D) DDoS

79. An attack surface is the sum of all the potential points (vulnerabilities) through which an attacker can interact with or compromise a system or network, indicating the overall exposure to potential threats. Examples of attack surfaces can be all software, hardware, and network interfaces with known security flaws. A threat vector represents the method or means through which a cyber threat is introduced or delivered to a target system. It outlines the pathway or avenue used by attackers to exploit vulnerabilities. Common threat vector types include phishing emails, malware, drive-by downloads, and social engineering techniques.

A) True
B) False

Respuesta no detectada automaticamente

80. Which of the answers listed below refers to an email-based threat vector?

A) Spoofing
B) Phishing
C) BEC attacks
D) Malicious links
E) Malware attachments
✓ F) All of the above

81. Which of the answers listed below refers to an example of a potential threat vector in IM-based communication?

A) Phishing attack
B) Malware distribution
C) Spoofing attack
D) Eavesdropping
E) Account hijacking

F) Malicious link/attachment

✓ **G) All of the above**

82. A BEC attack is an example of:

A) Smishing

✓ **B) Phishing**

C) Vishing

D) Pharming

83. The term "Typosquatting" refers to a deceptive practice involving the deliberate registration of domain names with misspellings or slight variations that closely resemble well-established and popular domain names. The primary goal of this strategy is to exploit the common typographical errors made by users while entering URLs into their web browser's address bar. Beyond capturing inadvertent traffic, typosquatting may also be used for hosting phishing sites to trick users into divulging sensitive information, distributing malware through deceptive websites, generating ad revenue by redirecting mistyped traffic, or engaging in brand impersonation to harm the reputation of authentic brands or deceive users.

A) True

B) False

Respuesta no detectada automaticamente

84. What would be an appropriate user response to an email phishing attempt? (Select all that apply)

A) Not replying to the message or providing any personal information

✓ **B) Reporting the message to the IT or security department, if applicable**

✓ **C) Deleting the message from the inbox**

✓ **D) Not clicking on any links or downloading any attachments in the message**

E) Forwarding the message to the sender to verify its legitimacy

F) Opening the attachment in a sandbox environment to check its safety

85. A wireless disassociation attack is a type of: (Select 2 answers)

A) Downgrade attack

✓ **B) Deauthentication attack**

C) Brute-force attack

✓ **D) DoS attack**

E) Cryptographic attack

86. A situation where an attacker intercepts and retransmits valid data exchange between an application and a server, or another application is known as:

A) Sideloading

✓ **B) Replay attack**

C) Phishing attack

D) Race condition

87. Which of the answers listed below refer(s) to encryption method(s) used to protect data at rest? (Select all that apply)

A) FDE

✓ **B) SED**

C) IPsec

D) TLS

✓ **E) VPN**

✓ **F) EFS**

88. Which of the answers listed below refers to the primary function of load balancing?

A) Maintains identical copies of data across multiple servers to enhance data availability and reliability

✓ **B) Distributes workload across multiple servers for improved performance**

✓ **C) Groups servers together to provide high availability and fault tolerance**

D) Distributes content geographically across multiple servers to improve performance, reduce latency, and handle high volumes of traffic

89. A legal contract between the holder of confidential information and another person to whom that information is disclosed restricting that other person from disclosing the confidential information to any other party is referred to as:

A) ISA

✓ **B) NDA**

✓ **C) BPA**

D) SLA

3.4 - Explain the importance of resilience and recovery in security architecture.

Conceptos clave:

- High availability: Load balancing vs clustering
- Site types: Hot, Cold, Warm, Geographic dispersion
- Backups: Onsite/offsite, Snapshots, Replication, Journaling
- Testing: Tabletop, Failover, Simulation, Parallel processing
- Power: Generators, UPS

Teoria (Professor Messer):

architecture."

Resiliency

- High availability
  - Redundant doesn't always mean available
  - HA (high-availability): always on, always available
    - Expensive (more systems, upgraded power, etc.)
- Server clustering: combine two or more servers to function as one
  - Usually configured in the OS
  -
- Load balancing: load distributed across multiple servers using load balancer
  - Distribute from central point
  - Adds or removes devices as needed
- Site resiliency
  - Recovery site is prepped
  - Disaster called, recover site used, problem addressed, back to primary
  - Hot site: exact replica of data center
    - Update data, software, AND hardware
  - Cold site: no hardware, empty building
    - Bring your own data and people
  - Warm site: just enough to get going
    - Big room with rack space, still bring your own stuff
  - Geographic dispersion
    - Recovery sites should be far enough away to not be affected by similar physical events (eg., natural disaster)
- Platform diversity: use different platforms/apps for different purposes
  - Spread the risk - if one vulnerability affects Windows, everything shouldn't shut down because of it
- Multi-cloud systems
  - Plan for cloud outages
  - Disperse data between multiple geographical sites and multiple cloud providers
- Continuity of operations planning (COOP)
  - Have an alternative to all technological systems in case of disaster
  - Document and test BEFORE a problem occurs

Capacity Planning

- Match supply to demand
- People - some services require human intervention
  - Not easy to add and remove
- Technology - pick tech that can scale

    - Web services - distribute load across multiple
    - Database services - cluster multiple SQL servers
    - Cloud services - (seemingly) unlimited resources (if you pay)
  - Infrastructure: the underlying framework
    - Physical devices - purchase, configure, install
    - Cloud-based - easier to deploy and useful for unexpected changes

Recovery Testing

- Test before an actual event
  - Use well-defined rules of engagement, a very specific scenario, and evaluate response
- Tabletop exercises: faux logistics for analysis
  - No physical drill or recovery, talk through a simulated disaster
- Fail over test
  - Ensure redundant systems switch to backups when a failure occurs
  -
- Simulation: test with a fully simulated event
  - Common - phishing simulation (curated emails, etc.)
- Parallel processing: split a process through multiple parallel CPUs
  - Improved performance and recovery

Backups

- Incredibly important for resilience and recovery
- Implementations:
  - Total data, type, media, storage location, software, time
- Onsite vs. offsite
  - Onsite: not internet link, data immediately available, less expensive
  - Offsite: transfer over internet or WAN link, available after disaster, performed from anywhere
  - Organizations often use both for more options
- Frequency: how often?
  - May be different between systems
  - May be multiple backup sets
- Encryption
  - Backups contain a history of data, makes it easy for an attacker
  - Protect using encryption = unreadable, recovery key required to restore
  - Useful for cloud backups and storage
- Snapshots: instant backup of entire system
  - Popular on virtual machines
  - Take snapshot after 24 hours, contains only changes between snapshots
  -
- Recovery testing: simulate disaster, attempt to restore from backup
  - Simulate, restore, test restorations
- Replication: keep data synchronized in multiple locations
  - Ongoing, (almost) real-time backup
  - Always available, stored locally, recoverable
- Journaling: like a data buffer
  - When writing, if power goes out, data may be corrupted or only a portion of the data may be saved
  - By writing to the journal, you essentially have two copies of the data being stored while it is being written
  - Data transfer redundancy!! :)

Power Resiliency

- Power is the foundation of our technology
- We usually don't make our own power - ways to mitigate issues
- UPS (Uninterruptable Power Supply): short-term backup power
  - Blackouts, brownouts (partial blackout), power surges
  - Types:
    - Offline/standby

    - Line-interactive
    - On-line/double-conversion
  - Features
    - Auto-shutdown, battery capacity, outlets, phone line suppression, etc.
- Generators: long-term power backup, fuel storage required
  - Power an entire building, may take a few minutes to get up to speed

Tips y trucos para el examen:

BACKUPS:

- Full backup: copia completa de todos los datos. Lento de hacer, rapido de restaurar
- Incremental: solo los cambios desde el ultimo backup (full o incremental). Rapido de hacer, lento de restaurar
- Differential: cambios desde el ultimo backup FULL. Termino medio
- Onsite vs Offsite: backups locales (rapidos) vs remotos (protegen de desastres fisicos)
- Snapshot: copia del estado de una VM en un momento dado
- Replication: copia continua de datos a un sitio remoto (menor RPO)
- 3-2-1 Rule: 3 copias, en 2 medios distintos, 1 fuera del sitio

PRUEBAS DE CONTINUIDAD:

- Tabletop exercise: simulacro en sala de juntas, sin afectar sistemas reales. El mas comun
- Failover test: se provoca el fallo real para verificar que el sistema secundario toma el control
- Simulation: simular un incidente especifico (ransomware, incendio) para probar la respuesta
- Parallel processing: ejecutar el sistema de recuperacion en paralelo al principal para validarlo

Preguntas de practica (47):

1. Which of the terms listed below refers to a duplicate of the original site, with fully operational computer systems as well as near-complete backups of user data?

A) Hot site
B) Warm site
C) Cold site
D) Mobile site

Respuesta no detectada automaticamente

2. Which of the terms listed below refers to a duplicate of the original site, with fully operational computer systems as well as near-complete backups of user data?

A) Hot site
B) Warm site
C) Cold site
D) Mobile site

Respuesta no detectada automaticamente

3. Which of the following defines the maximum acceptable amount of data loss measured by a specific point in time before a disaster or outage?

A) RPO
B) MTBF
C) RTO
✓ D) MTTR

4. Which of the following defines the maximum acceptable amount of data loss measured by a specific point in time before a disaster or outage?

A) RPO
B) MTBF
C) RTO
✓ D) MTTR

5. Which of the answers listed below refers to the primary function of load balancing?

A) Maintains identical copies of data across multiple servers to enhance data availability and reliability
✓ B) Distributes workload across multiple servers for improved performance

✓ **C) Groups servers together to provide high availability and fault tolerance**

D) Distributes content geographically across multiple servers to improve performance, reduce latency, and handle high volumes of traffic

6. A disaster recovery facility that provides only the physical space for recovery operations is known as:

A) Hot site

B) Warm site

✓ **C) Cold site**

D) Mirror site

7. Which alternate site allows for the fastest disaster recovery?

A) Cold site

✓ **B) Hot site**

C) Mobile site

D) Warm site

8. Which of the following terms refers to a backup strategy that relies on creating and maintaining copies of data in real-time or near real-time on a separate system?

A) Mirroring

B) Virtualization

✓ **C) Journaling**

✓ **D) Replication**

9. Which of the following power redundancy solutions would be best suited for providing long-term emergency power during an unexpected main power source outage?

A) Dual-power supply

B) Standby UPS

✓ **C) Backup generator**

D) Managed PDU

10. Which of the answers listed below refers to the primary function of load balancing?

A) Maintains identical copies of data across multiple servers to enhance data availability and reliability

✓ **B) Distributes workload across multiple servers for improved performance**

✓ **C) Groups servers together to provide high availability and fault tolerance**

D) Distributes content geographically across multiple servers to improve performance, reduce latency, and handle high volumes of traffic

11. A disaster recovery facility that provides only the physical space for recovery operations is known as:

A) Hot site

B) Warm site

✓ **C) Cold site**

D) Mirror site

12. Which alternate site allows for the fastest disaster recovery?

A) Cold site

✓ **B) Hot site**

C) Mobile site

D) Warm site

13. Which of the following terms refers to a backup strategy that relies on creating and maintaining copies of data in real-time or near real-time on a separate system?

A) Mirroring

B) Virtualization

✓ **C) Journaling**

✓ **D) Replication**

14. Which of the following power redundancy solutions would be best suited for providing long-term emergency power during an unexpected main power source outage?

A) Dual-power supply
B) Standby UPS
✓ **C) Backup generator**
D) Managed PDU

15. The term "RFID cloning" refers to copying the data stored on any RFID-enabled device (including tags, cards, key fobs, implants, and other objects embedded with RFID technology) onto another RFID-enabled device, which then can be read and used in the same way as the original tag. While RFID cloning can be utilized for legitimate purposes, such as replicating important tags for backup and testing purposes, it also poses significant security risk, as duplicate tags can potentially be used for gaining unauthorized access or unauthorized information disclosure.

A) True
B) False
Respuesta no detectada automaticamente

16. Which of the acronyms listed below refers to a maximum tolerable period of time required for restoring business functions after a failure or disaster?

A) SLA
B) RTO
C) AUP
D) RPO

17. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems
B) Video surveillance
✓ **C) MFA**
✓ **D) Application sandboxing**
✓ **E) Network segmentation**

18. Which of the following terms describes the process of identifying differences between an organization's current security posture and its desired security posture?

A) Tabletop exercise
✓ **B) Gap analysis**
C) Security awareness training
D) Risk assessment

19. What is the purpose of steganography?

A) Checking data integrity
B) Verifying hash values
✓ **C) Hiding data within another piece of data**
D) Encrypting data

20. Which of the answers listed below refers to a non-cryptographic hash function often used for error-checking purposes?

A) MD5
B) CRC
C) SHA
D) RIPEMD

21. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM
✓ **B) APT**
C) XSRF
D) DDoS

22. Which of the answers listed below refers to a cyberattack technique that relies on providing false DNS information to a DNS resolver for the purpose of redirecting or manipulating the resolution of domain names

to malicious IP addresses?

A) DNS spoofing
B) Credential stuffing
C) URL hijacking
D) Domain hijacking

23. The purpose of PCI DSS is to provide protection for:

A) Credit cardholder data
B) Licensed software
C) User passwords
D) Personal health information

24. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise
B) Sandboxing
C) Threat hunting
D) Security awareness training

Respuesta no detectada automaticamente

25. Which of the following answers refers to a more realistic scenario that tests cybersecurity incident response by mimicking actual attacks?

A) Fingerprinting
✓ B) Simulation
C) Threat hunting
D) Tabletop exercise

26. A file-based representation of the state of a virtual machine at a given point in time is referred to as:

A) Restore point
B) Shadow copy
✓ C) Snapshot
D) System image

27. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks
B) IEEE 802.1D
C) Does not require an authentication server
✓ D) IEEE 802.1X
E) Suitable for all types of wireless LANs
✓ F) Requires RADIUS authentication server

28. Which policy typically specifies the period during which certain types of data must be stored prior to disposal?

A) Data protection policy
B) Data classification policy
C) Data backup policy
✓ D) Data retention policy

29. In Windows Active Directory environment, this feature enables centralized management and configuration of operating systems, applications, and user account settings.

A) Local Users and Groups
B) Resource Monitor
✓ C) Group Policy
D) User Account Control

30. In the context of IT security, the term "Biometrics" refers to both biological characteristics of the human body and behavioral traits that can be used for identification and access control purposes.

A) True

B) False

Respuesta no detectada automaticamente

31. Which of the answers listed below refers to a process of intercepting network traffic data for analysis and troubleshooting purposes?

A) AIS

✓ B) PCAP

C) EDR

D) MaaS

32. A high MTBF value indicates that a component or system provides low reliability and is more likely to fail.

A) True

✓ B) False

33. Which of the following answers refers to an entity (such as an organization or individual) that determines the purpose and means of processing personal data?

✓ A) Data processor

B) Data owner

✓ C) Data controller

D) Data subject

34. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM

✓ B) APT

C) XSRF

D) DDoS

35. Which of the following answers refers to a non-cryptographic hash function often used for error-checking purposes?

A) MD5

B) CRC

C) SHA

D) RIPEMD

36. Which of the following terms refers to a technology that enables real-time audio and video communication between individuals or groups?

A) VPC

✓ B) VTC

C) VoIP

D) VDI

37. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems

B) Video surveillance

✓ C) MFA

✓ D) Application sandboxing

✓ E) Network segmentation

38. Which of the answers listed below refers to a non-cryptographic hash function often used for error-checking purposes?

A) MD5

✓ B) CRC

C) SHA

D) RIPEMD

39. Which of the following terms is used to describe sophisticated and prolonged cyberattacks often carried out by well-funded and organized groups, such as nation-states?

A) MitM

✓ **B) APT**

C) XSRF

D) DDoS

40. Which of the answers listed below refers to a cyberattack technique that relies on providing false DNS information to a DNS resolver for the purpose of redirecting or manipulating the resolution of domain names to malicious IP addresses?

A) DNS spoofing

B) Credential stuffing

C) URL hijacking

D) Domain hijacking

41. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise

B) Sandboxing

C) Threat hunting

D) Security awareness training

Respuesta no detectada automaticamente

42. Which of the following answers refers to a more realistic scenario that tests cybersecurity incident response by mimicking actual attacks?

A) Fingerprinting

✓ **B) Simulation**

C) Threat hunting

D) Tabletop exercise

43. A file-based representation of the state of a virtual machine at a given point in time is referred to as:

A) Restore point

B) Shadow copy

✓ **C) Snapshot**

D) System image

44. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks

B) IEEE 802.1D

C) Does not require an authentication server

✓ **D) IEEE 802.1X**

E) Suitable for all types of wireless LANs

✓ **F) Requires RADIUS authentication server**

45. Which of the answers listed below refers to a discussion-based activity where team members walk through different scenarios to evaluate the incident response plan without activating any systems?

A) Tabletop exercise

✓ **B) Simulation**

C) Threat hunting

D) Root cause analysis

46. Which of the following answers refers to a risk assessment conducted for a specific purpose or project, without plans for regular reassessment (e.g., risk assessment for a new product launch)?

A) One-time

B) Recurring

C) Ad hoc

D) Continuous

47. A high MTBF value indicates that a component or system provides low reliability and is more likely to fail.

A) True

✓ **B) False**

4.0 Security Operations (28% del examen)

4.1 - Apply common security techniques to computing resources.

Conceptos clave:

- Secure baselines: Establish, Deploy, Maintain
- Hardening targets: Mobile, Workstations, Switches, Routers, Cloud, Servers, IoT
- Mobile solutions: MDM, BYOD, COPE, CYOD
- Wireless security: WPA3, RADIUS, Cryptographic/Authentication protocols
- Application security: Input validation, Secure cookies, Static code analysis, Code signing

Teoria (Professor Messer):

computing resources."

Secure Baselines

- The security of an application should be well defined - everything follows this baseline
- Integrity measurements check for the secure baseline
- Establish baselines
  - Security baselines are often available from the manufacturer
  - Man OSes have extensive options - Windows has 3,000 group policies
- Deploy baselines
  - Usually managed through a centrally administered console
  - May require multiple deployment mechanisms, automation is key
- Maintain baselines
  - Many are best practices and won't change, but some require constant updates
    - New vulnerability, new app, new OS, etc.
  - Test and measure to avoid conflicts/contradictions

Hardening Targets

- **No system is secure with default configurations!!!**
- Hardening guides: specific to software/platform, have best details
- Mobile devices: always connected mobile technologies
  - Updates are critical
  - Segmentation can protect data (company vs. user data)
  - Control with MDM (Mobile Device Manager)
- Workstations: user desktops and laptops
  - Need constant monitoring and updates (OSes, apps, etc.)
  - Automate monthly patches, probably an existing process
  - Remove unnecessary software
- Network infrastructure devices: switches, routers, firewalls, etc.
  - Purpose-built - embedded OS and applications
  - Configure authentication - DO NOT USE DEFAULTS
  - Check with manufacturer for security updates
- Cloud infrastructure
  - Use principle of least privilege (services, network settings, etc.)
  - Configure Endpoint Detection and Response (EDR) - all devices accessing the cloud should be secure
  - Always have backups between different providers (Cloud to Cloud / C2)
- Servers
  - Windows, Linux, etc.
  - Updates - OS updates / service packs, patches
  - User accounts - password policies, account permissions
  - Limit network access and employ authentication
  - Monitor and secure with anti-virus, -malware, etc.
- SCADA/ICS: industrial and manufacturing equipment
  - PC manages equipment
    - Power, refining, manufacturing

    - Distributed control systems - real time info, system control
    - Requires extensive segmentation, no access from outside
- Embedded systems: hardware and software designed for a specific function or operate as par of a larger system
    - Can be difficult to upgrade
    - Correct vulnerabilities, segment and firewall to prevent access
- RTOS (Real-Time Operating System): deterministic processing schedule
    - Industrial equipment, automobiles, military
    - Isolate to prevent access
    - Run with minimum services
    - Use secure communication
- IoT devices: heating and cooling, lighting, home automation, wearables, etc.
    - Weak defaults - CHANGE PASSWORDS
    - Deploy updates quickly
    - Segmentation - put on own LAN/VLAN

Securing Wireless and Mobile

- Site survey: determine the existing the wireless landscape
    - Identify existing access points
    - Work around existing frequencies
    - Plan for ongoing surveys
    - Heat maps identify wireless signal strengths
- Wireless survey tools
    - Signal coverage, potential interference
    - Built-in tools sometimes exist in OSes, also 3rd-party tools
    - Spectrum analyzer shows all on particular freq.
- Mobile Device Manager (MDM)
    - Manage company-owned and user-owned mobile devices
    - Centralized management
    - Set policies on apps, data, etc.
    - Manage access control
- BYOD (bring your own device/tech)
    - Employee owns the device, difficult to secure
- COPE (corporate owned, personally enabled)
    - Company buys, used as corporate and personal
    - Org. keeps full control, info protected by corp. policies
    - CYOD (choose your own device) - choose your COPE
- Cellular networks (for mobile) - 4G LTE, 5G, etc.
    - Separate land into "cells" - antenna covers a cell with certain frequencies
    - Security concerns - traffic monitoring, location tracking, worldwide access to a mobile device
- Wi-Fi
    - Local network access = local problems
    - Same security concerns as other Wi-Fi devices
    - Data capture - encrypt!
    - On-path attack / MITM
    - Denial of service
- Bluetooth: PAN (personal area network), high speed comm. over short distances
    - Connects our mobile devices
    - Do not connect to unknown Bluetooth devices

Wireless Security Settings

- Authenticate users before granting access, ensure all communication is confidential, verify integrity of all communication
    - Message Integrity Check (MIC)
- The WPA2 PSK problem: brute force problem
    - Listen to four-way handshake, capture hash
    - With hash, pre-shared key (PSK) can be brute forced
    - Some methods can even derive PSK without the handshake

    - Weak PSK is easier to brute force
        - Amazing GPUs and cloud-based password cracking
    - Once you have PSK, you have everyone's wireless key
- WPA3 and GCMP: Wi-Fi Protected Access 3 (WPA3)
    - GCMP block cipher mode (Galois/Counter Mode Protocol)
        - Stronger encryption
        - Data confidentiality with AES
        - MIC with GMAC (Galois Message Authentication Code)
- SAE (Simultaneous Authentication of Equals)
    - WPA3 changes the PSK auth process
    - Creates a shared session key without sending that key across the network
    - Diffie-Hellman derived key exchange with an authentication component
    - IEEE standard - the dragonfly handshake
- Wireless authentication methods
    - Credentials - shard password / PSK or centralized authentication (802.1X)
    - Configuration - part of the connection, prompted during connection process
- Wireless security modes
    - Open system - no auth
    - WPA3-Personal/-PSK - WPA2 or 3 with a pre-shared key
    - WPA3-Enterprise/-802.1X - authenticate users individually w/ server
- AAA framework
    - Identification - who do you claim to be (username)
    - Authentication - prove you are who you claim to be (password)
    - Authorization - what access do you have
    - Accounting - what did you use and for how long
    -
- RADIUS (Remote Authentication Dial-in User Service) - common AAA protocol
    - Centralized authentication for users (user+pass)
    - Routers, switches, firewalls, servers, VPNs, 802.1X networks
- IEEE 802.1X - port-based Network Access Control (NAC)
    - Used in conjunction with an access database (RADIUS, LDAP, TACACS+)
- EAP (Extensible Authentication Protocol)
    - Many different ways to auth based on RFC standards
    - Integrates with 802.1X, prevents access until auth succeeds
- IEEE 802.1X and EAP
    - Supplicant - client
    - Authenticator - provides access
    - Authentication server - validates credentials
    - Supplicant talks to authenticator, authenticator talks to server

Application Security

- Secure coding concepts - balance between time and quality
    - Quality Assurance (QA) process - you MUST test
    - Vulnerabilities will eventually be found and exploited
- Input validation - what is the expected input? Compare
    - Document all input methods
    - Check and correct all input (normalization)
    - Prevent SQL injections!
    - Fuzzers (random inputters) will find what you missed
- Secure cookies - info stored on computer by browser
    - Used for tracking, personalization, session management
    - Secure cookies have secure attribute set (only over HTTPS)
    - Sensitive info should NOT be stored in cookies
- Static code analyzers
    - Static Application Security Testing (SAST)

    - Many vulns found easily with static analysis (buffer overflows, injections, etc.)
    - But not everything (auth security, insecure crypto, etc.), don't rely on automatic static analysis
    - You still have to verify each finding, some may be false positives
  - Code signing
    - Verifying application is the original and originated from the correct place
    - Application code can be digitally signed by developer, similar to website certificates
  - Sandboxing - running the application in a safe test environment
    - Limit to fewest resources possible
    - Used in many different deployments - VMs, mobile devices, browser iframes, Windows User Account Control (UAC)
  - Application security monitoring
    - Real-time information about usage, attacks, anomalies, etc.
    - View blocked attacks (injections, etc.)
    - Audit the logs to find info and hidden attacks

Tips y trucos para el examen:

SEGURIDAD WIRELESS:

- WPA3 (Wi-Fi Protected Access 3): estandar actual, usa SAE (Simultaneous Authentication of Equals)
- WPA2: anterior estandar, vulnerable a KRACK attack
- WEP: completamente roto, no usar nunca
- RADIUS: servidor de autenticacion centralizado para redes WiFi empresariales (802.1X)
- Rogue AP: punto de acceso no autorizado conectado a la red corporativa
- Evil twin: AP falso que imita al legitimo para capturar trafico

SEGURIDAD EN APLICACIONES:

- Input validation: verificar que los datos de entrada son del tipo y formato esperado (previene SQLi, XSS)
- Secure cookies: flags HttpOnly (no accesible por JS) y Secure (solo HTTPS)
- Static code analysis (SAST): analizar el codigo fuente sin ejecutarlo, busca vulnerabilidades
- Dynamic analysis (DAST): analizar la aplicacion mientras se ejecuta
- Code signing: firmar digitalmente el codigo para verificar su autenticidad e integridad
- Sandboxing: ejecutar codigo en un entorno aislado para observar su comportamiento

Preguntas de practica (43):

1. Which of the answers listed below refers to a mobile device deployment model where organizations provide and own the devices while allowing their personal use?

A) BYOD
B) COPE
C) VDI
D) CYOD

---

2. Which of the answers listed below refers to a mobile device deployment model that allows employees to use private mobile devices for accessing company's restricted data and applications?

A) COPE
B) BYOD
C) JBOD
D) CYOD

---

3. Which of the answers listed below refer to workstation hardening techniques? (Select 3 answers)

A) Hiding administrator accounts
✓ B) Regularly applying security patches and updates to the OS and installed software
C) Disabling all internet access
✓ D) Removing or disabling unnecessary drivers, services, software, and network protocols
✓ E) Limiting unauthorized or unauthenticated user access

---

4. Which type of software allows centralized control over the configuration, monitoring, and security of mobile devices used within an organization?

A) MDR
B) IAM

C) SIEM

✓ **D) MDM**

5. Which of the answers listed below refers to software that facilitates the enforcement of mobile device policies and procedures?

A) NAC

B) MDM

C) XDR

D) PAM

6. Which of the following answers refers to a countermeasure against code injection?

A) Fuzzing

✓ **B) Input validation**

C) Code signing

D) Normalization

7. Which of the following answers refers to a software tool that provides a single management interface for mobile devices, PCs, printers, IoT devices and wearables?

A) MDM

B) RCS

✓ **C) UEM**

D) MAM

8. Which of the following answers refers to a countermeasure against code injection?

A) Fuzzing

✓ **B) Input validation**

C) Code signing

D) Normalization

9. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting

✓ **B) Log monitoring**

C) Sandboxing

✓ **D) Security audits**

✓ **E) CCTV**

✓ **F) IDS**

✓ **G) Vulnerability scanning**

10. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems

B) Video surveillance

✓ **C) MFA**

✓ **D) Application sandboxing**

✓ **E) Network segmentation**

11. Given the computational limitations of IoT devices, smartcards, and mobile devices, which of the following digital signature algorithms would be the most efficient choice due to its smaller key size and lower processing requirements?

A) RSA

B) ECDHE

C) DSA

✓ **D) ECDSA**

E) ECC

12. The term "Rooting" refers to the capability of gaining administrative access to the operating system and system applications on:

A) Android devices

B) iOS devices

C) Microsoft devices
D) All types of mobile devices

13. Which of the following answers does not refer to the concept of system/application isolation?

A) Virtualization
B) Containerization
C) Sandboxing
✓ D) Data encryption

14. A mobile device's built-in functionality enabling the usage of locator applications is known as:

A) WPS
B) GSM
C) SIM
✓ D) GPS

15. Which of the answers listed below refers to a technology that provides control over the usage of a mobile device within a designated area?

A) Geofencing
B) Device tracking
C) Perimeter security
D) Geolocation

16. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise
B) Sandboxing
C) Threat hunting
D) Security awareness training
Respuesta no detectada automaticamente

17. Which of the terms listed below is used to describe a foundational level of security configurations and settings required to safeguard a system?

A) Logical segmentation
✓ B) Secure baseline
C) Access control levels
D) Principle of least privilege

18. Data on a lost or stolen mobile device can be erased by:

A) Rooting
B) Sideloading
C) Low-level formatting
✓ D) Remote wipe

19. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks
B) IEEE 802.1D
C) Does not require an authentication server
✓ D) IEEE 802.1X
E) Suitable for all types of wireless LANs
✓ F) Requires RADIUS authentication server

20. Which of the following acronyms refers to a client authentication method used in WPA3 Personal mode?

A) SAE
B) IKE
C) PSK
D) AES

21. Which of the programming aspects listed below are critical in the secure application development process? (Select 2 answers)

A) Patch management

✓ **B) Input validation**

C) Password protection

✓ **D) Error and exception handling**

E) Application whitelisting

---

22. Which of the terms listed below refers to an automated or manual code review process aimed at discovering logic and syntax errors in the application's source code?

A) Input validation

B) Dynamic code analysis

C) Fuzzing

✓ **D) Static code analysis**

---

23. The practice of finding vulnerabilities in an application by feeding it incorrect input is called:

A) Normalization

B) Hardening

C) Dynamic code analysis

✓ **D) Fuzzing**

---

24. Which of the terms listed below refers to tracking and managing software application components, such as third-party libraries and other dependencies?

A) Version control

B) Package monitoring

C) Configuration enforcement

D) Application hardening

---

25. In the incident response process, the step that involves identifying and understanding potential incidents to determine their scope, impact, and root cause is a part of the:

A) Preparation stage

✓ **B) Detection and analysis stage**

C) Containment, eradication, and recovery stage

D) Post-incident activity stage

---

26. The term "Metadata" refers to data that provides information about other data, but not the actual content of the data. Typically, metadata is not visible to the user by default but can be accessed if needed. For example, email metadata, found in email headers, includes detailed information about the sender, recipient, and the route the message took. Mobile device metadata encompasses details such as the device model, geolocation, camera information, internet usage, phone call and text messaging activity, application usage statistics, and metadata from various files on the device. In web browsing, metadata comes from HTML meta tags located in the head section of a web page. For files, metadata includes details about the author (e.g., the file creator), file type, size, creation date and time, and the last modification date and time.

A) True

B) False

---

27. Which wireless security protocol has been deprecated in favor of newer standards due to known vulnerabilities resulting from implementation flaws?

A) EAP

B) AES

C) WPA2

✓ **D) WEP**

---

28. Which of the terms listed below applies to the authentication process?

A) MFA

B) MMC

C) MDM

D) MFD

29. Which of the answers listed below refers to a mobile device's built-in functionality enabling the usage of locator applications?

A) WPS
B) GSM
C) SIM
✓ D) GPS

30. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ B) Log monitoring
C) Sandboxing
✓ D) Security audits
✓ E) CCTV
✓ F) IDS
✓ G) Vulnerability scanning

31. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems
B) Video surveillance
✓ C) MFA
✓ D) Application sandboxing
✓ E) Network segmentation

32. Given the computational limitations of IoT devices, smartcards, and mobile devices, which of the following digital signature algorithms would be the most efficient choice due to its smaller key size and lower processing requirements?

A) RSA
B) ECDHE
C) DSA
✓ D) ECDSA
E) ECC

33. The term "Rooting" refers to the capability of gaining administrative access to the operating system and system applications on:

A) Android devices
B) iOS devices
C) Microsoft devices
D) All types of mobile devices

34. Which of the answers listed below refers to a technology that provides control over the usage of a mobile device within a designated area?

A) Geofencing
B) Captive portal
C) Honeypot
D) Geolocation
Respuesta no detectada automaticamente

35. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise
B) Sandboxing
C) Threat hunting
D) Security awareness training
Respuesta no detectada automaticamente

36. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks
B) IEEE 802.1D
C) Does not require an authentication server
✓ **D) IEEE 802.1X**
E) Suitable for all types of wireless LANs
✓ **F) Requires RADIUS authentication server**

37. Which of the following acronyms refers to a client authentication method used in WPA3 Personal mode?

A) SAE
B) IKE
C) PSK
D) AES

38. Which of the wireless encryption schemes listed below offers the highest level of protection?

A) WPS
✓ **B) WPA3**
C) AES
D) TKIP

39. Which of the programming aspects listed below are critical in the secure application development process? (Select 2 answers)

A) Patch management
✓ **B) Input validation**
C) Password protection
✓ **D) Error and exception handling**
E) Application whitelisting

40. Which of the terms listed below refers to an automated or manual code review process aimed at discovering logic and syntax errors in the application's source code?

A) Input validation
B) Dynamic code analysis
C) Fuzzing
✓ **D) Static code analysis**

41. The practice of finding vulnerabilities in an application by feeding it incorrect input is called:

A) Normalization
B) Hardening
C) Dynamic code analysis
✓ **D) Fuzzing**

42. Which of the terms listed below refers to tracking and managing software application components, such as third-party libraries and other dependencies?

A) Version control
B) Package monitoring
C) Configuration enforcement
D) Application hardening

43. The principle of least privilege is a security rule that prevents users from accessing information and resources that lie beyond the scope of their responsibilities.

A) True
B) False
Respuesta no detectada automaticamente

4.2 - Explain the security implications of proper asset management.

Conceptos clave:

- Acquisition/procurement process

- Assignment/accounting: Ownership, Classification
- Monitoring: Inventory, Enumeration
- Disposal: Sanitization, Destruction, Certification, Data retention

Teoria (Professor Messer):

and data asset management."

Asset Management

- Acquisition/procurement process - the purchasing process
  - Start with request from user
  - Negotiate with suppliers
  - Purchase, invoice, and payment
- Assignment/accounting
  - Central asset tracking system to keep tabs
  - Ownership - associate person with asset
  - Classification - type of asset
    - Then classify it as hardware or software (taxed differently)
    - Hardware = capital expenditure
    - Software = operating expenditure
- Monitoring / asset tracking
  - Inventory every asset
  - Ability to associate support ticket with device make and model
  - Enumeration - list all parts of an asset, list as entity
  - Add an asset tag - barcode, RFID, tracking number, org. name, etc.
- Media sanitization
  - System disposal or decommissioning - completely remove data for security
  - Different use cases - clean hard drive, permanently delete single file, etc.
  - One-way trip so no recovery with forensics tools
  - Reuse the storage media
- Physical destruction - no recovery, no reuse, absolute certainty of destruction
  - Shredder/pulverizer - complete destruction
  - Drill/hammer - quick and easy
  - Electromagnetic (degaussing)
  - Incineration - fire :)
- Certificate of destruction - what if you need to destroy in bulk
  - Often done by 3rd party, need confirmation for destruction
  - Thus, service involves certificate with paper trail of destruction
- Data retention - back up your data!
  - Regulatory compliance - certain amount of data backup to comply
  - Operational needs - accidental deletion, disaster recovery
  - Differentiate by type and application

Tips y trucos para el examen:

INVENTARIO Y SEGUIMIENTO:

- Asset inventory: lista de todos los activos con sus propiedades (owner, clasificacion, ubicacion)
- Enumeration: proceso de descubrir activos en la red (escaneo activo)
- Configuration Management Database (CMDB): base de datos de activos y sus relaciones

DISPOSICION SEGURA DE DATOS:

- Data sanitization: eliminar datos de forma que no puedan recuperarse

- Overwriting: sobreescribir con ceros/unos (no vale para SSDs)

- Degaussing: campo magnetico que destruye datos en discos magneticos (no vale para SSDs)

- Cryptographic erasure: destruir la clave de cifrado (los datos cifrados son irrecuperables)

- Physical destruction: destruir fisicamente el medio (triturar, fundir)

- Data retention: cuanto tiempo deben guardarse los datos (definido por ley o politica)
- Certificate of destruction: documento que certifica la destruccion segura del medio

Preguntas de practica (2):

1. One of the ways to prevent data recovery from a storage drive is to overwrite its contents. The data overwriting technique is used by drive wipe utilities which might employ different methods (including multiple overwriting rounds) to decrease the likelihood of data retrieval. As an example, a disk sanitization utility might overwrite the data on the drive with the value of one in the first pass, change that value to zero in the second pass, and finally perform a few more passes, overwriting the contents with random characters.

A) True

B) False

---

2. Which policy typically specifies the period during which certain types of data must be stored prior to disposal?

A) Data protection policy

B) Data classification policy

C) Data backup policy

✓ **D) Data retention policy**

4.3 - Explain various activities associated with vulnerability management.

Conceptos clave:

- Identification: Vulnerability scan, Static/Dynamic analysis, Threat feed, OSINT, Pen testing
- Analysis: False positive/negative, CVSS, CVE, Exposure factor, Risk tolerance
- Response: Patching, Insurance, Segmentation, Compensating controls
- Validation: Rescanning, Audit, Verification

Teoria (Professor Messer):

management."

Vulnerability Scanning

- Minimally invasive, scan for potential of attack
- Port scan, identify systems, test from outside and inside network, gather info
- Static code analyzers (Static Application Security Testing) - prev.
- Dynamic analysis (fuzzing) - send random input to application
  - Look for something out of the ordinary
  - First: 1988 class project at Univ. Wisconsin, "The Fuzz Generator"
- Fuzzing engines and frameworks
  - Very time and resource heavy
  - Carnegie Mellon CERT Basic Fuzzing Framework (BFF)
- Package monitoring
  - Some apps distributed in a package (especially in Linux)
  - Confirm the package is legit - trusted source, no malware, etc.
  - Confirm a safe package before deployment

Threat Intelligence

- Always keep up to date with threats and threat actors
- Make security decisions based on this intelligence
- Open-source intelligence (OSINT)
  - Publicly available sources on the internet - social media, forums, etc.
  - Government data - public hearings, reports, websites, etc.
  - Commercial data - maps, financial reports, databases, etc.
- Proprietary / third-party intelligence
  - Someone else already compiled threat info, you buy it
  - Threat intelligence services - analytics, correlations, threat monitoring
- Information-sharing organizations
  - Public threat intelligence - often classified info, compiled publicly
  - Private threat intelligence - private companies with extensive resources, additional details
  - Cyber Threat Alliance (CTA) - org. of groups that share threat intelligence

    - Members upload specifically formatted threat intelligence
    - CTA scores and validates across other submissions
- Dark web intelligence
  - Dark web - overlay networks that use the internet, requires specific software to access
  - Hacking groups and services - extract activities, tools, techniques, etc.
  - Monitor dark web forums for intelligence

Penetration Testing

- Simulate an attack on your own systems - like vuln scanning, but you exploit the vulnerabilities
- Often for compliance purposes, done by a third-party
- [NIST Technical Guide to Information Security Testing and Assessment](https://csrc.nist.gov/pubs/sp/800/115/final)
- Rules of engagement - defines purpose and scope of testing
  - Type of testing and schedule - on-site vs remote, internal vs external, within or outside working hours, etc.
  - Rules - IP ranges, emergency contacts, sensitive info handling, in- and out-of-scope devices/applications
- Exploiting vulnerabilities - try to break into the system
  - Be careful, can cause DoS or loss of data
  - Try different vulnerabilities - password brute-force, social engineering, database (SQL) injections, buffer overflows, privilege escalation, etc.
- The process
  - Initial exploitation - get into the network
  - Lateral movement - system to system
  - Persistence - make sure you can stay or get a way back in (backdoor, etc.)
  - The pivot - gain access to systems normally not accessible
    - Use vulnerable system as proxy or relay
- Responsible disclosure program (like CVE db)
  - It takes time to fix a vulnerability - software changes, testing, deployment, etc.
    - May be a while between disclosure and patching!
  - Bug bounty programs - reward for discovering vulnerabilities
  - Controlled information release
    - Researcher reports vulnerability
    - Manufacturer creates a fix
    - Vulnerability announced publicly

Analyzing Vulnerabilities

- Dealing with false information\
  - False positives - vuln identifies that doesn't exist
    - Different than low-severity vuln - real but not highest priority
  - False negative - vuln exist but goes undetected
    - Much worse!
  - Update to the latest signatures, work with vuln detection manufacturer
- Prioritizing vulnerabilities - difficult
  - Refer to public disclosures and vulnerability databases
- Common Vulnerability Scoring System (CVSS) - quantitative scoring of a vulnerability, 0-10
  - Scoring standards change over time, different from CVSS 2.0 to 3.x
- CVE
  - Vulns can be cross-referenced
  - [Common Vulnerabilities and Exposures (CVE)](https://www.cve.org)
  - [National Vulnerability Database](https://nvd.nist.gov/) - synced with CVE list
  - [Microsoft Security Bulletins](https://learn.microsoft.com/en-us/security-updates/securitybulletins/securitybulletins)
  - Some vulns cannot be definitively identifies, check manually
- Vulnerability classification
  - Application scans - desktop/mobile apps
  - Web application scans - software on a web server
  - Network scans - misconfigured firewalls, open ports, vulnerable devices
- Exposure factor - loss of value or business activity if the vuln is exploited
  - Small DDoS may limit access to a service - 50%

    - Buffer overflow may completely disable a service - 100%
    - Consideration when prioritizing
  - Environmental variables - what type of environment is associated with this vulnerability?
    - Prioritization and patching frequency - isolated test lab vs database server in public cloud, etc.
    - Every environment is different!
      - Number and types of users (in- vs. external)
      - Revenue generating application
      - Potential for exploit
  - Industry/organizational impact - some exploits have significant consequences
    - Tallahassee Memorial HealthCare - Feb 2023 - ransomware
      - Diverted emergency cases, surgeries cancelled
    - Power utilities - SLC, Utah and LA County, California - March 2019 - DDoS from known unpatched vulnerability
  - Risk tolerance - amount of risk acceptable to an organization
    - Impractical to remove all risk
    - Timing of security patches - patching immediately doesn't allow for testing
      - Testing takes time, but you're vulnerable
      - Middle ground, may change based on security

Vulnerability Remediation

  - Patching - most common mitigation technique
    - Scheduled vuln/patch notices - normal, monthly/quarterly
    - Unscheduled patches - zero days, often urgent
    - Ongoing process, easy way to prevent most exploits
  - Insurance - cybersecurity insurance coverage
    - Lost revenue, data recovery, phishing, privacy lawsuits
    - Doesn't cover everything - intentional acts, funds transfers, etc.
    - Ransomware has increased popularity of this
  - Segmentation - limit the scope of an exploit by separating devices
    - Breach would have limited scope
    - Cant patch? Disconnect from the world, air-gap
    - Use internal NGFWs - block unwanted/unnecessary traffic between VLANs
      - Identify malicious traffic on the inside
    - Physical segmentation - separate switches, air-gapped
    - Logical segmentation - separate VLANs, cannot communicate b/w without layer 3 device / router
  - Compensating controls
    - Optimal security methods may not be available, compensate in other ways
    - Disable problematic service, revoke app access, limit external access, modify internal controls and firewalls, etc.
    - Provide coverage until a patch is deployed
  - Exceptions and exemptions
    - Removing vuln is optimal, but not everything can be patched
    - Provide service but also protect data and systems
    - Not all vulns share same severity - local login, physical access, etc.
    - Exception may be an option, formally approved for systems and apps
  - Validation of remediation - did the patch work?
    - Rescanning - vuln scan to verify
    - Audit - check systems to ensure
    - Verification - manually confirm security
  - Reporting
    - Ongoing checks required but difficult without automation
    - Continuous reporting solves this
      - Number of identified vulnerabilities
      - Systems patched vs. unpatched
      - New threat notifications
      - Errors, exceptions, exemptions

Tips y trucos para el examen:

ANALISIS DE RESULTADOS:

- False positive: la herramienta reporta una vulnerabilidad que no existe
- False negative: la herramienta NO reporta una vulnerabilidad que SI existe (el mas peligroso)
- Exposure factor: porcentaje del activo que se perderia si la vulnerabilidad se explota
- Risk tolerance: nivel de riesgo que la organizacion esta dispuesta a aceptar

RESPUESTA A VULNERABILIDADES:

- Patching: aplicar el parche del fabricante. Solucion preferida
- Compensating control: medida alternativa si no se puede parchear (ej: sistema legacy)
- Segmentation: aislar el sistema vulnerable en un segmento de red separado
- Insurance: transferir el riesgo economico mediante ciberseguro
- Accept: documentar y aceptar el riesgo conscientemente

Preguntas de practica (33):

1. A type of forensic evidence that can be used to detect unauthorized access attempts or other malicious activities is called:

A) CVE
✓ B) IoC
C) AIS
D) OSINT

---

2. Which of the answers listed below refers to a situation where no alarm is raised when an attack has taken place?

A) False negative
B) True positive
C) False positive
D) True negative
Respuesta no detectada automaticamente

---

3. Which of the following refers to a system that identifies, defines, and catalogs publicly known cybersecurity vulnerabilities?

A) TAXII
✓ B) CVE
C) STIX
D) CVSS

---

4. Which of the following answers refers to a more in-depth exercise, which can include activating systems and performing real actions to respond to the incident?

A) Penetration testing
B) Threat hunting
✓ C) Simulation
D) Vulnerability scanning

---

5. Which of the terms listed below refers to threat intelligence gathered from publicly available sources?

A) IoC
✓ B) OSINT
C) RFC
D) CVE/NVD

---

6. Which of the answers listed below refers to a concept that provides insights into methods and tools that cybercriminals use to carry out attacks?

A) TTP
B) CVE
C) ATT&CK
D) CVSS
Respuesta no detectada automaticamente

---

7. Which of the answers listed below refers to an industry standard for assessing and scoring the severity of computer system security vulnerabilities?

A) SIEM
B) CVSS
C) OSINT
D) SOAR

8. A type of forensic evidence that can be used to detect unauthorized access attempts or other malicious activities is called:

A) CVE
✓ B) IoC
C) AIS
D) OSINT

9. Which of the answers listed below refers to a situation where no alarm is raised when an attack has taken place?

A) False negative
B) True positive
C) False positive
D) True negative
Respuesta no detectada automaticamente

10. Which of the following refers to a system that identifies, defines, and catalogs publicly known cybersecurity vulnerabilities?

A) TAXII
✓ B) CVE
C) STIX
D) CVSS

11. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ B) Log monitoring
C) Sandboxing
✓ D) Security audits
✓ E) CCTV
✓ F) IDS
✓ G) Vulnerability scanning

12. Which of the following answers does not refer to a common type of OS-based vulnerability?

A) Access control and permissions vulnerabilities (weak passwords, privilege escalation)
B) Vulnerabilities in installed applications, system utilities, and device drivers
C) Memory-related vulnerabilities (memory leaks, buffer overflows, race conditions)
D) Patch and update management vulnerabilities (security patch and update delays, malicious updates)
E) Vulnerabilities related to system/security misconfigurations
F) Network-related vulnerabilities (DoS attacks, remote code execution attacks)
✓ G) All of the above answer choices are examples of OS-based vulnerabilities

13. Which of the answers listed below refer to workstation hardening techniques? (Select 3 answers)

A) Hiding administrator accounts
✓ B) Regularly applying security patches and updates to the OS and installed software
C) Disabling all internet access
✓ D) Removing or disabling unnecessary drivers, services, software, and network protocols
✓ E) Limiting unauthorized or unauthenticated user access

14. Which of the answers listed below refers to the process of assessing the physical environment, such as the layout of the building, to identify potential sources of interference and determine the optimal placement of a WAP?

A) Gap analysis
B) Capacity planning
✓ **C) Site survey**
D) Vulnerability scanning

15. Which of the programming aspects listed below are critical in the secure application development process? (Select 2 answers)

A) Patch management
✓ **B) Input validation**
C) Password protection
✓ **D) Error and exception handling**
E) Application whitelisting

16. A responsible disclosure program is a formal process established by an organization to encourage security researchers and ethical hackers to report vulnerabilities they discover in the organization's systems or software. A bug bounty program is a specific type of responsible disclosure program that offers financial rewards to security researchers for reporting valid vulnerabilities.

A) True
B) False

17. Which of the following terms refers to a framework and knowledge base that provides understanding of TTPs used during cyberattacks?

✓ **A) CVSS**
✓ **B) ATT&CK**
C) STIX
D) TAXII

18. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)
B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)
C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)
D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)
E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)
✓ **F) All of the above answers are examples of vulnerability response and remediation techniques**

19. Which of the answers listed below refers to a term primarily used in software development to describe the cost of short-term decisions that can lead to long-term problems?

A) Code entropy
B) Exposure factor
C) Risk register
✓ **D) Technical debt**

20. Which of the terms listed below refers to a general term that describes an organization’s overall attitude towards risk-taking?

A) Risk strategy
B) Risk control
✓ **C) Risk appetite**
D) Risk tolerance

21. In penetration testing, active reconnaissance involves gathering any type of publicly available information that can be used later for exploiting vulnerabilities found in the targeted system.

A) True
✓ **B) False**

22. Which of the following terms refers to a framework and knowledge base that provides understanding of TTPs used during cyberattacks?

A) CVSS

✓ B) ATT&CK

C) TAXII

D) STIX

23. Which of the terms listed below refers to a US government initiative for real-time sharing of cyber threat indicators?

A) NVD

✓ B) AIS

C) TTP

D) CVSS

24. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting

✓ B) Log monitoring

C) Sandboxing

✓ D) Security audits

✓ E) CCTV

✓ F) IDS

✓ G) Vulnerability scanning

25. What is the main vulnerability related to legacy hardware?

A) Compatibility issues

✓ B) Lack of security updates and patches

C) Worn-out physical components

D) Lack of skilled personnel to run it and maintain it

26. Which of the programming aspects listed below are critical in the secure application development process? (Select 2 answers)

A) Patch management

✓ B) Input validation

C) Password protection

✓ D) Error and exception handling

E) Application whitelisting

27. Vulnerability scanning: (Select all that apply)

A) Identifies lack of security controls

B) Actively tests security controls

✓ C) Identifies common misconfigurations

D) Exploits vulnerabilities

✓ E) Passively tests security controls

28. A responsible disclosure program is a formal process established by an organization to encourage security researchers and ethical hackers to report vulnerabilities they discover in the organization's systems or software. A bug bounty program is a specific type of responsible disclosure program that offers financial rewards to security researchers for reporting valid vulnerabilities.

A) True

B) False

29. Which of the following terms refers to a framework and knowledge base that provides understanding of TTPs used during cyberattacks?

✓ A) CVSS

✓ B) ATT&CK

C) STIX

D) TAXII

30. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ F) All of the above answers are examples of vulnerability response and remediation techniques

31. Which of the terms listed below refers to a general term that describes an organization's overall attitude towards risk-taking?

A) Risk strategy

B) Risk control

✓ C) Risk appetite

D) Risk tolerance

32. Penetration testing: (Select all that apply)

A) Bypasses security controls

B) Only identifies lack of security controls

✓ C) Actively tests security controls

✓ D) Exploits vulnerabilities

E) Passively tests security controls

33. In penetration testing, active reconnaissance involves gathering any type of publicly available information that can be used later for exploiting vulnerabilities found in the targeted system.

A) True

✓ B) False

4.4 - Explain security alerting and monitoring concepts and tools.

Conceptos clave:

- Activities: Log aggregation, Alerting, Scanning, Reporting, Archiving
- Alert response: Quarantine, Alert tuning
- Tools: SCAP, SIEM, Antivirus, DLP, SNMP traps, NetFlow, Vulnerability scanners

Teoria:

SIEM (Security Information and Event Management) - El centro neuralgico del SOC:

- Agrega logs de TODAS las fuentes: firewalls, servidores, endpoints, apps, cloud
- Correlaciona eventos de distintas fuentes para detectar ataques que no se ven aisladamente
- Ejemplo real: un login fallido en el firewall + acceso a un recurso sensible + transferencia de datos grande = posible compromiso aunque cada evento por separado parezca normal
- Productos: Splunk (lider de mercado), IBM QRadar, Microsoft Sentinel, Elastic SIEM, ArcSight

PROCESO DE ALERTING Y MONITOREO:

- Log aggregation: centralizar logs en un SIEM o SYSLOG server. Sin centralizacion no hay correlacion
- Alerting: reglas que disparan notificaciones cuando se cumplen condiciones (ej: 5 logins fallidos en 1 minuto)
- Alert tuning: ajustar umbrales para reducir FALSOS POSITIVOS sin perder detecciones reales. El mayor reto operativo de un SOC
- Quarantine: aislar automaticamente un endpoint cuando el SIEM detecta comportamiento malicioso
- Archiving: retener logs el tiempo exigido por ley (GDPR: minimo 1 ano, PCI DSS: 1 ano, algunos sectores hasta 7 anos)

HERRAMIENTAS DE MONITOREO CRITICAS:

- SCAP (Security Content Automation Protocol): framework NIST para automatizar verificacion de compliance y configuraciones seguras
- NetFlow/IPFIX: metadatos del trafico de red (origen, destino, puertos, bytes). No captura el contenido pero revela patrones
- SNMP v3: monitoreo de dispositivos de red con autenticacion y cifrado. SNMPv1/v2 son inseguros (comunidades en texto plano)

- DLP (Data Loss Prevention): inspecciona el contenido de emails, transferencias de archivos y trafico web buscando datos sensibles (numeros de tarjeta, SSN, datos marcados como confidenciales)
- Vulnerability scanner: Nessus, Qualys, OpenVAS. Escaneo periodico (minimo semanal en entornos criticos)
- Antivirus/EDR: diferencia clave: AV usa firmas, EDR analiza comportamiento en tiempo real y permite investigacion forense

TRUCO EXAMEN: SIEM = correlacion y retencion. DLP = prevencion de fuga. EDR = deteccion y respuesta en endpoint. NetFlow = quien habla con quien. SNMP = estado de dispositivos de red.

Preguntas de practica (29):

1. Which of the following answers refer to passive network monitoring techniques? (Select 2 answers)

A) Network tap
B) Trunk port
✓ C) Port mirroring
D) SNMP trap
E) Registered port

---

2. Which type of software allows centralized control over the configuration, monitoring, and security of mobile devices used within an organization?

A) MDR
B) IAM
C) SIEM
✓ D) MDM

---

3. Which of the following answers refer to SCAP? (Select 3 answers)

A) A type of security system designed to collect logs and events from various sources
✓ B) Designed to provide a centralized user interface for accessing collected data
✓ C) A collection of standards developed by NIST
✓ D) Provides a common language for communicating security information
✓ E) Allows different security tools to share data and work together more effectively
F) Enables real-time threat detection, incident response, and compliance monitoring

---

4. Simple Network Management Protocol (SNMP) is a UDP-based, application layer protocol used in network management systems to monitor network-attached devices. SNMP is typically integrated into most modern network infrastructure devices such as routers, bridges, switches, servers, printers, copiers, fax machines, and other network-attached devices. An SNMP-managed network comprises three essential components: a managed device, a network-management software module that resides on a managed device (Agent), and a Network Management Station (NMS), which runs applications responsible for monitoring and controlling managed devices, as well as collecting SNMP information from Agents. The manager receives notifications (Traps and InformRequests) on UDP port 162, while the SNMP Agent receives requests on UDP port 161.

A) True
B) False
Respuesta no detectada automaticamente

---

5. Which of the answers listed below refers to the process of maintaining the integrity of files and data?

A) DLP
B) SIEM
C) FIM
D) SHA

---

6. Which of the answers listed below refers to the process of maintaining the integrity of files and data?

A) DLP
B) SIEM
C) FIM
D) SHA

---

7. Which of the acronyms listed below refers to a protocol used in network management systems for monitoring network-attached devices?

A) SSH

B) VNC
C) SNMP
D) RDP

8. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ B) Log monitoring
C) Sandboxing
✓ D) Security audits
✓ E) CCTV
✓ F) IDS
✓ G) Vulnerability scanning

9. Which of the answers listed below refers to a Zero Trust Control Plane security approach that takes into account user identity, device security, network conditions, and other contextual information to enable dynamic access decisions?

A) Implicit trust
B) Monitoring and logging
✓ C) Adaptive identity
D) Microsegmentation

10. A honeyfile can be used for:

A) Attracting cyber attackers
B) Triggering alerts when accessed
C) Monitoring network activity
✓ D) All of the above

11. Which of the answers listed below refers to the most probable cause of an unauthorized access caused by the exploitation of a specific network entry point?

A) Outdated AV software
B) Browser cookies
✓ C) Open service ports
D) Insufficient logging and monitoring

12. Which of the answers listed below refer to the concept of data isolation? (Select 2 answers)

A) DLP
B) SDN
✓ C) EFS
D) SWG
E) EDR

13. Which of the following answers refers to software technology designed to simplify network infrastructure management?

A) SDN
B) SaaS
C) VDI
D) SNMP

14. Which of the terms listed below refers to tracking and managing software application components, such as third-party libraries and other dependencies?

A) Version control
B) Package monitoring
C) Configuration enforcement
D) Application hardening

15. Which of the following acronyms refers to software or hardware-based security solutions designed to detect and prevent unauthorized use and transmission of confidential information?

A) IPS

✓ **B) DLP**
C) IDS
D) DEP

16. In SNMP, each node in a MIB is uniquely identified by a(n):

A) DSU
✓ **B) OID**
C) CSU
D) OUI

17. A lightly protected subnet (a.k.a. DMZ) consisting of publicly available servers placed on the outside of the company's firewall is known as:

A) Captive portal
B) Quarantine network
C) Extranet
✓ **D) Screened subnet**

18. Which of the following answers refers to a solution that helps organizations mitigate risks associated with data breaches, insider threats, and compliance violations?

A) EDR
B) DLP
C) IAM
D) UTM

19. Which of the following acronyms refers to software or hardware-based security solutions designed to detect and prevent unauthorized use and transmission of confidential information?

A) IPS
✓ **B) DLP**
C) IDS
D) DEP

20. Which of the answers listed below refers to an industry standard for assessing and scoring the severity of computer system security vulnerabilities?

A) SIEM
B) CVSS
C) OSINT
D) SOAR

21. In modern OSs, this feature prevents malicious code from executing in certain memory regions intended for data.

A) DEP
B) ECB
C) DLP
D) CRC
Respuesta no detectada automaticamente

22. Which of the answers listed below refers to a protocol used by routers, hosts, and network devices to generate error messages and troubleshoot problems with delivery of IP packets?

A) CCMP
B) RSTP
C) ICMP
D) SNMP

23. Which of the following answers refers to a cybersecurity framework that combines network and security functions into a single cloud-based service?

A) SASE
B) SIEM
C) SWG

D) SOAR

24. Which of the following technologies enables automated handling of multiple security incidents?

A) SOAP
B) SIEM
✓ C) SOAR
D) SASE

25. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ B) Log monitoring
C) Sandboxing
✓ D) Security audits
✓ E) CCTV
✓ F) IDS
✓ G) Vulnerability scanning

26. Which of the terms listed below refers to tracking and managing software application components, such as third-party libraries and other dependencies?

A) Version control
B) Package monitoring
C) Configuration enforcement
D) Application hardening

27. Which of the following answers refer(s) to the containment, eradication, and recovery stage of the incident response process? (Select all that apply)

A) Restoring normal operations
✓ B) Eliminating the threat
C) Monitoring and detecting potential incidents
D) Establishing and maintaining an incident response policy
✓ E) Mitigating the impact of the incident

28. Which of the answers listed below refers to an example of recurring risk assessment?

✓ A) Real-time monitoring of network security threats
B) Assessing risk after a major organizational change or a security breach
C) Quarterly or annual risk assessments
D) Risk assessment for a new product launch

29. Which of the answers listed below refers to an example of continuous risk assessment?

A) Quarterly or annual risk assessments
B) Risk assessment for a new product launch
C) Assessing risk after a major organizational change or a security breach
D) Real-time monitoring of network security threats

4.5 - Modify enterprise capabilities to enhance security.

Conceptos clave:

- Firewall: Rules, Access lists, Ports/protocols, Screened subnets
- IDS/IPS: Trends, Signatures
- Web filter: URL scanning, Content categorization, Reputation
- Email security: DMARC, DKIM, SPF
- DNS filtering, File integrity monitoring, DLP, NAC, EDR/XDR

Teoria:

FIREWALLS - Configuracion y tipos:

- Reglas de firewall se evaluan en orden, de arriba a abajo. La primera regla que coincide gana
- Implicit deny all: ultima regla implicita que deniega todo lo no permitido explicitamente. SIEMPRE existe aunque no se vea

• Stateful inspection: recuerda el estado de las conexiones TCP. Permite respuestas a conexiones iniciadas desde dentro sin regla explicita de retorno
• Screened subnet (DMZ): red intermedia entre internet e intranet. Los servidores publicos van aqui
• Fail-open vs Fail-closed: si el firewall falla, fail-open deja pasar todo (disponibilidad), fail-closed bloquea todo (seguridad)

IDS vs IPS - La diferencia critica para el examen:

• IDS (Intrusion Detection System): PASIVO. Detecta y alerta. No bloquea. Se conecta a un TAP o puerto SPAN del switch
• IPS (Intrusion Prevention System): ACTIVO. Detecta Y bloquea. Se conecta EN LINEA (inline). Puede causar falsos positivos que bloqueen trafico legitimo
• Signature-based: compara con firmas de ataques conocidos. Rapido, pocos falsos positivos, NO detecta zero-days
• Anomaly/behavior-based: aprende el trafico 'normal' y alerta ante desviaciones. Detecta zero-days, mas falsos positivos
• HIDS/HIPS: instalado en el host, ve trafico cifrado desde dentro, consume recursos del sistema
• NIDS/NIPS: en la red, no consume recursos del host, no ve trafico cifrado sin inspeccion SSL

EMAIL SECURITY - SPF, DKIM y DMARC:

• SPF: registro TXT en DNS que lista las IPs autorizadas a enviar email del dominio. El receptor verifica que el email viene de una IP en la lista

Ejemplo: 'v=spf1 ip4:192.168.1.0/24 include:sendgrid.net ~all'

• DKIM: el servidor de email firma el mensaje con su clave privada. El receptor verifica la firma con la clave publica en DNS

Garantiza: el contenido no fue modificado en transito

• DMARC: politica que dice que hacer si SPF o DKIM fallan

- p=none: solo monitorizar, no rechazar
- p=quarantine: enviar a spam
- p=reject: rechazar el email completamente

• TRUCO: para recordar el orden: 'SPF Dice que IPs pueden enviar, DKIM firma el contenido, DMARC decide que hacer si fallan'

OTRAS CAPACIDADES DE SEGURIDAD EMPRESARIAL:

• Web filter/URL filtering: categorizar sitios (gambling, adult, malware) y bloquear categorias. Puede hacerse a nivel DNS (Cisco Umbrella) o a nivel proxy (Zscaler)
• DNS filtering: bloquear dominios maliciosos antes de que la conexion se establezca. Primera linea de defensa contra phishing y C2
• File integrity monitoring (FIM): Tripwire, AIDE. Detecta cambios no autorizados en archivos criticos del sistema (/etc/passwd, registros de Windows). Critico para detectar rootkits
• NAC (Network Access Control): verifica que un dispositivo cumple los requisitos de seguridad ANTES de permitirle conectarse a la red (antivirus actualizado, parches al dia, certificado valido)
• EDR (Endpoint Detection and Response): va mas alla del antivirus. Registra TODA la actividad del endpoint (procesos, conexiones, archivos) para investigacion forense. Permite aislar remotamente un endpoint comprometido
• XDR (Extended Detection and Response): correlaciona telemetria de endpoint, red, email y cloud en una sola plataforma

Preguntas de practica (62):

1. Which of the following answers refers to a policy framework that allows domain owners to specify how email receivers should handle emails that fail authentication checks?

✓ A) DKIM
B) SPF
C) PEM
✓ D) DMARC

---

2. Which of the answers listed below refers to an authentication method that enables the signing of an outbound email message with a digital signature?

A) SPF
B) DKIM
C) DMARC
D) PEM

---

3. Which of the following answers refers to an email authentication mechanism that allows domain owners to specify which IP addresses are authorized to send emails on behalf of their domain?

A) DMARC
B) PEM

C) DKIM
D) SPF

4. Which of the answers listed below refers to a cryptographic standard (and a file format) used for the storage and transmission of private keys in email communications?

A) PEM
B) DMARC
C) SPF
D) DKIM

5. Which DNS TXT records are used for spam management? (Select 3 answers)

A) SPF
✓ B) DKIM
C) SRV
✓ D) DMARC
E) PTR

6. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP
✓ B) AUP
C) IDS
D) MFA
E) IPS

7. Which of the following provides active network security breach response on an individual computer system?

A) NIDS
B) HIDS
C) NIPS
✓ D) HIPS

8. Which of the answers listed below refers to software that facilitates the enforcement of mobile device policies and procedures?

A) NAC
B) MDM
C) XDR
D) PAM

9. Which of the following acronyms refers to software or hardware-based security solutions designed to detect and prevent unauthorized use and transmission of confidential information?

A) IPS
✓ B) DLP
C) IDS
D) DEP

10. Which of the following answers illustrates the difference between passive and active network security breach response?

A) HIPS vs. NIPS
B) UTM vs. Firewall
C) NIPS vs. UTM
✓ D) IDS vs. IPS

11. Which of the following acronyms refers to software or hardware-based security solutions designed to detect and prevent unauthorized use and transmission of confidential information?

A) IPS
✓ B) DLP
C) IDS
D) DEP

12. Which of the answers listed below refers to a network security technology designed to monitor, detect, and mitigate unauthorized access, security threats, and suspicious activities in WLANs?

A) WIPS
B) NIDS
C) NIPS
D) WIDS

13. Which of the following solutions provides active network security breach response on an individual computer system?

A) NIDS
B) HIDS
C) NIPS
✓ D) HIPS

14. Which of the following answers refers to a DNS TXT record that allows the owner of a domain to specify all the servers authorized to send mail from their domain?

A) DKIM
B) SRV
C) CNAME
D) SPF

15. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP
✓ B) AUP
C) IDS
D) MFA
E) IPS

16. What are the examples of preventive security controls? (Select 3 answers)

A) Encryption
B) IDS
C) Sensors
✓ D) Firewalls
E) Warning signs
✓ F) AV software

17. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ B) Log monitoring
C) Sandboxing
✓ D) Security audits
✓ E) CCTV
✓ F) IDS
✓ G) Vulnerability scanning

18. Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication, and data integrity for network traffic?

A) TLS
B) SSH
✓ C) IPsec
D) VPN

19. An encryption protocol primarily used in Wi-Fi networks implementing the WPA2 security standard is called:

A) TKIP
✓ B) CCMP
C) SSL

D) IPsec

20. Which of the following answers refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL
B) IKE
C) ESP
D) DHE

21. Which of the following would indicate an attempt to hide evidence of malicious activity?

A) Account lockout
B) Resource inaccessibility
✓ C) Missing logs
D) Concurrent session usage

22. Which of the answers listed below refers to a solution that allows for easier management and control of network segmentation policies through software applications?

A) VDI
✓ B) SDN
C) VPC
D) EDR

23. Which of the answers listed below refer to the concept of data isolation? (Select 2 answers)

A) DLP
B) SDN
✓ C) EFS
D) SWG
E) EDR

24. Which of the answers listed below refers to a means for logical network segmentation?

A) Switch
B) VLAN
C) Screened subnet
D) Router

25. Which of the answers listed below refers to network security technology designed to monitor WLANs for unauthorized access, security threats, and suspicious activities?

A) UTM
B) WIDS
C) NGFW
D) WAF
Respuesta no detectada automaticamente

26. Which of the answers listed below refers to a hardware or software solution providing secure remote access to networks and resources?

A) NAC
B) RDP
C) SSH
✓ D) RAS

27. Which of the answers listed below refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL
✓ B) IKE
C) ESP
D) DHE

28. Which part of IPsec provides confidentiality, data integrity, and authentication?

A) AES
B) SHA
C) AH
✓ **D) ESP**

29. An IPsec mode providing encryption only for the payload (the data part of the packet) is referred to as:

A) Protected mode
B) Tunnel mode
✓ **C) Transport mode**
D) Safe mode

30. Encryption methods used to protect data in transit include: (Select all that apply)

A) NFS
✓ **B) VPN**
C) SED
✓ **D) IPsec**
E) FDE
✓ **F) TLS**

31. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA
✓ **B) CAPTCHA**
C) SSO
D) NIDS

32. Firewall rules are evaluated based on their order of precedence. Rules at the top of the list take precedence over rules further down the list. Once a matching rule is found, no further evaluation of subsequent rules occurs. The "implicit deny" policy on a firewall is a common default behavior in which any traffic that does not explicitly match any of the configured allow rules is automatically denied or blocked. In other words, if a packet does not meet the criteria of any allow rule, the default behavior of the firewall is to deny the traffic.

A) True
B) False

33. A lightly protected subnet (a.k.a. DMZ) consisting of publicly available servers placed on the outside of the company's firewall is known as:

A) Captive portal
B) Quarantine network
C) Extranet
✓ **D) Screened subnet**

34. Agent-based web filtering: (Select 3 answers)

A) Requires installing software on each device that needs to be monitored
✓ **B) Provides flexibility and granular control over web activity at the device level**
✓ **C) Involves increased management overhead and system resource consumption**
D) Simplifies administration and ensures consistent enforcement of web filtering policies across the network
✓ **E) Does not require software to be installed on each individual device**
F) Requires a functioning central server for web filtering to operate

35. Which of the answers listed below refer to filtering techniques that can allow or block access to a site based on its web address? (Select 2 answers)

A) SSL/TLS inspection
✓ **B) URL scanning**
C) Content categorization
✓ **D) DNS filtering**
E) Reputation-based filtering

36. In Windows Active Directory environment, this feature enables centralized management and configuration of operating systems, applications, and user account settings.

A) Local Users and Groups

B) Resource Monitor

✓ C) Group Policy

D) User Account Control

---

37. Which of the following answers refers to a security mechanism imposed by SELinux over system access?

A) DAC

B) RBAC

✓ C) MAC

D) ABAC

---

38. Which of the answers listed below refers to a secure replacement for Telnet?

A) RSH

B) IPsec

✓ C) SSH

D) RTPS

---

39. Which of the answers listed below refers to a secure network protocol used to provide encryption, authentication, and integrity for real-time multimedia communication?

A) IPsec

B) SIP

C) VoIP

✓ D) SRTP

---

40. Which of the following answers refers to a solution that helps organizations mitigate risks associated with data breaches, insider threats, and compliance violations?

A) EDR

B) DLP

C) IAM

D) UTM

---

41. Which of the answers listed below refers to a process of intercepting network traffic data for analysis and troubleshooting purposes?

A) AIS

✓ B) PCAP

C) EDR

D) MaaS

---

42. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA

✓ B) CAPTCHA

C) ACL

D) NIPS

---

43. An authentication subsystem that enables a user to access multiple, connected system components (such as separate hosts on a network) after a single login on only one of the components is referred to as:

A) NAC

✓ B) SSO

C) AAA

D) MFA

---

44. Which of the answers listed below refers to a suite of protocols and technologies providing encryption, authentication, and data integrity for network traffic?

A) TLS

B) SSH
C) IPsec
D) VPN

45. Which of the solutions listed below allows to check whether a digital certificate has been revoked?

A) OCR
✓ B) CRL
C) CSR
D) OSPF

46. Which of the following answers refers to a routing protocol used in computer networks to determine the best path for routing data packets from one network node to another?

A) BGP
B) EIGRP
C) RIP
D) OSPF

47. Which of the following answers refers to a hardware or software solution providing secure remote access to networks and resources?

A) NAC
B) RDP
C) SSH
D) RAS

48. Which of the following answers refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL
✓ B) IKE
C) ESP
D) DHE

49. Which type of software is used to prevent, detect, and remove malware from computer systems and networks?

A) IDS
B) SaaS
✓ C) AV
D) WAF

50. What is the fastest way for checking the validity of a digital certificate?

A) CRL
B) OSPF
C) CSR
✓ D) OCSP

51. Which of the answers listed below refer to the characteristic features of NIDS? (Select 3 answers)

A) Takes proactive measures to block or mitigate intrusion attempts
✓ B) Does not take direct action to block or prevent attacks
✓ C) Generates alerts and notifies security personnel or administrators when suspicious activity is detected
✓ D) Monitors network traffic without direct involvement in traffic routing or packet modification
E) Can drop or reject network packets, terminate connections, or take other actions to stop the attack
F) Operates in an inline mode, actively intercepting and inspecting network traffic

52. Which of the answers listed below refers to a deprecated TLS-based method for securing SMTP?

A) IDPS
B) STARTTLS
C) DKIM
D) SMTPS

53. What are the examples of preventive security controls? (Select 3 answers)

A) Encryption
B) IDS
C) Sensors
✓ D) Firewalls
E) Warning signs
✓ F) AV software

54. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting
✓ B) Log monitoring
C) Sandboxing
✓ D) Security audits
✓ E) CCTV
✓ F) IDS
✓ G) Vulnerability scanning

55. Which part of IPsec provides authentication, integrity, and confidentiality?

A) SPD
B) PFS
C) AH
✓ D) ESP

56. Which cryptographic protocol is designed to provide secure communications over a computer network and is the successor to SSL?

A) IPsec
✓ B) TLS
C) AES
D) CCMP

57. Which of the answers listed below refers to a protocol used to set up secure connections and exchange of cryptographic keys in IPsec VPNs?

A) SSL
✓ B) IKE
C) ESP
D) DHE

58. Which of the following would indicate an attempt to hide evidence of malicious activity?

A) Account lockout
B) Resource inaccessibility
✓ C) Missing logs
D) Concurrent session usage

59. Which of the answers listed below refer(s) to encryption method(s) used to protect data at rest? (Select all that apply)

A) FDE
✓ B) SED
C) IPsec
D) TLS
✓ E) VPN
✓ F) EFS

60. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA
✓ B) CAPTCHA
C) SSO

D) NIDS

61. Which of the protocols listed below is used to enable secure web browsing?

A) L2TP

✓ B) HTTPS

C) SSH

D) IPsec

62. Which of the answers listed below refers to a secure replacement for Telnet?

A) RSH

B) IPsec

C) SSH

D) RTPS

4.6 - Implement and maintain identity and access management.

Conceptos clave:

- Provisioning/de-provisioning, Identity proofing, Federation
- SSO: LDAP, OAuth, SAML
- Access controls: Mandatory, Discretionary, Role-based, Rule-based, Attribute-based
- MFA: Biometrics, Hard/soft tokens, Security keys (something you know/have/are/somewhere)
- Password: Length, Complexity, Reuse, Expiration, Managers, Passwordless
- PAM: Just-in-time permissions, Password vaulting, Ephemeral credentials

Teoria:

CICLO DE VIDA DE IDENTIDADES:

- Provisioning: crear cuenta, asignar rol y permisos cuando el empleado entra. Debe seguir el principio de least privilege
- Identity proofing: verificar la identidad antes de crear la cuenta (documento de identidad, presencia fisica en RRHH)
- De-provisioning: CRITICO hacerlo el mismo dia que el empleado sale. Cuentas huerfanas son un riesgo enorme
- Access review: revision periodica de que cada usuario solo tiene los permisos que necesita. Detecta privilege creep
- Privilege creep: acumulacion gradual de permisos a lo largo del tiempo. El empleado gana accesos para proyectos especificos y nunca se los retiran

PROTOCOLOS DE AUTENTICACION Y FEDERACION:

- LDAP (Lightweight Directory Access Protocol): puerto 389 (o 636 con LDAPS). Protocolo para consultar directorios (Active Directory). No es un protocolo de SSO sino de directorio
- Kerberos: protocolo de autenticacion de Windows. Funciona con tickets. KDC (Key Distribution Center) emite un TGT (Ticket Granting Ticket) que se usa para obtener tickets de servicio sin reenviar la contrasena
- SAML 2.0: estandar XML para SSO federado entre empresas. IdP (Identity Provider) emite assertions que el SP (Service Provider) acepta. Usado en SSO empresarial con aplicaciones web
- OAuth 2.0: framework de AUTORIZACION (no autenticacion). Permite a una app (cliente) acceder a recursos en nombre del usuario sin compartir la contrasena. Usado por 'Login con Google'
- OpenID Connect (OIDC): capa de AUTENTICACION sobre OAuth 2.0. Anade el concepto de ID Token (JWT) que contiene informacion del usuario
- TRUCO: SAML = SSO empresarial entre organizaciones, OAuth = autorizacion de APIs, OIDC = autenticacion moderna sobre OAuth

MODELOS DE CONTROL DE ACCESO - Comparativa:

- MAC (Mandatory Access Control): el administrador del sistema asigna etiquetas de clasificacion a usuarios y recursos. El SO decide el acceso. Nadie puede cambiar su propio nivel de acceso. Ejemplo: sistemas militares (Top Secret, Secret, Confidential)
- DAC (Discretionary Access Control): el PROPIETARIO del recurso decide quien puede acceder. El modelo de Windows/Linux con permisos de archivo. Mas flexible pero menos seguro
- RBAC (Role-Based Access Control): el acceso se basa en el ROL del usuario en la organizacion. Mas facil de gestionar que DAC en organizaciones grandes. Ejemplo: todos los 'contables' tienen acceso al sistema financiero
- ABAC (Attribute-Based Access Control): el acceso se decide evaluando ATRIBUTOS del usuario, el recurso y el entorno. Ejemplo: 'acceso permitido si el usuario es gerente Y el recurso es del departamento de ventas Y son horario laboral'. El mas granular y flexible
- Rule-based: reglas fijas que se aplican a todos. Ejemplo: reglas de firewall

MFA - FACTORES DE AUTENTICACION:

• Something you know: contrasena, PIN, patron de desbloqueo, preguntas de seguridad
• Something you have: token hardware (YubiKey, RSA SecurID), smartphone con app TOTP, tarjeta inteligente, certificado digital
• Something you are: biometria. Tipos: huella dactilar, reconocimiento facial, iris, voz, escritura (behavioral)
• Somewhere you are: geolocation, IP de red conocida
• TOTP (Time-based OTP): RFC 6238. Codigo de 6 digitos que cambia cada 30 segundos. Calculado con HMAC-SHA1(secret_key, timestamp/30)
• FIDO2/WebAuthn: el estandar mas moderno y seguro. Usa criptografia asimetrica. La clave privada nunca sale del dispositivo. Resistente a phishing porque la clave esta vinculada al dominio
• Passwordless: elimina la contrasena completamente. Usa FIDO2, magic links por email, o biometria

PAM - PRIVILEGED ACCESS MANAGEMENT:

• El mayor riesgo en cualquier organizacion son las cuentas privilegiadas (admin, root, service accounts)
• Password vaulting: las contrasenas de cuentas privilegiadas se almacenan en un vault cifrado (CyberArk, HashiCorp Vault). Los administradores solicitan acceso al vault, no conocen la contrasena directamente
• Just-in-time (JIT) access: el acceso privilegiado se concede solo cuando se necesita y por un tiempo limitado (ej: 1 hora). Tras ese tiempo se revoca automaticamente
• Session recording: todas las acciones de administradores privilegiados se graban para auditoria y no repudio
• Ephemeral credentials: credenciales de un solo uso que expiran tras ser usadas. Ideal para pipelines CI/CD

Preguntas de practica (87):

1. Which access control model allows for defining granular rules that consider user roles, time constraints, and network access restrictions?

A) ABAC
B) MAC
✓ C) RuBAC
D) DAC
E) RBAC

---

2. Which access control model defines access control rules with the use of statements that closely resemble natural language?

A) DAC
✓ B) ABAC
C) MAC
D) RBAC

---

3. Which of the following access control methods would be the most suitable for scheduling system maintenance tasks during periods of low user activity?

A) Resource provisioning
✓ B) Time-of-day restrictions
C) Principle of least privilege
D) Just-in-time permissions

---

4. Which of the following provides granular control over user access to specific network segments and resources based on their assigned roles and permissions?

A) IAM
B) SSO
C) PAM
D) MFA
Respuesta no detectada automaticamente

---

5. Which of the access control models listed below enforces the strictest set of access rules?

A) MAC
B) RBAC
C) DAC
D) ABAC

---

6. Which of the answers listed below refer to common methods of device authentication used within the AAA framework? (Select 3 answers)

A) Usernames and passwords

✓ B) Digital certificates

✓ C) IP addresses

D) MFA

E) Biometric authentication

✓ F) MAC addresses

7. A rule-based access control mechanism implemented on routers, switches, and firewalls is referred to as:

A) MAC

B) AUP

C) DAC

✓ D) ACL

8. Which of the following answers refers to a security mechanism imposed by SELinux over system access?

A) DAC

B) RBAC

✓ C) MAC

D) ABAC

9. Which type of control access model connects user permissions to their specific responsibilities?

A) DAC

✓ B) RBAC

C) MAC

D) ABAC

10. Which of the answers listed below refer(s) to a medium type that can be used as a hardware authentication token? (Select all that apply)

A) Smart card

✓ B) Key fob

✓ C) Security key

D) Passphrase

E) Biometric reader

✓ F) RFID badge

11. Which of the answers listed below refer to the features of a security key? (Select 3 answers)

A) Used for OTP generation, remote vehicle access, and building access

✓ B) Hardware authentication token

✓ C) Typically, a physical USB stick or key fob-sized device

✓ D) Primarily used for digital security (2FA/MFA)

E) Software authentication token

F) Typically, a credit card-sized plastic card with an embedded chip

12. Which type of control access model connects user permissions to their specific responsibilities?

A) DAC

✓ B) RBAC

C) MAC

D) ABAC

13. Which type of control access model connects user permissions to their specific responsibilities?

A) DAC

✓ B) RBAC

C) MAC

D) ABAC

14. Which of the terms listed below is used to describe a foundational level of security configurations and settings required to safeguard a system?

A) Logical segmentation

✓ B) Secure baseline

C) Access control levels
D) Principle of least privilege

15. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA
✓ B) CAPTCHA
C) SSO
D) NIDS

16. Which of the following answers refers to a solution that helps organizations mitigate risks associated with data breaches, insider threats, and compliance violations?

A) EDR
B) DLP
C) IAM
D) UTM

17. What are the characteristic features of SAML? (Select 3 answers)

A) Enables only the exchange of SSO authorization data
✓ B) Handles both authentication and authorization for SSO
✓ C) Uses XML for data exchange
✓ D) Commonly used in enterprise environments and legacy systems
E) Enables only the exchange of SSO authentication data
F) Uses JSON for data exchange
G) Specifically designed for web and mobile applications

18. Which of the following answers refer(s) to the Mandatory Access Control (MAC) model? (Select all that apply)

A) Users are not allowed to change access policies at their own discretion
✓ B) Labels and clearance levels can only be applied and changed by an administrator
C) Every object has an owner who at his/her own discretion determines what kind of permissions other users can have to that object
D) Access to resources based on user identity
✓ E) Every resource has a sensitivity label matching a clearance level assigned to a user

19. In the context of IT security, the term "Biometrics" refers to both biological characteristics of the human body and behavioral traits that can be used for identification and access control purposes.

A) True
B) False
Respuesta no detectada automaticamente

20. An authentication subsystem that enables a user to access multiple, connected system components (such as separate hosts on a network) after a single login on only one of the components is referred to as:

A) NAC
✓ B) SSO
C) AAA
D) MFA

21. Which of the answers listed below refers to a rule-based access control mechanism associated with files and/or directories?

A) EFS
✓ B) FACL
C) FIM
D) NTFS

22. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA

✓ **B) CAPTCHA**

C) SSO

D) NIDS

23. Which of the following answers refer(s) to the Mandatory Access Control (MAC) model? (Select all that apply)

A) Users are not allowed to change access policies at their own discretion

✓ **B) Labels and clearance levels can only be applied and changed by an administrator**

C) Every object has an owner who at his/her own discretion determines what kind of permissions other users can have to that object

D) Access to resources based on user identity

✓ **E) Every resource has a sensitivity label matching a clearance level assigned to a user**

24. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems

B) Video surveillance

✓ **C) MFA**

✓ **D) Application sandboxing**

✓ **E) Network segmentation**

25. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP

✓ **B) AUP**

C) IDS

D) MFA

E) IPS

26. Which of the following should not be used as honeytokens? (Select all that apply)

A) Active user account credentials

B) Database entries mimicking real data

✓ **C) Actual URLs to live websites or resources**

D) Dummy server logs with enticing information

E) Fake identifiers, including usernames, passwords, email addresses, and IP addresses

27. Replacing password characters in a password field with a series of asterisks is an example of:

A) Data masking

B) Tokenization

C) Anonymization

D) Pseudo-anonymization

Respuesta no detectada automaticamente

28. Which of the following combines a cryptographic hash function with a secret key to provide a means of verifying both the authenticity and integrity of a message or data?

A) MD5

B) DSA

✓ **C) HMAC**

D) DES

29. Which of the following is an example of a key stretching algorithm?

A) RIPEMD

B) SHA

C) HMAC

✓ **D) PBKDF2**

30. Which of the answers listed below refers to a file-based threat vector?

A) PDF exploits

B) Malicious macros in documents

C) Compressed files (ZIP, RAR)

D) Malicious scripts in web pages
E) Infected images
F) Malicious executables
✓ **G) All of the above**

31. Which of the following answers refer to agentless software threat vectors? (Select 2 answers)

A) Phishing email
B) Malicious USB drive
✓ **C) Network protocol vulnerability**
D) Infected macro
✓ **E) Packet sniffing**

32. Which of the following answers does not refer to a common type of OS-based vulnerability?

A) Access control and permissions vulnerabilities (weak passwords, privilege escalation)
B) Vulnerabilities in installed applications, system utilities, and device drivers
C) Memory-related vulnerabilities (memory leaks, buffer overflows, race conditions)
D) Patch and update management vulnerabilities (security patch and update delays, malicious updates)
E) Vulnerabilities related to system/security misconfigurations
F) Network-related vulnerabilities (DoS attacks, remote code execution attacks)
✓ **G) All of the above answer choices are examples of OS-based vulnerabilities**

33. Which of the following answers refers to a type of software embedded into a hardware chip?

A) Firmware
B) Middleware
C) Device driver
D) Machine code
Respuesta no detectada automaticamente

34. Which of the following exploits targets a protocol used for managing and accessing networked resources?

A) CSRF/XSRF attack
✓ **B) XML injection attack**
✓ **C) LDAP injection attack**
D) SQL injection attack

35. A dot-dot-slash attack is also referred to as:

A) Disassociation attack
B) On-path attack
✓ **C) Directory traversal attack**
D) Downgrade attack

36. Which of the terms listed below most accurately describes a situation wherein a single account is being used from multiple locations/devices at the same time?

A) Spraying attack
✓ **B) Concurrent session usage**
C) Single Sign-On (SSO)
D) Impossible travel

37. Which of the answers listed below refers to a solution that simplifies web browser configurations by using predefined rules or scripts to make server selection decisions for specific web traffic?

A) PAC
B) DDNS
C) PAM
D) NAT

38. Which of the answers listed below refer to examples of non-human readable data types? (Select 2 answers)

A) Binary code

B) XML files

✓ **C) Machine language**

D) HTML code

E) SQL queries

39. Which of the answers listed below refers to a technique that enables converting input data into a fixed-size string, making it difficult to reverse or retrieve the original data?

✓ **A) Obfuscation**

✓ **B) Tokenization**

C) Hashing

D) Encryption

40. A file-based representation of the state of a virtual machine at a given point in time is referred to as:

A) Restore point

B) Shadow copy

✓ **C) Snapshot**

D) System image

41. Which type of software allows centralized control over the configuration, monitoring, and security of mobile devices used within an organization?

A) MDR

B) IAM

C) SIEM

✓ **D) MDM**

42. Which of the answers listed below refers to software that facilitates the enforcement of mobile device policies and procedures?

A) NAC

B) MDM

C) XDR

D) PAM

43. Which of the following answers refers to a security feature used in Bluetooth device pairing?

A) SAE

✓ **B) PIN**

C) MFA

D) ACL

44. Which of the following statements does not apply to dark web?

A) Typically requires specialized software to access its contents

✓ **B) Forms a large part of the deep web**

C) Not indexed by traditional search engines

D) Often associated with trading stolen data, malware, and cyber threats

45. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ **F) All of the above answers are examples of vulnerability response and remediation techniques**

46. Simple Network Management Protocol (SNMP) is a UDP-based, application layer protocol used in network management systems to monitor network-attached devices. SNMP is typically integrated into most modern network infrastructure devices such as routers, bridges, switches, servers, printers, copiers, fax machines,

and other network-attached devices. An SNMP-managed network comprises three essential components: a managed device, a network-management software module that resides on a managed device (Agent), and a Network Management Station (NMS), which runs applications responsible for monitoring and controlling managed devices, as well as collecting SNMP information from Agents. The manager receives notifications (Traps and InformRequests) on UDP port 162, while the SNMP Agent receives requests on UDP port 161.

A) True

B) False

Respuesta no detectada automaticamente

---

47. Which of the answers listed below refers to a software tool specifically designed to store and manage login credentials?

A) BitLocker

B) Password manager

C) Key escrow

D) Password vault

---

48. Which of the terms listed below refer(s) to the concept of ephemeral access, where access to systems, resources, or permissions is provided for a limited duration? (Select all that apply)

A) TOTP

✓ B) OTP

✓ C) Just-in-time permissions

D) User password

E) API key

---

49. Which of the answers listed below refers to public sector organizations that set and enforce laws and regulations at local, regional, or national levels?

A) Government entities

B) Trade associations

C) Statutory bodies

D) Regulatory agencies

---

50. Which of the answers listed below refers to organizations or individuals responsible for ensuring compliance with data protection laws?

A) Controllers

B) Stewards

C) Owners

D) Processors

---

51. Which of the following answers refers to entities that act on behalf of the data controller to perform specific data-related tasks?

A) Stewards

B) Owners

C) Processors

D) Controllers

---

52. Which of the following answers refers to an entity (such as an organization or individual) that determines the purpose and means of processing personal data?

✓ A) Data processor

B) Data owner

✓ C) Data controller

D) Data subject

---

53. A type of user identification mechanism used as a countermeasure against automated software (such as network bots) is known as:

A) MFA

✓ B) CAPTCHA

C) ACL

D) NIPS

54. A type of document stipulating rules of behavior to be followed by users of computers, networks, and associated resources is called:

A) SLA
B) EULA
✓ C) AUP
D) BPA

55. Which of the terms listed below applies to the authentication process?

A) MFA
B) MMC
C) MDM
D) MFD

56. Which of the answers listed below refers to a broad term that encompasses various control and automation systems used in industrial settings to control and monitor physical processes and machinery?

A) ICS
B) PLC
C) SCADA
D) HMI

57. Which of the acronyms listed below refers to a piece of hardware and associated software/firmware designed to provide cryptographic and key management functions?

A) EFS
✓ B) HSM
C) SFC
D) TPM

58. A measure of the likelihood that a biometric security system will incorrectly reject an access attempt by an authorized user is referred to as:

A) FAR
B) CER
C) CRC
✓ D) FRR

59. Which of the answers listed below refers to a cryptographic method used to verify that a message or data has remained unaltered during transmission and originates from an authorized source?

A) MAC
B) CBC
C) PEM
D) GCM

60. In a Kerberos-protected network, this type of secure token is granted to users during their initial login to enable them access to multiple network services without the need to re-enter their login information.

A) OTP
✓ B) TGT
C) AS
D) TGS

61. Which of the following answers refers to a language primarily used for automating the assessment of security vulnerabilities and configuration issues on computer systems?

A) OVAL
B) SAML
C) XML
D) SOAP

62. Which DNS TXT records are used for spam management? (Select 3 answers)

A) SPF

✓ **B) DKIM**

C) SRV

✓ **D) DMARC**

E) PTR

63. Which of the following combines a cryptographic hash function with a secret key to provide a means of verifying both the authenticity and integrity of a message or data?

A) MD5

B) DSA

✓ **C) HMAC**

D) DES

64. Which of the answers listed below refers to a language used to structure and describe data in a format that is both human- and machine-readable?

A) HTML

B) XML

C) JSON

D) XHTML

65. Which of the following answers refers to an encryption protocol primarily used in Wi-Fi networks implementing the WPA2 security standard?

A) TKIP

B) CCMP

C) SSL

D) HMAC

66. Which of the answers listed below refers to a solution that simplifies web browser configurations by using predefined rules or scripts to make server selection decisions for specific web traffic?

A) PAC

B) DDNS

C) PAM

D) NAT

67. Which of the answers listed below refer(s) to compensating security control(s)? (Select all that apply)

A) Backup power systems

B) Video surveillance

✓ **C) MFA**

✓ **D) Application sandboxing**

✓ **E) Network segmentation**

68. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP

✓ **B) AUP**

C) IDS

D) MFA

E) IPS

69. Which cryptographic protocol is designed to provide secure communications over a computer network and is the successor to SSL?

A) IPsec

✓ **B) TLS**

C) AES

D) CCMP

70. Which of the answers listed below refers to a cryptographic hash function that has been widely used in the past but is now considered deprecated for security-sensitive applications due to known vulnerabilities?

A) MD5

B) SHA
C) CRC
D) HMAC
Respuesta no detectada automaticamente

71. Which of the hash functions listed below offers the highest level of security?

A) MD5
✓ B) SHA-3
C) RIPEMD-160
✓ D) HMAC

72. A type of digital document that verifies the identity of an individual, device, service, or organization in online communications is known as:

A) Encryption key
✓ B) Digital certificate
C) Identity token
D) Digital signature

73. Which of the answers listed below refers to a file-based threat vector?

A) PDF exploits
B) Malicious macros in documents
C) Compressed files (ZIP, RAR)
D) Malicious scripts in web pages
E) Infected images
F) Malicious executables
G) All of the above

74. What would be an appropriate user response to an email phishing attempt? (Select all that apply)

A) Not replying to the message or providing any personal information
✓ B) Reporting the message to the IT or security department, if applicable
✓ C) Deleting the message from the inbox
✓ D) Not clicking on any links or downloading any attachments in the message
E) Forwarding the message to the sender to verify its legitimacy
F) Opening the attachment in a sandbox environment to check its safety

75. A wireless disassociation attack is a type of: (Select 2 answers)

A) Downgrade attack
✓ B) Deauthentication attack
C) Brute-force attack
✓ D) DoS attack
E) Cryptographic attack

76. Which type of exploit targets web applications that generate content used to store and transport data?

A) SQL injection attack
B) CSRF/XSRF attack
✓ C) XML injection attack
D) LDAP injection attack

77. Which of the terms listed below most accurately describes a situation wherein a single account is being used from multiple locations/devices at the same time?

A) Spraying attack
✓ B) Concurrent session usage
C) Single Sign-On (SSO)
D) Impossible travel

78. Which of the answers listed below refers to any type of information pertaining to an individual that can be used to uniquely identify that person?

A) PHI

B) Biometrics
C) ID
✓ **D) PII**

79. Which of the answers listed below refers to a technique that enables converting input data into a fixed-size string, making it difficult to reverse or retrieve the original data?

A) Obfuscation
B) Tokenization
✓ **C) Hashing**
D) Encryption

80. Which of the answers listed below refers to a situation where sensitive data is stored in a separate location and can be retrieved with a non-sensitive replacement that can also be processed just like the original data without the risk of revealing the contents of original data?

A) Masking
✓ **B) Obfuscation**
C) Encryption
✓ **D) Tokenization**

81. A file-based representation of the state of a virtual machine at a given point in time is referred to as:

A) Restore point
B) Shadow copy
✓ **C) Snapshot**
D) System image

82. Which of the following answers refers to a security feature used in Bluetooth device pairing?

A) SAE
✓ **B) PIN**
C) MFA
D) ACL

83. Which of the following statements does not apply to dark web?

A) Typically requires specialized software to access its contents
✓ **B) Forms a large part of the deep web**
C) Not indexed by traditional search engines
D) Often associated with trading stolen data, malware, and cyber threats

84. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)
B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)
C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)
D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)
E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)
✓ **F) All of the above answers are examples of vulnerability response and remediation techniques**

85. Examples of properties used for defining access policies in Attribute-Based Access Control (ABAC) model include:

A) Subject (i.e., user or process requesting access)
B) Type of action (for example "read", "write", "execute")
C) Resource type (medical record, bank account etc.)
D) Environment (contextual data, such as time of day or geolocation)
✓ **E) All of the above**

86. The principle of least privilege is a security rule that prevents users from accessing information and resources that lie beyond the scope of their responsibilities.

A) True

B) False

Respuesta no detectada automaticamente

87. Which of the answers listed below refers to a software tool specifically designed to store and manage login credentials?

A) BitLocker

B) Password manager

C) Key escrow

D) Password vault

4.7 - Explain the importance of automation and orchestration.

Conceptos clave:

- Use cases: User provisioning, Resource provisioning, Security groups, Ticket creation
- Benefits: Efficiency, Enforcing baselines, Scaling, Reaction time, Workforce multiplier
- Considerations: Complexity, Cost, Single point of failure, Technical debt

Teoria:

AUTOMATIZACION Y ORQUESTACION EN SEGURIDAD:

- Automatizacion: ejecutar una tarea especifica sin intervencion humana (un script que bloquea una IP)
- Orquestacion: coordinar MULTIPLES herramientas y procesos automatizados en un flujo de trabajo (workflow)
- SOAR (Security Orchestration, Automation and Response): plataforma que integra herramientas de seguridad y automatiza la respuesta a incidentes

Ejemplo de playbook SOAR: alerta de phishing → extraer IOCs del email → buscar IOCs en SIEM → bloquear dominio en firewall → aislar endpoint → crear ticket → notificar al usuario → todo en segundos sin intervencion humana

CASOS DE USO REALES:

- User provisioning/de-provisioning: cuando RRHH crea/desactiva un empleado en el sistema, se dispara automaticamente la creacion/desactivacion de todas sus cuentas (AD, email, Slack, Jira...)
- Threat intelligence enrichment: cuando el SIEM genera una alerta con una IP, el SOAR consulta automaticamente VirusTotal, Shodan y feeds de threat intel para enriquecer la alerta
- Incident ticket creation: cada alerta critica del SIEM crea automaticamente un ticket en ServiceNow/Jira con toda la informacion relevante
- Vulnerability remediation: cuando el scanner detecta una vulnerabilidad critica, se crea automaticamente el ticket, se asigna al equipo correcto y se establece el SLA
- Security group updates: cuando un endpoint se comporta de forma sospechosa, se mueve automaticamente a una VLAN de cuarentena

BENEFICIOS vs RIESGOS:

- Beneficios: velocidad (segundos vs horas), consistencia (siempre hace lo mismo), escalabilidad (gestiona miles de alertas simultaneas), workforce multiplier (un analista hace el trabajo de muchos)
- Riesgos: Single point of failure (si el SOAR falla, los procesos automatizados tambien), complexity (bugs en playbooks pueden causar acciones incorrectas), technical debt (playbooks obsoletos que nadie mantiene), over-automation (automatizar decisiones que requieren criterio humano)

SCRIPTING Y APIS:

- Python: el lenguaje mas usado en seguridad para automatizacion. Scripts para parsear logs, interactuar con APIs, analizar malware
- APIs REST: permiten integrar herramientas de seguridad entre si. El SIEM puede llamar a la API del firewall para bloquear una IP
- CI/CD security (DevSecOps): integrar pruebas de seguridad (SAST, DAST, dependency scanning) en el pipeline de desarrollo para detectar vulnerabilidades antes de produccion

Preguntas de practica (13):

1. Which of the following terms refers to the use of technology to perform individual tasks with minimal human intervention?

A) Automation

B) Scripting

✓ **C) Orchestration**

D) Sequencing

2. Which of the terms listed below refers to a process that deals with coordinating and managing multiple repetitive tasks?

A) Sequencing

B) Orchestration

C) Scripting

D) Automation

3. A collection of precompiled functions designed to be used by more than one Microsoft Windows application simultaneously to save system resources is known as:

A) DLL

B) API

C) EXE

D) INI

4. Which of the answers listed below describe the characteristics of a cross-site scripting attack? (Select 3 answers)

A) Exploits the trust a user's web browser has in a website

✓ **B) A malicious script is injected into a trusted website**

✓ **C) User's browser executes attacker's script**

D) Exploits the trust a website has in the user's web browser

E) A user is tricked by an attacker into submitting unauthorized web requests

F) Website executes attacker's requests

5. Which of the terms listed below refer(s) to the concept of ephemeral access, where access to systems, resources, or permissions is provided for a limited duration? (Select all that apply)

A) TOTP

✓ **B) OTP**

✓ **C) Just-in-time permissions**

D) User password

E) API key

6. Which of the answers listed below refers to a term primarily used in software development to describe the cost of short-term decisions that can lead to long-term problems?

A) Code entropy

B) Exposure factor

C) Risk register

✓ **D) Technical debt**

7. Which of the following solutions alleviates the problem of the depleting IPv4 address space by allowing multiple hosts on the same private LAN to share a single public IP address?

A) DNS

B) APIPA

✓ **C) NAT**

D) DHCP

8. Which of the answers listed below refers to an industry standard for assessing and scoring the severity of computer system security vulnerabilities?

A) SIEM

B) CVSS

C) OSINT

D) SOAR

9. Which of the answers listed below refers to a broad term that encompasses various control and automation systems used in industrial settings to control and monitor physical processes and machinery?

A) ICS
B) PLC
C) SCADA
D) HMI

10. Which of the following answers refers to a text-based command interpreter and scripting language for Unix-like operating systems?

A) CLI
B) JS
C) Bash
D) cmd.exe

11. Which of the following answers refers to a cybersecurity framework that combines network and security functions into a single cloud-based service?

A) SASE
B) SIEM
C) SWG
D) SOAR

12. Which of the following technologies enables automated handling of multiple security incidents?

A) SOAP
B) SIEM
✓ C) SOAR
D) SASE

13. Which of the answers listed below describe the characteristics of a cross-site scripting attack? (Select 3 answers)

A) Exploits the trust a user's web browser has in a website
✓ B) A malicious script is injected into a trusted website
✓ C) User's browser executes attacker's script
D) Exploits the trust a website has in the user's web browser
E) A user is tricked by an attacker into submitting unauthorized web requests
F) Website executes attacker's requests

4.8 - Explain appropriate incident response activities.

Conceptos clave:

- Process: Preparation, Detection, Analysis, Containment, Eradication, Recovery, Lessons learned
- Testing: Tabletop exercise, Simulation
- Digital forensics: Legal hold, Chain of custody, Acquisition, E-discovery
- Root cause analysis, Threat hunting

Teoria:

LAS 6 FASES DE RESPUESTA A INCIDENTES (NIST SP 800-61):

- 1. PREPARATION: antes de que ocurra nada. Crear el IRP, formar el equipo, preparar herramientas forenses, establecer canales de comunicacion, realizar tabletop exercises periodicos
- 2. DETECTION & ANALYSIS: identificar que ha ocurrido un incidente. Fuentes: SIEM, AV, usuarios, logs. Determinar alcance, sistemas afectados y tipo de incidente. Clasificar la severidad
- 3. CONTAINMENT: limitar el dano. Dos tipos:

- Short-term: aislar el sistema afectado de la red inmediatamente (puede perder evidencias volatiles)

- Long-term: parchear la vulnerabilidad, cambiar credenciales comprometidas, reforzar controles

- 4. ERADICATION: eliminar la causa raiz. Eliminar malware, cerrar backdoors, revocar credenciales comprometidas, aplicar parches
- 5. RECOVERY: restaurar sistemas a operacion normal. Restaurar desde backups limpios, monitorizar intensamente los sistemas recuperados
- 6. LESSONS LEARNED: post-mortem. Que paso, como se detecto, que funciono, que no funciono, que hay que mejorar. OBLIGATORIO documentarlo

MNEMONICO: 'Puedo Detectar Cualquier Cosa, Esforzandome Responsablemente' → Preparation, Detection, Containment, Eradication, Recovery, Lessons learned

FORENSIA DIGITAL - Conceptos criticos para el examen:

- Legal hold: lo PRIMERO al inicio de una investigacion legal. Notificacion formal para preservar TODA la evidencia relevante. No se puede borrar nada una vez emitido
- Chain of custody: registro detallado de quien ha manejado la evidencia, cuando, donde y por que. Sin chain of custody intacta, la evidencia puede ser inadmisible en juicio
- Order of volatility (RFC 3227): orden en que recoger evidencias de mas a menos volatil:

1. Registros CPU y cache
2. Memoria RAM (contiene procesos activos, conexiones, claves de cifrado)
3. Trafico de red activo
4. Estado del sistema operativo
5. Disco duro
6. Logs remotos y backups

- Write blocker: dispositivo hardware que impide modificar el disco original al hacer la imagen forense
- Imagen forense: copia bit a bit del disco. Se verifica con hash MD5/SHA-256 que la copia es identica al original
- E-discovery: proceso legal de identificar, preservar y producir evidencias digitales para litigios

THREAT HUNTING:

- Busqueda PROACTIVA de amenazas que han evadido los controles automaticos
- No espera a que el SIEM alerte. El analista formula hipotesis ('podria haber un atacante que...')
- Se basa en conocimiento de TTPs (Tactics, Techniques and Procedures) del adversario (MITRE ATT&CK)
- Herramientas: EDR, SIEM, logs de red, threat intelligence feeds

Preguntas de practica (29):

1. In the incident response process, the step that involves identifying and understanding potential incidents to determine their scope, impact, and root cause is a part of the:

A) Preparation stage
✓ B) Detection and analysis stage
C) Containment, eradication, and recovery stage
D) Post-incident activity stage

---

2. Which stage of the incident response process involves updating incident response plans, policies, and procedures?

A) Preparation
B) Detection and analysis
C) Containment, eradication, and recovery
✓ D) Post-incident activity

---

3. Which part of the incident response process involves establishing and maintaining the incident response capability as well as setting up an incident response team?

A) Preparation
B) Detection and analysis
C) Containment, eradication, and recovery
D) Post-incident activity

---

4. Which of the following answers refer(s) to the containment, eradication, and recovery stage of the incident response process? (Select all that apply)

A) Restoring normal operations
✓ B) Eliminating the threat
C) Monitoring and detecting potential incidents
D) Establishing and maintaining an incident response policy
✓ E) Mitigating the impact of the incident

---

5. Which of the answers listed below refers to a discussion-based activity where team members walk through different scenarios to evaluate the incident response plan without activating any systems?

A) Tabletop exercise

✓ **B) Simulation**

C) Threat hunting

D) Root cause analysis

6. During the post-incident activity stage, this step involves analyzing logs, forensics data, and other evidence to prevent incident reoccurrence.

A) Reporting

B) E-discovery

✓ **C) Root cause analysis**

D) Threat hunting

7. Which of the following answers refers to a more realistic scenario that tests cybersecurity incident response by mimicking actual attacks?

A) Fingerprinting

✓ **B) Simulation**

C) Threat hunting

D) Tabletop exercise

8. Which of the following answers refers to a more realistic scenario that tests cybersecurity incident response by mimicking actual attacks?

A) Fingerprinting

✓ **B) Simulation**

C) Threat hunting

D) Tabletop exercise

9. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise

B) Sandboxing

C) Threat hunting

D) Security awareness training

Respuesta no detectada automaticamente

10. Which of the following answers refer to SCAP? (Select 3 answers)

A) A type of security system designed to collect logs and events from various sources

✓ **B) Designed to provide a centralized user interface for accessing collected data**

✓ **C) A collection of standards developed by NIST**

✓ **D) Provides a common language for communicating security information**

✓ **E) Allows different security tools to share data and work together more effectively**

F) Enables real-time threat detection, incident response, and compliance monitoring

11. The process of identifying, collecting, and producing electronically stored information with the intent of using it in a legal proceeding or investigation is referred to as:

A) Litigation hold

B) Evidence management

C) Digital forensics

✓ **D) E-discovery**

12. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise

B) Sandboxing

C) Threat hunting

D) Security awareness training

Respuesta no detectada automaticamente

13. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP

✓ **B) AUP**

C) IDS

D) MFA

E) IPS

14. Which of the following terms describes the process of identifying differences between an organization's current security posture and its desired security posture?

A) Tabletop exercise

✓ **B) Gap analysis**

C) Security awareness training

D) Risk assessment

15. Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answers)

A) Enhances security by limiting the spread of cyberattacks

✓ **B) Helps organizations comply with data regulatory requirements by isolating and protecting specific data types**

C) Provides security for data in transit with the use of encryption

D) Guarantees data recovery in case of accidental deletion or system failures

✓ **E) Provides better control over user access to sensitive data**

16. A disaster recovery facility that provides only the physical space for recovery operations is known as:

A) Hot site

B) Warm site

✓ **C) Cold site**

D) Mirror site

17. Which alternate site allows for the fastest disaster recovery?

A) Cold site

✓ **B) Hot site**

C) Mobile site

D) Warm site

18. One of the ways to prevent data recovery from a storage drive is to overwrite its contents. The data overwriting technique is used by drive wipe utilities which might employ different methods (including multiple overwriting rounds) to decrease the likelihood of data retrieval. As an example, a disk sanitization utility might overwrite the data on the drive with the value of one in the first pass, change that value to zero in the second pass, and finally perform a few more passes, overwriting the contents with random characters.

A) True

B) False

19. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ **F) All of the above answers are examples of vulnerability response and remediation techniques**

20. Which of the following answers refers to a more in-depth exercise, which can include activating systems and performing real actions to respond to the incident?

A) Penetration testing

B) Threat hunting

✓ **C) Simulation**

D) Vulnerability scanning

21. The term "Threat hunting" refers to a proactive search for IoC to identify and address potential threats and vulnerabilities before they can escalate into full-blown incidents.

A) True

B) False

Respuesta no detectada automaticamente

22. Which of the following terms refers to a documented plan outlining the steps that should be taken in each phase of a cybersecurity incident?

A) DRP

✓ B) IRP

C) BCP

D) ERP

23. Which of the terms listed below refers to a documented plan outlining the steps that should be taken in each phase of a cybersecurity incident?

A) DRP

✓ B) IRP

C) BCP

D) ERP

24. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP

✓ B) AUP

C) IDS

D) MFA

E) IPS

25. Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answers)

A) Enhances security by limiting the spread of cyberattacks

✓ B) Helps organizations comply with data regulatory requirements by isolating and protecting specific data types

C) Provides security for data in transit with the use of encryption

D) Guarantees data recovery in case of accidental deletion or system failures

✓ E) Provides better control over user access to sensitive data

26. A disaster recovery facility that provides only the physical space for recovery operations is known as:

A) Hot site

B) Warm site

✓ C) Cold site

D) Mirror site

27. Which alternate site allows for the fastest disaster recovery?

A) Cold site

✓ B) Hot site

C) Mobile site

D) Warm site

28. Which of the statements listed below does not refer to a vulnerability response and remediation technique?

A) Applying updates or fixes provided by software vendors to address the vulnerability (patching)

B) Ensuring financial recovery from the costs associated with a successful cyberattack (insurance)

C) Dividing a network into smaller, isolated zones to limit the potential impact of a vulnerability (segmentation)

D) Mitigating the risk associated with a vulnerability that cannot be immediately patched by implementing alternative security measures (compensating controls)

E) Delaying or forgoing a patch for a specific system, e.g., when applying a patch may not be feasible due to compatibility issues or potential disruptions to critical systems (exceptions and exemptions)

✓ F) All of the above answers are examples of vulnerability response and remediation techniques

29. The process of maintaining a documented record of the handling and movement of evidence to ensure its integrity and admissibility in court is called:

A) Chain of custody

B) Chain of evidence

C) Chain of accountability

D) Chain of responsibility

Respuesta no detectada automaticamente

4.9 - Use data sources to support an investigation.

Conceptos clave:

- Log data: Firewall, Application, Endpoint, OS, IPS/IDS, Network, Metadata
- Data sources: Vulnerability scans, Automated reports, Dashboards, Packet captures

Teoria:

FUENTES DE DATOS PARA INVESTIGACIONES - Conocer donde buscar es critico:

- Firewall logs: registros de trafico permitido y bloqueado. Buscar: conexiones a IPs maliciosas, trafico en puertos inusuales, volumenes anormales de datos salientes (exfiltracion)
- Application logs: errores de aplicacion, autenticaciones, acciones de usuarios. Buscar: logins en horas inusuales, accesos a datos fuera del rol del usuario, errores repetidos
- Endpoint logs (Windows Event Logs): eventos del sistema operativo. Logs criticos de Windows:

- 4624: login exitoso

- 4625: login fallido

- 4648: login con credenciales explicitas (puede indicar pass-the-hash)

- 4688: creacion de nuevo proceso

- 7045: nuevo servicio instalado (posible malware como servicio)

- IDS/IPS logs: alertas de ataques detectados en la red. Incluyen la firma que disparo la alerta y el trafico raw
- DNS logs: resoluciones de nombres. Critico para detectar:

- C2 (Command & Control): el malware resuelve dominios generados aleatoriamente (DGA)

- DNS tunneling: datos exfiltrados codificados en consultas DNS

- Typosquatting: resoluciones de dominios similares al legitimo

- Network logs/NetFlow: metadatos del trafico (origen, destino, puertos, bytes, duracion). NO el contenido. Util para detectar:

- Lateral movement: conexiones internas inusuales entre hosts

- Data exfiltration: grandes transferencias de datos hacia el exterior

- Port scanning: un host conectandose a muchos puertos de otro host

- Metadata: datos SOBRE los datos. Ejemplo: metadatos de un documento Word incluyen autor, fecha de creacion, historial de revisiones, ruta del archivo en el PC del autor (puede revelar el nombre de usuario del atacante)
- Authentication logs: intentos de login. Buscar: password spraying (muchas cuentas, pocas contrasenas), brute force (muchos intentos a una cuenta), impossible travel (login desde dos paises en minutos)

HERRAMIENTAS DE ANALISIS:

- Wireshark: analisis de capturas de trafico (PCAP). Permite ver el contenido completo de conexiones no cifradas. Filtros: ip.addr==x.x.x.x, tcp.port==80, http.request
- tcpdump: captura de trafico desde linea de comandos. Mas eficiente que Wireshark para capturar en produccion
- Volatility: analisis forense de volcados de memoria RAM. Extrae procesos, conexiones de red, artefactos de malware de la memoria
- Autopsy/FTK: plataformas de analisis forense de discos. Recuperan archivos borrados, analizan el sistema de archivos
- SIEM dashboards: visualizacion en tiempo real. Permiten ver tendencias, picos de actividad y correlaciones
- Threat intelligence platforms (TIP): agregan feeds de threat intel (IOCs: IPs, dominios, hashes de malware) y los correlacionan con eventos del SIEM

TRUCO EXAMEN: 'Donde busco X?' → Logins fallidos: auth logs. Malware en red: IDS logs + NetFlow. Exfiltracion: firewall logs + DNS logs. Proceso malicioso: endpoint logs (Event ID 4688). Trafico cifrado sospechoso: NetFlow (no el contenido, pero si el patron).

Preguntas de practica (2):

1. The term "Metadata" refers to data that provides information about other data, but not the actual content of the data. Typically, metadata is not visible to the user by default but can be accessed if needed. For example, email metadata, found in email headers, includes detailed information about the sender, recipient, and the route the message took. Mobile device metadata encompasses details such as the device model, geolocation, camera information, internet usage, phone call and text messaging activity, application usage statistics, and metadata from various files on the device. In web browsing, metadata comes from HTML meta tags located in the head section of a web page. For files, metadata includes details about the author (e.g., the file creator), file type, size, creation date and time, and the last modification date and time.

A) True

B) False

---

2. Which of the answers listed below refers to a process of intercepting network traffic data for analysis and troubleshooting purposes?

A) AIS

✓ **B) PCAP**

C) EDR

D) MaaS

5.0 Security Program Management and Oversight (20% del examen)

5.1 - Summarize elements of effective security governance.

Conceptos clave:

- Policies: AUP, Information security, Business continuity, DR, Incident response, SDLC
- Standards: Password, Access control, Physical security, Encryption
- Procedures: Change management, Onboarding/offboarding, Playbooks
- Governance structures: Boards, Committees, Centralized/decentralized
- Roles: Owners, Controllers, Processors, Custodians/stewards

Teoria:

JERARQUIA DE DOCUMENTOS DE GOBERNANZA - Del mas general al mas especifico:

- Policy (Politica): declaracion de ALTO NIVEL de la intencion de la organizacion. Aprobada por la direccion. EL QUE. No cambia frecuentemente. Ejemplo: 'Todos los datos de clientes deben protegerse segun su clasificacion'
- Standard (Estandar): requisitos ESPECIFICOS y MEDIBLES que implementan la politica. EL CUANTO. Ejemplo: 'Los datos confidenciales deben cifrarse con AES-256'
- Procedure (Procedimiento): instrucciones PASO A PASO de como implementar el estandar. EL COMO. Ejemplo: 'Para cifrar un disco: 1. Abrir BitLocker 2. Seleccionar modo...'
- Guideline (Directriz): RECOMENDACIONES no obligatorias. Best practices. El mas flexible. Ejemplo: 'Se recomienda usar un gestor de contrasenas'
- Playbook: procedimiento especifico para responder a UN TIPO ESPECIFICO de incidente (playbook de ransomware, playbook de phishing)

POLITICAS CLAVE QUE DEBES CONOCER:

- AUP (Acceptable Use Policy): define el uso aceptable de los recursos IT. Todos los empleados deben firmarla. Cubre: uso de internet, email corporativo, dispositivos, redes sociales
- Information Security Policy: politica paraguas que gobierna toda la seguridad de la informacion en la organizacion
- BCP (Business Continuity Plan): como CONTINUAR OPERANDO durante un desastre. Se centra en el negocio, no solo en IT
- DRP (Disaster Recovery Plan): como RECUPERAR los sistemas IT tras un desastre. Parte del BCP, mas tecnico
- IRP (Incident Response Plan): como responder a incidentes de seguridad. Define roles, escalado, comunicacion
- SDLC (Software Development Life Cycle) Policy: como integrar seguridad en el desarrollo de software desde el principio (Secure SDLC / DevSecOps)
- Onboarding/Offboarding: procedimientos para dar de alta y baja empleados de forma segura

ROLES DE DATOS - Los mas preguntados en el examen:

- Data owner: el responsable del NEGOCIO del activo. Decide la clasificacion, quien puede acceder y el tiempo de retencion. Normalmente un director o VP
- Data custodian/steward: el responsable TECNICO. Implementa los controles definidos por el owner. Normalmente IT o el DBA
- Data controller (GDPR): entidad que decide el PROPOSITO y los MEDIOS del procesamiento de datos personales. La empresa que recopila tus datos
- Data processor (GDPR): entidad que procesa datos en nombre del controller. Un proveedor cloud, una empresa de marketing
- Data subject (GDPR): la persona fisica cuyos datos se procesan. Tu cuando una empresa tiene tus datos
- TRUCO: Owner = decide QUE hacer con los datos. Custodian = COMO protegerlos. Controller = POR QUE procesarlos. Processor = los procesa para otro.

ESTRUCTURAS DE GOBERNANZA:

- CISO (Chief Information Security Officer): maximo responsable de seguridad. Reporta al CEO o al Board
- Centralized governance: el equipo central de seguridad toma todas las decisiones. Consistencia pero puede ser lento
- Decentralized governance: cada departamento/BU gestiona su seguridad. Mas agil pero inconsistente
- Board/steering committee: comite ejecutivo que supervisa la estrategia de seguridad y aprueba inversiones
- Monitoring and revision: las politicas deben revisarse periodicamente (minimo anual) y tras incidentes significativos

Preguntas de practica (17):

1. Which of the following answers refers to an entity (such as an organization or individual) that determines the purpose and means of processing personal data?

✓ A) Data processor

B) Data owner

✓ **C) Data controller**

D) Data subject

2. A new-user setup checklist includes all the activities that enable a new hire to become productive. Examples of such activities (which are part of the so-called onboarding process) include setting up the hardware and software environment for the new user as well as providing all the necessary training. An end-user termination checklist deals with all the actions that should take place during the offboarding process (i.e., whenever an employee leaves the company). Examples of the checklist items include fulfilling all the required documents, removing the employee's access to resources (e.g., company-owned devices, user accounts, etc.), and discussing their reasons for leaving and experiences with the employer during an exit interview.

A) True

B) False

Respuesta no detectada automaticamente

3. Which of the answers listed below refers to organizations or individuals responsible for ensuring compliance with data protection laws?

A) Controllers

B) Stewards

C) Owners

D) Processors

4. Which of the following answers refers to entities that act on behalf of the data controller to perform specific data-related tasks?

A) Stewards

B) Owners

C) Processors

D) Controllers

5. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP

✓ **B) AUP**

C) IDS

D) MFA

E) IPS

6. Which of the following answers refers to an embedded microcontroller used for secure boot, disk encryption, and system integrity verification?

A) TPM

B) SoC

C) UEFI

✓ **D) HSM**

7. A rule-based access control mechanism implemented on routers, switches, and firewalls is referred to as:

A) MAC

B) AUP

C) DAC

✓ **D) ACL**

8. A disaster recovery facility that provides only the physical space for recovery operations is known as:

A) Hot site

B) Warm site

✓ **C) Cold site**

D) Mirror site

9. Which alternate site allows for the fastest disaster recovery?

A) Cold site

✓ **B) Hot site**

C) Mobile site
D) Warm site

10. Which of the terms listed below refers to the process of creating and maintaining computer applications?

A) RAD
✓ B) SDLC
C) OOP
D) SaaS

11. Which of the terms listed below refers to the process of creating and maintaining computer applications?

A) RAD
✓ B) SDLC
C) OOP
D) SaaS

12. A type of document stipulating rules of behavior to be followed by users of computers, networks, and associated resources is called:

A) SLA
B) EULA
✓ C) AUP
D) BPA

13. Which of the acronyms listed below refers to a maximum tolerable period of time required for restoring business functions after a failure or disaster?

A) SLA
B) RTO
C) AUP
D) RPO

14. Which of the following answers refers to an embedded microcontroller used for secure boot, disk encryption, and system integrity verification?

A) TPM
B) SoC
C) UEFI
D) HSM

15. Which of the following terms fall into the category of directive security controls? (Select 2 answers)

A) IRP
✓ B) AUP
C) IDS
D) MFA
E) IPS

16. A disaster recovery facility that provides only the physical space for recovery operations is known as:

A) Hot site
B) Warm site
✓ C) Cold site
D) Mirror site

17. Which alternate site allows for the fastest disaster recovery?

A) Cold site
✓ B) Hot site
C) Mobile site
D) Warm site

5.2 - Explain elements of the risk management process.

Conceptos clave:

- Risk identification, Assessment (Ad hoc, Recurring, Continuous)
- Risk analysis: Qualitative, Quantitative, SLE, ALE, ARO, Exposure factor
- Risk register: Key indicators, Risk owners, Risk threshold
- Risk appetite: Expansionary, Conservative, Neutral
- Strategies: Transfer, Accept, Avoid, Mitigate
- BIA: RTO, RPO, MTTR, MTBF

Teoria:

PROCESO DE GESTION DE RIESGOS (NIST RMF):

- 1. Identificacion de riesgos: catalogar activos, identificar amenazas y vulnerabilidades
- 2. Assessment: evaluar probabilidad e impacto. Puede ser ad-hoc (puntual), recurring (periodico) o continuous (continuo)
- 3. Response: decidir como tratar cada riesgo (mitigar, transferir, evitar, aceptar)
- 4. Monitoring: vigilar los riesgos y la efectividad de los controles continuamente

ANALISIS CUANTITATIVO - Las formulas del examen:

- AV (Asset Value): valor monetario del activo. Ej: servidor de base de datos = 500.000€
- EF (Exposure Factor): porcentaje del activo que se perderia si el riesgo se materializa. Ej: 40% (perdida parcial)
- SLE (Single Loss Expectancy): perdida esperada por UN incidente = AV x EF = 500.000 x 0.40 = 200.000€
- ARO (Annual Rate of Occurrence): cuantas veces al ano se espera que ocurra el incidente. Ej: 0.5 (una vez cada 2 anos)
- ALE (Annual Loss Expectancy): perdida anual esperada = SLE x ARO = 200.000 x 0.5 = 100.000€
- TRUCO: si el control cuesta menos que el ALE, tiene sentido implementarlo. Si cuesta mas, quizas es mejor aceptar el riesgo

ANALISIS CUALITATIVO:

- Usa matrices de riesgo con escalas descriptivas (bajo/medio/alto/critico)
- Mas rapido y facil que el cuantitativo pero subjetivo
- Util cuando no hay datos suficientes para calcular valores monetarios precisos
- Herramientas: risk matrix (probabilidad x impacto), heat maps de riesgo

ESTRATEGIAS DE RESPUESTA AL RIESGO:

- Mitigate (reducir): implementar controles para reducir la probabilidad o el impacto. La respuesta mas comun
- Transfer (transferir): ciberseguro (transfiere el riesgo financiero al asegurador), contratos que transfieren responsabilidad a terceros
- Avoid (evitar): no realizar la actividad que genera el riesgo. Ej: no lanzar una app movil si no se puede asegurar su seguridad
- Accept (aceptar): documentar conscientemente que se asume el riesgo. Apropiado cuando el coste de mitigarlo supera el impacto esperado. Requiere aprobacion de la direccion
- Risk appetite: cuanto riesgo esta dispuesta a asumir la organizacion en total
- Risk tolerance: variacion aceptable alrededor del apetito de riesgo
- Residual risk: el riesgo que QUEDA despues de aplicar todos los controles. Nunca es cero
- Risk register: documento vivo que lista todos los riesgos con su propietario, controles actuales y riesgo residual

BIA (Business Impact Analysis) - Critico para el examen:

- Objetivo: identificar cuales son los procesos CRITICOS del negocio y que pasa si se interrumpen
- MTD (Maximum Tolerable Downtime): el tiempo maximo que el negocio puede sobrevivir sin el proceso
- RTO (Recovery Time Objective): tiempo maximo para restaurar el servicio. RTO < MTD siempre
- RPO (Recovery Point Objective): cuanta perdida de datos es aceptable. Si RPO=4h, el ultimo backup debe tener maximo 4h de antiguedad
- MTTR (Mean Time To Repair): tiempo medio para reparar un sistema
- MTBF (Mean Time Between Failures): frecuencia media de fallos. Usado para planificar mantenimiento preventivo

Preguntas de practica (41):

1. Which of the following defines the maximum acceptable amount of data loss measured by a specific point in time before a disaster or outage?

A) RPO
B) MTBF
C) RTO
✓ D) MTTR

---

2. Which of the following defines the maximum acceptable amount of data loss measured by a specific point in time before a disaster or outage?

A) RPO
B) MTBF
C) RTO
✓ **D) MTTR**

3. An estimate based on the historical data of how often a threat would be successful in exploiting a vulnerability is known as:

A) ALE
B) SLA
✓ **C) ARO**
D) SLE

4. Cybersecurity insurance is an example of which risk management strategy?

A) Risk avoidance
B) Risk deterrence
✓ **C) Risk transference**
D) Risk acceptance

5. Which term describes the predicted loss of value to an asset based on a single security incident?

A) SLE
B) ARO
C) ALE
D) SLA

6. Cybersecurity insurance is an example of which risk management strategy?

A) Risk avoidance
B) Risk deterrence
✓ **C) Risk transference**
D) Risk acceptance

7. Which of the answers listed below refers to a comprehensive document used in risk management and project management to identify, assess, and track risks?

A) Risk register
B) Risk heat map
C) Risk matrix
D) Risk repository

8. Which of the terms listed below refers to a general term that describes an organization's overall attitude towards risk-taking?

A) Risk strategy
B) Risk control
✓ **C) Risk appetite**
D) Risk tolerance

9. Which of the following terms describes the process of taking proactive measures to reduce the impact of identified risks?

A) Risk acceptance
B) Risk avoidance
C) Risk transference
✓ **D) Risk mitigation**

10. Which of the acronyms listed below refers to a maximum tolerable period of time required for restoring business functions after a failure or disaster?

A) SLA
B) RTO
C) AUP
D) RPO

11. Which of the acronyms listed below refers to a comprehensive strategy and set of procedures designed to ensure that an organization can continue its critical operations and functions during and after a disruptive event?

A) BIA
B) SLE
✓ **C) BCP**
D) BPA

12. A set of procedures put in place to recover IT systems and data following a major disruption is called:

A) DRP
B) BIA
C) SLE
D) BCP
Respuesta no detectada automaticamente

13. The process of determining potential risks that could affect an organization's ability to achieve its objectives is called:

✓ **A) Risk assessment**
✓ **B) Risk identification**
C) Risk analysis
D) Risk management

14. Which of the following answers refers to a risk assessment conducted for a specific purpose or project, without plans for regular reassessment (e.g., risk assessment for a new product launch)?

A) One-time
B) Recurring
C) Ad hoc
D) Continuous

15. Which of the terms listed below refers to a general term that describes an organization’s overall attitude towards risk-taking?

A) Risk strategy
B) Risk control
✓ **C) Risk appetite**
D) Risk tolerance

16. Which of the following terms describes the process of taking proactive measures to reduce the impact of identified risks?

A) Risk acceptance
B) Risk avoidance
C) Risk transference
✓ **D) Risk mitigation**

17. Which of the following terms describes the process of identifying differences between an organization's current security posture and its desired security posture?

A) Tabletop exercise
✓ **B) Gap analysis**
C) Security awareness training
D) Risk assessment

18. A honeyfile can be used for:

A) Attracting cyber attackers
B) Triggering alerts when accessed
C) Monitoring network activity
✓ **D) All of the above**

19. What is the purpose of steganography?

A) Checking data integrity

B) Verifying hash values

✓ **C) Hiding data within another piece of data**

D) Encrypting data

20. Which of the answers listed below refers to a non-cryptographic hash function often used for error-checking purposes?

A) MD5

B) CRC

C) SHA

D) RIPEMD

21. The term "RFID cloning" refers to copying the data stored on any RFID-enabled device (including tags, cards, key fobs, implants, and other objects embedded with RFID technology) onto another RFID-enabled device, which then can be read and used in the same way as the original tag. While RFID cloning can be utilized for legitimate purposes, such as replicating important tags for backup and testing purposes, it also poses significant security risk, as duplicate tags can potentially be used for gaining unauthorized access or unauthorized information disclosure.

A) True

B) False

Respuesta no detectada automaticamente

22. Which of the answers listed below refers to a cyberattack technique that relies on providing false DNS information to a DNS resolver for the purpose of redirecting or manipulating the resolution of domain names to malicious IP addresses?

A) DNS spoofing

B) Credential stuffing

C) URL hijacking

D) Domain hijacking

23. The purpose of PCI DSS is to provide protection for:

A) Credit cardholder data

B) Licensed software

C) User passwords

D) Personal health information

24. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise

B) Sandboxing

C) Threat hunting

D) Security awareness training

Respuesta no detectada automaticamente

25. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks

B) IEEE 802.1D

C) Does not require an authentication server

✓ **D) IEEE 802.1X**

E) Suitable for all types of wireless LANs

✓ **F) Requires RADIUS authentication server**

26. In the context of IT security, the term "Biometrics" refers to both biological characteristics of the human body and behavioral traits that can be used for identification and access control purposes.

A) True

B) False

Respuesta no detectada automaticamente

27. Which of the answers listed below refers to a term primarily used in software development to describe the cost of short-term decisions that can lead to long-term problems?

A) Code entropy
B) Exposure factor
C) Risk register
✓ D) Technical debt

28. Which of the answers listed below refers to a process of intercepting network traffic data for analysis and troubleshooting purposes?

A) AIS
✓ B) PCAP
C) EDR
D) MaaS

29. A high MTBF value indicates that a component or system provides low reliability and is more likely to fail.

A) True
✓ B) False

30. Which of the following answers refers to an entity (such as an organization or individual) that determines the purpose and means of processing personal data?

✓ A) Data processor
B) Data owner
✓ C) Data controller
D) Data subject

31. Which of the following answers refers to a non-cryptographic hash function often used for error-checking purposes?

A) MD5
B) CRC
C) SHA
D) RIPEMD

32. Which of the answers listed below refer to the characteristic features of NIDS? (Select 3 answers)

A) Takes proactive measures to block or mitigate intrusion attempts
✓ B) Does not take direct action to block or prevent attacks
✓ C) Generates alerts and notifies security personnel or administrators when suspicious activity is detected
✓ D) Monitors network traffic without direct involvement in traffic routing or packet modification
E) Can drop or reject network packets, terminate connections, or take other actions to stop the attack
F) Operates in an inline mode, actively intercepting and inspecting network traffic

33. Which of the answers listed below refers to a non-cryptographic hash function often used for error-checking purposes?

A) MD5
✓ B) CRC
C) SHA
D) RIPEMD

34. Which of the following terms best describes deliberately false or misleading information spread with the intent to deceive or manipulate?

A) Disinformation
B) Deception
C) Gaslighting
D) Manipulation
Respuesta no detectada automaticamente

35. Which of the answers listed below refers to a cyberattack technique that relies on providing false DNS information to a DNS resolver for the purpose of redirecting or manipulating the resolution of domain names to malicious IP addresses?

A) DNS spoofing
B) Credential stuffing
C) URL hijacking
D) Domain hijacking

36. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise
B) Sandboxing
C) Threat hunting
D) Security awareness training
Respuesta no detectada automaticamente

37. What are the characteristic features of WPA2/WPA3 Enterprise mode? (Select 3 answers)

A) Suitable for large corporate networks
B) IEEE 802.1D
C) Does not require an authentication server
✓ D) IEEE 802.1X
E) Suitable for all types of wireless LANs
✓ F) Requires RADIUS authentication server

38. Which of the following answers refers to a risk assessment method based on need, typically conducted in response to specific events or changes, such as after a major organizational change or a security breach?

A) Ad hoc
B) Recurring
C) One-time
D) Continuous

39. Which of the answers listed below refers to an example of recurring risk assessment?

✓ A) Real-time monitoring of network security threats
B) Assessing risk after a major organizational change or a security breach
C) Quarterly or annual risk assessments
D) Risk assessment for a new product launch

40. Which of the answers listed below refers to an example of continuous risk assessment?

A) Quarterly or annual risk assessments
B) Risk assessment for a new product launch
C) Assessing risk after a major organizational change or a security breach
D) Real-time monitoring of network security threats

41. A high MTBF value indicates that a component or system provides low reliability and is more likely to fail.

A) True
✓ B) False

5.3 - Explain third-party risk assessment and management.

Conceptos clave:

- Vendor assessment: Penetration testing, Right-to-audit, Supply chain analysis
- Vendor selection: Due diligence, Conflict of interest
- Agreement types: SLA, MOA, MOU, MSA, NDA, BPA, SOW
- Vendor monitoring, Questionnaires, Rules of engagement

Teoria:

GESTION DE RIESGOS DE TERCEROS - Por que es critico:

- El 60%+ de las brechas de seguridad implican a un tercero (proveedor, partner, contratista)
- Cuando contratas a un proveedor, le das acceso a tus sistemas, datos o red → heredas sus riesgos

• Ejemplos reales: Target (brecha via proveedor HVAC), SolarWinds (supply chain attack), MOVEit (software de transferencia de archivos comprometido)

PROCESO DE EVALUACION DE PROVEEDORES:

• Due diligence: investigacion exhaustiva ANTES de contratar. Incluye: historial de brechas, certificaciones de seguridad (ISO 27001, SOC 2), referencias, revision de politicas de seguridad
• Vendor questionnaire: cuestionario de seguridad que el proveedor debe responder. Evalua sus controles tecticos, fisicos y administrativos
• Right-to-audit clause: clausula en el contrato que te da derecho a auditar al proveedor (o a contratar un auditor independiente). CRITICO incluirla en todos los contratos con acceso a datos sensibles
• Penetration testing: realizar o exigir pentests periodicos al proveedor
• Conflict of interest: verificar que el proveedor no tiene intereses que puedan comprometer la seguridad (ej: trabaja tambien para tu competencia)
• Supply chain analysis: no solo evaluar al proveedor directo, sino tambien a sus proveedores (n-tier supply chain)

TIPOS DE ACUERDOS - Los MAS preguntados en el examen:

• SLA (Service Level Agreement): define los niveles MINIMOS de servicio garantizados. Incluye: uptime (99.9%), tiempo de respuesta ante incidentes, penalizaciones por incumplimiento. EXAMEN: SLA = metricas de rendimiento
• NDA (Non-Disclosure Agreement): acuerdo de CONFIDENCIALIDAD. Protege informacion sensible compartida con terceros. Bidireccional o unidireccional
• MOU (Memorandum of Understanding): acuerdo de INTENCIONES. Describe la voluntad de cooperar pero NO es legalmente vinculante. Comun entre organismos publicos
• MOA (Memorandum of Agreement): MAS FORMAL que MOU. Describe compromisos especificos. Mas cercano a un contrato
• MSA (Master Service Agreement): contrato MARCO que establece las condiciones generales de una relacion de largo plazo. Los proyectos individuales se rigen por SOWs bajo el MSA
• SOW (Statement of Work): describe el ALCANCE ESPECIFICO de un proyecto concreto. Que se va a hacer, cuando, como y cuanto cuesta
• BPA (Business Partnership Agreement): acuerdo entre socios de negocio. Define derechos, responsabilidades y beneficios de cada parte
• ISA (Interconnection Security Agreement): acuerdo tecnico que define como se conectaran de forma segura dos redes de distintas organizaciones

TRUCO EXAMEN: SLA = cumplimiento de niveles de servicio. NDA = confidencialidad. SOW = que trabajo se hace. MOU = intenciones sin fuerza legal. ISA = conexion segura entre redes de dos organizaciones.

MONITORIZACION CONTINUA DE PROVEEDORES:

• Periodic reviews: revisar el estado de seguridad del proveedor periodicamente (trimestral/anual)
• Security ratings services: plataformas como SecurityScorecard o BitSight que evaluan continuamente la postura de seguridad externa de proveedores
• Rules of engagement: definir claramente el alcance, metodos y limites de cualquier prueba de seguridad al proveedor
• Offboarding: cuando se termina la relacion, revocar todos los accesos del proveedor y recuperar cualquier dato compartido

Preguntas de practica (56):

1. Which of the following terms refers to an agreement that specifies performance requirements for a vendor?

A) MSA
✓ B) SLA
C) MOU
D) SOW

---

2. A type of nonbinding agreement outlining mutual goals and the general framework for cooperation between two or more parties is referred to as:

A) MOA
B) SOW
✓ C) MOU
✓ D) MSA

---

3. Which of the terms listed below refers to a formal contract between business partners outlining the rights, responsibilities, and obligations of each partner regarding the management, operation, and decision-making processes within the business?

A) MSA

B) SLA

✓ **C) BPA**

D) MOA

4. A less formal document outlining mutual goals and cooperation established between two or more parties is referred to as:

A) MOA

B) SOW

✓ **C) MOU**

D) MSA

5. Which of the following terms refers to an agreement that specifies performance requirements for a vendor?

A) MSA

✓ **B) SLA**

C) MOU

D) SOW

6. A type of nonbinding agreement outlining mutual goals and the general framework for cooperation between two or more parties is referred to as:

A) MOA

B) SOW

✓ **C) MOU**

✓ **D) MSA**

7. Which of the following acronyms refers to a document that authorizes, initiates, and tracks the progress and completion of a particular job or task?

A) SOW

✓ **B) WO**

C) SLA

D) MSA

8. A detailed agreement between a client and a vendor that describes the work to be performed on a project is called:

A) MSA

B) SLA

C) WO

✓ **D) SOW**

9. A detailed agreement between a client and a vendor describing the work to be performed on a project is referred to as:

A) MSA

B) SLA

C) WO

✓ **D) SOW**

10. Which of the following acronyms refers to a document that authorizes, initiates, and tracks the progress and completion of a particular job or task?

A) SOW

✓ **B) WO**

C) SLA

D) MSA

11. A legal contract between the holder of confidential information and another person to whom that information is disclosed restricting that other person from disclosing the confidential information to any other party is referred to as:

A) ISA

✓ **B) NDA**

✓ **C) BPA**

D) SLA

12. Which of the terms listed below is used to describe actions taken to address and mitigate already identified risks?

A) Due diligence
B) Standard of care
✓ C) Due care
D) Fiduciary duty

13. A type of document stipulating rules of behavior to be followed by users of computers, networks, and associated resources is called:

A) SLA
B) EULA
✓ C) AUP
D) BPA

14. Which type of user account violates the concept of non-repudiation?

A) Standard user account
✓ B) Shared account
C) Guest user account
D) Service account

15. An encryption protocol primarily used in Wi-Fi networks implementing the WPA2 security standard is called:

A) TKIP
✓ B) CCMP
C) SSL
D) IPsec

16. Which of the answers listed below refers to a set of standards and specifications that define various cryptographic techniques, including formats for public keys, private keys, digital signatures, and digital certificates?

A) ITIL
B) RFC
C) PKCS
D) ISO/IEC

17. Which of the following would be the best solution for a company that needs IT services but lacks any IT personnel?

A) MSA
B) MaaS
✓ C) MSP
D) MSSP

18. Which of the following answers refer to common threat vectors that apply to MSPs, vendors, and suppliers in the supply chain? (Select 2 answers)

A) Compliance violations
B) Brand reputation damage
✓ C) Propagation of malware
D) Operational disruptions
✓ E) Social engineering techniques

19. A standalone malicious computer program that typically propagates itself over a computer network to adversely affect system resources and network bandwidth is referred to as:

A) Worm
B) Fileless virus
C) Bot
D) Logic bomb

20. As opposed to simple DoS attacks that usually are performed from a single system, a DDoS attack uses multiple compromised computer systems to perform the attack against its target. The intermediary systems that are used as a platform for the attack (often referred to as zombies, and collectively as a botnet) are the secondary victims of the DDoS attack.

A) True

B) False

Respuesta no detectada automaticamente

21. A dot-dot-slash attack is also referred to as:

A) Disassociation attack

B) On-path attack

✓ C) Directory traversal attack

D) Downgrade attack

22. Which of the answers listed below refers to an IEEE standard that can be implemented in a situation where an Ethernet switch acts as an authenticator for devices that intend to connect to a network through one of its ports?

A) IEEE 802.1X

B) IEEE 802.11ac

C) IEEE 802.1D

D) IEEE 802.11x

23. Which of the following power redundancy solutions would be best suited for providing long-term emergency power during an unexpected main power source outage?

A) Dual-power supply

B) Standby UPS

✓ C) Backup generator

D) Managed PDU

24. Which of the terms listed below is used to describe a foundational level of security configurations and settings required to safeguard a system?

A) Logical segmentation

✓ B) Secure baseline

C) Access control levels

D) Principle of least privilege

25. Which of the answers listed below refer to the characteristic features of static code analysis? (Select 3 answers)

A) Involves examining the code without executing it

✓ B) Often used early in the development process

✓ C) Examines code structure, syntax, and semantics to detect issues like syntax errors, coding standards violations, security vulnerabilities, and bugs

D) Typically used later in the software development lifecycle

E) Involves executing the code and analyzing its behavior at runtime

F) Analyzes runtime properties like memory usage, performance, and error handling to identify issues such as memory leaks, performance bottlenecks, and runtime errors

26. Which of the following statements describe the features of dynamic code analysis? (Select 3 answers)

A) Typically used later in the software development lifecycle

B) Involves examining the code without executing it

✓ C) Analyzes runtime properties like memory usage, performance, and error handling to identify issues such as memory leaks, performance bottlenecks, and runtime errors

D) Often used early in the development process

E) Examines code structure, syntax, and semantics to detect issues like syntax errors, coding standards violations, security vulnerabilities, and bugs

✓ F) Involves executing the code and analyzing its behavior at runtime

27. Which of the following answers refer to SCAP? (Select 3 answers)

A) A type of security system designed to collect logs and events from various sources

✓ B) Designed to provide a centralized user interface for accessing collected data

✓ C) A collection of standards developed by NIST

✓ D) Provides a common language for communicating security information

✓ E) Allows different security tools to share data and work together more effectively

F) Enables real-time threat detection, incident response, and compliance monitoring

---

28. Which of the answers listed below refers to a cryptographic standard (and a file format) used for the storage and transmission of private keys in email communications?

A) PEM

B) DMARC

C) SPF

D) DKIM

---

29. Which of the following answers refer(s) to the Mandatory Access Control (MAC) model? (Select all that apply)

A) Users are not allowed to change access policies at their own discretion

✓ B) Labels and clearance levels can only be applied and changed by an administrator

C) Every object has an owner who at his/her own discretion determines what kind of permissions other users can have to that object

D) Access to resources based on user identity

✓ E) Every resource has a sensitivity label matching a clearance level assigned to a user

---

30. Which password policy enforces a mandatory password change after a specific time?

A) Password expiration policy

B) Password history policy

C) Minimum password age policy

D) Password reuse policy

---

31. Which of the answers listed below refers to an organization that develops a wide range of standards on a global level?

A) IEEE

B) ANSI

C) ISO

D) NIST

---

32. An estimate based on the historical data of how often a threat would be successful in exploiting a vulnerability is known as:

A) ALE

B) SLA

✓ C) ARO

D) SLE

---

33. In the risk acceptance strategy, the practice of temporarily not complying with a standard or policy due to a specific risk scenario is referred to as:

A) Exclusion

✓ B) Exception

C) Evasion

D) Exemption

---

34. Which of the following defines the maximum acceptable amount of data loss measured by a specific point in time before a disaster or outage?

A) RPO

B) MTBF

C) RTO

✓ D) MTTR

35. Which of the following answers refers to a contractual provision that grants one party the right to inspect the other party's operations, facilities, processes, and records?

A) Right-to-audit clause
B) Oversight clause
C) Compliance verification clause
D) Transparency clause

36. Which term describes the predicted loss of value to an asset based on a single security incident?

A) SLE
B) ARO
C) ALE
D) SLA

37. Which wireless security protocol has been deprecated in favor of newer standards due to known vulnerabilities resulting from implementation flaws?

A) EAP
B) AES
C) WPA2
✓ **D) WEP**

38. Which of the answers listed below refers to a security standard introduced to address the vulnerabilities found in WEP?

A) TKIP
B) AES
C) WPA
D) CCMP

39. Which of the following answers refers to a global standard development organization composed of different national standards bodies?

A) NIST
B) ISO
C) IEEE
D) ANSI

40. Which of the acronyms listed below refers to a maximum tolerable period of time required for restoring business functions after a failure or disaster?

A) SLA
B) RTO
C) AUP
D) RPO

41. Which of the answers listed below refers to an industry standard for assessing and scoring the severity of computer system security vulnerabilities?

A) SIEM
B) CVSS
C) OSINT
D) SOAR

42. Which of the acronyms listed below refers to a comprehensive strategy and set of procedures designed to ensure that an organization can continue its critical operations and functions during and after a disruptive event?

A) BIA
B) SLE
✓ **C) BCP**
D) BPA

43. Which of the answers listed below refers to a set of standards and specifications that define various cryptographic techniques, including formats for public keys, private keys, digital signatures, and digital

certificates?

A) ITIL
B) RFC
C) PKCS
D) ISO/IEC

---

44. Which of the following solutions would be best suited for a company that needs comprehensive IT services but lacks qualified IT personnel?

A) MSA
B) MaaS
✓ **C) MSP**
D) MSSP

---

45. Which of the terms listed below refers to a third-party vendor offering IT security management services?

A) MSP
B) MaaS
C) MSA
D) MSSP

---

46. Which of the answers listed below refers to a global standard development organization composed of different national standards bodies?

A) NIST
B) ISO
C) IEEE
D) ANSI

---

47. Which of the following answers refers to an encryption protocol primarily used in Wi-Fi networks implementing the WPA2 security standard?

A) TKIP
B) CCMP
C) SSL
D) HMAC

---

48. A standalone malicious computer program that typically propagates itself over a computer network to adversely affect system resources and network bandwidth is referred to as:

A) Worm
B) Fileless virus
C) Bot
D) Logic bomb

---

49. As opposed to simple DoS attacks that usually are performed from a single system, a DDoS attack uses multiple compromised computer systems to perform the attack against its target. The intermediary systems that are used as a platform for the attack (often referred to as zombies, and collectively as a botnet) are the secondary victims of the DDoS attack.

A) True
B) False
Respuesta no detectada automaticamente

---

50. Which of the following power redundancy solutions would be best suited for providing long-term emergency power during an unexpected main power source outage?

A) Dual-power supply
B) Standby UPS
✓ **C) Backup generator**
D) Managed PDU

---

51. Which of the answers listed below refers to an open standard wireless network authentication protocol that enhances security by encapsulating authentication process within an encrypted TLS tunnel?

A) PEAP

B) EAP
C) LEAP
D) RADIUS
Respuesta no detectada automaticamente

52. Which of the following statements describe the features of dynamic code analysis? (Select 3 answers)

A) Typically used later in the software development lifecycle
B) Involves examining the code without executing it
✓ C) Analyzes runtime properties like memory usage, performance, and error handling to identify issues such as memory leaks, performance bottlenecks, and runtime errors
D) Often used early in the development process
E) Examines code structure, syntax, and semantics to detect issues like syntax errors, coding standards violations, security vulnerabilities, and bugs
✓ F) Involves executing the code and analyzing its behavior at runtime

53. Which of the following answers refer(s) to the Mandatory Access Control (MAC) model? (Select all that apply)

A) Users are not allowed to change access policies at their own discretion
✓ B) Labels and clearance levels can only be applied and changed by an administrator
C) Every object has an owner who at his/her own discretion determines what kind of permissions other users can have to that object
D) Access to resources based on user identity
✓ E) Every resource has a sensitivity label matching a clearance level assigned to a user

54. Which password policy enforces a mandatory password change after a specific time?

A) Password expiration policy
B) Password history policy
C) Minimum password age policy
D) Password reuse policy

55. In the risk acceptance strategy, the practice of temporarily not complying with a standard or policy due to a specific risk scenario is referred to as:

A) Exclusion
✓ B) Exception
C) Evasion
D) Exemption

56. Which of the following defines the maximum acceptable amount of data loss measured by a specific point in time before a disaster or outage?

A) RPO
B) MTBF
C) RTO
✓ D) MTTR

5.4 - Summarize elements of effective security compliance.

Conceptos clave:

- Compliance reporting: Internal, External
- Consequences: Fines, Sanctions, Reputational damage, Loss of license
- Privacy: Legal implications (Local/National/Global), PII, PHI
- Data subject, Controller vs processor, Right to be forgotten

Teoria:

MARCOS REGULATORIOS PRINCIPALES:

- GDPR (General Data Protection Regulation): regulacion europea que protege los datos personales de ciudadanos de la UE. Aplica a CUALQUIER empresa del mundo que procese datos de europeos. Principios clave: minimizacion de datos, proposito limitado, exactitud, limitacion del almacenamiento. Multas: hasta 4% del revenue global anual o 20M€ (lo que sea mayor)

• HIPAA (Health Insurance Portability and Accountability Act): ley de EEUU que protege la informacion medica protegida (PHI). Aplica a covered entities (hospitales, aseguradoras) y business associates (sus proveedores). Requiere salvaguardas tecnicas, fisicas y administrativas
• PCI DSS (Payment Card Industry Data Security Standard): estandar de la industria de tarjetas de pago. NO es una ley sino un estandar contractual. 12 requisitos de seguridad. Aplica a cualquier entidad que procese, almacene o transmita datos de tarjetas
• SOX (Sarbanes-Oxley Act): ley de EEUU para empresas cotizadas en bolsa. Seccion 404: los controles internos sobre informes financieros (incluyendo IT) deben ser auditados anualmente
• FERPA: protege los registros educativos de estudiantes en EEUU
• COPPA: protege la privacidad de menores de 13 anos en EEUU en internet

CONCEPTOS CLAVE DE PRIVACIDAD:

• Data subject: la persona fisica cuyos datos se procesan (tu cuando una empresa tiene tus datos)
• Data controller: entidad que decide el PROPOSITO y los MEDIOS del procesamiento. Ej: Amazon que recoge tus datos de compra
• Data processor: entidad que procesa datos EN NOMBRE del controller. Ej: el proveedor de email marketing de Amazon
• Right to be forgotten (GDPR Art. 17): derecho a solicitar la eliminacion de tus datos personales cuando ya no son necesarios para el proposito original
• Data portability: derecho a recibir tus datos en formato estructurado para transferirlos a otro proveedor
• Privacy by design: integrar la privacidad desde el DISENO del sistema, no como un anado posterior. Principio fundamental del GDPR
• Data sovereignty: los datos deben almacenarse y tratarse segun las leyes del pais donde residen o del pais del sujeto
• Legitimate interest: base legal para procesar datos sin consentimiento explicito cuando hay un interes legitimo justificado

COMPLIANCE REPORTING Y CONSECUENCIAS:

• Attestation: declaracion FORMAL de cumplimiento firmada por un responsable (DPO, CISO, CEO)
• Internal compliance: auditorias internas, self-assessments, revision de politicas
• External compliance: auditores externos independientes, certificaciones (ISO 27001, SOC 2 Type II), examenes regulatorios
• Consecuencias del incumplimiento:
- Fines economicos (GDPR: hasta 4% revenue global)
- Sanciones regulatorias (suspension de licencias, exclusion de contratos publicos)
- Dano reputacional (perdida de clientes, caida del precio de la accion)
- Responsabilidad civil (demandas de los afectados)
- Responsabilidad penal (en casos graves de negligencia)
• DPO (Data Protection Officer): rol requerido por GDPR en organizaciones que procesan datos a gran escala. Supervisa el cumplimiento y actua como punto de contacto con reguladores

Preguntas de practica (32):

1. Which of the following regulates personal data privacy of the EU citizens?

✓ A) PHI
B) HIPAA
C) PCI DSS
✓ D) GDPR

2. Which of the following terms refers to an industry-specific regulation?

A) RFC
✓ B) ISO
✓ C) PCI DSS
D) GDPR

3. In the context of audits, an attestation is typically provided by:

A) Regulatory body
✓ B) External auditor
C) Audit committee
D) Internal audit team

4. The US Health Insurance Portability and Accountability Act (HIPAA) provides privacy protection for:

A) PII
B) PI

✓ **C) PHI**

D) PIV

5. In the Zero Trust security architecture, the Policy Enforcement Point (PEP) is a Data Plane component that enforces the security policies defined at the Control Plane by the Policy Decision Point (PDP).

A) True

B) False

Respuesta no detectada automaticamente

6. Which of the answers listed below refers to a set of standards and specifications that define various cryptographic techniques, including formats for public keys, private keys, digital signatures, and digital certificates?

A) ITIL

B) RFC

C) PKCS

D) ISO/IEC

7. Which of the following answers refer to common threat vectors that apply to MSPs, vendors, and suppliers in the supply chain? (Select 2 answers)

A) Compliance violations

B) Brand reputation damage

✓ **C) Propagation of malware**

D) Operational disruptions

✓ **E) Social engineering techniques**

8. What defines a reflected DDoS attack?

A) Overwhelming the target with a high volume of traffic to saturate its bandwidth

B) Exploiting vulnerabilities in network protocols to consume resources and disrupt services

✓ **C) Utilizing third-party servers to reflect and amplify attack traffic towards the target**

D) Targeting vulnerabilities in applications or web servers to exhaust resources

9. Which of the following policies applies to any requests that fall outside the criteria defined in an ACL?

A) Fair access policy

✓ **B) Implicit deny policy**

C) Transitive trust

D) Context-aware authentication

10. Which of the answers listed below refers to a solution that simplifies web browser configurations by using predefined rules or scripts to make server selection decisions for specific web traffic?

A) PAC

B) DDNS

C) PAM

D) NAT

11. The purpose of PCI DSS is to provide protection for:

A) Credit cardholder data

B) Licensed software

C) User passwords

D) Personal health information

12. Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answers)

A) Enhances security by limiting the spread of cyberattacks

✓ **B) Helps organizations comply with data regulatory requirements by isolating and protecting specific data types**

C) Provides security for data in transit with the use of encryption

D) Guarantees data recovery in case of accidental deletion or system failures

✓ **E) Provides better control over user access to sensitive data**

13. Which of the following refers to a system that identifies, defines, and catalogs publicly known cybersecurity vulnerabilities?

A) TAXII

✓ B) CVE

C) STIX

D) CVSS

14. Which of the following answers refer to SCAP? (Select 3 answers)

A) A type of security system designed to collect logs and events from various sources

✓ B) Designed to provide a centralized user interface for accessing collected data

✓ C) A collection of standards developed by NIST

✓ D) Provides a common language for communicating security information

✓ E) Allows different security tools to share data and work together more effectively

F) Enables real-time threat detection, incident response, and compliance monitoring

15. Which of the following terms refers to predefined patterns or characteristics of known threats or attack methods?

A) Security logs

B) Baselines

C) Trends

✓ D) Signatures

16. Which of the following answers refers to a solution that helps organizations mitigate risks associated with data breaches, insider threats, and compliance violations?

A) EDR

B) DLP

C) IAM

D) UTM

17. OpenID Connect is a protocol used for:

A) Attestation

B) Authorization

C) Auditing

✓ D) Authentication

18. Which access control model defines access control rules with the use of statements that closely resemble natural language?

A) DAC

✓ B) ABAC

C) MAC

D) RBAC

19. Which of the answers listed below refers to public sector organizations that set and enforce laws and regulations at local, regional, or national levels?

A) Government entities

B) Trade associations

C) Statutory bodies

D) Regulatory agencies

20. Which of the answers listed below refers to organizations or individuals responsible for ensuring compliance with data protection laws?

A) Controllers

B) Stewards

C) Owners

D) Processors

21. Which of the following defines the maximum acceptable amount of data loss measured by a specific point in time before a disaster or outage?

A) RPO
B) MTBF
C) RTO
✓ **D) MTTR**

22. Which of the following answers refers to a contractual provision that grants one party the right to inspect the other party's operations, facilities, processes, and records?

A) Right-to-audit clause
B) Oversight clause
C) Compliance verification clause
D) Transparency clause

23. Which of the following answers refers to an entity (such as an organization or individual) that determines the purpose and means of processing personal data?

✓ **A) Data processor**
B) Data owner
✓ **C) Data controller**
D) Data subject

24. Which of the terms listed below refers to a legal principle that allows individuals to request the removal of personal information from Internet searches and other public sources?

A) De-identification
✓ **B) Right to be forgotten**
C) Anonymization
D) Consent management

25. Which of the answers listed below refers to an individual or role responsible for overseeing and ensuring compliance with data protection laws and policies within an organization?

A) CTO
B) DPO
C) CIO
D) CSO

26. Which of the answers listed below refers to a set of standards and specifications that define various cryptographic techniques, including formats for public keys, private keys, digital signatures, and digital certificates?

A) ITIL
B) RFC
C) PKCS
D) ISO/IEC

27. Which of the answers listed below refers to a solution that simplifies web browser configurations by using predefined rules or scripts to make server selection decisions for specific web traffic?

A) PAC
B) DDNS
C) PAM
D) NAT

28. What defines a reflected DDoS attack?

A) Overwhelming the target with a high volume of traffic to saturate its bandwidth
B) Exploiting vulnerabilities in network protocols to consume resources and disrupt services
✓ **C) Utilizing third-party servers to reflect and amplify attack traffic towards the target**
D) Targeting vulnerabilities in applications or web servers to exhaust resources

29. Which of the following answers refers to an individual or role responsible for overseeing and ensuring compliance with data protection laws and policies within an organization?

A) CTO
✓ **B) DPO**

C) CIO
D) CSO

30. Which of the answers listed below refer to the advantages of segmentation as a method for securing data? (Select 3 answers)

A) Enhances security by limiting the spread of cyberattacks
✓ B) Helps organizations comply with data regulatory requirements by isolating and protecting specific data types
C) Provides security for data in transit with the use of encryption
D) Guarantees data recovery in case of accidental deletion or system failures
✓ E) Provides better control over user access to sensitive data

31. Which of the following refers to a system that identifies, defines, and catalogs publicly known cybersecurity vulnerabilities?

A) TAXII
✓ B) CVE
C) STIX
D) CVSS

32. Which of the following defines the maximum acceptable amount of data loss measured by a specific point in time before a disaster or outage?

A) RPO
B) MTBF
C) RTO
✓ D) MTTR

5.5 - Explain types and purposes of audits and assessments.

Conceptos clave:

- Internal: Compliance, Audit committee, Self-assessments
- External: Regulatory, Examinations, Independent third-party audit
- Penetration testing: Physical, Offensive, Defensive, Integrated
- Environments: Known, Partially known, Unknown
- Reconnaissance: Passive, Active

Teoria:

TIPOS DE AUDITORIAS Y ASSESSMENTS:

- Internal audit: realizada por el propio equipo de auditoria interna de la organizacion. Identifica gaps antes de que los encuentre un auditor externo. Menos credibilidad externa pero mas conocimiento del negocio
- External audit: realizada por un tercero independiente acreditado. Mayor credibilidad. Requerida para certificaciones (ISO 27001) y por algunos reguladores
- Regulatory examination: auditoria impuesta y realizada por un regulador (banco central, FDA, FCA). No es opcional
- Self-assessment: la propia organizacion evalua su cumplimiento contra un framework (NIST CSF, CIS Controls). Rapido y barato, menos fiable
- Audit committee: comite interno que supervisa el proceso de auditoria y garantiza su independencia

PENETRATION TESTING - Clasificacion por nivel de conocimiento:

- Black box (Unknown environment): el pentester comienza sin ningun conocimiento previo de la organizacion. Simula un atacante externo real. El mas realista pero el mas lento y costoso
- White box (Known environment): el pentester tiene acceso completo a documentacion, codigo fuente, arquitectura de red, credenciales. El mas exhaustivo. Usado para revisar el codigo o la arquitectura en profundidad
- Gray box (Partially known): el mas comun en la practica. El pentester tiene conocimiento parcial (ej: credenciales de usuario normal pero no de admin). Buen balance entre realismo y eficiencia

PENETRATION TESTING - Clasificacion por tipo de equipo:

- Red Team: equipo ofensivo. Simula al atacante. Busca vulnerabilidades y las explota para demostrar el impacto real. Puede incluir ingenieria social y ataques fisicos
- Blue Team: equipo defensivo. Monitoriza, detecta y responde a los ataques del Red Team
- Purple Team: Red y Blue trabajan COLABORATIVAMENTE. El Red Team comparte sus TTPs con el Blue Team en tiempo real para mejorar las defensas de forma iterativa. El objetivo no es 'ganar' sino mejorar

• White Team: arbitros. Gestionan las reglas del ejercicio, resuelven disputas y evaluan los resultados

RECONOCIMIENTO - CRITICO para el examen:

• Passive reconnaissance: recopilar informacion SIN interactuar directamente con el objetivo. El objetivo NO puede detectarlo

Tecnicas: OSINT (Google, LinkedIn, WHOIS, Shodan), analisis de metadatos de documentos publicos, monitoreo de redes sociales

Herramientas: Maltego, theHarvester, Shodan, WHOIS

• Active reconnaissance: interactuar DIRECTAMENTE con el objetivo. El objetivo PUEDE detectarlo

Tecnicas: port scanning (nmap), banner grabbing, vulnerability scanning

Herramientas: Nmap, Nessus, Nikto

• Rules of Engagement (RoE): documento LEGAL que debe firmarse ANTES de cualquier pentest. Define: alcance (que sistemas se pueden atacar), metodos permitidos, ventanas de tiempo, contacto de emergencia, que hacer si se encuentra algo critico

VULNERABILITY ASSESSMENT vs PENETRATION TEST:

• Vulnerability Assessment: identifica y CLASIFICA vulnerabilidades. NO las explota. Mas rapido y barato. Resultado: lista de vulnerabilidades con su severidad (CVSS)

• Penetration Test: identifica Y EXPLOTA vulnerabilidades para demostrar el IMPACTO REAL. Mas lento y caro. Resultado: informe de vulnerabilidades + evidencias de explotacion exitosa

• Bug bounty program: programa donde la organizacion PAGA a investigadores externos por encontrar y reportar vulnerabilidades de forma responsable. Crowdsourced security testing

Preguntas de practica (21):

1. In cybersecurity exercises, the defending team is known as:

A) Red team

✓ B) Blue team

✓ C) White team

D) Purple team

---

2. In penetration testing, active reconnaissance involves gathering any type of publicly available information that can be used later for exploiting vulnerabilities found in the targeted system.

A) True

✓ B) False

---

3. In cybersecurity exercises, the defending team is known as:

A) Red team

✓ B) Blue team

✓ C) White team

D) Purple team

---

4. In penetration testing, active reconnaissance involves gathering any type of publicly available information that can be used later for exploiting vulnerabilities found in the targeted system.

A) True

✓ B) False

---

5. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting

✓ B) Log monitoring

C) Sandboxing

✓ D) Security audits

✓ E) CCTV

✓ F) IDS

✓ G) Vulnerability scanning

---

6. Which of the following terms describes the process of identifying differences between an organization's current security posture and its desired security posture?

A) Tabletop exercise

✓ B) Gap analysis

C) Security awareness training

D) Risk assessment

7. OpenID Connect is a protocol used for:

A) Attestation

B) Authorization

C) Auditing

✓ D) Authentication

8. Which of the following answers refers to a more in-depth exercise, which can include activating systems and performing real actions to respond to the incident?

A) Penetration testing

B) Threat hunting

✓ C) Simulation

D) Vulnerability scanning

9. Which of the following answers refers to a contractual provision that grants one party the right to inspect the other party's operations, facilities, processes, and records?

A) Right-to-audit clause

B) Oversight clause

C) Compliance verification clause

D) Transparency clause

10. In the context of audits, an attestation is typically provided by:

A) Regulatory body

✓ B) External auditor

C) Audit committee

D) Internal audit team

11. In cybersecurity exercises, a purple team assumes the integrated role of all other teams (i.e., red, blue, and white).

A) True

✓ B) False

12. Which part of the AAA security architecture deals with the verification of the identity of a person or process?

A) Accounting

✓ B) Authentication

C) Auditing

D) Authorization

13. Which of the following answers refers to a language primarily used for automating the assessment of security vulnerabilities and configuration issues on computer systems?

A) OVAL

B) SAML

C) XML

D) SOAP

14. Which of the answers listed below refer(s) to detective security control(s)? (Select all that apply)

A) Lighting

✓ B) Log monitoring

C) Sandboxing

✓ D) Security audits

✓ E) CCTV

✓ F) IDS

✓ G) Vulnerability scanning

15. The process of determining potential risks that could affect an organization's ability to achieve its objectives is called:

✓ **A) Risk assessment**
✓ **B) Risk identification**
C) Risk analysis
D) Risk management

16. Which of the following answers refers to a risk assessment method based on need, typically conducted in response to specific events or changes, such as after a major organizational change or a security breach?

A) Ad hoc
B) Recurring
C) One-time
D) Continuous

17. Which of the answers listed below refers to an example of recurring risk assessment?

✓ **A) Real-time monitoring of network security threats**
B) Assessing risk after a major organizational change or a security breach
C) Quarterly or annual risk assessments
D) Risk assessment for a new product launch

18. Which of the following answers refers to a risk assessment conducted for a specific purpose or project, without plans for regular reassessment (e.g., risk assessment for a new product launch)?

A) One-time
B) Recurring
C) Ad hoc
D) Continuous

19. Which of the answers listed below refers to an example of continuous risk assessment?

A) Quarterly or annual risk assessments
B) Risk assessment for a new product launch
C) Assessing risk after a major organizational change or a security breach
D) Real-time monitoring of network security threats

20. Penetration testing: (Select all that apply)

A) Bypasses security controls
B) Only identifies lack of security controls
✓ **C) Actively tests security controls**
✓ **D) Exploits vulnerabilities**
E) Passively tests security controls

21. In cybersecurity exercises, a purple team assumes the integrated role of all other teams (i.e., red, blue, and white).

A) True
✓ **B) False**

5.6 - Implement security awareness practices.

Conceptos clave:

- Phishing: Campaigns, Recognizing attempts, Responding to suspicious messages
- Anomalous behavior: Risky, Unexpected, Unintentional
- User training: Policy/handbooks, Insider threat, Password management, Social engineering
- Reporting and monitoring: Initial, Recurring

Teoria:

EL FACTOR HUMANO - Por que es el objetivo mas importante del examen:

- El 90%+ de los incidentes de seguridad tienen un componente humano (error, engano o malicia)
- La tecnologia puede ser perfecta pero un empleado que hace clic en un phishing lo anula todo
- Security awareness no es un evento anual, es un programa continuo
- Objetivo: cambiar el COMPORTAMIENTO de las personas, no solo su conocimiento

PROGRAMA DE CONCIENCIACION - Componentes:

- Security awareness training: formacion periodica obligatoria para TODOS los empleados, incluyendo la direccion. Contenido: phishing, ingenieria social, manejo de datos, uso de dispositivos, incidentes
- Policy acknowledgment: los empleados firman que han leido, entendido y se comprometen a cumplir las politicas. Critico para demostrar compliance y para procedimientos disciplinarios
- Role-based training: formacion especifica segun el rol. Los desarrolladores necesitan formacion sobre OWASP. Los de RRHH sobre proteccion de datos. Los ejecutivos sobre BEC y whaling
- Initial vs recurring training: formacion en el onboarding + actualizaciones periodicas (minimo anual, idealmente trimestral) + formacion adicional tras incidentes

PHISHING SIMULATION - El metodo mas efectivo:

- Enviar emails de phishing FALSOS y controlados a empleados sin que lo sepan
- Medir: % que abre el email, % que hace clic en el enlace, % que introduce credenciales, % que reporta el intento
- Los que 'caen': reciben formacion inmediata y especifica
- Objetivo: reducir el click rate con el tiempo. Un buen programa baja del 30% inicial al 5% en 12 meses
- NO es para castigar. Es para identificar quienes necesitan mas formacion
- Tipos de phishing simulado: generic (baja dificultad), spear phishing (personalizado, alta dificultad)

INDICADORES DE COMPORTAMIENTO DE RIESGO:

- Risky behavior: acciones que aumentan el riesgo aunque no sean intencionadamente maliciosas

Ejemplos: conectar un USB encontrado en el parking, usar WiFi publica sin VPN, compartir credenciales con companeros

- Unexpected behavior: comportamiento inusual que puede indicar compromiso de cuenta o insider threat

Ejemplos: acceder a datos fuera del horario habitual, descargar grandes cantidades de datos, acceder a sistemas fuera de su rol

- Unintentional insider threat: empleado bien intencionado que causa un incidente por error

Ejemplos: enviar email con datos sensibles a la direccion equivocada, publicar credenciales en GitHub por error

- Malicious insider threat: empleado que actua deliberadamente en contra de la organizacion

Indicadores: descontento laboral reciente, sancion disciplinaria, conocimiento de despido inminente, acceso inusual a datos

CONTENIDO CLAVE DE LA FORMACION:

- Reconocer phishing: remitente sospechoso, urgencia artificial ('tu cuenta sera cancelada en 24h'), links que no coinciden con el texto al pasar el raton, adjuntos no esperados, errores ortograficos
- Gestion de contrasenas: usar gestor de contrasenas (Bitwarden, 1Password), nunca reutilizar contrasenas, activar MFA en todas las cuentas
- Ingenieria social: verificar siempre la identidad del solicitante por un canal alternativo antes de dar informacion o accesos, aunque parezca ser el CEO
- Manejo de datos: clasificar los datos antes de compartirlos, no enviar PII sin cifrar, no almacenar datos sensibles en dispositivos no aprobados
- Reporte de incidentes: a quien reportar, como hacerlo, que informacion incluir. El tiempo es critico: cada minuto que un incidente no se reporta aumenta el dano

Preguntas de practica (9):

1. Which of the answers listed below can be used to describe operational security controls (Select 3 answers)

A) Also known as administrative controls

✓ B) Focused on the day-to-day procedures of an organization

C) Executed by computer systems (instead of people)

✓ D) Used to ensure that the equipment continues to work as specified

E) Focused on managing risk

✓ F) Primarily implemented and executed by people (as opposed to computer systems)

---

2. Which of the answers listed below refers to security controls designed to deter, detect, and prevent unauthorized access, theft, damage, or destruction of material assets?

A) Managerial security controls

✓ B) Physical security controls

C) Technical security controls

D) Operational security controls

---

3. Which of the following terms describes the process of identifying differences between an organization's current security posture and its desired security posture?

A) Tabletop exercise

✓ **B) Gap analysis**

C) Security awareness training

D) Risk assessment

4. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise

B) Sandboxing

C) Threat hunting

D) Security awareness training

Respuesta no detectada automaticamente

5. Which of the following answers refers to a solution that helps organizations mitigate risks associated with data breaches, insider threats, and compliance violations?

A) EDR

B) DLP

C) IAM

D) UTM

6. Which term best describes a disgruntled employee abusing legitimate access to a company's internal resources?

A) APT

✓ **B) Insider threat**

C) Gray hat

D) Threat actor

7. Which of the answers listed below can be used to describe operational security controls (Select 3 answers)

A) Also known as administrative controls

✓ **B) Focused on the day-to-day procedures of an organization**

C) Executed by computer systems (instead of people)

✓ **D) Used to ensure that the equipment continues to work as specified**

E) Focused on managing risk

✓ **F) Primarily implemented and executed by people (as opposed to computer systems)**

8. Which of the answers listed below refers to security controls designed to deter, detect, and prevent unauthorized access, theft, damage, or destruction of material assets?

A) Managerial security controls

✓ **B) Physical security controls**

C) Technical security controls

D) Operational security controls

9. Which of the answers listed below refers to a simulated scenario conducted in a controlled environment, typically involving discussions and planning around hypothetical security incidents?

A) Tabletop exercise

B) Sandboxing

C) Threat hunting

D) Security awareness training

Respuesta no detectada automaticamente

Glosario de Acronimos - SY0-701

Todos los acronimos del examen CompTIA Security+ SY0-701

Acronimo	Significado
3DES	Triple Data Encryption Standard
AAA	Authentication, Authorization, and Accounting
ABAC	Attribute-Based Access Control
ACL	Access Control List
AES	Advanced Encryption Standard
AH	Authentication Header
AI	Artificial Intelligence
AIS	Automated Indicator Sharing
ALE	Annualized Loss Expectancy
AP	Access Point
API	Application Programming Interface
APT	Advanced Persistent Threat
ARO	Annualized Rate of Occurrence
ARP	Address Resolution Protocol
ASVS	Application Security Verification Standard
AUP	Acceptable Use Policy
AV	Asset Value / Antivirus
BCP	Business Continuity Plan
BGP	Border Gateway Protocol
BIA	Business Impact Analysis
BPA	Business Partnership Agreement
BYOD	Bring Your Own Device
CA	Certificate Authority
CAPTCHA	Completely Automated Public Turing test to tell Computers and Humans Apart
CAR	Corrective Action Report
CASB	Cloud Access Security Broker
CBC	Cipher Block Chaining
CCMP	Counter Mode with Cipher Block Chaining Message Authentication Code Protocol
CCTV	Closed-Circuit Television
CERT	Computer Emergency Response Team
CFB	Cipher Feedback
CHAP	Challenge Handshake Authentication Protocol
CIA	Confidentiality, Integrity, Availability
CIO	Chief Information Officer
CIRT	Computer Incident Response Team
CISO	Chief Information Security Officer
CMDB	Configuration Management Database
CMS	Content Management System

Acronimo	Significado
COPE	Corporate Owned, Personally Enabled
CSP	Cloud Service Provider / Content Security Policy
CSR	Certificate Signing Request
CSRF	Cross-Site Request Forgery
CTM	Counter Mode
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
CYOD	Choose Your Own Device
DAC	Discretionary Access Control
DDoS	Distributed Denial of Service
DEP	Data Execution Prevention
DES	Data Encryption Standard
DHCP	Dynamic Host Configuration Protocol
DHE	Diffie-Hellman Ephemeral
DKIM	DomainKeys Identified Mail
DLP	Data Loss Prevention
DMARC	Domain-based Message Authentication, Reporting, and Conformance
DMZ	Demilitarized Zone
DNS	Domain Name System / Service / Server
DoS	Denial of Service
DPO	Data Protection Officer
DRP	Disaster Recovery Plan
DSA	Digital Signature Algorithm
EAP	Extensible Authentication Protocol
ECB	Electronic Codebook
ECC	Elliptic Curve Cryptography
ECDHE	Elliptic Curve Diffie-Hellman Ephemeral
EDR	Endpoint Detection and Response
EF	Exposure Factor
EFS	Encrypted File System
EOL	End of Life
ERP	Enterprise Resource Planning
ESP	Encapsulating Security Payload
FACP	Fire Alarm Control Panel
FDE	Full Disk Encryption
FIM	File Integrity Monitoring
FIDO	Fast Identity Online
FTP	File Transfer Protocol
FTPS	File Transfer Protocol Secure
GCM	Galois/Counter Mode
GDPR	General Data Protection Regulation

Acronimo	Significado
GPG	GNU Privacy Guard
GPO	Group Policy Object
GPS	Global Positioning System
GRE	Generic Routing Encapsulation
HA	High Availability
HIDS	Host-based Intrusion Detection System
HIPAA	Health Insurance Portability and Accountability Act
HIPS	Host-based Intrusion Prevention System
HMAC	Hash-based Message Authentication Code
HOTP	HMAC-based One-Time Password
HSM	Hardware Security Module
HTML	HyperText Markup Language
HTTP	HyperText Transfer Protocol
HTTPS	HyperText Transfer Protocol Secure
HVAC	Heating, Ventilation, Air Conditioning
IaaS	Infrastructure as a Service
IAM	Identity and Access Management
ICS	Industrial Control System
IdP	Identity Provider
IDS	Intrusion Detection System
IEEE	Institute of Electrical and Electronics Engineers
IKE	Internet Key Exchange
IM	Instant Messaging
IMAP	Internet Message Access Protocol
IoT	Internet of Things
IP	Internet Protocol
IPS	Intrusion Prevention System
IPSec	Internet Protocol Security
IR	Incident Response
IRP	Incident Response Plan
ISA	Interconnection Security Agreement
ISP	Internet Service Provider
ISSO	Information Systems Security Officer
IV	Initialization Vector
JIT	Just-in-Time
JSON	JavaScript Object Notation
LDAP	Lightweight Directory Access Protocol
LDAPS	Lightweight Directory Access Protocol Secure
MAC	Mandatory Access Control / Media Access Control / Message Authentication Code
MAM	Mobile Application Management
MAN	Metropolitan Area Network

Acronimo	Significado
MBR	Master Boot Record
MD5	Message Digest 5
MDM	Mobile Device Management
MFA	Multi-Factor Authentication
MFD	Multifunction Device
MitM	Man-in-the-Middle
ML	Machine Learning
MOA	Memorandum of Agreement
MOU	Memorandum of Understanding
MSA	Master Service Agreement
MSP	Managed Service Provider
MSSP	Managed Security Service Provider
MTBF	Mean Time Between Failures
MTTR	Mean Time to Repair
MTD	Maximum Tolerable Downtime
MX	Mail Exchange
NAC	Network Access Control
NDA	Non-Disclosure Agreement
NFC	Near Field Communication
NGFW	Next-Generation Firewall
NIDS	Network-based Intrusion Detection System
NIPS	Network-based Intrusion Prevention System
NIST	National Institute of Standards and Technology
NTLM	New Technology LAN Manager
OCSP	Online Certificate Status Protocol
OFB	Output Feedback
OIDC	OpenID Connect
OT	Operational Technology
OTP	One-Time Password
OWASP	Open Worldwide Application Security Project
PaaS	Platform as a Service
PAM	Privileged Access Management
PAP	Password Authentication Protocol
PCI DSS	Payment Card Industry Data Security Standard
PEM	Privacy Enhanced Mail
PGP	Pretty Good Privacy
PHI	Protected Health Information
PII	Personally Identifiable Information
PIN	Personal Identification Number
PKI	Public Key Infrastructure
POP3	Post Office Protocol v3

Acronimo	Significado
PTZ	Pan-Tilt-Zoom
RADIUS	Remote Authentication Dial-in User Service
RBAC	Role-Based Access Control
RC4	Rivest Cipher 4
RDP	Remote Desktop Protocol
RFC	Request for Change / Request for Comments
RMF	Risk Management Framework
RPO	Recovery Point Objective
RSA	Rivest, Shamir, Adleman
RTOS	Real-Time Operating System
RTO	Recovery Time Objective
S/MIME	Secure/Multipurpose Internet Mail Extensions
SaaS	Software as a Service
SAE	Simultaneous Authentication of Equals
SAML	Security Assertions Markup Language
SASE	Secure Access Service Edge
SCAP	Security Content Automation Protocol
SCIF	Sensitive Compartmented Information Facility
SD-WAN	Software-Defined Wide Area Network
SDK	Software Development Kit
SDLC	Software Development Life Cycle
SFTP	SSH File Transfer Protocol / Secure File Transfer Protocol
SHA	Secure Hashing Algorithm
SIEM	Security Information and Event Management
SLA	Service Level Agreement
SLE	Single Loss Expectancy
SMS	Short Message Service
SMTP	Simple Mail Transfer Protocol
SMTPS	Simple Mail Transfer Protocol Secure
SNMP	Simple Network Management Protocol
SOAR	Security Orchestration, Automation, and Response
SOC	Security Operations Center
SOW	Statement of Work
SPF	Sender Policy Framework
SQL	Structured Query Language
SQLi	SQL Injection
SSH	Secure Shell
SSID	Service Set Identifier
SSL	Secure Sockets Layer
SSO	Single Sign-On
STIG	Security Technical Implementation Guide

Acronimo	Significado
TACACS+	Terminal Access Controller Access Control System Plus
TCP	Transmission Control Protocol
TGT	Ticket Granting Ticket
TIP	Threat Intelligence Platform
TLS	Transport Layer Security
TOTP	Time-based One-Time Password
TPM	Trusted Platform Module
TTL	Time to Live
TTP	Tactics, Techniques, and Procedures
UAT	User Acceptance Testing
UDP	User Datagram Protocol
UEFI	Unified Extensible Firmware Interface
UPS	Uninterruptible Power Supply
URL	Uniform Resource Locator
USB	Universal Serial Bus
UTM	Unified Threat Management
VBA	Visual Basic for Applications
VLAN	Virtual Local Area Network
VM	Virtual Machine
VoIP	Voice over Internet Protocol
VPN	Virtual Private Network
WAF	Web Application Firewall
WAN	Wide Area Network
WEP	Wired Equivalent Privacy
WIPS	Wireless Intrusion Prevention System
WPA2	Wi-Fi Protected Access 2
WPA3	Wi-Fi Protected Access 3
XDR	Extended Detection and Response
XML	Extensible Markup Language
XSS	Cross-Site Scripting
ZTNA	Zero Trust Network Access